

2026년 전자금융기반시설 보안 취약점 평가기준 안내서

제2026-1호



금융보안원
FINANCIAL SECURITY INSTITUTE

2026년 전자금융기반시설 보안 취약점 평가기준 안내서

제2026-1호



금융보안원
FINANCIAL SECURITY INSTITUTE

CONTENTS

1	평가 개요	1
2	평가 방법	2
3	평가 절차	3
4	평가 기준 구성	6
5	평가 항목 선정	12
6	평가 결과 표현 및 보고	18

참고

1	평가 전담반 구성 기준 및 유의사항	21
2	전자금융기반시설 보안 취약점 평가기준 주요 개정사항	27
3	전자금융기반시설 보안 취약점 평가기준	93

2026년
전자금융기반시설
보안 취약점
평가기준 안내서



1

평가 개요

- ❖ **(개요)** 「보안 취약점 분석·평가」란, 전자금융기반시설의 안전성과 신뢰성을 저해하는 사이버 위협에 대응하기 위해 잠재된 보안 위협을 찾고 이를 개선하기 위한 사전 예방 활동을 의미
- ❖ **(평가대상)** 금융회사 및 전자금융업자(이하 금융회사)는 관계 법령에서 정한 내용에 따라 전자금융 업무를 처리하기 위한 정보처리시스템(전자금융기반시설¹⁾)을 대상으로 취약점을 분석하고 이를 평가
- ❖ **(평가주기)** 공개용 홈페이지 점검은 연 2회 이상, 전자금융기반시설 점검은 연 1회 이상 평가



참고

전자금융기반시설 보안 취약점 분석·평가 관계 법령

【평가대상 및 절차 관련】

- 전자금융거래법 제21조의3 (전자금융기반시설의 취약점 분석·평가)
- 전자금융거래법 시행령 제11조의5 (전자금융기반시설 취약점 분석·평가의 내용), 제11조의6 (전자금융기반시설 취약점 분석·평가의 절차 및 방법 등)

【평가주기 관련】

- 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등)
- 전자금융감독규정시행세칙 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용)

※ 자세한 내용은 “국가법령정보센터(<http://www.law.go.kr>)” 또는 “전자금융감독규정 해설서(2025.8, 금융감독원)” 등을 참고

1) **전자금융기반시설** : 전자금융거래에 이용되는 정보처리시스템 및 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망을 의미

- **전자금융거래** : 금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공(이하 “전자금융업무”라 한다)하고, 이용자가 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래를 말한다.
- **정보통신망** : 「전기통신사업법」 제2조제2호에 따른 전기통신설비를 이용하거나 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집·가공·저장·검색·송신 또는 수신하는 정보통신체제를 말한다.

2

평가 방법

본 안내서의 보안 취약점 분석·평가 방법 및 절차는 단순 참고용으로 평가전문기관에서 보유하고 있는 평가 방법 또는 금융회사 내부에서 정한 절차 및 기준을 직접 또는 변형하여 사용해도 무방함

❖ **(평가 방법)** 취약점 평가 수행 시 금융회사가 자체전담반을 구성하여 운영하는 방안과 외부 평가전문 기관에 위탁하는 방안으로 구분

① 금융회사가 자체전담반을 구성하여 운영하는 방안

- 정보보호최고책임자를 포함한 5인 이상으로 자체전담반을 구성
- 자체전담반 구성 시 구성원 중 100분의 30 이상은 「정보보호산업의 진흥에 관한 법률 시행규칙」 제8조의 정보보호 전문서비스 기업 지정기준에서 정한 고급 기술 인력을 갖춘 자로 구성

② 금융회사가 평가전문기관에 위탁하는 방안

- 자체전담반을 구성하지 않을 경우 평가전문기관에 위탁 가능
- 평가전문기관은 「전자금융감독규정」 제37조의3(전자금융기반시설의 취약점 분석·평가전문기관의 지정 등)에서 정의



참고

평가전문기관이란?

【관계 법령】

- 관계 법령에서 정한 평가전문기관으로, 전자금융기반시설에 대해 보안 취약점을 분석·평가할 경우, 정보보호 전문서비스기업(약 29개, 2025.11.28. 기준) 또는 침해사고대응기관(금융보안원)에서 수행하도록 규정
- 전자금융감독규정 제37조의3(전자금융기반시설의 취약점 분석·평가 전문기관의 지정 등)
 1. 「정보통신기반 보호법」 제16조에 따라 금융분야 정보공유·분석센터로 지정된 자
 2. 「정보보호산업의 진흥에 관한 법률」 제23조에 따라 지정된 정보보호전문서비스 기업
 3. 침해사고대응기관
 4. 금융위원장이 지정하는 자

3

평가 절차

❖ **(평가 절차)** 보안 취약점 분석·평가 절차는 5단계로 구성되며, 단계별 주요 행위는 다음과 같음

평가 순서	평가 단계	주요 행위
①	사전 분석	평가계획 수립 및 업무현황 파악 등
②	취약점 분석	자산분석, 취약점 분석 등
③	취약점 평가	정보보호 분석·평가 지수 산출 등의 종합평가
④	대책 수립	발견된 취약점에 대한 보안대책 수립 등
⑤	사후 관리	발견된 취약점에 대한 조치계획 수립 등

① 「사전 분석 단계」에서의 주요 활동

- **(계획 수립)** 취약점 분석·평가를 실시하기 위해 수행 방법, 수행 절차, 소요 예산 등이 포함된 실행 계획을 수립
- **(환경 파악)** 평가대상에 대한 자산 현황, 업무 현황 등 시스템 운영 및 업무환경을 파악²⁾

2) 운영 및 업무환경 파악 : 필요에 따라 평가대상 시스템에 대한 보안성 검토 자료 또는 정보보호 정책 및 지침 등을 검토

② 「취약점 분석 단계」에서의 주요 활동

- **(자산 분석)** 자산이 업무 및 서비스에 미치는 영향을 파악하여 자산의 가치(중요도 등)를 산출하는 과정
 - **(자산 분류)** 보유 또는 운영하고 있는 자산의 업무 목적을 파악하여 업무 특성별로 자산을 분류
 - **(자산 평가)** 자산이 가지고 있는 정보의 성격, 자산의 가용성 수준을 복합적으로 평가하여 자산의 중요도를 결정
 - 자산 중요도 : 각 자산에 대한 상대적 중요도를 기준으로 구분

[자산 중요도 분류 예시]

중요도	역할	점수 (등급)	서버	네트워크장비	정보보호시스템	영향
핵심 설비 (Core)	1그룹	4	- 중요DB 서버 등	- 인터넷연결구간 네트워크장비 등	- 침입차단시스템 (인터넷 차단) 등	- 금전적 손실 발생 등
	2그룹	3	- 인터넷뱅킹 서버 등	- बैं킹서버구간 - 대외구간연결 등	- 침입차단시스템 (뱅킹/대외 등) - 암호화 장비 등	- 정보유출 등
	3그룹	2	- 메일,DNS 서버 등	- DMZ구간	- 침입탐지시스템	- 손실이 경미한 경우
지원설비 (Peripheral)		1	- 개발서버 기타서버	- 내부구간 네트워크장비		- 테스트 용도 등

- 정보 성격 : 위험성이 커지는 정보의 특성과 정보 자체가 가지고 있는 민감성을 고려하여 정보 성격을 구분
- 가용성 수준 : 업무 연속성 측면에서 업무 또는 서비스가 지속적으로 지원되어야 할 성질의 정도를 산정
- **(취약점 분석)** 자산의 중요도 및 업무 목적 등을 고려하여 자산에 내재된 보안 취약점을 분석

③ 「취약점 평가 단계」에서의 주요 활동

- **(취약점 평가)** 식별된 취약점이 금융회사에 미치는 영향을 파악하기 위해 각 취약점에 대한 위험도와 자산의 가치를 고려하여 분야별로 취약 수준을 평가
- **(평가 지수 산출)** 식별된 취약점에 대한 자산 가치, 취약점, 재발생률 등을 종합적으로 분석하여 금융 회사의 전반적인 정보보호 관리 상황을 정량적으로 평가

④ 「대책 수립 단계」에서의 주요 활동

- **(우선순위 산정)** 식별된 취약점을 목록화하고 금융회사 업무 및 서비스 환경을 고려하여 조치 우선순위를 산정
- **(보안대책 수립)** 금융회사의 보안정책, 인터뷰 내용, 우선순위 산정 값 등을 활용하여 종합적인 보안 대책을 수립

⑤ 「사후 관리 단계」에서의 주요 활동

- **(이행 계획 수립)** 보안대책 수립 내용을 참고하여 취약점에 대한 조치 이행 계획을 수립하고, 이행 결과를 최고경영자에게 보고
- **(위험 수용)** 식별된 취약점의 제거 또는 이에 상응하는 조치가 어려운 경우, 최고경영자의 승인이 필요하고 관련 취약점은 지속적인 관리 및 모니터링 필요

4

평가 기준 구성

- ❖ (구성) 전자금융기반시설 보안 취약점 평가기준은 「금융IT 보안 컴플라이언스 가이드」(2017.10, 금융보안원)를 준용하여 11개 통제분야 및 40개 통제구분으로 분류

[전자금융기반시설 보안 취약점 평가기준 구성]

구분	통제분야 (금융IT 보안컴플라이언스 가이드)	통제구분	평가분야 및 항목
관리적 보안	1. 정보보호 정책	40개 통제구분	15개 평가분야 ³⁾ 869개 평가항목
	2. 정보보호 조직		
	3. 인적 보안		
	8. 업무 지속성 관리		
	10. 외부주문 보안		
기술적 보안	5. 운영 관리		
	6. 접근통제		
	7. IT도입·개발·유지보수 관리		
	9. 전자금융거래 보안		
	11. 보안사고 대응		
물리적 보안	4. 물리적·환경적 보안		



참고

각 평가항목은 아래 나열된 금융IT 관계법령 및 가이드 등을 참고함

- 전자금융거래법 (법률 제19734호, 2023. 9. 14.)
 - 전자금융거래법 시행령 (대통령령 제35038호, 2024. 12. 3.)
 - 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.)
 - 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
 - 주요정보통신기반시설 취약점 분석 평가기준 (과학기술정보통신부공고 제2025-0832호, 2025년 8월)
- * (유의사항) 「전자금융기반시설 보안 취약점 평가항목」에서 인용되는 각종 법규 내용은 평가항목에 대한 이해 증진을 목적으로 활용된 것으로 이에 관한 해석의 권한은 금융위원회 등 관계 부처에 있음을 밝힘

3) 필수 평가분야 14개(정보보호 관리체계, 서버, 데이터베이스 등)와 선택 평가분야 1개(모의해킹)로 구성

❖ 통제분야 설명

가. 관리적 보안

- **(1. 정보보호 정책)** 정보보호 및 정보기술 부문 계획 수립 및 관리에 관한 적정성을 평가
 - 통제구분 : 1.1 정보보호 계획
- **(2. 정보보호 조직)** 정보보호 인력 구성, 예산 및 정보보호최고책임자(CISO) 지정에 관한 적정성을 평가
 - 통제구분 : 2.1 조직 및 인력 구성
 - 2.2 정보보호 예산
 - 2.3 정보보호최고책임자(CISO) 지정 및 업무
- **(3. 인적 보안)** 금융회사 임직원 등에 대한 정보보호 교육 및 훈련에 관한 적정성을 평가
 - 통제구분 : 3.1 정보보호 교육 및 훈련
- **(8. 업무 지속성 관리)** 업무 지속성 확보 방안, 비상지원 인력 확보 관리 및 위기대응 매뉴얼 수립 등에 관한 적정성을 평가
 - 통제구분 : 8.1 업무지속성 확보방안
 - 8.2 비상지원인력 확보관리
 - 8.3 위기대응 행동 매뉴얼 수립
- **(10. 외부주문 보안)** 외부주문 시 계약 준수 사항, 외부주문 시 보호대책 운영 기준, 업무 위·수탁 운영 기준 등에 관한 적정성을 평가
 - 통제구분 : 10.1 외부주문 계약 준수사항
 - 10.2 외부주문시 보호대책
 - 10.3 외부주문 등에 대한 기준

나. 기술적 보안

○ (5. 운영 관리) 전산자료·정보처리시스템 보호 기술 및 관리에 관한 적정성을 평가

- 통제구분 : 5.1 단말기 보호대책
 - 5.2 전산자료 보호대책
 - 5.3 정보처리시스템 보호대책
 - 5.3.1 보안관리
 - 5.3.2 사용자 인증
 - 5.3.3 패치 관리
 - 5.4 취약점 분석·평가
 - 5.5 정보보호시스템 설치 및 운영
 - 5.5.1 보안관리
 - 5.5.2 사용자 인증
 - 5.5.3 패치 관리
 - 5.6 무선통신망 설치 및 운영
 - 5.7 악성코드 감염 방지대책
 - 5.8 공개서버 보안
 - 5.8.1 (전자금융) 거래 인증
 - 5.8.2 (전자금융) 거래정보 검증
 - 5.8.3 (전자금융) 단말 보안
 - 5.8.4 (일반공통) 서비스 보호
 - 5.8.5 (일반공통) 이용자 인증
 - 5.8.6 (일반공통) 단말 보안
 - 5.8.7 (일반공통) 데이터 보호
 - 5.9 IP주소 관리
 - 5.10 암호프로그램 및 암호키 관리

- **(6. 접근통제)** 전산장비에 대한 사용자 계정 관리를 비롯한 비밀번호 정책 등에 관한 적정성을 평가
 - 통제구분 : 6.1 계정 및 권한 관리
 - 6.2 정보처리시스템 관리자 통제
 - 6.3 내부사용자 비밀번호 관리
 - 6.4 이용자 비밀번호 관리
 - 6.5 전산원장 통제
 - 6.6 일괄작업 통제
- **(7. IT도입·개발·유지보수 관리)** 전자금융과 관련된 시스템 및 서비스 도입에 관한 타당성 검토를 비롯한 통제, 감리 및 보안성 심의 등에 관한 적정성을 평가
 - 통제구분 : 7.1 사업추진 시 준수사항
 - 7.2 사업계약 관련 준수사항
 - 7.3 정보처리시스템 감리
 - 7.4 직무분리
 - 7.5 프로그램 통제절차 수립
 - 7.6 자체 보안성심의
- **(9. 전자금융거래 보안)** 전자금융거래 시 준수사항, 전자금융거래 기록·보관 및 이용자 정보보호 등에 관한 적정성을 평가
 - 통제구분 : 9.1 전자금융거래 시 준수사항
 - 9.2 전자금융거래 기록·보관 (미평가)
 - 9.3 전자자금이체 한도 (미평가)
 - 9.4 이용자 정보보호
- **(11. 보안사고 대응)** 보안사고 발생 시 보고 및 침해사고 대응에 관한 적정성을 평가
 - 통제구분 : 11.1 정보기술부문 및 전자금융 사고 보고
 - 11.2 침해사고 대응
 - 11.3 손해배상

다. 물리적 보안

- **(4. 물리적·환경적 보안)** 전산센터 및 전산실에 대한 물리적 환경 보안 사항에 관한 적정성을 평가
 - 통제구분 : 4.1 전산센터 건물
 - 4.2 전산센터 설비
 - 4.3 전산실 보안

❖ 평가분야 설명

가. 관리체계 영역

- **(정보보호 관리체계)** 전자금융거래법, 전자금융감독규정 등을 중심으로 금융회사 내부규정 및 절차의 적정성을 평가
- **(가상화 시스템 관리체계)** 가상화 인스턴스 관리, 시스템 운영 등 가상화 시스템 운영에 대한 내부규정 수립 및 이행 적정성을 평가
- **(클라우드 관리체계)** 퍼블릭 클라우드에 대한 정책 수립, 구성, 접근 통제 정책 등의 적정성을 평가

나. 인프라 영역

- **(서버)** 정보처리시스템 운영 시 불필요한 서비스 활성화 등 운영체제 보안설정에 관한 적정성을 기술 중심으로 평가
- **(웹서버-WAS)** 웹, WAS 보안 및 권한 설정 등을 포함한 서버 설정에 관한 적정성을 기술 중심으로 평가
- **(데이터베이스)** DBA 계정 권한, 비밀번호 등에 관한 보안설정의 적정성을 기술 중심으로 평가
- **(네트워크 인프라)** 네트워크 망분리, 네트워크 접근통제 등 네트워크 구성 및 가용성 확보에 관한 적정성을 관리 중심으로 평가
- **(네트워크 장비)** 네트워크 운영 장비에 관한 보안설정 등에 관한 적정성을 기술 중심으로 평가
- **(정보보호시스템 장비)** 보안정책 및 정보보호시스템 보안설정 등에 관한 적정성을 기술 중심으로 평가
- **(OS 가상화 시스템)** OS 가상화 구현 및 관리에 사용되는 시스템의 보안 설정 적정성을 평가
- **(컨테이너 가상화 시스템)** 컨테이너 가상화 구현 및 관리에 사용되는 시스템의 보안 설정 적정성을 평가

다. 서비스 영역

- **(웹 애플리케이션)** 인터넷뱅킹 등 웹 기반 전자금융거래 서비스에 대한 침해 가능성을 기술 중심으로 평가
- **(모바일 애플리케이션)** 모바일뱅킹 등 모바일 기반 전자금융거래 서비스에 대한 보안 침해 가능성을 기술 중심으로 평가
- **(HTS 애플리케이션)** 증권회사에서 제공하는 HTS 애플리케이션에 대한 침해 가능성을 기술 중심으로 평가

라. 기타(선택)

- **(모의해킹)** 실제 해커가 사용하는 해킹도구 및 기법을 이용하여 인가받지 않은 외부 및 내부 침입자로부터의 침투 가능성 및 안정성을 평가

❖ **(위험도 분류)** 보안 취약점 평가항목에 해당되는 취약점에 대해 위험을 가늠할 수 있도록 위험도의 정도를 5단으로 분류

- 3단 분류 표기법을 이용할 경우 아래 <표기 방법 적용 예시>와 같이 상, 중, 하 적용 가능

[위험도 분류에 따른 표기 방법 적용 예시]

위험도 (5단 분류)		위험도 (3단 분류)
높음 (위험도 : 5)	- 시스템 관리자 권한 획득 - 웹 사용자 및 관리자 권한 획득 - 가용성에 직접적인 영향 - 중요 정보 노출 등	상
다소 높음 (위험도 : 4)	- 시스템 사용자 권한 획득 - 가용성에 직접적인 영향 - 다른 취약점과 연계될 경우 시스템 관리자 또는 웹 관리자 권한 획득 등	
보통 (위험도 : 3)	- 다른 취약점과 연계될 경우 시스템 사용자 또는 웹 사용자 권한 획득 - 다른 취약점과 연계될 경우 중요 정보 유출 가능성 있음 - 가용성에 간접적인 영향 등	중
다소 낮음 (위험도 : 2)	- 추가적인 공격에 활용 가능한 시스템 정보 유출 - 가용성에 간접적인 영향 등	하
낮음 (위험도 : 1)	- 공격과 직접적인 연관은 없으나 불필요한 정보 등이 외부에 유출 - 호스트에 관한 일반 정보 유출 등	

5

평가 항목 선정

❖ **(공통사항)** 금융회사는 전자금융기반시설에 해당되는 경우 또는 전자금융기반시설과 주요정보통신기반시설을 겸하여 운영되는 경우가 존재하므로, 해당되는 기반시설을 선택하고 평가항목을 최종 결정

❖ **기반시설 선택**

- **(전자금융)** 금융회사가 운영하는 전자금융거래시스템 또는 서비스가 전자금융기반시설인 경우 선택
- **(주요정보)** 금융회사가 운영하는 전자금융거래시스템이 전자금융기반시설과 주요정보통신기반시설을 겸하는 경우 선택

❖ **평가항목 선정 방법**

가. 정보보호 관리체계 평가분야

- **(평가항목 선정)** 해당되는 기반시설을 선택

[평가항목 선정 예시]

구분	기반 시설 종류
정보보호 관리체계	전자금융기반시설, 주요정보통신기반시설

나. 가상화 시스템 관리체계 평가분야

- **(평가항목 선정)** 해당되는 기반시설을 선택하고 평가항목 선정

[평가항목 선정 예시]

평가항목ID	전자금융	주요정보
PRCI-001	○	○
PRCI-003	○	

☞ (예1) 기반시설이 전자금융인 경우 : PRCI-001, 003 점검

☞ (예2) 기반시설이 주요정보인 경우 : PRCI-001 점검

다. 클라우드 관리체계 평가분야

- (평가항목 선정) 해당되는 기반시설을 제공하는 클라우드 서비스 제공자를 선정

[평가항목 선정 예시]

구분	평가 대상 종류
클라우드 관리체계	AWS, Azure

라. 서버 평가분야

- (평가항목 선정) 해당되는 기반시설에서 운영되는 운영체제(OS)를 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	AIX	HP-UX	LINUX	Solaris	Windows
SRV-001	○	○	○	○	○
SRV-003					○
SRV-005	○	○	○	○	

☞ (예1) 평가대상이 HP-UX 인 경우 : SRV-001, 005 점검

☞ (예2) 평가대상이 Windows 인 경우 : SRV-001, 003 점검

마. 웹서버-WAS 평가분야

- (평가항목 선정) 해당되는 기반시설에서 운영되는 운영체제(OS)와 미들웨어(웹서버, WAS)를 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	AIX	HP-UX	LINUX	Solaris	Windows	Apache	WebtoB	IIS	Tomcat	JEUS
WST-038	○	○	○	○	○	○		○		
WST-039	○	○	○	○	○	○	○	○	○	○
WST-040					○			○		

☞ (예1) 평가대상이 HP-UX + WebtoB인 경우 : WST-039 점검

☞ (예2) 평가대상이 Windows + IIS인 경우 : WST-038, 039, 040 점검

바. 데이터베이스 평가분야

- (평가항목 선정) 해당되는 기반시설에서 평가대상이 운영되는 환경(온프레미스, 클라우드 관리형)과 DBMS 종류를 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	클라우드	ORACLE	MSSQL	MYSQL	MariaDB	PostgreSQL	Tibero
DBM-012		○					
DBM-013	○	○	○	○	○	○	○
DBM-014	○	○					

☞ (예1) 평가대상이 온프레미스 ORACLE인 경우 : DBM-012, 013, 014 점검

☞ (예2) 평가대상이 클라우드 관리형* ORACLE인 경우 : DBM-013, 014 점검

* ORACLE, MSSQL, MYSQL, MariaDB, PostgreSQL만 해당

사. 네트워크 장비 평가분야

- (평가항목 선정) 해당되는 기반시설에서 평가대상의 그룹 및 장비(스위치, 라우터) 종류를 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	스위치	라우터	A Group (CISCO)	B Group (A10)	C Group (BROCADE, ALTEON, NOTEL,BIGIP, CITRIX, PIOLINK)	D Group (3COM, JUNIPER)
NET-005	○	○	○	○	○	○
NET-006		○	○		○	
NET-007	○	○	○	○	○	○

☞ (예1) 평가대상이 A Group 이고, 스위치인 경우 : NET-005, 007 점검

평가대상이 A Group 이고, 라우터인 경우 : NET-005, 006, 007 점검

☞ (예2) 평가대상이 B Group 이고, 스위치, 라우터인 경우 : NET-005, 007 점검

아. 정보보호시스템 장비 평가분야

- **(평가항목 선정)** 해당되는 기반시설에서 평가대상 장비(방화벽, IDS, DDoS 등)를 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	FW	VPN	IDS	IPS	DDoS	WAF
ISS-011			○	○	○	
ISS-013	○	○				
ISS-014	○	○	○	○	○	○

☞ (예1) 평가대상이 방화벽(FW) 인 경우 : ISS-013, 014 점검

☞ (예2) 평가대상이 웹방화벽(WAF) 인 경우 : ISS-014 점검

자. 웹·모바일·HTS 애플리케이션 평가분야

- **(평가항목 선정)** 해당되는 기반시설에서 평가대상 애플리케이션의 평가분야 및 서비스 유형(금융·비금융)을 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID (WEB)	취약점ID (Mobile)	취약점ID (HTS)	Sub NUM
WEB-SER-	MOB-SER-	HTS-SER-	019
	MOB-SER-		020
WEB-SER-			021

☞ (예1) 대상이 WEB 인 경우 : WEB-SER-019, WEB-SER-021 점검

☞ (예2) 대상이 Mobile 인 경우 : MOB-SER-019, MOB-SER-020 점검

☞ (예3) 평가대상이 HTS 인 경우 : HTS-SER-019 점검

- **(서비스 유형별)** 금융회사에서 제공하는 서비스를 우선 선별 후 선별된 서비스의 유형에 따라 평가항목을 선택하여 평가

[평가항목 선정 예시]

서비스 유형	대상 (예시)	구 분	평가항목 선정결과
전자금융거래 기능이 포함된 경우	- 인터넷뱅킹, 기업뱅킹 등	「전자금융」 평가항목 : A개 + 「서비스」 평가항목 : B개	A+B개 항목 적용
전자금융거래 기능이 미포함된 경우	- 단순 홍보성 또는 정보 제공 사이트 등	「전자금융」 평가항목 : NA + 「서비스」 평가항목 : B개	B개 항목 적용

차. OS 가상화 시스템 평가분야

- (평가대상) 해당되는 기반시설에서 운영하는 자산을 확인

구분	평가 대상 종류
OS 가상화 시스템	VMware vCenter, VMware ESXi, Citrix XenServer

- (평가항목 선정) 해당되는 기반시설에서 운영되는 가상화 시스템을 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	vCenter	ESXi	XenServer
PRCV-001	○	○	○
PRCV-008		○	

- ☞ (예1) 평가대상이 vCenter인 경우 : PRCV-001 점검
- ☞ (예2) 평가대상이 ESXi인 경우 : PRCV-001, 008 점검
- ☞ (예3) 평가대상이 XenServer인 경우 : PRCV-001 점검

카. 컨테이너 가상화 시스템 평가분야

- (평가대상) 해당되는 기반시설에서 운영하는 자산을 확인

구분	평가 대상 종류
컨테이너 가상화 시스템	Kubernetes(master, worker), OCP(master, worker), EKS*(master, worker), AKS**(master, worker), Docker

* Elastic Kubernetes Service

** Azure Kubernetes Service

- **(평가항목 선정)** 해당되는 기반시설에서 운영하는 가상화 시스템을 선택하여 자산별 평가항목을 선정

[평가항목 선정 예시]

평가항목ID	EKS MASTER	EKS WORKER	AKS MASTER	AKS WORKER	DOCKER
PRCC-001	○		○		
PRCC-007	○	○	○	○	○
PRCC-040		○		○	○

- ☞ (예1) 평가대상이 EKS MASTER, AKS MASTER인 경우 : PRCC-001, 007 점검
- ☞ (예2) 평가대상이 EKS WORKER, AKS WORKER, DOCKER인 경우 : PRCC-007, 040 점검

- ❖ **(평가항목 예외처리)** 금융회사에서 제공하지 않는 서비스에 관한 평가항목 또는 각종 관계법령에 적용 받지 않는 평가항목은 평가 시 예외처리(NA) 가능



참고

평가항목 예외처리(NA)시 부적절 사례

☞ (예1) [평가항목] 전자적 침해행위로 인한 정보처리시스템 사고 보고 여부

- (적절한 사례) 우리회사는 전자금융감독규정 제00조에서 정한 내용을 준수하지만 최근 발생한 사고가 없어 보고한 사실이 없으므로 → 양호
- (부적절한 사례) 우리회사는 전자금융감독규정 제00조에서 정한 내용을 준수하지만 최근 발생한 사고가 없어 보고한 사실이 없으므로 → NA

☞ (예2) 불필요한 SMTP 서비스 실행 여부

- (적절한 사례) 우리회사 서버는 업무와 관계없는 SMTP서비스를 사용하지 않으므로 → 양호
- (부적절한 사례) 우리회사 서버는 업무와 관계없는 SMTP서비스를 사용하지 않으므로 → NA

6

평가 결과 표현 및 보고

- ❖ **(평가 결과 표현)** 각 평가 결과는 ‘취약, 양호, 이행, 부분이행’ 등 사전에 정한 방법으로 명확하고 일관되게 표기
 - 평가 결과 표현을 ‘권고, 검토, 점검요망’ 등 취약 여부를 불명확하게 표기하여 관리 및 보고하는 방법은 권장하지 않음
- ❖ **(취약점 조치)** 평가대상에 실제 적용된 정보를 근거로 취약 여부를 판단하고 발견된 취약점은 시스템 패치, 소스코드 수정, 보안 설정 적용 등의 방법으로 직접 조치
- ❖ **(위험수용)** 취약점 분석·평가에서 도출된 보안 취약점을 제거하기 어렵거나 상응하는 조치가 불가한 경우
 - 위험 수용한 취약점은 위험이 제거되지 않은 상태이므로 취약으로 설정하고, 해당 취약점을 별도로 관리할 것을 권장
- ❖ **(평가 결과 보고)** 금융회사는 내부 정보보호위원회 또는 금융당국 보고 시 발견된 취약점 위주로 보고 및 관리할 것을 권장



참고

평가 결과 보고 시 부적절 사례 예시

【 가 정 】

- A 금융회사는 금번 평가에서 총 300개의 취약점이 발견됨 (취약그룹 총 20개)
- A 금융회사는 평가기준 중 발견된 취약점 150개를 즉시 조치
- 나머지 150개 취약점 중 130개를 현장에서 위험수용 등 실제 조치할 잔여 취약점 총 20개

☞ 금융회사 정보보호위원회 내부 보고 및 금융당국 보고 시 부적절 사례

- (예1) 발견된 총 300개 취약점은 보고하지 않고, 취약그룹 20개만 보고
- (예2) 발견된 총 300개 중 잔여 취약점 20개만 보고
- (예3) 130개 위험수용 된 취약점은 조치된 것으로 자체 판단

☞ 금융회사 정보보호위원회 내부 보고 및 금융당국 보고 시 적절 사례

- 가. 발견된 취약점 총 : 300개
- 나. 현장조치된 취약점 수 : 150개
- 다. 잔여취약점 : 20개
- 라. 위험수용 취약점 : 130개 (정보보호위원회 승인 득함)

참고

1

평가 전담반 구성 기준 및 유의사항



2026년
전자금융기반시설
보안 취약점
평가기준 안내서

1

평가 전담반 구성 기준 및 유의사항

아래 내용은 전자금융기반시설 관계 법령 원문을 인용

① 취약점 분석·평가 전담반 구성

- 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) 제2항
- ② 금융회사 및 전자금융업자는 취약점 분석·평가를 위하여 정보보호최고책임자(정보보호최고책임자가 없는 경우 최고경영자가 지정한다)를 포함하여 5인 이상으로 자체전담반을 구성하여야 하며, 구성원 중 100분의 30 이상은 「정보보호산업의 진흥에 관한 법률 시행규칙」 제8조의 정보보호 전문서비스 기업 지정기준에서 정한 고급 기술인력 이상의 자격을 갖춘 자이어야 한다. 다만, 제37조의3제1항에 따른 평가전문기관에 위탁하는 경우에는 자체전담반을 구성하지 아니할 수 있다.

② 취약점 분석·평가 실시

- 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) 제1항
- ① 전자금융기반시설의 취약점 분석·평가는 총자산이 2조원 이상이고, 상시 종업원 수(「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 기준으로 한다. 이하 같다) 300명 이상인 금융회사 또는 전자금융업자이거나 「수산업협동조합법」, 「산림조합법」, 「신용협동조합법」, 「상호저축은행법」 및 「새마을금고법」에 따른 중앙회의 경우 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시하여야 한다.

③ 취약점 분석·평가 결과 제출

- 전자금융거래법 제21조의3(전자금융기반시설 취약점 분석·평가)
 - ① 금융회사 및 전자금융업자는 전자금융거래의 안전성과 신뢰성을 확보하기 위하여 전자금융기반 시설에 대한 다음 각 호의 사항을 분석·평가하고 그결과(「정보통신기반 보호법」제9조에 따른 취약점 분석·평가를 한 경우에는 그 결과를 말한다)를 금융위원회에 보고하여야 한다.
 1. 정보기술부문의 조직, 시설 및 내부통제에 관한 사항
 2. 정보기술부문의 전자적 장치 및 접근매체에 관한 사항
 3. 전자금융거래의 유지를 위한 침해사고 대응조치에 관한 사항
 4. 그 밖에 대통령령으로 정하는 사항
- 전자금융거래법시행령 제11조의6(전자금융기반시설 취약점 분석·평가의 절차 및 방법 등) 제3항
 - ③ 금융회사 및 전자금융업자는 법 제21조의3제1항에 따라 전자금융기반시설의 취약점 분석·평가를 하였을 때에는 다음 각 호의 사항이 포함된 결과보고 및 보완조치 이행계획서를 그 취약점 분석·평가 종료 후 30일 이내에 금융위원회에 제출하여야 한다.
 1. 취약점 분석·평가의 사유, 대상, 기간 등 실시개요
 2. 취약점 분석·평가의 세부 수행방법
 3. 취약점 분석·평가 결과
 4. 취약점 분석·평가 결과에 따른 필요한 보완조치의 이행계획
 5. 그 밖에 취약점 분석·평가의 적정성을 확보하기 위하여 필요한 사항으로서 금융위원회가 정하여 고시하는 사항
- 전자금융거래법시행령 제30조(권한의 위탁)제1항, 제2항
 - ① 금융위원회는 법 제48조에 따라 다음 각 호의 업무를 금융감독원장에게 위탁한다.
(1의3호) 법 제21조의3제1항에 따른 취약점 분석·평가 결과의 접수
 - ② 금융감독원장은 제1항에 따라 위탁받은 업무의 처리결과를 금융위원회가 정하여 고시하는 바에 따라 금융위원회에 보고하여야 한다.

4 취약점 분석·평가 의무위반에 관한 관련 제재

- 전자금융거래법 제51조(과태료) 제2항, 제3항
 - ② 다음 각 호의 어느 하나에 해당하는 자에게는 2천만원 이하의 과태료를 부과한다.
〈개정 2014. 10. 15., 2017. 4. 18.〉
 - 4. 제21조의3제1항을 위반하여 전자금융기반시설의 취약점을 분석·평가하지 아니한 자
 - 5. 제21조의3제2항을 위반하여 보완조치의 이행계획을 수립·시행하지 아니한 자
 - ③ 다음 각 호의 어느 하나에 해당하는 자(제1호, 제6호부터 제8호까지 및 제10호의 경우에는 제28조제4항에 따라 해당 규정을 준용하는 선불전자지급수단을 발행하는 자를 포함한다)에게는 1천만원 이하의 과태료를 부과한다. 〈개정 2017.4.18.〉
 - 5. 제21조의3제1항을 위반하여 전자금융기반시설의 취약점 분석·평가의 결과를 보고하지 아니한 자

참고 2

전자금융기반시설 보안 취약점 평가기준 주요 개정사항



2026년
전자금융기반시설
보안 취약점
평가기준 안내서

❖ 개정 결과(요약)

- 전체 789개 항목에서 869개 항목으로 557개 항목 개정

【 (현행) 제2025-1호 】		【 (개정) 제2026-1호 】			
평가분야		제2025-1호	제2026-1호	신규	삭제
관리체계 영역 (필수)	정보보호 관리체계	288	175	3	116
	가상화 시스템 관리체계	20	20	-	-
	클라우드 관리체계	-	73	73	-
	서버	118	106	3	15
인프라 영역 (필수)	웹서버-WAS	-	126	126	-
	데이터베이스	27	31	4	-
	네트워크 인프라	18	18	-	-
	네트워크 장비	43	45	2	-
	정보보호시스템 장비	42	43	1	-
	OS 가상화 시스템	36	35	-	1
서비스 영역 (필수)	컨테이너 가상화 시스템	50	50	-	-
	웹	48	48	-	-
	모바일	56	56	-	-
	HTS	43	43	-	-
공통 (선택)	모의해킹 ¹⁾	-	-	-	-
	합계	789	869	212	132
					개선
					165
					1
					-
					17
					-
					4
					-
					1
					2
					7
					9
					2
					3
					2
					-
					213

1) 선택 평가분야로 모의해킹 수행 시 사전 인내 예정

❖ 주요 개정 사항

- 정보보호 관리체계 : '25년 개정된 전지금융감독규정 및 시행세칙, 전지금융 감독규정 해설서 반영
- 가상화 시스템 관리체계 : 기존 “클라우드 관리체계”에서 “가상화 시스템 관리체계”로 분야명 변경
- 클라우드 관리체계 : 퍼블릭 클라우드(AWS, Azure) 콘솔 점검을 위한 평가분야 신규 추가
- 웹서버-WAS : 웹서버 등 설정 점검을 위한 평가분야 신규 추가
- 데이터베이스 : 평가대상 확대(AWS RDS, Aurora 등 9개)
- 가상화 시스템 : 평가대상 확대(XenServer, EKS, AKS)
- 인프라 부문(서버, 데이터베이스, 네트워크 장비 등) : EoS 기준 강화

항목 명	변경 전	변경 후
서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	○ 공개된 취약점에 의한 침해를 방지하고, 시스템에 대한 안전성 향상을 위해 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행(또는 보호방안 수립) 여부를 점검 ○ EoS 장비 사용 여부 점검 * EoS의 경우 별도의 계약으로 벤더사의 보안패치를 받을 수 있거나 EoS 장비 교체 계획을 수립하고 보고를 마친 경우 제외	○ 서비스 지원이 종료된(EoS) 버전을 사용하는 경우, 알려진 취약점 또는 신규로 발견되는 취약점으로부터 발생하는 보안위협에 대처할 수 없는 위험이 존재하므로 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검 ※ 장비 교체 계획을 수립하고 보고를 마친 경우 취약으로 반영하고, 위험수용으로 관리 ※ 예외사항: 네트워크에 연결되지 않은 오프라인 서버는 별도 내부 기준을 마련하여 관리

❖ 정보보호 관리체계 분야 개정사항

- 기존 288개 항목에서 175개 항목으로 284개 항목 개정(신규 3개, 삭제 116개, 개선 165개)

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	FISM-001	정보보안 관련법규 위반에 관한 제재기준 및 절차수립 및 운영 여부	개선	-	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
2	FISM-002	정보기술(IT)부문계획 매년 수립 및 운용 여부	개선	-	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
3	FISM-003	정보처리시스템 관련 전담조직 운영 여부	개선	-	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
4	FISM-004	전자금융업무 관련 전담조직 운영 여부	개선	-	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
5	FISM-005	IT 아웃소싱(이하 'IT자회사' 포함) 통제/관리 조직(인력포함) 운영 여부	개선	-	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
6	FISM-010	정보보호최고책임자(CISO) 지정 여부	개선	-	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선		주요 개정사항
7	FISM-011	정기적으로 수행되는 임직원 정보 보안 관련법규 준수여부 점검 결과에 대한 임원(정보보호최고 책임자, 최고경영자)보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
8	FISM-014	정보보호위원회 심의·의결 사항에 관한 적정성	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
9	FISM-015	정보보호위원회 심의·의결 사항에 관한 임원(정보보호최고책임자, 최고경영자) 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
10	FISM-019	IT인력 및 정보보호인력에 대한 연수 프로그램 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
11	FISM-021	정보보호 교육 실시 이후, 대상 임직원에 대한 평가 수행 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
12	FISM-022	건물 출입통제보안대책의 수립/운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
13	FISM-031	주요설비시설 출입통제장치 설치 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목	주요 개정사항
14	FISM-041	화재감지센서와 연동된 경보장치 설치 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
15	FISM-056	국내 본점을 둔 금융기관의 전산실 및 재해복구센터의 국내 설치 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
16	FISM-057	전산실내 무선통신망 설치 및 운용 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
17	FISM-058	업무(관련)담당자 이외 사용자에게 대한 단말기 무단조작 방지조치 적용 여부	개선	인가된 사용자 외 단말기 무단조작 방지 여부	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
18	FISM-059	정보처리시스템 접속과 관련하여 사용자인가 여부를 확인할 수 있는 기록 유지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
19	FISM-060	외부 반출, 인터넷 접속, 그룹웨어 접속의 금지 등 강화된 보호대책이 적용되는 중요단말기 지정 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
20	FISM-061	사용자 단말기에서 보조기억매체 및 휴대용 전산장비에 관한 접근 통제(정보유출, 악성코드 감염방지 등) 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
21	FISM-062	자산자료 보유현황 관리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
22	FISM-063	자산자료 책임자 지정 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
23	FISM-064	자산자료 및 전산장비의 반출/반입 통제 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
24	FISM-065	보조기억매체 등 전산자료에 대한 안전지출 및 파기계획 수립 및 운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
25	FISM-066	보조기억매체 보유현황 및 관리 실태에 관한 정기점검 및 책임자 확인 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
26	FISM-067	자산자료의 정기백업/소산 등 백업 내역에 관한 기록 및 관리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
27	FISM-068	자산자료 중요도 분류기준 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
28	FISM-069	주요 백업 전산자료에 대한 정기 검증 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
29	FISM-070	이용자 정보 조회 및 출력에 대한 통제 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
30	FISM-071	테스트 시 이용자 정보 사용금지 (부하테스트 등의 불가피한 경우 이용자정보 변환 사용 및 테스트 종료즉시 삭제) 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
31	FISM-072	정보처리시스템 가동기록(정보처리 시스템 접속기록, 전산자료 사용 기록, 전산자료 처리기록) 1년 이상 보존 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
32	FISM-074	단말기에 이용자 정보 등 주요정보 보관 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
33	FISM-075	단말기 공유 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
34	FISM-076	단말기 내 주요정보 보관 필요시, 관련 절차 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
35	FISM-078	주요 정보처리시스템에 대한 운영 매뉴얼 등 작성 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선사항		주요 개정사항
36	FISM-083	정상작동여부 확인을 위한 정보 처리시스템 자원 상태의 감시, 경고 및 제어가 가능한 모니터링 시스템 설치 및 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
37	FISM-084	시스템 통합, 전환 및 재개별시 정보 처리시스템의 운영에 지장을 초래하지 않도록 통제절차 마련 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
38	FISM-086	운영체제, 시스템 유틸리티 등의 긴급하고 중요한 보정(patch) 사항에 대하여는 즉시 보정 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
39	FISM-087	중요도에 따른 운영체제(Operating System) 및 설정내용 등의 정기 백업, 원격안전지역 소산 및 백업 자료 1년 이상 기록/관리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
40	FISM-088	정보처리시스템의 운영체제(Operating System) 계정으로 로그인(Log in)할 경우 계정 및 비밀번호 이외에 별도의 추가인증 적용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선		주요 개정사항
41	FISM-089	정보처리시스템 운영체제 (Operating System) 계정에 대한 사용권한, 접근 기록, 작업 내역 등에 대한 상시 모니터링 체계 수립 여부 및 이상 징후 발생 시 필요한 통제 조치 시행 여부	개선	-	정보처리시스템 운영체제 계정에 대한 작업 내역 등 상시 모니터링 체계 수립 여부 및 이상징후 발생 시 통제 조치 시행 여부
42	FISM-091	정보처리시스템 사용 현황 및 추이 분석 등 정기적 실시 여부	개선	-	정보처리시스템 운영체제 계정에 대한 작업 내역 등 상시 모니터링 체계 수립 여부 및 이상징후 발생 시 통제 조치 시행 여부
43	FISM-092	전자금융기반시설의 취약점 분석·평가는 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시 여부	개선	-	전자금융감독규정 및 시행세칙 개정안 반영
44	FISM-093	취약점 분석·평가결과에 따른 취약점 제거 또는 이에 상응하는 조치 이행 여부	개선	-	전자금융감독규정 및 시행세칙 개정안 반영
45	FISM-094	취약점 제거 또는 이에 상응하는 조치가 불기한 경우 최고경영자 승인 취득 여부	개선	-	전자금융감독규정 및 시행세칙 개정안 반영
46	FISM-095	취약점 분석·평가결과에 대한 이행계획 수립 여부 및 최고경영자 보고 여부	개선	-	전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선사항	평가항목ID	평가항목
47	FISM-096	해킹 등을 방지하기 위한 정보 보호시스템 설치 및 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
48	FISM-097	내부 단말기의 정보보호시스템을 우회한 인터넷 등 외부 통신망(무선 통신망 포함) 접속 차단 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
49	FISM-098	내부통신망과 연결된 내부 업무용 시스템이 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
50	FISM-099	내부통신망에서의 파일 배포기능 이용 시 파일 무결성 검증 수행 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
51	FISM-100	전산실 내에 위치한 정보처리 시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기가 인터넷 등 외부 통신망으로부터 물리적으로 분리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
52	FISM-101	정보보호시스템에 최소한의 서비스 번호와 기능 적용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
53	FISM-102	정보보호시스템의 업무목적 이외 기능 및 프로그램 제거 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
54	FISM-103	정보보안 정책 승인 및 적용 시, 정책 등록, 변경, 삭제 내용에 대한 보관 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
55	FISM-104	정보보호시스템 원격관리 차단 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
56	FISM-105	정보보호시스템 원격관리 이용 시, 원격 접속에 관한 보안대책 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
57	FISM-106	정보보호시스템 작동상태 모니터링 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
58	FISM-107	정보보호시스템에 대한 백업 및 복구절차 수립 및 시행 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
59	FISM-109	무선통신망 이용 업무의 정보보호 최고책임자 승인 및 사전 지정 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
60	FISM-110	사용자인증, 암호화 등 무선통신망 보안대책 수립	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
61	FISM-111	금융회사 내부망에 연결된 정보처리 시스템이 지정 된 업무 용도와 사용 지역(zone) 이외의 무선통신망에 접속하는 것을 차단하기 위한 차단 시스템 구축 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
62	FISM-112	무선통신망 실시간 모니터링체계 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
63	FISM-114	응용프로그램에 대한 악성코드감색 프로그램 진단/치료 후 사용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
64	FISM-117	중요 단말기의 악성코드 감염 여부 매일 점검 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
65	FISM-119	공개용 웹사이트의 DMZ구간내 설치 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
66	FISM-120	공개용 웹서버를 네트워크 및 웹 접근 제어 수단으로 보호 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
67	FISM-121	공개용 웹서버 접근 사용자계정을 업무관련자로 제한 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
68	FISM-122	공개용 웹서버에 접근할 수 있는 사용자계정은 아이디 비밀번호 이외에 추가인증수단 적용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
69	FISM-123	공개용 웹서버 제공이외 다른 서비스 및 시험/개발도구 등의 사용 제한 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
70	FISM-128	홈페이지에 자료를 게시하는 담당자의 지정/운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
71	FISM-129	개인정보의 유출 및 위/변조를 방지하기 위한 보안조치 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
72	FISM-131	단말기에서 음란, 도박 등 업무와 무관한 프로그램 및 인터넷사이트에 대한 접근 통제 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
73	FISM-135	내/외부 IP주소의 인터넷 접속 내용 1년이상 별도 기록/보관 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
74	FISM-138	암호프로그램 담당자 지정 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
75	FISM-139	암호프로그램의 비담당자 이용에 관한 통제 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선사항	평가항목ID	평가항목
76	FISM-140	암호프로그램에 대한 원시프로그램 별도 보관 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
77	FISM-141	암호 및 인증시스템에 적용되는 키에 대하여 주입/운용/갱신/폐기에 대한 절차 및 방법 마련 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
78	FISM-142	사용자계정에 대한 비밀번호 등록/변경/폐기 체계 및 절차 마련 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
79	FISM-146	사용자 인사조치 시 지체없이 해당 사용자 계정 삭제, 사용 중지, 공동 사용 계정 변경 등 정보처리시스템 접근 통제 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
80	FISM-147	사용자 계정 공동사용 시 개인별 사용내역에 대한 기록저장 및 관리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
81	FISM-148	정보처리시스템 관리자에 대한 적절한 통제장치 마련 및 운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
82	FISM-149	정보처리시스템 관리자 주요업무 관행행위의 책임자 이중 확인 및 모니터링 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선사항		주요 개정사항
83	FISM-153	내부사용자 비밀번호에 관한 주기적 (분기별 1회 이상) 변경 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
84	FISM-154	내부사용자 비밀번호 보관시 암호화 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
85	FISM-156	내부사용자 비밀번호 연속 입력 오류(최대5회)시 즉시 접속 차단 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
86	FISM-158	정보처리시스템 및 전산자료에 보관하고 있는 이용자 비밀번호 암호화 보관 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
87	FISM-159	이용자 비밀번호 조회 금지 및 불가피한 경우 조회사유 및 내용 기록 관리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
88	FISM-160	이용자 비밀번호 등록 시, 주민등록번호/동일숫자/연속숫자 등 제3자가 쉽게 유추할 수 있는 비밀번호의 등록 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
89	FISM-162	이용자 비밀번호가 일정횟수(최대 5회) 입력오류 시 해당비밀번호 이용거래에 대한 즉시 중지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
90	FISM-163	이체비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우 입력오류 횟수는 이용되는 모든 전자금융 거래에 대한 통산 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
91	FISM-164	이용 중지된 이용자 비밀번호의 재부여 또는 거래재개 시 본인확인 절차 적용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
92	FISM-167	신규거래, 비밀번호 변경, 이체 신청 등 비밀번호를 등록/사용하는 경우 사전에 신청서등에 기재 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
93	FISM-168	비밀번호를 등록·사용하는 경우 핀패드 등 보안장치를 이용 또는 사후에 전자적 장치를 이용하여 직접 입력하는 방식의 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
94	FISM-169	전산원장 변경을 위한 변경절차 수립 및 운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
95	FISM-170	전산원장 변경절차에 변경 대상 및 방법 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
96	FISM-171	전산원장 변경절차에 변경 권한자 지정 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
97	FISM-172	전산원장 변경 절차에 변경 전후 내용 자동기록 및 보존 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
98	FISM-173	전산원장 변경절차에 변경내용의 정당여부에 대한 제3자 확인 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
99	FISM-174	대차대표 등 중요자료 계상액과 각종 보조부/거래기록/전산원장 파일의 계상액에 대한 상호일치 여부에 대한 전산시스템을 통한 주기적인 확인 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
100	FISM-175	전산원장 불일치 원인과 조치 내용을 전산자료형태로 5년간 보존 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
101	FISM-176	중요원장의 조회, 수정, 삭제, 삽입한 작업자와 작업내용 기록 및 5년간 보존 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
102	FISM-177	사고위험도가 높은 거래에 대한 전산시스템 기반의 책임자 이중 확인 절차 적용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
103	FISM-178	전산원장, 주요정보, 이용자정보 등이 저장된 정보처리시스템 중요 작업에 대한 책임자 이중확인 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
104	FISM-179	일괄작업 요청 시 작업요청서의 책임자 승인 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
105	FISM-184	부서장 전결 금액 이상 사업에 대한 사전 타당성 검토 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
106	FISM-188	객관적인 업체 선정 기준 및 절차 마련 및 운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
107	FISM-197	정보처리시스템 감리 지침에 감리 목적, 대상, 감리인, 감리시기, 계획 등 일반기준 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
108	FISM-201	프로그램과 오퍼레이터의 직무 분리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
109	FISM-209	적용대상 프로그램 종류 및 등록/변경/폐기 방법에 관한 절차 수립 및 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
110	FISM-219	신규 업무 및 표준 제정 시 보안성 심의 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
111	FISM-221	업무지속성 확보방안에 상황별 대응절차 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
112	FISM-222	업무지속성 확보방안에 백업 또는 재해복구센터를 활용한 재해복구 계획 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
113	FISM-223	업무지속성 확보방안에 비상대응 조직의 구성 및 운용 포함	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
114	FISM-224	업무지속성 확보방안에 입력대행, 수작업 등의 조건 및 절차 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
115	FISM-225	업무지속성 확보방안에 모의 훈련의 실시 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
116	FISM-226	업무지속성 확보방안에 유관기관 및 관련업체와의 비상연락체계 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
117	FISM-227	업무지속성 확보방안에 보고 및 대외통보의 범위와 절차 포함 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
118	FISM-228	업무지속성 확보대책을 매년 1회 이상 점검 및 최신상태 유지 및 관리 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
119	FISM-229	정보처리시스템 및 데이터저장 장치 등 주요 전산장비의 이중화 구축 또는 예비장치 확보 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
120	FISM-230	주전산센터와 일정거리 이상 떨어진 안전장소에 재해복구센터 구축 및 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
121	FISM-231	적정한 규모와 인력을 구비한 재해 복구센터 구축 및 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
122	FISM-232	재해복구 목표시간 내 재해복구 가능 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
123	FISM-233	매년 1회 이상 재해복구센터로 재해 복구전환훈련 실시 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
124	FISM-238	위기대응 행동매뉴얼 또는 비상 대책 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
125	FISM-241	연 1회 해킹, 디도스공격 등 침해 사고 대응 및 복구훈련 실시와 침해 사고대응기관에 제출 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
126	FISM-242	금융위원회 주관 금융분야 합동 비상대응훈련 실시 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
127	FISM-243	전자금융거래 시 암호화 통신 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
128	FISM-244	전자금융거래 시 비대면 전자금융 거래를 허용하지 않는 계좌개설 서비스를 제공할 수 있도록 시스템 구축 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
129	FISM-245	전자금융거래 시 중요거래정보에 대한 문자메시지 및 이메일서비스를 제공할 수 있도록 시스템 구축 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
130	FISM-246	전자금융거래 시 전자금융거래에 사용되는 접근매체의 본인 실명 증표 확인 후 교부 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
131	FISM-247	전자금융거래에 관한 거래인증 수단 채택시 안전성, 보안성, 이용 편의성 등을 충분히 고려 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
132	FISM-249	전자금융거래의 종류·성격·위험 수준 등을 고려한 인증방법 사용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개선사항	평가항목	주요 개정사항
133	FISM-251	이용자 비밀번호 유출위험 및 관리에 관한 사항 공지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
134	FISM-256	IT외부주문 업무에 대한 업무직정성 검토 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
135	FISM-257	IT외부주문 계약 체결시 계약내용의 적정성 검토 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
136	FISM-258	외부주문 등의 입찰·계약·수행·완료 등 각 단계별로 금융감독 원장이 정하는 보안관리방안 준수 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
137	FISM-259	외부주문 시 내부통제방안 수립 및 운용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
138	FISM-260	외부주문 시 정보처리시스템 개발 업무에 사용되는 업무장소 및 전산 설비는 내부 업무용과 분리하여 설치·운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
139	FISM-262	외부주문 시 계좌번호, 비밀번호 등 이용자 금융정보 보관 및 유출 금지 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목	주요 개정사항
140	FISM-263	외부주문 시 접근매체 위/변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
141	FISM-264	외부주문 시 금융기관과 전자금융 보조업자간의 접속은 전용회선 사용 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
142	FISM-265	외부주문 시 정보처리시스템 장애 등 서비스 중단에 대비한 비상대책 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
143	FISM-266	외부주문 시 중요전자자료의 백업 자료 보존 및 백업설비 확보 등 백업대책 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
144	FISM-267	외부주문 사항에 대해 연1회 이상 재무건전성 평가 및 주요 경영활동 상시모니터링 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
145	FISM-268	외부주문 사항에 대해 연1회 이상 서비스 품질수준 평가 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
146	FISM-269	외부주문 사항에 대해 사전 동의 없는 재위탁, 계약업체 변경 금지 (사전 동의시 계약서 기재사항 포함) 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
147	FISM-270	외부주문 사항에 대해 위탁회사가 전자금융거래정보 보호와 관련된 전산장비·소프트웨어 개발, 운영, 유지관리 업무 재위탁 시, 금융거래 정보 변경사항에 대해 위탁회사 또는 원수탁업자가 이를 관리, 통제할 수 있는 절차 마련 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
148	FISM-271	외부주문 사항에 대해 위탁된 금융 거래정보가 위탁회사의 전산실 내 관리 및 보관 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
149	FISM-272	외부주문 시 업무 수행인력에 대한 사전 신원조회 실시, 대표자 신원 보증서 징구, 인력변경시 인수 인계에 관한사항 등 업무수행인력에 관한 관리방안 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
150	FISM-273	외부주문 시 자체 보안성 검토 및 정기 보안점검 실시 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
151	FISM-274	정보처리시스템 또는 통신회선 등의 장애로 10분 이상 전산 업무가 중단 또는 지연 사고에 대한 금융감독 원장 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목	주요 개정사항
152	FISM-275	전산자료 또는 프로그램의 조직과 관련 금융사고 보고에 대한 금융 감독원장 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
153	FISM-281	해킹 등 전자적 침해행위로 인한 피해 발생시 즉시 대처할 수 있도록 적절한 대책 마련 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
154	FISM-282	전자금융사고 시 책임이행을 위한 보험 등 가입 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
155	FISM-283	전자금융사고시 보상한도설정의 적정성 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
156	FISM-284	전자금융사고 시 책임이행을 위한 준비금 관리 및 지급에 관한 내부 절차 수립 및 운영 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
157	FISM-286	전자금융거래를 위한 전자적 장치 또는 정보통신망에 침입하여 부정확한 방법으로 획득한 접근매체의 이용으로 발생한 사고에 대한 금융 감독원장 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
158	FISM-287	오픈뱅킹 운영기관 등에서 정한 기준에 따라 보안 점검을 실시* 하고, 결과에 따른 미흡사항의 제거 또는 그에 상응하는 조치시행 여부 * 오픈뱅킹 서비스 개시 1년이상 경과한 금융회사 등에 해당	개선	-	오픈뱅킹 운영기관에서 정한 기준에 따라 오픈뱅킹 서비스 보안 점검 실시 및 이행점검 실시 여부
159	FISM-289	클라우드컴퓨팅서비스 이용계약 신규 체결 시 금융감독원 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
160	FISM-290	클라우드컴퓨팅서비스 제공자 변경(합병, 재위탁 등) 시 금융감독원 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
161	FISM-291	클라우드컴퓨팅서비스 제공자의 서비스 품질 미이행 시 대응 계획 보고 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
162	FISM-292	클라우드컴퓨팅서비스 이용 업무의 중요도 평가 기준 수립 및 시행 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
163	FISM-293	클라우드컴퓨팅서비스 제공자의 건전성 및 안전성에 대한 평가 실시 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
164	FISM-294	클라우드컴퓨팅서비스 업무 연속성 계획 수립 및 안전성 확보 조치 수립 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
165	FISM-295	클라우드컴퓨팅서비스 정보보호 위원회 심의 및 의결을 통해 평가 결과 승인 여부	개선	-	○ 평가 항목 개선 - 전자금융감독규정 및 시행세칙 개정안 반영
166	-	-	신규	FISM-297	○ 평가 항목 신규 - 전자금융감독규정 제23조(비상대책 등의 수립·운용) 반영
167	-	-	신규	FISM-298	○ 평가 항목 신규 - 전자금융감독규정 제34조의3(이용자 비밀번호 관리) 반영
168	-	-	신규	FISM-299	○ 평가 항목 신규 - 전자금융감독규정 제8조(인력, 조직, 교육 및 예산) 반영
169	FISM-016	정보보안점검의 날 지정 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
170	FISM-017	정보보안 점검의 날 금융감독원이 정한 정보보호 점검항목에 대한 점검 이행(매월) 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
171	FISM-018	정보보안 점검의 날 점검결과에 관한 최고경영자에게 보고 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
172	FISM-020	정보보호최고책임자는 임직원의 정보보호역량 강화를 위하여 필요한 교육프로그램을 개발하고, 전자 금융감독규정에서 정한 기준에 따른 주기(매년)적 교육 시행 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
173	FISM-023	건물 출입구의 경비원 통제 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
174	FISM-024	비상시 대피를 위한 비상계단 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
175	FISM-025	정전대비 유도등 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
176	FISM-026	피뢰설비 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
177	FISM-027	적재하중 안전대책 수립 및 운영 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
178	FISM-028	소화기 및 자동소화설비 등 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
179	FISM-029	배연설비 설치 등 화재예방 안전 대책 수립 및 운용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
180	FISM-030	전산센터가 위치한 건물에 대해 화재발생, 상습침수 및 진동피해 발생 등 물리적, 환경적 위험지역 제외 및 건물 구조의 안정성 확보 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
181	FISM-032	전원, 공조, 방재, 방범 설비에 대한 감시제어시스템 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
182	FISM-033	자가발전설비 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
183	FISM-034	무정전전원장치 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
184	FISM-035	전력선 대체를 위한 복수회선 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
185	FISM-036	과전류차단기, 누전경보기 등 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
186	FISM-037	정전입정주파수장치 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
187	FISM-038	전원 및 공조설비는 부하가 큰 설비 부분과 분리 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
188	FISM-039	공조설비 상태 점검을 위한 입력계, 온도계 등 설치	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
189	FISM-040	전산실내 자동제어 항온/항습기 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
190	FISM-042	재해 및 외부 위해방지대책 수립/운용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
191	FISM-043	상시출입문은 한 곳으로 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
192	FISM-044	상시출입자의 사전 등록 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
193	FISM-045	상시출입자와 책임자 승인 및 출입자관리기록부 기록 및 보관 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
194	FISM-046	상시출입자와 출입사항 사후 확인을 위한 무인감시카메라 또는 출입 자동기록시스템설치 등 조치 및 사후 확인 가능 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
195	FISM-047	출입문은 이중안전장치로 보호 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
196	FISM-048	외벽 유리 창문을 통한 접근차단 조치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
197	FISM-049	외벽과 전산장비간 충분한 거리 유지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
198	FISM-050	이중비박설치 등 침수 대비 방안 강구 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
199	FISM-051	온도/습도자료 자동기록장치 및 경보장치 설치 등 조치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
200	FISM-052	전용 통로관 설치 등 케이블보호 조치 강구 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
201	FISM-053	조명설비 및 휴대용손전등 비치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개정사항	평가항목ID	평가항목
202	FISM-054	IDC 등 다수기관 공동이용장소에 정보처리시스템 설치 시 미승인자 접근 차단에 필요한 접근통제대책 수립 및 운용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
203	FISM-055	전산센터, 재해복구센터, 전산 자료보관실, 정보보호시스템 설치 장소 등 중요시설 및 지역의 보호 구역 설정 및 관리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
204	FISM-073	정보처리시스템 접속 오류(최대 5회)시 사용 제한 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
205	FISM-077	정보처리시스템 접근기록(접속일시, 접속자, 전산자료 사용일시, 사용자, 자료내용, 사용자 로그인, 액세스 로그 등)에 대한 자동 기록 및 보관 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
206	FISM-079	주요 정보처리시스템에 대한 시스템 운영 매뉴얼에 구동, 조작방법, 명령어사용법, 운용순서, 장애조치 및 연락처 등 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
207	FISM-080	주요 프로그램에 대한 유지보수 관리대장에 작업일, 작업내용, 작업결과 등을 작성 및 보관 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
208	FISM-081	데이터베이스관리시스템(Database Management System : DBMS), 운영체제(Operating System), 웹프로그래밍에 대한 주기적 유지보수 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
209	FISM-082	정보처리시스템 장애 발생시 장애 상황기록부에 장애일시, 장애내용, 조치사항 등을 작성 및 보관 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
210	FISM-085	정보처리시스템 책임자 지정 및 운영 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
211	FISM-113	비인가 무선접속장치 설치/점속 여부 및 중요정보노출여부에 대한 주기적 점검 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
212	FISM-115	악성코드 검색 및 치료프로그램의 최신상태 유지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
213	FISM-116	악성코드 감염대비 복구절차 마련 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
214	FISM-118	악성코드 감염 발견시 악성코드 확산 및 피해 최소화를 위한 필요 조치 마련 및 시행 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
215	FISM-124	DMZ구간내 이용자 정보 등 주요 정보 저장 및 관리 금지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
216	FISM-125	공개용 웹서버 거래로그의 암호화 하여 저장/관리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
217	FISM-126	공개용 웹서버 게시자료에 대한 사전 관리 실시 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
218	FISM-127	공개용 웹서버에 무기명 또는 가명에 의한 게시 금지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
219	FISM-130	공개용 웹서버가 해킹공격에 노출 되지 않도록 대응 조치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
220	FISM-132	내부통신망 IP에 대한 사설IP 주소 사용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
221	FISM-133	IP주소 체계 외부유출 금지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
222	FISM-134	개인별로 내부 IP주소를 부여 및 유지/관리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
223	FISM-136	운영, 개발, 외주 등 업무특성별로 네트워크 분리 및 IP주소 사용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
224	FISM-137	내부통신망의 다른 기관 내부 통신망과 분리 사용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
225	FISM-143	개인별 사용자계정 및 비밀번호 부여 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
226	FISM-144	외부사용자에 대한 최소 작업권한 할당 및 통제장치 설치 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
227	FISM-145	전산자료 입력/출력/열람 시 사용자 업무별 접근권한 통제 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
228	FISM-150	내부사용자에 대한 비밀번호 설정 및 운영 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
229	FISM-151	내부사용자 비밀번호 설정 시, 이용자 식별부호(아이디), 생년월일, 주민등록번호, 전화번호 포함 금지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
230	FISM-152	비밀번호는 숫자, 영문자 및 특수 문자 등 혼합 8자리이상 설정 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
231	FISM-155	정보처리시스템마다 각기 다른 관리자 비밀번호 적용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
232	FISM-157	차단된 내부사용자 비밀번호 변경 시 본인확인 절차 적용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
233	FISM-161	이용자 비밀번호가 통신용 비밀 번호와 계좌원장 비밀번호를 구분 하여 사용하고 있는지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
234	FISM-165	거래전표, 계좌개설신청서 등에 이용자 비밀번호 기재 금지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
235	FISM-180	일괄작업 자동화 및 오류 최소화 방안 적용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
236	FISM-181	일괄작업 오류 발생시 책임자 확인 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
237	FISM-182	모든 일괄작업 내용 기록 및 관리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
238	FISM-183	일괄작업 수행자 주요업무관련 행위에 관한 책임자 모니터링 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
239	FISM-185	사업 신규/통합/전환/재개발 등 주요 추진사업에 대한 효과분석 실시 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
240	FISM-186	타당성 검토와 비용대비 효과분석 결과에 대한 전산운영위원회 등 승인 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
241	FISM-187	정보처리시스템의 분석/설계 단계부터 보안대책 마련 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
242	FISM-189	업체 선정 기준 및 절차에 정보보안 관련사항 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
243	FISM-190	공정하고 합리적인 예정가격 산출 기준 수립 및 적용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
244	FISM-191	계약이행에 필요한 내용을 포함한 계약서 작성기준 수립 및 운용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
245	FISM-192	소유권, 저작권, 지적재산권 등의 귀속관계 명확화 및 사후 분쟁 방지대책 마련 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
246	FISM-193	공급업체 파산 등 비상사태 대비 대책 마련 및 운용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
247	FISM-194	검수의 계약자, 개발자 등 이해 당사자 배제 및 공정한 검수 실시 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
248	FISM-195	계약조항 미이행 또는 계약조항 변경에 대한 검사부서 승인 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
249	FISM-196	검사가 정한 금액이상 계약에 대한 자체감사 또는 검사부서 승인 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
250	FISM-198	정보처리시스템 감리 지침에 기획, 개발 및 운영의 감리 실시 기준 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
251	FISM-199	정보처리시스템 감리 지침에 지적 사항 및 개선사항 등 감리 후 보고 기준 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
252	FISM-200	정보처리시스템 감리 지침에 전자 금융업무와 관련된 외부주문 등의 감리기준 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
253	FISM-202	응용 프로그램과 시스템 프로그래머의 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
254	FISM-203	시스템보안관리자와 시스템 프로그래머의 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
255	FISM-204	전산자료관리와 그 밖의 업무 담당자의 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
256	FISM-205	업무운영자와 내부감사자의 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
257	FISM-206	내부인력과 전자금융보조업자 및 유지보수업자 등을 포함한 외부 인력의 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
258	FISM-207	정보기술부문인력과 정보보호 인력의 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
259	FISM-208	내부통제와 관련한 직무 분리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
260	FISM-210	프로그램 변경 전후내용 기록 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
261	FISM-211	프로그램 등록/변경/폐기 내용의 정당성에 대한 제3자 검증 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
262	FISM-212	개발 또는 테스트 시스템으로 복사 후 프로그램 수정 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
			개정사항	평가항목ID	평가항목
263	FISM-213	업무담당자에 한정하여 프로그램 접근 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
264	FISM-214	정보의 기밀성/무결성/가용성을 고려하여 충분한 테스트 및 관련 책임자 승인 후 운영시스템에 적용 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
265	FISM-215	프로그램 반출, 실행프로그램 생성 및 운영시스템 등록은 전산자로 관리자 등 해당프로그램 담당자 이외자의 수행 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
266	FISM-216	데이터 베이스 관리 시스템(Database Management System : DBMS), 운영체제(Operating System) 등 시스템프로그램의 응용프로그램과 동일 수준 관리	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
267	FISM-217	프로그램 설명서, 입/출력레코드 설명서, 프로그램목록, 사용자 지침서, 운영지침서 등 프로그램 유지보수 문서 작성 및 관리 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
268	FISM-218	전자금융거래용 전산프로그램에 대한 사전 보안성 검증 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
					주요 개정사항
269	FISM-234	업무지속성 확보대책에 핵심전산 업무의 비상지원인력에 관한 확보 및 운영방안 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
270	FISM-235	업무지속성 확보대책에 비상지원 인력 또는 외부전문업체 활용방안 수립 및 운영 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
271	FISM-236	업무지속성 확보대책에 전산시스템 운영지침서, 사용자매뉴얼 등이 최신 상태로 유지되고 있는지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
272	FISM-237	업무지속성 확보대책에 비상지원 인력에 대한 연수 실시 여부 포함 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
273	FISM-248	전자금융거래 프로그램의 위/변조 등 무결성 검증방법 제공 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
274	FISM-250	사용자 단말기에서 이용자 정보 조회 내역(사용자, 사용일시, 변경 /조회내용, 접속방법)이 정보처리 시스템에 자동 기록되고 관련 기록의 1년 이상 보관여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
275	FISM-252	금융기관 등이 제공하는 이용자 보호제도에 관한 사항 공시 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
276	FISM-253	해킹/피싱 등 전자적 침해방지에 관한 사항 공지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
277	FISM-254	본인확인절차 후 비밀번호 변경 가능한 정보처리시스템 구축 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
278	FISM-255	이용자 비밀번호 변경시 동일 비밀번호 재사용 금지 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
279	FISM-276	전자적 침해행위로 인한 정보처리 시스템 사고에 대한 금융감독원장 보고 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
280	FISM-277	이용자가 전자적 침해행위로 인해 금전적 피해를 입었다고 통지한 사고에 대한 금융감독원장 보고 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
281	FISM-278	접근매체의 위조나 변조로 발생한 사고에 대한 금융감독원장 보고 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
282	FISM-279	계약체결 또는 거래지시의 전자적 전송이나 처리과정에서 발생한 사고에 대한 금융감독원장 보고 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목	주요 개정사항
283	FISM-280	사고보고의 고의 지연 및 숨긴 자에 대한 징계절차 수립 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영
284	FISM-296	클라우드컴퓨팅서비스 최신 상태의 보고 서류 유지 및 금융감독원 요청 시 즉시 제공 가능 여부	삭제	-	○ 평가 항목 삭제 - 전자금융감독규정 및 시행세칙 개정안 반영

❖ 가상화 시스템 관리체계 분야 개정사항

- 기존 20개 항목 중 1개 항목 개정(개선 1개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	PRCI-017	최신/긴급 보안 패치 및 업데이트 적용 여부	개선	-	주기적인 보안패치 및 벤더 권고사항 적용 여부	○ 평가 항목명 변경 - 분야 간 평가 항목명 통일

❖ 클라우드 관리체계 분야 신설

○ 73개 항목 신설

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	-	-	신규	PISM-001	통신구간 암호화 적용 여부	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
2	-	-	신규	PISM-002	취약한 HTTPS 프로토콜 허용	
3	-	-	신규	PISM-003	앱 배포 시 취약한 프로토콜 허용	
4	-	-	신규	PISM-004	소스코드 저장소 접근 시 안전한 네트워크 경로 사용	
5	-	-	신규	PISM-005	가상자원에 대한 퍼블릭 액세스 허용	
6	-	-	신규	PISM-006	업무 목적 기반 네트워크 분리 및 접근 통제	
7	-	-	신규	PISM-007	네트워크 접근 제어 설정의 최소 권한 적용	
8	-	-	신규	PISM-008	네트워크 설정 변경 이력 추적	
9	-	-	신규	PISM-009	확장 가능한 데이터 수명주기 관리 정의	

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
10	-	-	신규	PISM-010	데이터 민감도에 따른 보호 조치	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
11	-	-	신규	PISM-011	데이터 분류 체계 수립	
12	-	-	신규	PISM-012	보안 로그의 안전한 저장 및 장기 보존 설정	
13	-	-	신규	PISM-013	접근 로그 수집 기능 활성화 여부	
14	-	-	신규	PISM-014	보안 로그 및 이벤트 상관 관계 분석	
15	-	-	신규	PISM-015	가상자원 생성·변경·삭제 행위 추적	
16	-	-	신규	PISM-016	저장소 임의 삭제 방지 대책 적용 여부	
17	-	-	신규	PISM-017	삭제된 저장소 내 데이터 복원 기능 활성화 여부	
18	-	-	신규	PISM-018	API 호출 이력 행위 추적	
19	-	-	신규	PISM-019	가상자원 상태 및 장애 모니터링 기능 적용	

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
20	-	-	신규	PISM-020	강화된 이미지 기반 컴퓨팅 리소스 제공	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
21	-	-	신규	PISM-021	소프트웨어 및 이미지 무결성 확인 체계 구축	
22	-	-	신규	PISM-022	가상 머신 이미지 또는 템플릿이 외부에 노출되지 않도록 설정	
23	-	-	신규	PISM-023	업무상 불필요한 가상자원 존재	
24	-	-	신규	PISM-024	운영체제 및 플랫폼 구성요소에 대한 보안 업데이트 정책 설정	
25	-	-	신규	PISM-025	서비스 지원이 종료된(EoS) 런타임 교체 여부	
26	-	-	신규	PISM-026	암호화 키 생성·보관·교체·폐기 관리 정책 수립	
27	-	-	신규	PISM-027	안전한 암호화 알고리즘 적용	
28	-	-	신규	PISM-028	자격증명 주기적인 갱신	
29	-	-	신규	PISM-029	암호화 대상 자원 식별 및 암호화 적용	

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
30	-	-	신규	PISM-030	디스크 볼륨 생성 시 암호화 설정 여부	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
31	-	-	신규	PISM-031	디스크 볼륨 암호화 적용 여부	
32	-	-	신규	PISM-032	스냅샷 암호화 적용 여부	
33	-	-	신규	PISM-033	이미지 암호화 적용 여부	
34	-	-	신규	PISM-034	DB 인스턴스 암호화 적용 여부	
35	-	-	신규	PISM-035	초기화 스크립트 내 인증정보 또는 비밀값 미포함 여부	
36	-	-	신규	PISM-036	환경변수 내 중요정보 암호화 적용 여부	
37	-	-	신규	PISM-037	비밀번호 정책 수립 및 로그인 제한 설정	
38	-	-	신규	PISM-038	가상자원 접속 보안 인증 절차 적용	

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목
39	-	-	신규	PISM-039	클라우드 자원에 접근 가능한 계정에 추가인증수단 적용 여부
40	-	-	신규	PISM-040	최고 권한 계정(root 등) 보호 및 사용 제한
41	-	-	신규	PISM-041	관리자 계정의 액세스 키 삭제 여부
42	-	-	신규	PISM-042	API 자격 증명 다중 발급 방지 여부
43	-	-	신규	PISM-043	API 자격 증명의 정기적 갱신 이행 여부
44	-	-	신규	PISM-044	조직 내부 자원 안전 공유
45	-	-	신규	PISM-045	그룹 및 속성 기반 권한 부여 및 최소 권한 정책 적용
46	-	-	신규	PISM-046	웹 기반 셸 환경 권한 통제 여부

○ 평가 항목 신규

- 퍼블릭 클라우드(AWS, Azure) 대상

평가 항목 신규 개발

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
47	-	-	신규	PISM-047	사용 권한 정기 검토 및 불필요 권한 제거 여부	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
48	-	-	신규	PISM-048	외부/계정 간 리소스 공유 및 접근 권한	
49	-	-	신규	PISM-049	테넌트 간 개체 복제 허용 방지	
50	-	-	신규	PISM-050	컨테이너 작업에서 호스트 네트워크 사용 시 권한 상승 제한 여부	
51	-	-	신규	PISM-051	제3자 접근 시 임시 권한 부여 및 최소 권한 적용	
52	-	-	신규	PISM-052	워크로드 팀의 보안 책임 부여 및 자율적 보안 수행 체계	
53	-	-	신규	PISM-053	보안 통제 목표 식별 및 검증	
54	-	-	신규	PISM-054	위협 모델링을 통한 보안 위험 식별 및 대응	
55	-	-	신규	PISM-055	최신 보안 위협 및 권고사항 반영	

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
56	-	-	신규	PISM-056	중앙 관리 도구 또는 에이전트를 활용한 인스턴스 관리	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
57	-	-	신규	PISM-057	보안 관리 범위 최소화	
58	-	-	신규	PISM-058	표준 보안 통제 자동화 적용	
59	-	-	신규	PISM-059	개발 및 배포 전 과정에서 보안 테스트 자동화	
60	-	-	신규	PISM-060	실행 코드 무결성 검증 절차 운용 여부	
61	-	-	신규	PISM-061	컴퓨팅 자원 보호 작업(스캔, 패치, 대응)의 자동화	
62	-	-	신규	PISM-062	취약점 관리 수행	
63	-	-	신규	PISM-063	정기적인 침투 테스트 수행	

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
64	-	-	신규	PISM-064	컴퓨팅 인스턴스에서 IMDSv1 비활성화 여부	○ 평가 항목 신규 - 퍼블릭 클라우드(AWS, Azure) 대상 평가 항목 신규 개발
65	-	-	신규	PISM-065	보안 사고 대응을 위한 체계 구축	
66	-	-	신규	PISM-066	보안 사고 대응 계획 문서화 및 정기 점검	
67	-	-	신규	PISM-067	사고 대응 시나리오 개발 및 테스트	
68	-	-	신규	PISM-068	사고 발생 시 재발 방지 체계 구축	
69	-	-	신규	PISM-069	사전 접근 권한 부여	
70	-	-	신규	PISM-070	침해사고 조사 분석 역량 체계 구축	
71	-	-	신규	PISM-071	비상 접근 절차 수립	
72	-	-	신규	PISM-072	중요 데이터 백업 및 복구 정책 적용 여부	
73	-	-	신규	PISM-073	관리용 단말기 보호대책 적용 여부	

❖ 서버 분야 개정사항

- 기존 118개 항목 중 35개 항목 개정(신규 3개, 삭제 15개, 개선 17개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	SRV-001	안전한 네트워크 모니터링 서비스 사용	개선	-	-	
2	SRV-003	네트워크 모니터링 서비스 접근 통제 설정	개선	-	네트워크 모니터링 서비스 접근 통제 설정 적절성	○ 상세 설명 개선 - 점검이 필요한 상황에 대한 설명 보충
3	SRV-147	불필요한 네트워크 모니터링 서비스 실행	개선	-	불필요한 네트워크 모니터링 서비스 비활성화	
4	SRV-027	서비스 접근 IP 및 포트 제한 미비	개선	-	서비스 접근 IP 및 포트 제한 여부	○ 상세 설명 개선 - 네트워크에 연결되지 않은 오프라인 서버에 대한 예외 사항 추가
5	SRV-119	백신 프로그램 업데이트 미흡	개선	-	백신 프로그램 업데이트 적용 여부	
6	SRV-135	TCP 보안 설정 미비	개선	-	TCP 보안 설정 여부	
7	SRV-175	NTP 및 시각 동기화 설정	개선	-	시간 동기화를 위한 NTP 설정	
8	SRV-028	원격 터미널 접속 타임아웃 미설정	개선	-	원격 터미널 접속 타임아웃 설정 여부	○ 판단 방법 개선 - TIMEOUT 환경변수 관련 내용 제거
9	SRV-069	비밀번호 관리정책 설정 미비	개선	-	비밀번호 관리정책 설정 적절성	○ 판단 방법 개선 - 복잡도 설정 파라미터 내용 추가
10	SRV-070	취약한 패스워드 저장 방식 사용	개선	-	취약한 패스워드 저장 방식 사용 제한 여부	○ 판단 방법 개선 - HP-UX에 대한 판단방법 수정
11	SRV-081	Crontab 설정파일 권한 설정 미흡	개선	-	Crontab 설정파일 권한 설정 적절성	○ 판단 방법 개선 - crontab 명령어 권한 관련 내용 추가

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
12	SRV-087	C 컴파일러 존재 및 권한 설정 미흡	개선	-	설치된 C 컴파일러의 권한 설정 적절성	○ 판단 방법 개선 - 업무상 컴파일러가 필요한 서버의 경우 판단방법 추가
13	SRV-095	존재하지 않는 소유자 및 그룹 권한을 가진 파일 또는 디렉터리 존재	개선	-	존재하지 않는 소유자 및 그룹 권한을 가진 파일 또는 디렉터리 제거	○ 판단 방법 개선 - nouser, nogroup 관련 예외사항 추가
14	SRV-103	LAN Manager 인증 수준 미흡	개선	-	LAN Manager 인증 수준 적절성	○ 상세 설명 개선 - 점검이 필요한 상황에 대한 설명 보충
15	SRV-104	보안 채널 데이터 디지털 암호화 또는 서명 기능 비활성화	개선	-	보안 채널 데이터 디지털 암호화 또는 서명 기능 설정 적절성	
16	SRV-108	로그에 대한 접근통제 및 관리 미흡	개선	-	로그에 대한 접근통제 및 관리 적절성	○ 판단 방법 개선 - Solaris 점검 불가 항목 제거
17	SRV-118	주기적인 보안패치 및 벤더 권고 사항 미적용	개선	-	주기적인 보안패치 및 벤더 권고 사항 적용 여부	○ 상세 설명 개선 - EoS 관련 내용 분리(신규 항목) - 네트워크에 연결되지 않은 오프라인 서버에 대한 예외 사항 추가
18	SRV-040	웹 서비스 디렉터리 리스팅 방지 설정 미흡	삭제	-	-	
19	SRV-041	웹 서비스의 CGI 스크립트 관리 미흡	삭제	-	-	
20	SRV-042	웹 서비스 상위 디렉터리 접근 제한 설정 미흡	삭제	-	-	
21	SRV-043	웹 서비스 경로 내 불필요한 파일 존재	삭제	-	-	○ 평가 항목 삭제 - 웹 서비스 관련 항목 서버 분야에서 제거

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
22	SRV-044	웹 서비스 파일 업로드 및 다운로드 용량 제한 미설정	삭제	-	-	○ 평가 항목 삭제 - 웹 서비스 관련 항목 서버 분야에서 제거
23	SRV-045	웹 서비스 프로세스 권한 제한 미비	삭제	-	-	
24	SRV-046	웹 서비스 경로 설정 미흡	삭제	-	-	
25	SRV-047	웹 서비스 경로 내 불필요한 링크 파일 존재	삭제	-	-	
26	SRV-048	불필요한 웹 서비스 실행	삭제	-	-	
27	SRV-055	웹 서비스 설정 파일 노출	삭제	-	-	
28	SRV-057	웹 서비스 경로 내 파일의 접근 통제 미흡	삭제	-	-	
29	SRV-058	웹 서비스의 불필요한 스크립트 매핑 존재	삭제	-	-	
30	SRV-059	웹 서비스 서버 명령 실행 기능 제한 설정 미흡	삭제	-	-	
31	SRV-060	웹 서비스 기본 계정(아이디 또는 비밀번호) 미변경	삭제	-	-	
32	SRV-148	웹 서비스 정보 노출	삭제	-	-	
33	-	-	신규	SRV-177	sudo 명령어 접근 권한 설정 적절성	○ 평가 항목 신규 - 주요정보통신기반시설 신규 취약점 반영
34	-	-	신규	SRV-178	개인 키 사용 시 passphrase 설정 여부	
35	-	-	신규	SRV-179	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	○ 평가 항목 신규 - EoS 관련 내용 분리

❖ 웹서버-WAS 분야 신설

- 126개 항목 신설 (서버 분야와 중복되지 않는 항목만 기재, 중복 항목은 해당 분야 참고)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	-	-	신규	WST-031	웹 서비스 디렉터리 리스팅 방지 설정 여부	○ 평가 항목 신규 - 기존 서버 분야의 웹 서비스 관련 항목 이동
2	-	-	신규	WST-032	웹 서비스 CGI 스크립트 관리 여부	
3	-	-	신규	WST-033	웹 서비스 상위 디렉터리 접근 제한 설정 여부	
4	-	-	신규	WST-034	웹 서비스 경로 내 불필요 파일 관리 여부	
5	-	-	신규	WST-035	웹 서비스 파일 업로드 및 다운로드 용량 제한 설정 여부	
6	-	-	신규	WST-036	웹 서비스 프로세스 권한 제한 여부	
7	-	-	신규	WST-037	웹 서비스 경로 설정 적절성	
8	-	-	신규	WST-038	웹 서비스 경로 내 불필요한 링크 파일 관리 여부	
9	-	-	신규	WST-039	불필요한 웹 서비스 비활성화	
10	-	-	신규	WST-040	웹 서비스 설정 파일 노출 방지 여부	
11	-	-	신규	WST-041	웹 서비스 경로 내 파일의 접근 통제 설정 적절성	

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
12	-	-	신규	WST-042	웹 서비스의 불필요한 스크립트 매핑 제거	○ 평가 항목 신규 - 기존 서버 분야의 웹 서비스 관련 항목 이동
13	-	-	신규	WST-043	웹 서비스의 서버 명령 실행 기능 제한 설정 적절성	
14	-	-	신규	WST-044	웹 서비스 기본 계정(아이디 또는 비밀번호) 변경 여부	
15	-	-	신규	WST-102	웹 서비스 정보 노출 방지 여부	
16	-	-	신규	WST-121	웹 서비스 불필요한 프록시 설정 제한 여부	○ 평가 항목 신규 - 주요정보통신기반시설 신규 취약점 반영
17	-	-	신규	WST-122	웹 서비스 불필요한 SSI(Server Side Includes) 기능 비활성화	
18	-	-	신규	WST-123	웹 서비스 기본 에러 페이지 노출 방지 여부	
19	-	-	신규	WST-124	웹 서비스 부적절한 LDAP 알고리즘 설정 제한 여부	
20	-	-	신규	WST-125	웹 서비스 독립된 업로드 경로 및 권한 설정 여부	

❖ 데이터베이스 분야 개정사항

- 기존 27개 항목 중 8개 항목 개정(신규 4개, 개선 4개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	DBM-005	데이터베이스 내 중요정보 암호화 미적용	개선	-	데이터베이스 내 중요정보 안전한 암호화 적용 여부	○ 상세 설명 및 판단 방법 개선 - 안전한 암호화 알고리즘 사용 여부와 관련된 내용 추가
2	DBM-009	사용되지 않는 세션 종료 미흡	개선	-	사용되지 않는 세션 종료 여부	○ 판단 방법 개선 - MSSQL 대상 판단 방법 개선
3	DBM-013	원격 접속에 대한 접근 제어 미흡	개선	-	원격 접속에 대한 접근 제어 여부	○ 상세 설명 개선 - 클라우드 DB 인스턴스에 대한 점검 방법 내용 추가
4	DBM-016	설정 파일 및 중요정보가 포함된 파일의 접근 권한 설정 미흡	개선	-	주기적인 보안패치 및 벤더 권고사항 적용 여부	○ 상세 설명 개선 - EoS 관련 내용 분리(신규 항목)
5	-	-	신규	DBM-025	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	○ 평가 항목 신규 - EoS 관련 내용 분리
6	-	-	신규	DBM-034	DBMS 서비스의 구동 권한 적절성	○ 평가 항목 신규 - 주요정보통신기반시설 신규 취약점 반영
7	-	-	신규	DBM-035	xp_cmdshell 사용 비활성화	
8	-	-	신규	DBM-036	Registry Procedure 접근 권한 설정 적절성	

❖ 네트워크 장비 분야 개정사항

- 기존 58개 항목 중 3개 항목 개정(신규 2개, 개선 1개)

【 (현행) 제2025-1호 】			【 (개정) 제2026-1호 】			
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	NET-048	최신/긴급 보안 패치 및 업데이트 적용 여부	개선	-	주기적인 보안패치 및 벤더 권고사항 적용 여부	○ 상세 설명 개선 - EoS 관련 내용 분리(신규 항목)
2	-	-	신규	NET-058	계정 잠금 임계값 설정 여부 및 적정성	○ 평가 항목 신규 - 주요 정보통신기반시설 취약점 분석 평가기준 개정사항(N-04 계정 잠금 임계값 설정) 반영
3	-	-	신규	NET-059	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	○ 평가 항목 신규 - EoS 관련 내용 분리

❖ 정보보호시스템 장비 분야 개정사항

- 기존 42개 항목 중 3개 항목 개정(신규 1개, 개선 2개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	ISS-004	외부구간 NAT 설정	개선	-	NAT 정책 설정 적정성	○ 판단 기준 개선 - NAT 정책 설정 판단 방법 개선
2	ISS-005	주기적인 보안패치 및 벤더 권고 사항 적용 여부	개선	-	주기적인 보안패치 및 벤더 권고사항 적용 여부	○ 상세 설명 개선 - EoS 관련 내용 분리(신규 항목)
3	-	-	신규	ISS-043	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	○ 평가 항목 신규 - EoS 관련 내용 분리

❖ OS기상화 시스템 분야 개정사항

- 기존 36개 항목 중 8개 항목 개정(삭제 1개, 개선 7개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	PRCV-011	시스템 사용 주의사항 미출력	개선	-	시스템 사용 주의사항 출력	○ 판단 기준 개선 - 설정파일 경로 및 설정파일 이름 수정
2	PRCV-017	관리 홈페이지 세션 타임아웃 설정	개선	-	-	○ 판단 기준 개선 - 기준 간 타임아웃 값 통일
3	PRCV-020	하이퍼바이저 관리도구 세션 타임아웃 설정	개선	-	-	○ 판단 기준 개선 - 기준 간 타임아웃 값 통일
4	PRCV-021	직접콘솔(Direct Console) 세션 타임아웃 설정	개선	-	콘솔 세션 타임아웃 설정	○ 상세 설명 개선 - 특정 시스템 종속 용어 삭제 및 개선
5	PRCV-024	비휘발성 경로 내 로그 파일 저장	개선	-	-	○ 판단 방법 개선 - 판단 방법 내 오류 제거 및 보완
6	PRCV-032	가상머신 콘솔 복사 및 붙여넣기 GUI 옵션 활성화	삭제	-	-	○ 평가 항목 삭제 - 실효성이 떨어지는 설정 점검으로 평가 항목 삭제
7	PRCV-035	가상스위치 무차별(Promiscuous) 모드 정책 활성화	개선	-	가상스위치 트래픽 복제 및 무차별 수신 방지	○ 상세 설명 개선 - 특정 시스템 종속 용어 삭제 및 개선
8	PRCV-036	가상스위치 위조전송(Forged Transmits)모드 정책 활성화	개선	-	가상스위치 위조 MAC 승인 차단 정책 설정	○ 상세 설명 개선 - 특정 시스템 종속 용어 삭제 및 개선

❖ 컨테이너 가상화 시스템 분야 개정사항

- 기존 50개 항목 중 9개 항목 개정(개선 9개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	PRCC-002	Role(ClusterRole)의 과도한 권한 부여	개선	-	Role(ClusterRole)의 과도한 권한 부여 제거 여부	○ 판단 방법 개선 - 판단 방법 내 오류 제거 및 보완
2	PRCC-003	기본 서비스 계정(default) 사용	개선	-	기본 서비스 계정(default) 사용 제거 여부	○ 판단 방법 개선 - 판단 방법 내 오류 제거 및 보완
3	PRCC-006	서비스 계정 토큰 수명 제한 설정	개선	-	서비스 계정 토큰 자동 마운트 제한 설정 여부	○ 평가항목 및 상세설명 등 개선 - 실효성이 높은 설정 점검으로 항목 개선
4	PRCC-013	Anonymous 계정의 API 접속 제한 미비	개선	-	Anonymous 계정의 API 접속 제한 여부	○ 평가대상 개선 - 설정 변경이 불가능한 시스템 평가대상 제외
5	PRCC-014	API 요청 타임아웃 설정	개선	-	-	○ 평가대상 개선 - 설정 변경이 불가능한 시스템 평가대상 제외
6	PRCC-038	마운트 전파 모드(Mount Propagation Mode) 공유 설정	개선	-	마운트 전파 모드(Mount Propagation Mode) 공유 설정 제한 여부	○ 판단 방법 개선 - 판단 방법 내 오류 제거 및 보완
7	PRCC-039	컨테이너의 불필요한 외부 장치 연결	개선	-	컨테이너의 불필요한 외부 장치 제거	○ 판단 방법 개선 - 판단 방법 내 오류 제거 및 보완
8	PRCC-041	호스트의 사용자 네임스페이스 공유	개선	-	호스트의 사용자 네임스페이스 공유 제한 설정	○ 상세 설명 개선 - 평가항목의 상세 설명 개선
9	PRCC-046	HostPort 사용 컨테이너의 하용 최소화	개선	-	불필요한 HostPort 제거	○ 상세 설명 개선 - 평가항목의 상세 설명 개선

❖ 웹·모바일·HTS 애플리케이션 분야 개정사항

- 기존 147개 항목 중 7개 항목 개정(개선 7개)

【 (현행) 제2025-1호 】				【 (개정) 제2026-1호 】		
구분	평가항목ID	평가항목	개정사항	평가항목ID	평가항목	주요 개정사항
1	MOB-HTS-SER-009	메모리 내 중요정보 노출 방지	개선	-	-	○ 상세 설명 개선 - 상세 설명 내 평가 예시 개선
2	MOB-HTS-SER-020	화면 내 중요정보 평문노출	개선	-	화면 내 중요정보 평문노출 방지	○ 상세 설명 개선 - 상세 설명 내 평가 예시 개선
3	WEB-SER-024	단말기 브라우저 영역 내에서의 중요정보 노출	개선	-	단말기 브라우저 영역 내에서의 중요정보 노출 방지	○ 상세 설명 개선 - 상세 설명 내 평가 예시 개선
4	WEB-MOB-SER-034	취약한 HTTPS 프로토콜 이용	개선	-	취약한 HTTPS 프로토콜 이용 제한	○ 상세 설명 개선 - 점검 실효성을 위한 상세 설명 개선

참고

3

전자금융기반시설 보안 취약점 평가기준



2026년
전자금융기반시설
보안 취약점
평가기준 안내서

정보보호 관리체계

❖ 평가기준

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-001	1.1 정보보호 계획	정보보안 관련법규 위반에 관한 제재기준 및 절차수립 및 운영 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 6. 최고경영자는 임직원이 정보보안 관련법규를 위반할 경우 그 제재에 관한 세부기준 및 절차를 마련하여 운영할 것<종전의 제5호에서 이동, 2025. 2. 5.> ○ (전자금융감독규정) 제36조의2(정보기술부문 계획서 제출 절차 등) ① 시행령 제11조의3에 따라 금융위원회에 정보기술부문 계획을 제출해야 하는 금융회사 또는 전자금융업자는 현실적이고 실현 가능한 장·단기 정보기술부문 계획을 매년 수립·운영하여야 하며, 정보기술부문 계획서 제출에 관한 세부적인 절차, 양식 등에 관해서는 금융감독원장이 정하는 바에 따른다. ○ (전자금융감독규정시행세칙) 제3조(자체 보안성심의 기준 등) ① 규정 제36조제1항에 따른 금융감독원장이 정하는 기준과 절차란 다음 각 호를 말한다. 1. 정보통신망을 이용하여 신규전자금융업무를 수행하는 경우 <별표 1>의 기준에 따라 보안성심의를 실시한 후 정보보호최고책임자의 승인을 받을 것 2. 공동으로 전자금융거래 관련 표준을 제정하는 경우 <별표 1의2>의 기준에 따라 보안성심의를 실시할 것(다만, 이 경우 특정 금융회사 또는 전자금융업자가 다른 금융회사등을 대표하여 규정 제36조제2항에 따른 자체 보안성심의 결과보고서를 제출할 수 있음).
FISM-002	1.1 정보보호 계획	정보기술(IT)부문계획 매년 수립 및 운용 여부	5	○ (전자금융감독규정시행세칙) 제3조(자체 보안성심의 기준 등) ① 규정 제36조제1항에 따른 금융감독원장이 정하는 기준과 절차란 다음 각 호를 말한다. 1. 정보통신망을 이용하여 신규전자금융업무를 수행하는 경우 <별표 1>의 기준에 따라 보안성심의를 실시한 후 정보보호최고책임자의 승인을 받을 것 2. 공동으로 전자금융거래 관련 표준을 제정하는 경우 <별표 1의2>의 기준에 따라 보안성심의를 실시할 것(다만, 이 경우 특정 금융회사 또는 전자금융업자가 다른 금융회사등을 대표하여 규정 제36조제2항에 따른 자체 보안성심의 결과보고서를 제출할 수 있음).

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-003	2.1 조직 및 인력 구성	정보처리시스템 관련 전담조직 운영 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 1. 정보처리시스템 및 전자금융업무 관련 전담 조직을 확보할 것 ○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 1. 정보처리시스템 및 전자금융업무 관련 전담 조직을 확보할 것 ○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 2. 외부주문 등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것
FISM-004	2.1 조직 및 인력 구성	전자금융업무 관련 전담조직 운영 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 1. 정보처리시스템 및 전자금융업무 관련 전담 조직을 확보할 것 ○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 2. 외부주문 등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것
FISM-005	2.1 조직 및 인력 구성	IT 아웃소싱(이하 'IT자회사' 포함) 통제/관리 조직(인력포함) 운영 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 2. 외부주문 등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것
FISM-010	2.3 정보보호최고 책임자 지정 및 업무	정보보호최고책임자(CISO) 지정 여부	5	○ (전자금융감독규정) 제6조의2(정보보호최고책임자의 지정대상) ① 시행령 제11조의3제1항 후단에서 "금융위원회가 정하여 고시하는 상시 종업원 수의 산정방식"이란 「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 말한다. ② 시행령 <별표 1>의제3호나목 단서에서 "금융위원회가 정하여 고시하는 산정방식"이란 「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 말한다.
FISM-011	2.3 정보보호최고 책임자 지정 및 업무	정기적으로 수행되는 임직원 정보보안 관련법규 준수여부 점검결과에 대한 임원(정보보호최고책임자, 최고경영자)보고 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 5. 정보보호최고책임자는 임직원이 정보보안 관련법규를 준수하고 있는지 정기적으로 점검하고 그 점검결과 및 보완계획을 최고경영자에게 보고할 것 <개정 2025. 2. 5.> <신설 2013. 12. 3>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-012	2.3 정보보호최고 책임자 지정 및 업무	정보보호 관련 사항을 심의·의결하는 정보보호위원회 설치 및 운영 여부	5	○ (전자금융감독규정) 제8조의2(정보보호위원회 운영) ① 금융회사 또는 전자금융업자는 중요 정보보호에 관한 사항을 심의·의결하는 정보보호위원회를 설치 운영하여야 한다.
FISM-013	2.3 정보보호최고 책임자 지정 및 업무	정보보호위원회 구성의 적정성 여부	5	○ (전자금융감독규정) 제8조의2(정보보호위원회 운영) ② 정보보호위원회의 장은 정보보호최고책임자로 하며, 위원은 정보보호업무 관련 부서장, 전산운영 및 개발 관련 부서장, 준법업무 관련 부서의 장 등으로 구성한다.
FISM-014	2.3 정보보호최고 책임자 지정 및 업무	정보보호위원회 심의·의결 사항에 관한 적정성 여부	5	○ (전자금융감독규정) 제8조의2(정보보호위원회 운영) ③ 정보보호위원회는 다음 각 호의 사항을 심의·의결한다. 1. 법 제21조제4항에 따른 정보기술부문 계획서에 관한 사항 2. 법 제21조의2제4항제1호에 관한 사항 <개정 2015. 6. 24.> 3. 법 제21조의3에서 정한 취약점 분석·평가 결과 및 보완조치의 이행계획에 관한 사항 4. 전산보안사고 및 전산보안관련 규정 위반자의 처리에 관한 사항 5. 제14조의2제1항의 클라우드컴퓨팅서비스의 이용에 관한 사항 <신설 2022. 11. 23.> 6. 기타 정보보호위원회의 장이 정보보호업무 수행에 필요하다고 정한 사항 <개정 2022. 11. 23.>
FISM-015	2.3 정보보호최고 책임자 지정 및 업무	정보보호위원회 심의·의결 사항에 관한 임원(정보보호최고책임자, 최고경영자) 보고 여부	5	○ (전자금융감독규정) 제8조의2(정보보호위원회 운영) ④ 정보보호최고책임자는 정보보호위원회 심의·의결사항을 최고경영자에게 보고하여야 하며, 정보보호최고책임자가 전자금융거래의 안전성 및 신뢰성에 중대한 영향을 미친다고 판단하는 심의·의결사항에 대해서는 이사회에 보고 하여야 한다.
FISM-019	3.1 정보보호 교육 및 훈련	임직원의 정보보호역량 강화를 위한 교육계획 수립·시행 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다.<개정 2013. 12. 3, 2025. 2. 5.> 3. 정보보호최고책임자는 임직원의 정보보호역량 강화를 위하여 매년 교육계획을 수립·시행할 것 <개정 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-021	3.1 정보보호 교육 및 훈련	전년도 교육계획 시행 결과 평가 및 금년도 교육계획 반영 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3, 2025. 2. 5.> 4. 최고경영자는 전년도 교육계획 시행 결과를 평가하고, 정보보호최고책임자는 그 결과를 금년도 교육계획에 반영할 것 <신설 2025. 2. 5.>
FISM-022	4.1 전산센터 건물	건물 안전대책 및 출입통제 보안대책의 수립/운용 여부	5	○ (전자금융감독규정) 제9조(건물에 관한 사항) 금융회사 또는 전자금융업자는 전산실이 위치한 건물에 관하여 안전대책 및 출입통제 보안대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.>
FISM-031	4.2 전산센터 설비	전산실 건물의 안정성을 위한 기준 수립/운용 여부	5	○ (전자금융감독규정) 제10조(전원, 공조 등 설비에 관한 사항) 금융회사 또는 전자금융업자는 전산실이 위치한 건물의 전원, 공조 등 설비의 안전성을 위한 기준을 수립·운용해야 한다. <개정 2013. 12. 3. 2025. 2. 5.>
FISM-041	4.3 전산실 보안	전산실의 재해, 출입, 접근통제 등 안전 및 보안 준수 여부	5	○ (전자금융감독규정) 제11조(전산실 등에 관한 사항) 금융회사 또는 전자금융업자는 전산실에 관하여 다음 각 호의 사항을 포함한 대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.> 3. 그 밖에 재해 및 위해방지, 출입·접근통제 등 전산실의 안전 및 보안에 관한 사항 <개정 2025. 2. 5.>
FISM-056	4.3 전산실 보안	국내 본점을 둔 금융회사의 전산실 및 재해복구센터 국내 설치 여부	5	○ (전자금융감독규정) 제11조(전산실 등에 관한 사항) 금융회사 또는 전자금융업자는 전산실에 관하여 다음 각 호의 사항을 포함한 대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.> 1. 국내에 본점을 둔 금융회사 또는 전자금융업자의 전산실 및 재해복구센터는 국내에 설치할 것(단, 제50조제2항에 따라 등록된 국외 사이버물을 위한 전자기급 결제대행업자는 제외) <개정 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-057	4.3 전산실 보안	전산실내 무선통신망 설치 및 운용 금지 여부	5	○ (전자금융감독규정) 제11조(전산실 등에 관한 사항) 금융회사 또는 전자금융업자는 전산실에 관하여 다음 각 호의 사항을 포함한 대책을 수립·운용하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉 2. 무선통신망을 설치하지 아니할 것 〈개정 2025. 2. 5.〉
FISM-058	5.1 단말기 보호대책	인가된 사용자 외 단말기 무단조작 방지 여부	5	○ (전자금융감독규정) 제12조(단말기 보호대책) 금융회사 또는 전자금융업자는 단말기 보호를 위하여 다음 각 호의 사항을 준수하여야 한다.〈개정 2013. 12. 3.〉 1. 단말기는 인가된 사용자만 사용할 수 있도록 관리할 것 〈개정 2015. 2. 3., 2025. 2. 5.〉
FISM-059	5.1 단말기 보호대책	정보처리시스템 접속과 관련하여 사용자인가 여부를 확인할 수 있는 기록 유지 여부	5	○ (전자금융감독규정) 제12조(단말기 보호대책) 금융회사 또는 전자금융업자는 단말기 보호를 위하여 다음 각 호의 사항을 준수하여야 한다.〈개정 2013. 12. 3.〉 2. 정보처리시스템에 접속하는 단말기에 대해 정당한 사용자인가의 여부를 확인할 수 있는 기록을 유지할 것 〈개정 2015. 2. 3.〉
FISM-060	5.1 단말기 보호대책	강화된 보호대책이 적용되는 중요단말기 지정 여부	5	○ (전자금융감독규정) 제12조(단말기 보호대책) 금융회사 또는 전자금융업자는 단말기 보호를 위하여 다음 각 호의 사항을 준수하여야 한다.〈개정 2013. 12. 3.〉 3. 외부 반출, 인터넷 접속, 그룹웨어 접속의 금지, 정기적인 악성코드 감염여부 확인 등 강화된 보호대책이 적용되는 중요단말기를 지정할 것 〈개정 2013. 12. 3., 2015. 2. 3., 2025. 2. 5.〉
FISM-061	5.1 단말기 보호대책	단말기에서 보조기억매체 등 점근통제(정보유출, 악성코드 감염 방지 등) 여부	5	○ (전자금융감독규정) 제12조(단말기 보호대책) 금융회사 또는 전자금융업자는 단말기 보호를 위하여 다음 각 호의 사항을 준수하여야 한다.〈개정 2013. 12. 3.〉 4. 정보유출 및 악성코드 감염 등을 방지할 수 있도록 단말기에서 보조기억매체 등에 접근하는 것을 통제할 것 〈개정 2015. 2. 3., 2025. 2. 5.〉

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-062	5.2 전산자료 보호대책	전산자료 보유현황 관리 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 2. 전산자료의 보유현황을 관리하고 책임자를 지정·운영할 것<종전의 제3호에서 이동, 2025. 2. 5.>
FISM-063	5.2 전산자료 보호대책	전산자료 책임자 지정 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 2. 전산자료의 보유현황을 관리하고 책임자를 지정·운영할 것<종전의 제3호에서 이동, 2025. 2. 5.>
FISM-064	5.2 전산자료 보호대책	전산자료 및 전산장비의 반출/반입 통제 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 3. 전산자료 및 전산장비의 반출·반입을 통제할 것<종전의 제5호에서 이동, 2025. 2. 5.>
FISM-065	5.2 전산자료 보호대책	보조기억매체 등 전산자료에 대한 안전지출 및 파기계획 수립 및 운용 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 4. 비상시에 대비하여 전산자료에 대한 안전지출 및 긴급파기 계획을 수립·운영할 것<개정 2013. 12. 3. 2025. 2. 5.>
FISM-066	5.2 전산자료 보호대책	보조기억매체 보유현황 및 관리실태에 관한 정기점검 및 책임자 확인 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 5. 정기적으로 보조기억매체의 보유 현황 및 관리실태를 점검하고 책임자의 확인을 받을 것<종전의 제7호에서 이동, 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-067	5.2 전산자료 보호대책	전산자료의 정기백업/소산 등 백업내역에 관한 기록 및 관리 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 6. 중요도에 따라 전산자료를 정기적으로 백업하여 원격 안전지역에 소산하고 백업내역을 기록·관리할 것<총전의 제8호에서 이동, 2025. 2. 5.>
FISM-068	5.2 전산자료 보호대책	전산자료 중요도 분류기준 수립 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 6. 중요도에 따라 전산자료를 정기적으로 백업하여 원격 안전지역에 소산하고 백업내역을 기록·관리할 것<총전의 제8호에서 이동, 2025. 2. 5.>
FISM-069	5.2 전산자료 보호대책	주요 백업 전산자료에 대한 정기 검증 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 7. 주요 백업 전산자료에 대하여 정기적으로 검증할 것<총전의 제9호에서 이동, 2025. 2. 5.>
FISM-070	5.2 전산자료 보호대책	이용자 정보 조회 및 출력에 대한 통제 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 8. 이용자 정보의 조회·출력에 대한 통제를 하고 테스트 시 이용자 정보 사용 금지(다만, 법인이 이용자 정보는 금융감독원장이 정하는 바에 따라 이용자의 동의를 얻은 경우 테스트 시 사용 가능하며, 그 외 부하 테스트 등 이용자 정보의 사용이 불가피한 경우 이용자 정보를 변환하여 사용하고 테스트 종료 즉시 삭제하여야 한다)<총전의 제10호에서 이동, 2025. 2. 5.> <개정 2013. 12. 3., 2016. 10. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				○ (전자금융감독규정시행세칙) 제2조의5(법인 이용자 정보의 사용에 대한 동의) 규정 제13조제1항제8호에 따라 동의를 얻는 경우 다음 각 호의 사항을 정보주체에게 사전에 알려야 한다. 1. 테스트의 목적 및 기간 2. 사용되는 이용자 정보의 항목 3. 테스트 기간 중 정보유출 방지를 위한 통제 계획 4. 테스트 종료 후 테스트에 사용된 이용자 정보의 파기 계획 [중전의 제2조의4에서 이동]
FISM-071	5.2 전산자료 보호대책	테스트 시 이용자 정보 사용금지(부하테스트 등의 불가피한 경우 이용자정보 변환 사용 및 테스트 종료즉시 삭제) 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 8. 이용자 정보의 조화·출력에 대한 통제를 하고 테스트 시 이용자 정보 사용 금지(다만, 법인인 이용자 정보는 금융감독원장이 정하는 바에 따라 이용자의 동의를 얻은 경우 테스트 시 사용 가능하며, 그 외 부하 테스트 등 이용자 정보의 사용이 불가피한 경우 이용자 정보를 변환하여 사용하고 테스트 종료 즉시 삭제하여야 한다)<중전의 제10호에서 이동, 2025. 2. 5.> <개정 2013. 12. 3., 2016. 10. 5.> ○ (전자금융감독규정시행세칙) 제2조의5(법인 이용자 정보의 사용에 대한 동의) 규정 제13조제1항제8호에 따라 동의를 얻는 경우 다음 각 호의 사항을 정보주체에게 사전에 알려야 한다. 1. 테스트의 목적 및 기간 2. 사용되는 이용자 정보의 항목 3. 테스트 기간 중 정보유출 방지를 위한 통제 계획 4. 테스트 종료 후 테스트에 사용된 이용자 정보의 파기 계획 [중전의 제2조의4에서 이동]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-072	5.2 전산자료 보호대책	정보처리시스템 가동기록은 접속의 성공여부 상관없이 1년 이상 보존 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 9. 정보처리시스템의 가동기록은 금융감독원장이 정하는 사항을 접속의 성공여부와 상관 없이 자동적으로 기록·유지하고 1년 이상 보존할 것 <개정 2025. 2. 5.>
FISM-074	5.2 전산자료 보호대책	단말기에 이용자 정보 등 주요정보 보관 금지 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 10. 단말기에 이용자 정보 등 주요정보를 보관하지 아니하고, 단말기를 공유하지 아니할 것 (다만, 불가피하게 단말기에 보관할 필요가 있는 경우 보관사유, 보관기간 및 관리 비밀번호 등을 정하여 책임자의 승인을 받아야 한다)<종전의 제13호에서 이동, 2025. 2. 5.>
FISM-075	5.2 전산자료 보호대책	단말기 공유 금지 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 10. 단말기에 이용자 정보 등 주요정보를 보관하지 아니하고, 단말기를 공유하지 아니할 것 (다만, 불가피하게 단말기에 보관할 필요가 있는 경우 보관사유, 보관기간 및 관리 비밀번호 등을 정하여 책임자의 승인을 받아야 한다)<종전의 제13호에서 이동, 2025. 2. 5.>
FISM-076	5.2 전산자료 보호대책	단말기 내 주요정보 보관 필요시, 관련 절차 수립 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 10. 단말기에 이용자 정보 등 주요정보를 보관하지 아니하고, 단말기를 공유하지 아니할 것 (다만, 불가피하게 단말기에 보관할 필요가 있는 경우 보관사유, 보관기간 및 관리 비밀번호 등을 정하여 책임자의 승인을 받아야 한다)<종전의 제13호에서 이동, 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-078	5.3 정보처리 시스템 보호대책	주요 정보처리시스템에 대한 운영 매뉴얼 등 작성 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 운영매뉴얼, 유지보수관리대장, 책임자명부 및 장애상황기록부 등 다음 각 호를 포함한 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.> 1. 다음 각 목을 작성·보관 할 것 <개정 2025. 2. 5.> 가. 주요 정보처리시스템에 대한 운영매뉴얼 <신설 2025. 2. 5.> 나. 주요 정보처리시스템에 대한 정기적인 유지보수 실시 내용을 기록한 유지보수관리대장 <신설 2025. 2. 5.> 다. 정보처리시스템에 대한 책임자명부 및 장애상황기록부 <신설 2025. 2. 5.>
FISM-083	5.3 정보처리 시스템 보호대책	정상작동여부 확인을 위한 정보처리시스템 자원 상태의 감시, 경고 및 제어가 가능한 모니터링 시스템 설치 및 운영 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 운영매뉴얼, 유지보수관리대장, 책임자명부 및 장애상황기록부 등 다음 각 호를 포함한 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.> 2. 정보처리시스템의 정상작동여부 확인을 위하여 시스템 자원 상태의 감시, 경고 및 제어가 가능하도록 모니터링시스템을 갖출 것 <개정 2025. 2. 5.>
FISM-084	5.3 정보처리 시스템 보호대책	시스템 통합, 전환 및 재개발시 정보처리시스템의 운영에 지장을 초래하지 않도록 통제절차 마련 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 운영매뉴얼, 유지보수관리대장, 책임자명부 및 장애상황기록부 등 다음 각 호를 포함한 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.> 3. 시스템 통합, 전환 및 재개발 시 장애 등으로 인하여 정보처리시스템의 운영에 지장이 초래되지 않도록 통제 절차를 마련하여 준수할 것 <중전의 제5호에서 이동, 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-086	5.3 정보처리 시스템 보호대책	운영체계, 시스템 유틸리티 등의 긴급하고 중요한 보정(patch) 사항에 대하여는 즉시 보정 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 운영매뉴얼, 유지보수관리대장, 책임자명부 및 장애상황기록부 등 다음 각 호를 포함한 보호대책을 수립·운용하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉 4. 정보처리시스템의 긴급하고 중요한 보정(patch)사항에 대하여는 즉시 보정 작업을 할 것 〈개정 2025. 2. 5.〉 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해 행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다. 2. 해킹 등 전자적 침해행위에 대비한 시스템프로그램 등의 긴급하고 중요한 보정(patch) 사항에 대하여 즉시 보정작업 실시
FISM-087	5.3 정보처리 시스템 보호대책	중요도에 따른 운영체계(Operating System) 및 설정내용 등의 정기 백업, 원격안전지역 소산 및 백업자료 1년 이상 기록/관리 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 다음 각 호를 포함한 보호대책을 수립·운용하여야 한다.〈개정 2013. 12. 3.〉 5. 중요도에 따라 정보처리시스템의 운영체제 및 설정내용 등을 정기 백업 및 원격 안전지역에 소산하고 백업자료는 1년 이상 기록·관리할 것〈종전의 제8호에서 이동, 2025. 2. 5.〉
FISM-088	5.3 정보처리 시스템 보호대책	정보처리시스템의 운영체제 계정으로 로그인할 경우 이중인증 절차 적용 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 다음 각 호를 포함한 보호대책을 수립·운용하여야 한다.〈개정 2013. 12. 3.〉 6. 정보처리시스템의 운영체제(Operating System) 계정으로 로그인(Log in)할 경우 이중인증 절차를 시행하고, 계정에 대한 사용권한, 접근 기록, 작업 내역 등에 대한 상시 모니터링체계를 수립하며, 이상 징후 발생 시 필요한 통제 조치를 즉시 시행할 것〈신설 2013. 12. 3., 개정 2025. 2. 5.〉

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-089	5.3 정보처리 시스템 보호대책	정보처리시스템 운영체제 계정에 대한 작업 내역 등 상시 모니터링 체계 수립 여부 및 이상징후 발생 시 통제 조치 시행 여부	5	○ (전자금융감독규정) 제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 다음 각 호를 포함한 보호대책을 수립·운영하여야 한다.<개정 2013. 12. 3.> 6. 정보처리시스템의 운영체제(Operating System) 계정으로 로그인(Log in)할 경우 이중인증 절차를 시행하고, 계정에 대한 사용권한, 접근 기록, 작업 내역 등에 대한 상시 모니터링체계를 수립하며, 이상 징후 발생 시 필요한 통제 조치를 즉시 시행할 것<신설 2013. 12. 3., 개정 2025. 2. 5.>
FISM-091	5.3 정보처리 시스템 보호대책	정보처리시스템 사용 현황 및 추이 분석 등 정기적 실시 여부	5	○ (전자금융감독규정) 제25조(정보처리시스템의 성능관리) 금융회사 또는 전자금융업자는 정보처리시스템의 장애예방 및 성능의 최적화를 위하여 정보처리시스템의 사용 현황 및 추이 분석 등을 정기적으로 실시하여야 한다.<개정 2013. 12. 3.>
FISM-092	5.4 취약점 분석·평가	전자금융기반시설의 취약점 분석·평가는 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시 여부	5	○ (전자금융감독규정) 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) ① 전자금융기반시설의 취약점 분석·평가는 총자산이 2조원 이상이고, 상시 종업원 수('소속세법'에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 기준으로 한다. 이하 같다) 300명 이상인 금융회사 또는 전자금융업자이거나 「수산업협동조합법」, 「산림조합법」, 「신용협동조합법」, 「상호저축은행법」 및 「새마을금고법」에 따른 중앙회의 경우 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시하여야 한다. ○ (전자금융감독규정시행세칙) 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용) 규정 제37조의2제3항에 따라 감독원장이 정하는 취약점 분석·평가의 내용은 별표 3과 같다.<신설 2014. 3. 31., 개정 2022. 12. 29.>
FISM-093	5.4 취약점 분석·평가	취약점 분석·평가결과에 따른 취약점 제거 또는 이에 상응하는 조치 시행 여부	5	○ (전자금융감독규정) 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) ⑤ 금융회사 또는 전자금융업자는 취약점 분석·평가에 따라 이행계획을 수립·시행하여야 하며 다음 각 호의 사항을 준수하여야 한다. 1. 취약점 분석·평가 결과에 따른 취약점의 제거 또는 이에 상응하는 조치의 시행 ○ (전자금융감독규정시행세칙) 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용) 규정 제37조의2제3항에 따라 감독원장이 정하는 취약점 분석·평가의 내용은 별표 3과 같다.<신설 2014. 3. 31., 개정 2022. 12. 29.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-094	5.4 취약점 분석·평가	취약점 제거 또는 이에 상응하는 조치가 불가한 경우 최고경영자 승인 취득 여부	5	○ (전자금융감독규정) 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) ⑤ 금융회사 또는 전자금융업자는 취약점 분석·평가에 따라 이행계획을 수립·시행하여야 하며 다음 각 호의 사항을 준수하여야 한다. 2. 취약점의 제거 또는 이에 상응하는 조치가 불가한 경우에는 최고경영자 승인을 득할 것 ○ (전자금융감독규정시행세칙) 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용) 규정 제37조의2제3항에 따라 감독원장이 정하는 취약점 분석·평가의 내용은 별표 3과 같다.〈신설 2014. 3. 31., 개정 2022. 12. 29.〉
FISM-095	5.4 취약점 분석·평가	취약점 분석·평가결과에 대한 이행계획 수립 여부 및 최고경영자 보고 여부	5	○ (전자금융감독규정) 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) ⑤ 금융회사 또는 전자금융업자는 취약점 분석·평가에 따라 이행계획을 수립·시행하여야 하며 다음 각 호의 사항을 준수하여야 한다. 1. 취약점 분석·평가 결과에 따른 취약점의 제거 또는 이에 상응하는 조치의 시행 2. 취약점의 제거 또는 이에 상응하는 조치가 불가한 경우에는 최고경영자 승인을 득할 것 3. 이행계획의 시행 결과는 최고경영자에게 보고할 것 ○ (전자금융감독규정시행세칙) 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용) 규정 제37조의2제3항에 따라 감독원장이 정하는 취약점 분석·평가의 내용은 별표 3과 같다.〈신설 2014. 3. 31., 개정 2022. 12. 29.〉
FISM-096	5.5 정보보호시스 템 설치 및 운영	해킹 등을 방지하기 위한 정보보호시스템 설치 및 운영 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해 행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운영하여야 한다. 1. 해킹 등 전자적 침해행위로 인한 사고를 방지하기 위한 정보보호시스템 설치 및 운영

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-097	5.5 정보보호 시스템 설치 및 운영	내부 단말기의 정보보호시스템을 우회한 인터넷 등 외부 통신망(무선통신망 포함) 접속 차단 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해 행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운영하여야 한다. 5. 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것. 다만, 다음 각 목의 경우에는 그러하지 아니하다.〈신설 2013. 12. 3., 개정 2015. 2. 3., 2022. 11. 23.〉 가. 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구·개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원장이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한한다) 〈신설 2022. 11. 23.〉〈개정 2025. 2. 5.〉 나. 업무상 불가피한 경우로서 금융감독원장이 인정하는 경우 〈신설 2022. 11. 23.〉 ○ (전자금융감독규정시행세칙) 제2조의3(망분리 적용 예외) ① 규정 제15조제1항제3호나목에서 감독원장의 확인을 받은 경우란 다음 각 호와 같다.〈개정 2020. 11. 6., 2022. 12. 29.〉 1. 내부 통신망에 연결된 단말기가 업무상 필수적으로 외부기관과 연결해야 하는 경우(다만, 이 경우 필요한 서비스번호(port)에 한하여 특정 외부기관과 연결할 수 있다). 2. 규정 제12조의 보안대책을 적용한 단말기에서 전용회선과 동등한 보안수준을 갖춘 통신망을 이용하여 외부망으로부터 내부 업무용시스템으로 원격접속 하는 경우 ② 규정 제15조제1항제5호나목에서 감독원장이 인정하는 경우란 다음 각 호와 같다.〈개정 2022. 12. 29.〉 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」에 따라 정보처리 업무를 국외 소재 전산센터에 위탁하여 처리하는 경우(다만, 해당 국외 소재 전산센터에 대해서는 물리적 방식 외의 방법으로 망을 분리하여야 하며, 이 경우에도 국내 소재 전산센터 및 정보처리 시스템 등은 물리적으로 망을 분리하여야 한다)

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				2. 업무상 외부통신망과 연결이 불가피한 다음의 정보처리시스템(다만, 필요한 서비스번호(port)에 한하여 연결할 수 있다) 가. 전자금융업무의 처리를 위하여 특정 외부기관과 데이터를 송수신하는 정보처리시스템 나. DMZ구간 내 정보처리시스템과 실시간으로 데이터를 송수신하는 내부통신망의 정보처리시스템 다. 다른 계열사(「금융회사」의 정보처리 업무 위탁에 관한 규정」 제2조제3항의 “계열사”를 말한다)와 공동으로 사용하는 정보처리시스템 3. 규정 제23조의 비상대책에 따라 원격 접속이 필요한 경우 4. 전산실 내에 위치한 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기와 외부통신망과의 연결 구간, 규정 제15조제1항제3호의 내부 업무용 시스템과의 연결 구간을 각각 차단한 경우<신설 2016. 5. 12.> ③ 제1항 및 제2항의 규정은 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 별표 7에서 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한하여 적용한다. [종전의 제2조의2에서 이동]
FISM-098	5.5 정보보호 시스템 설치 및 운영	내부통신망과 연결된 내부 업무용시스템이 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다. 3. 내부통신망과 연결된 내부 업무용시스템은 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지. 다만, 다음 각 목의 경우에는 그러하지 아니하다. <개정 2013. 12. 3., 2022. 11. 23.> 가. 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구·개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한한다) <신설 2022. 11. 23.>(개정 2025. 2. 5.) 나. 업무상 불가피한 경우로서 금융감독원의 확인을 받은 경우 <신설 2022. 11. 23.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				○ (전자금융감독규정시행세칙) 제2조의3(민본리 적용 예외) ① 규정 제15조제1항제3호나목에서 감독원장의 확인을 받은 경우란 다음 각 호와 같다.<개정 2020. 11. 6., 2022. 12. 29.> 1. 내부 통신망에 연결된 단말기가 업무상 필수적으로 외부기관과 연결해야 하는 경우(다만, 이 경우 필요한 서비스번호(port)에 한하여 특정 외부기관과 연결할 수 있다). 2. 규정 제12조의 보안대책을 적용한 단말기에서 전용회선과 동등한 보안수준을 갖춘 통신망을 이용하여 외부망으로부터 내부 업무용시스템으로 원격접속 하는 경우 ② 규정 제15조제1항제5호나목에서 감독원장이 인정하는 경우란 다음 각 호와 같다.<개정 2022. 12. 29.> 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」에 따라 정보처리 업무를 국외 소재 전산센터에 위탁하여 처리하는 경우(다만, 해당 국외 소재 전산센터에 대해서는 물리적 방식 외의 방법으로 망을 분리하여야 하며, 이 경우에도 국내 소재 전산센터 및 정보처리 시스템 등은 물리적으로 망을 분리하여야 한다) 2. 업무상 외부통신망과 연결이 불가피한 다음의 정보처리시스템(다만, 필요한 서비스번호(port)에 한하여 연결할 수 있다) 가. 전자금융업무의 처리를 위하여 특정 외부기관과 데이터를 송수신하는 정보처리시스템 나. DMZ구간 내 정보처리시스템과 실시간으로 데이터를 송수신하는 내부통신망의 정보처리시스템 다. 다른 계열사(「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제3항의 “계열사”를 말한다)와 공동으로 사용하는 정보처리시스템 3. 규정 제23조의 비상대책에 따라 원격 접속이 필요한 경우 4. 전산실 내에 위치한 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기와 외부통신망과의 연결 구간, 규정 제15조제1항제3호의 내부 업무용 시스템과의 연결 구간을 각각 차단한 경우<신설 2016. 5. 12.> ③ 제1항 및 제2항의 규정은 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 별표 7에서 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한하여 적용한다. [총전의 제2조의2에서 이동]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-099	5.5 정보보호 시스템 설치 및 운영	내부통신망에서의 파일 배포기능 이용 시 파일 무결성 검증 수행 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해 행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다. 4. 내부통신망에서의 파일 배포기능은 통합 및 최소화하여 운영하고, 이를 배포할 경우에는 무결성 검증을 수행할 것 <신설 2013. 12. 3.> ○ (전자금융감독규정) 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해 행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다. 5. 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리 할 것. 다만, 다음 각 목의 경우에는 그러하지 아니하다.<신설 2013. 12. 3., 개정 2015. 2. 3., 2022. 11. 23.> 가. 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구·개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원장이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한한다) <신설 2022. 11. 23.>개정 2025. 2. 5.> 나. 업무상 불가피한 경우로서 금융감독원장이 인정하는 경우 <신설 2022. 11. 23.>
FISM-100	5.5 정보보호 시스템 설치 및 운영	전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기가 인터넷 등 외부통신망으로부터 물리적으로 분리 여부	5	○ (전자금융감독규정시행세칙) 제2조의3(망분리 적용 예외) ② 규정 제15조제1항제5호나목에서 금융감독원장이 인정하는 경우란 다음 각 호와 같다. <개정 2022. 12. 29.> 4. 전산실 내에 위치한 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기와 외부통신망과의 연결 구간, 규정 제15조제1항제3호의 내부 업무용 시스템과의 연결 구간을 각각 차단한 경우 <신설 2016. 5. 12.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-101	5.5 정보보호 시스템 설치 및 운영	정보보호시스템에 최소한의 서비스번호와 기능 적용 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 1. 최소한의 서비스번호(port)와 기능만을 적용하고 업무목적 이외의 기능 및 프로그램을 제거할 것
FISM-102	5.5 정보보호 시스템 설치 및 운영	정보보호시스템의 업무목적 이외 기능 및 프로그램 제거 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 2. 보안정책의 승인, 적용, 등록, 변경 및 삭제에 대해 기록·보관하고 적용된 보안정책의 적정성을 주기적으로 점검할 것
FISM-103	5.5 정보보호 시스템 설치 및 운영	정보보안 정책 승인 및 적용 시, 정책 등록, 변경, 삭제 내용에 대한 보관 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ③ 제1 항 각 호의 정보보호시스템에 대하여 책임자를 지정·운영하여야 하며, 운영결과는 1년 이상 보존하여야 한다. ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 2. 보안정책의 승인, 적용, 등록, 변경 및 삭제에 대해 기록·보관하고 적용된 보안정책의 적정성을 주기적으로 점검할 것

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-104	5.5 정보보호 시스템 설치 및 운영	정보보호시스템 원격관리 차단 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원장이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 3. 정보보호시스템 원격관리를 금지할 것. 다만, 원격관리가 불가피한 경우 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다) 사용, 접근통제 등을 포함한 원격 접속 보안 대책을 수립·운영할 것
FISM-105	5.5 정보보호 시스템 설치 및 운영	정보보호시스템 원격관리 이용 시, 원격 접속에 관한 보안대책 수립 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원장이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 3. 정보보호시스템 원격관리를 금지할 것. 다만, 원격관리가 불가피한 경우 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다) 사용, 접근통제 등을 포함한 원격 접속 보안 대책을 수립·운영할 것
FISM-106	5.5 정보보호 시스템 설치 및 운영	정보보호시스템 작동상태 모니터링 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원장이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 4. 정보보호시스템의 정상 작동 여부 확인을 위하여 시스템 상태의 감시, 경고가 가능하도록 모니터링시스템을 갖추고 시스템 장애, 가동중지 등 긴급사태에 대비하여 백업 및 복구 절차 등을 수립·운영할 것

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-107	5.5 정보보호 시스템 설치 및 운영	정보보호시스템에 대한 백업 및 복구절차 수립 및 시행 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ② 제1 항제1 호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원이 정하는 사항을 준수하여야 한다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 4. 정보보호시스템의 정상 작동 여부 확인을 위하여 시스템 상태의 감시, 경고가 가능하도록 모니터링시스템을 갖추고 시스템 장애, 가동중지 등 긴급사태에 대비하여 백업 및 복구 절차 등을 수립·운영할 것
FISM-108	5.5 정보보호 시스템 설치 및 운영	정보보호시스템 책임자 지정/운영 및 운영결과 1년 이상 보존 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ③ 제1 항 각 호의 정보보호시스템에 대하여 책임자를 지정·운영하여야 하며, 운영결과는 1년 이상 보존하여야 한다.
FISM-109	5.6 무선통신망 설치 및 운영	무선통신망 이용 업무의 정보보호최고책임자 승인 및 사전 지정 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ⑥ 금융회사 또는 전자금융업자는 무선통신망을 설치·운영할 때에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 1. 무선통신망 이용 업무는 최소한으로 국한하고 법 제21조의2에 따른 정보보호최고 책임자의 승인을 받아 사전에 지정할 것
FISM-110	5.6 무선통신망 설치 및 운영	사용자인증, 암호화 등 무선통신망 보안대책 수립	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ⑥ 금융회사 또는 전자금융업자는 무선통신망을 설치·운영할 때에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 2. 무선통신망을 통한 불법 접속을 방지하기 위한 사용자인증, 암호화 등 보안대책을 수립·운영할 것 <개정 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-111	5.6 무선통신망 설치 및 운영	금융회사 내부망에 연결된 정보처리시스템이 지정 된 업무 용도와 사용 지역(zone) 이외의 무선통신망에 접속하는 것을 차단하기 위한 차단시스템 구축 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ⑥ 금융회사 또는 전자금융업자는 무선통신망을 설치·운영할 때에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 3. 무선통신망에 인가되지 않은 정보처리시스템 및 단말기의 접속을 차단하여야 하며, 비인가 무선접속장비(Access Point: AP) 설치·접속여부, 중요 정보 노출여부를 주기적으로 점검할 것 <개정 2015. 2. 3., 2025. 2. 5.>
FISM-112	5.6 무선통신망 설치 및 운영	무선통신망 실시간 모니터링체계 운영 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ⑥ 금융회사 또는 전자금융업자는 무선통신망을 설치·운영할 때에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 3. 무선통신망에 인가되지 않은 정보처리시스템 및 단말기의 접속을 차단하여야 하며, 비인가 무선접속장비(Access Point: AP) 설치·접속여부, 중요 정보 노출여부를 주기적으로 점검할 것 <개정 2015. 2. 3., 2025. 2. 5.>
FISM-114	5.7 악성코드 감염 방지대책	악성코드 감염·확산 방지, 피해 최소화 및 복구를 위한 대책을 수립·운영 여부	5	○ (전자금융감독규정) 제16조(악성코드 감염 방지대책) 금융회사 또는 전자금융업자는 악성코드 감염·확산 방지, 피해 최소화 및 복구를 위한 대책을 수립·운영하여야 한다.<개정 2025. 2. 5.>
FISM-117	5.7 악성코드 감염 방지대책	중요 단말기의 악성코드 감염 여부 정기 점검 여부	5	○ (전자금융감독규정) 제12조(단말기 보호대책) 금융회사 또는 전자금융업자는 단말기 보호를 위하여 다음 각 호의 사항을 준수하여야 한다.<개정 2013. 12. 3.> 3. 외부 반출, 인터넷 접속, 그룹웨어 접속의 금지, 정기적인 악성코드 감염여부 확인 등 강화된 보호대책이 적용되는 중요단말기를 지정할 것 <개정 2013. 12. 3., 2015. 2. 3., 2025. 2. 5.> 제16조(악성코드 감염 방지대책) 금융회사 또는 전자금융업자는 악성코드 감염·확산 방지, 피해 최소화 및 복구를 위한 대책을 수립·운영하여야 한다.<개정 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-119	5.8 공개 서버 보안	공개용 웹서버의 DMZ구간내 설치 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 1. 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망사이의 독립된 통신망(이하 "DMZ구간"이라 한다)에 설치하고 네트워크 및 웹 접근제어 수단으로 보호할 것
FISM-120	5.8 공개 서버 보안	공개용 웹서버를 네트워크 및 웹 접근 제어 수단으로 보호 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 1. 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망사이의 독립된 통신망(이하 "DMZ구간"이라 한다)에 설치하고 네트워크 및 웹 접근제어 수단으로 보호할 것
FISM-121	5.8 공개 서버 보안	공개용 웹서버 접근 사용자계정을 업무관련자로 제한 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 2. 공개용 웹서버에 접근할 수 있는 사용자계정은 업무관련자만 접속할 수 있도록 제한하고 이중 인증수단을 적용할 것 <개정 2025. 2. 5.>
FISM-122	5.8 공개 서버 보안	공개용 웹서버에 접근할 수 있는 사용자계정은 아이디 비밀번호 이외에 추가인증수단 적용 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 2. 공개용 웹서버에 접근할 수 있는 사용자계정은 업무관련자만 접속할 수 있도록 제한하고 이중 인증수단을 적용할 것 <개정 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-123	5.8 공개 서버 보안	공개용 웹서버 제공이외 다른 서비스 및 시험/개발도구 등의 사용 제한 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 3. 공개용 웹서버에서 제공하는 서비스를 제외한 다른 서비스 및 시험·개발 도구 등의 사용을 제한하고, DMZ구간 내에 이용자 정보 등 주요 정보를 저장 및 관리하지 아니할 것(다만, 거래로그를 관리하기 위한 경우에는 예외로 하되 고유식별정보는 반드시 암호화하며 그 외 이용자 정보는 별도의 보안대책을 수립하여 저장·관리하여야 한다) <개정 2025. 2. 5.>
FISM-128	5.8 공개 서버 보안	홈페이지에 자료를 게시하는 절차 및 내부통제 방안 수립/운용 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 4. 금융회사 또는 전자금융업자는 공개용 웹서버에 자료 게시 절차·내용에 관한 내부통제 방안과 개인정보 유출 및 위·변조를 방지하기 위한 보안조치 방안을 수립·운용하여야 한다. <개정 2025. 2. 5.>
FISM-129	5.8 공개 서버 보안	개인정보의 유출 및 위/변조를 방지하기 위한 보안조치 여부	5	○ (전자금융감독규정) 제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운용하여야 한다. <개정 2025. 2. 5.> 4. 금융회사 또는 전자금융업자는 공개용 웹서버에 자료 게시 절차·내용에 관한 내부통제 방안과 개인정보 유출 및 위·변조를 방지하기 위한 보안조치 방안을 수립·운용하여야 한다. <개정 2025. 2. 5.>
FISM-131	5.8 공개 서버 보안	단말기에서 음란, 도박 등 업무와 무관한 프로그램 및 인터넷사이트에 대한 접근 통제 여부	5	○ (전자금융감독규정) 제15조(해킹 등 방지대책) ⑦ 금융회사 또는 전자금융업자는 단말기에서 음란, 도박 등 업무와 무관한 프로그램 또는 인터넷 사이트에 접근하는 것에 대한 통제대책을 수립·운용하여야 한다. <신설 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-135	5.9 IP주소 관리	내/외부 IP주소의 인터넷 접속내용 1년이상 별도 기록/보관 여부	5	○ (전자금융감독규정) 제18조(IP주소 관리대책) 금융회사 또는 전자금융업자는 정보제공자 주소(이하 "IP주소"라 한다)의 안전한 사용을 위하여 주소 체계·할당·관리 등에 대한 내용을 포함한 적절한 대책을 수립·운영하고, 내부 IP주소 및 외부 IP주소의 인터넷 접속 내용을 1년 이상 별도로 기록·보관하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉
FISM-138	5.10 암호프로그램 및 암호키 관리	암호프로그램 담당자 지정 여부	5	○ (전자금융감독규정) 제19조(암호프로그램 및 키 관리 통제) ① 금융회사 또는 전자금융업자는 암호프로그램에 대하여 담당자 지정, 담당자 이외의 이용 통제 및 원시프로그램(source program) 별도 보관 등을 준수하여 유포 및 부당 이용이 발생하지 않도록 하여야 한다.
FISM-139	5.10 암호프로그램 및 암호키 관리	암호프로그램의 비담당자 이용에 관한 통제 여부	5	○ (전자금융감독규정) 제19조(암호프로그램 및 키 관리 통제) ① 금융회사 또는 전자금융업자는 암호프로그램에 대하여 담당자 지정, 담당자 이외의 이용 통제 및 원시프로그램(source program) 별도 보관 등을 준수하여 유포 및 부당 이용이 발생하지 않도록 하여야 한다.
FISM-140	5.10 암호프로그램 및 암호키 관리	암호프로그램에 대한 원시프로그램 별도 보관 여부	5	○ (전자금융감독규정) 제19조(암호프로그램 및 키 관리 통제) ① 금융회사 또는 전자금융업자는 암호프로그램에 대하여 담당자 지정, 담당자 이외의 이용 통제 및 원시프로그램(source program) 별도 보관 등을 준수하여 유포 및 부당 이용이 발생하지 않도록 하여야 한다.
FISM-141	5.10 암호프로그램 및 암호키 관리	암호 및 인증시스템에 적용되는 키에 대하여 주입/운용/갱신/폐기에 대한 절차 및 방법 마련 여부	5	○ (전자금융감독규정) 제19조(암호프로그램 및 키 관리 통제) ② 금융회사 또는 전자금융업자는 암호 및 인증시스템 등에 적용되는 키(Key)(프로그램 진위 및 무결성 확인에 사용되는 암호 또는 인증시스템 등에 적용되는 키를 포함한다)에 대하여 주입·운용·갱신·폐기에 대한 절차 및 방법을 마련하여 안전하게 관리하여야 한다. [본조 신설 2025. 2. .5.]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-142	6.1 계정 및 권한 관리	사용자 인증수단 개인별 부여 및 최소한의 접근권한 부여 등 수립/운용 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 1. 사용자 인증 수단을 개인별로 부여하고 접근권한은 최소한으로 부여하는 등 적절한 접근권한 관리 및 통제 절차를 수립·운용할 것 <개정 2025. 2. 5.>
FISM-146	6.1 계정 및 권한 관리	사용자 인사조치 시 지체없이 해당 사용자 계정 삭제, 사용 중지, 공동 사용 계정 변경 등 정보처리시스템 접근 통제 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 11. 사용자가 전출·퇴직 등 인사조치가 있을 때에는 지체 없이 해당 사용자계정 삭제, 계정 사용 중지, 공동 사용 계정 변경 등 정보처리시스템에 대한 접근을 통제할 것<종전의 제14호에서 이동, 2025. 2. 5.>
FISM-147	6.1 계정 및 권한 관리	사용자 계정 공동사용 시 개인별 사용내역에 대한 기록저장 및 관리 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다. <개정 2013. 12. 3.> 1. 사용자 인증 수단을 개인별로 부여하고 접근권한은 최소한으로 부여하는 등 적절한 접근권한 관리 및 통제 절차를 수립·운용할 것 <개정 2025. 2. 5.> ② 사용자계정의 공동 사용이 불가피한 경우에는 개인별 사용내역을 기록·관리하여야 한다. <개정 2025. 2. 5.>
FISM-148	6.2 정보처리시스템 관리자 통제	정보처리시스템 관리자에 대한 적절한 통제장치 마련 및 운용 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ③ 금융회사 또는 전자금융업자는 단말기와 전산자료의 접근권한이 부여되는 정보처리 시스템 관리자에 대하여 적절한 통제장치를 마련·운용하여야 한다. 다만, 정보처리시스템 관리자의 주요 업무 관련 행위는 책임자가 제28조제2항에 따라 이중확인 및 모니터링을 하여야 한다.<종전의 제5항에서 이동, 2025. 2. 5.> <개정 2013. 12. 3.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-149	6.2 정보처리시스템 관리자 통제	정보처리시스템 관리자 주요업무관련행위의 책임자 이중 확인 및 모니터링 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ③ 금융회사 또는 전자금융업자는 단말기와 전산자료의 접근권한이 부여되는 정보처리 시스템 관리자에 대하여 적절한 통제장치를 마련·운영하여야 한다. 다만, 정보처리시스템 관리자의 주요 업무 관련 행위는 책임자가 제28조제2항에 따라 이중확인 및 모니터링을 하여야 한다.〈종전의 제5항에서 이동, 2025. 2. 5.〉〈개정 2013. 12. 3.〉
FISM-153	6.3 내부사용자 비밀번호 관리	사용자 비밀번호에 관한 주기적 변경 여부	5	○ (전자금융감독규정) 제19조의2(사용자 인증수단 관리) 금융회사 또는 전자금융업자는 비밀번호, 생체정보 등 사용자 인증수단 유효를 방지하기 위하여 인증수단의 발급·보관·주기적 변경 및 인증오류 발생시 처리 절차 등을 포함한 관리방안을 수립·운영하여야 한다.
FISM-154	6.3 내부사용자 비밀번호 관리	사용자 비밀번호 보관시 암호화 여부	5	○ (전자금융감독규정) 제19조의2(사용자 인증수단 관리) 금융회사 또는 전자금융업자는 비밀번호, 생체정보 등 사용자 인증수단 유효를 방지하기 위하여 인증수단의 발급·보관·주기적 변경 및 인증오류 발생시 처리 절차 등을 포함한 관리방안을 수립·운영하여야 한다.
FISM-156	6.3 내부사용자 비밀번호 관리	사용자 비밀번호 연속 입력 오류 시 즉시 접속 차단 여부	5	○ (전자금융감독규정) 제19조의2(사용자 인증수단 관리) 금융회사 또는 전자금융업자는 비밀번호, 생체정보 등 사용자 인증수단 유효를 방지하기 위하여 인증수단의 발급·보관·주기적 변경 및 인증오류 발생시 처리 절차 등을 포함한 관리방안을 수립·운영하여야 한다.
FISM-158	6.4 이용자 비밀번호 관리	정보처리시스템 및 전산자료에 보관하고 있는 이용자 비밀번호 암호화 보관 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 전산자료에 보관하고 있는 이용자의 비밀번호를 암호화하여 보관하며 동 비밀번호를 조회할 수 없도록 하여야 한다. 다만, 비밀번호의 조회가 불가피하다고 인정되는 경우에는 그 조회사유·내용 등을 기록·관리 하여야 한다.

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-159	6.4 이용자 비밀번호 관리	이용자 비밀번호 조회 금지 및 불가피한 경우 조화사유 및 내용 기록 관리 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 전산자료에 보관하고 있는 이용자의 비밀번호를 암호화하여 보관하며 동 비밀번호를 조회할 수 없도록 하여야 한다. 다만, 비밀번호의 조회가 불가피하다고 인정되는 경우에는 그 조화사유·내용 등을 기록·관리하여야 한다.
FISM-160	6.4 이용자 비밀번호 관리	이용자 비밀번호 등록 시 제3자가 쉽게 유추 할 수 있는 비밀번호의 설정 금지 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 1. 제3자가 쉽게 유추할 수 없는 비밀번호 작성규칙 및 등록·변경 절차를 수립·운영할 것
FISM-162	6.4 이용자 비밀번호 관리	이용자 비밀번호가 일정횟수 입력오류 시 해당비밀번호 이용거래에 대한 즉시 중지 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 2. 미리 정한 횟수 이상의 비밀번호 입력 오류가 발생한 경우 즉시 해당 비밀번호를 이용하는 거래를 중지시키고 본인 확인절차를 거친 후 비밀번호 재부여 및 거래 재개(이체 비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우, 입력오류 횟수는 이용되는 모든 전자금융거래에 대하여 통산한다)
FISM-163	6.4 이용자 비밀번호 관리	이체비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우 입력오류 횟수는 이용되는 모든 전자금융거래에 대한 통산 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 2. 미리 정한 횟수 이상의 비밀번호 입력 오류가 발생한 경우 즉시 해당 비밀번호를 이용하는 거래를 중지시키고 본인 확인절차를 거친 후 비밀번호 재부여 및 거래 재개(이체 비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우, 입력오류 횟수는 이용되는 모든 전자금융거래에 대하여 통산한다)

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-164	6.4 이용자 비밀번호 관리	이용 중지된 이용자 비밀번호의 재부여 또는 거래재개 시 본인확인 절차 적용 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 2. 미리 정한 횟수 이상의 비밀번호 입력 오류가 발생한 경우 즉시 해당 비밀번호를 이용하는 거래를 중지시키고 본인 확인절차를 거친 후 비밀번호 재부여 및 거래 재개(이체 비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우, 입력오류 횟수는 이용되는 모든 전자금융거래에 대하여 통산한다)
FISM-167	6.4 이용자 비밀번호 관리	신규거래, 비밀번호 변경, 이체 신청 등 비밀번호를 등록/사용하는 경우 사전에 신청서등에 기재 금지 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 3. 신규 거래, 비밀번호 변경, 이체 신청과 같이 비밀번호를 등록·사용하는 경우 사전에 신청서 등에 기입하지 않고, 핀패드 등 보안장치를 이용하거나 이용자가 사후에 전자적 장치를 이용하여 직접 입력하는 방식으로 운영할 것
FISM-168	6.4 이용자 비밀번호 관리	비밀번호를 등록·사용하는 경우 핀패드 등 보안장치를 이용 또는 사후에 전자적 장치를 이용하여 직접 입력하는 방식의 운영 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 3. 신규 거래, 비밀번호 변경, 이체 신청과 같이 비밀번호를 등록·사용하는 경우 사전에 신청서 등에 기입하지 않고, 핀패드 등 보안장치를 이용하거나 이용자가 사후에 전자적 장치를 이용하여 직접 입력하는 방식으로 운영할 것
FISM-169	6.5 전산원장 통제	전산원장 변경을 위한 변경절차 수립 및 운용 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ① 금융기관 또는 전자금융업자는 장애 또는 오류 등에 의한 전산원장의 변경을 위하여 별도의 통제절차를 수립·운용하여야 한다. <개정 2025. 2. 5.>
FISM-170	6.5 전산원장 통제	전산원장 변경절차에 변경 대상 및 방법 포함 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다.

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-171	6.5 전산원장 통제	전산원장 변경절차에 변경 권한자 지정 포함 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다. ○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다. ○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다.
FISM-172	6.5 전산원장 통제	전산원장 변경 절차에 변경 전후 내용 자동기록 및 보존 포함 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다. ○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다.
FISM-173	6.5 전산원장 통제	전산원장 변경절차에 변경내용의 정당여부에 대한 제3자 확인 포함 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다. ○ (전자금융감독규정) 제27조(전산원장 통제) ② 제1항의 절차에는 변경 대상 및 방법, 변경 권한자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다.
FISM-174	6.5 전산원장 통제	대차대조표 등 중요자료 계상액과 각종 보조부/거래기록/전산원장파일의 계상액에 대한 상호일치여부에 대한 전산시스템을 통한 주기적인 확인 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ③ 금융회사 또는 전자금융업자는 대차대조표 등 중요 자료의 계상액과 각종 보조부·거래 기록·전산원장파일의 계상액에 대한 상호일치 여부를 전산시스템을 통하여 주기적으로 확인하여야 한다. <개정 2013. 12. 3.>
FISM-175	6.5 전산원장 통제	전산원장 불일치 원인과 조치 내용을 전산자료형태로 5년간 보존 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ④ 금융회사 또는 전자금융업자는 제3항에 따른 확인 결과 불일치가 발견된 때에는 그 원인 및 조치 내용을 전산자료의 형태로 5년간 보존하여야 한다. <개정 2013. 12. 3.>
FISM-176	6.5 전산원장 통제	중요원장의 조회, 수정, 삭제, 삽입한 작업자와 작업내용 기록 및 5년간 보존 여부	5	○ (전자금융감독규정) 제27조(전산원장 통제) ⑤ 금융회사 또는 전자금융업자는 사용자 중요원장에 직접 접근하여 중요원장을 조회·수정·삭제·삽입하는 경우에는 작업자 및 작업내용 등을 기록하여 5년간 보존하여야 한다. <개정 2013. 12. 3.>
FISM-177	6.5 전산원장 통제	사고위험도가 높은 거래에 대한 전산시스템 기반의 책임자 이중확인 절차 적용 여부	5	○ (전자금융감독규정) 제28조(거래통제 등) ① 금융회사 또는 전자금융업자는 사고위험도가 높은 거래에 대하여는 책임자 승인거래로 처리토록 하는 등 전산시스템에 의한 이중확인인 가능하도록 하여야 한다. <개정 2013. 12. 3.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-178	6.5 전산원장 통제	전산원장, 주요정보, 이용자정보 등이 저장된 정보처리시스템 중요작업에 대한 책임자 이중확인 여부	5	○ (전자금융감독규정) 제13조(전산자료 보호대책) ③ 금융회사 또는 전자금융업자는 단말기와 전산자료의 접근권한이 부여되는 정보처리 시스템 관리자에 대하여 적절한 통제장치를 마련·운용하여야 한다. 다만, 정보처리시스템 관리자의 주요 업무 관련 행위는 책임자가 제28조제2항에 따라 이중확인 및 모니터링을 하여야 한다.〈중전의 제5항에서 이동, 2025. 2. 5.〉〈개정 2013. 12. 3.〉 - 제28조(거래통제 등) ② 금융회사 또는 전자금융업자는 전산원장, 주요정보 또는 이용자 정보 등이 저장된 정보처리시스템에 대한 중요작업 수행 시 책임자가 이중확인을 해야 한다.〈개정 2013. 12. 3.〉
FISM-179	6.6 일괄작업 통제	일괄작업(batch) 수행을 위한 절차 수립/운용 여부	5	○ (전자금융감독규정) 제30조(일괄작업에 대한 통제) 금융회사 또는 전자금융업자는 안전하고 체계적인 일괄작업(batch)의 수행을 위한 절차를 수립·운용하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉
FISM-184	7.1 사업추진 시 준수사항	사업 추진 시 내부통제 기준 수립/운용 여부	5	○ (전자금융감독규정) 제20조(정보처리시스템 구축 및 전자금융거래 관련 사업 추진) 금융회사 또는 전자금융업자는 정보처리시스템 및 전자금융거래와 관련된 사업 추진에 대한 내부통제 기준을 수립·운용하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉
FISM-188	7.2 사업계약 관련 준수사항	계약 체결 시 내부통제 절차 수립/운용 여부	5	○ (전자금융감독규정) 제21조(정보처리시스템 구축 및 전자금융거래 관련 계약) 금융회사 또는 전자금융업자는 정보처리시스템 구축 및 전자금융거래와 관련된 계약 체결시에 정보처리시스템의 안전성·신뢰성 및 계약의 공정성이 확보될 수 있도록 체결·이행·감사 등에 관한 내용을 포함한 내부통제 절차를 수립·운용해야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉
FISM-197	7.3 정보처리 시스템 감리	정보처리시스템 감리 지침 수립/운용 여부	5	○ (전자금융감독규정) 제22조(정보처리시스템 감리) 금융회사 또는 전자금융업자는 정보 처리시스템의 안전성 및 효율성 확보를 위한 정보처리시스템 감리 지침을 수립·운용하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-201	7.4 직무분리	정보기술부문의 내부통제를 위한 직무분리 기준 수립/운영 여부	5	○ (전자금융감독규정) 제8조의3(직무의 분리) 금융회사 또는 전자금융업자는 정보기술 부문의 내부통제를 위한 직무분리 기준을 수립·운영하여야 한다.
FISM-209	7.5 프로그램 통제절차 수립	프로그램 등록/변경/폐기 방법에 관한 절차 수립 및 운영 여부	5	○ (전자금융감독규정) 제29조(프로그램 통제) 금융회사 또는 전자금융업자는 프로그램 등록·변경·폐기 등에 관하여 금융감독원장이 정하는 사항을 포함한 절차를 수립·운영하여야 한다. <개정 2013. 12. 3., 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제2조의7(프로그램 통제) 규정 제29조에 따라 감독원장이 정하는 사항은 다음 각 호와 같다. 1. 적용대상 프로그램 종류 및 등록·변경·폐기 방법을 마련할 것 2. 프로그램 변경 전후 내용을 기록·관리할 것 3. 프로그램 등록·변경·폐기내용의 정당성에 대해 제3자의 검증을 받을 것 4. 변경 필요시 해당 프로그램을 개발 또는 테스트 시스템으로 복사 후 수정할 것 5. 프로그램에 대한 접근은 업무담당자에 한정하고, 적절한 접근권한(읽기·쓰기·실행 등 포함) 설정 및 중요 조작에 대한 책임자 사전 승인 등 통제절차를 수립·운영할 것 6. 프로그램 반출, 실행프로그램의 생성 및 운영시스템 적용은 해당 프로그램 담당자 이외의 자가 수행할 것 7. 운영시스템 적용은 처리하는 정보의 기밀성·무결성·가용성 및 전자금융거래의 안전성과 신뢰성이 훼손되지 않도록 충분한 테스트 및 관련 책임자 승인 후 실시할 것 8. 운영체제, 데이터베이스관리프로그램 등의 시스템 프로그램도 응용프로그램과 동일한 수준으로 관리할 것 9. 프로그램 설명서, 프로그램 목록 및 사용자·운영자 지침서 등 프로그램 유지보수에 필요한 문서를 작성·관리할 것 10. 전자금융거래에 사용되는 프로그램은 도입·분석·설계 단계에서부터 안전성과 신뢰성을 확보할 수 있는 대책을 마련하고, 운영시스템 적용 전에 동 대책이 반영되었는지 충분히 검증하고 적용할 것 [본조신설 2025. 2. 3.]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				○ (전자금융감독규정) 제36조(자체 보안성심의) ① 금융회사 또는 전자금융업자는 다음 각 호의 행위를 하고자 하는 경우 금융감독원장이 정하는 기준과 절차에 따라 보안성심의를 실시하여야 한다. <개정 2016. 6. 30.> 1. 정보통신망을 이용하여 이용자를 대상으로 신규 전자금융업무를 수행 2. 복수의 금융회사 또는 전자금융업자가 공동으로 전자금융거래 관련 표준을 제정 ② 금융회사 또는 전자금융업자는 제1항에 따른 심의(이하 "자체 보안성심의"라 한다)를 마친 후 제1항 각 호의 행위를 수행한 날로부터 30일 이내에 금융감독원장이 정하는 자체 보안성심의 결과보고서를 금융감독원에 제출하여야 한다. 다만, 제1항제1호에 따른 보안성심의의 경우 신규 전자금융업무가 제공 또는 시행된 날을 기준으로 과거 1년 이내에 전자금융사고가 발생하지 않은 기관으로서 금융감독원장이 정하는 기준에 해당하는 금융회사 또는 전자금융업자는 그러하지 아니하다. <개정 2025. 2. 5.> ○ (전자금융감독규정시행세칙) 제3조(자체 보안성심의 기준 등) ① 규정 제36조제1항에 따른 금융감독원장이 정하는 기준과 절차란 다음 각 호를 말한다. 1. 정보통신망을 이용하여 신규전자금융업무를 수행하는 경우 <별표 1>의 기준에 따라 보안성심의를 실시한 후 정보보호최고책임자의 승인을 받을 것 2. 공동으로 전자금융거래 관련 표준을 제정하는 경우 <별표 1의2>의 기준에 따라 보안성 심의를 실시할 것(다만, 이 경우 특정 금융회사 또는 전자금융업자가 다른 금융회사들을 대표하여 규정 제36조제2항에 따른 자체 보안성심의 결과보고서를 제출할 수 있음). <개정 2014. 3. 31., 2016. 7. 27.> ② 금융회사 또는 전자금융업자가 규정 제36조제2항에 따라 제출하는 자체 보안성심의 결과보고서의 양식은 제1항제1호의 경우 별지 제3호서식에, 제1항제2호의 경우 별지 제4호서식에 각각 따른다. <개정 2014. 3. 31., 2016. 7. 27.>
FISM-219	7.6 자체 보안성심의	신규 업무 및 표준 제정 시 보안성 심의 여부	5	

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-221	8.1 업무 지속성 확보방안	업무지속성 확보방안에 상황별 대응절차 포함 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 1. 상황별 대응절차 ○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 2. 백업 또는 재해복구센터를 활용한 재해복구계획 ○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 3. 비상대응조직의 구성 및 운용 ○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 4. 입력대행, 수작업 등의 조건 및 절차 ○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 5. 모의훈련의 실시
FISM-222	8.1 업무 지속성 확보방안	업무지속성 확보방안에 백업 또는 재해복구센터를 활용한 재해복구계획 포함 여부	5	
FISM-223	8.1 업무 지속성 확보방안	업무지속성 확보방안에 비상대응조직의 구성 및 운용 포함	5	
FISM-224	8.1 업무 지속성 확보방안	업무지속성 확보방안에 입력대행, 수작업 등의 조건 및 절차 포함 여부	5	
FISM-225	8.1 업무 지속성 확보방안	업무지속성 확보방안에 모의 훈련의 실시 포함 여부	5	

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-226	8.1 업무 지속성 확보방안	업무지속성 확보방안에 유관기관 및 관련업체와의 비상연락체계 포함 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 6. 유관기관 및 관련업체와의 비상연락체계 구축
FISM-227	8.1 업무 지속성 확보방안	업무지속성 확보방안에 보고 및 대외통보의 범위와 절차 포함 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 7. 보고 및 대외통보의 범위와 절차 등
FISM-228	8.1 업무 지속성 확보방안	업무지속성 확보대책을 매년 1회 이상 점검 및 최신상태 유지 및 관리 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ③ 금융회사 또는 전자금융업자는 제1항의 규정에 따른 업무지속성 확보대책의 실효성·적정성 등을 매년 1회 이상 점검하여 최신상태로 유지하고 관리하여야 한다. <개정 2013. 12. 3.>
FISM-229	8.1 업무 지속성 확보방안	정보처리시스템 및 데이터저장장치 등 주요 전산장비의 이중화 구축 또는 예비장치 확보 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ⑦ 금융회사 또는 전자금융업자는 중앙처리장치, 데이터저장장치 등 주요 전산장비에 대하여 이중화 또는 예비장치를 확보하여야 한다. <개정 2013. 12. 3.>
FISM-230	8.1 업무 지속성 확보방안	주전산센터와 일정거리 이상 떨어진 안전장소에 재해복구센터 구축 및 운영 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ⑧ 다음 각 호의 금융회사 및 전자금융업자는 시스템 오류, 자연재해 등으로 인한 전산센터 마비에 대비하여 업무지속성을 확보할 수 있도록 적정 규모·인력을 구비한 재해복구센터를 주전산센터와 일정거리 이상 떨어진 장소에 구축·운영하여야 한다. <개정 2013. 12. 3., 2015. 6. 24, 2025. 2. 5.> 1. 「은행법」에 의해 인가를 받아 설립된 은행(다만, 「은행법」 제58조에 의해 인가를 받은 외국금융회사의 국내지점은 제외한다) <개정 2013. 12. 3.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				2. 「한국산업은행법」에 의한 한국산업은행, 「중소기업은행법」에 의한 중소기업은행, 「농업협동조합법」에 의한 농협은행, 「수산업협동조합법」에 의한 수협은행 <개정 2013. 12. 3., 2025. 2. 5.> 3. 「자본시장과 금융투자업에 관한 법률」에 의한 투자매매업자·투자중개업자(다만, 「자본시장과 금융투자업에 관한 법률」 제12조에 의해 인가를 받은 외국 투자매매업자·투자중개업자의 지점 등은 제외한다) 4. 「자본시장과 금융투자업에 관한 법률」에 의한 증권금융회사 및 한국예탁결제원 5. 「자본시장과 금융투자업에 관한 법률」에 의한 거래소 <개정 2013. 12. 3.> 6. 「여신전문금융업법」에 의한 신용카드업자(다만, 법인신용카드 회원에 한하여 신용카드업을 영위하는 자는 제외한다) 6의2. 「여신전문금융업법」에 의한 시설대여업자, 할부금융업자, 신기술사업금융업자(시행령 제11조의4제1항에 해당하는 회사에 한정한다) <신설 2025. 2. 5.> 7. 「보험업법」에 의한 보험요율산출기관 8. 「상호저축은행법」에 의한 상호저축은행중앙회 및 자체 전산시스템을 구축하여 운영 하는 상호저축은행 <개정 2025. 2. 5.> 9. 「신용협동조합법」에 의한 신용협동조합중앙회 10. 「보험업법」에 의한 보험회사 11. 「전자금융거래법」에 의한 전자금융업자(연간 전자금융거래 총액이 2조원 이상인 회사에 한정한다) <신설 2025. 2. 5.>
FISM-231	8.1 업무 지속성 확보방안	적정한 규모와 인력을 구비한 재해복구센터 구축 및 운영 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운영) ⑥ 다음 각 호의 금융회사 및 전자금융업자는 시스템 오류, 자연재해 등으로 인한 전산센터 마비에 대비하여 업무지속성을 확보할 수 있도록 적정 규모·인력을 구비한 재해복구센터를 주전산센터와 일정거리 이상 떨어진 장소에 구축·운영하여야 한다.<개정 2013. 12. 3., 2015. 6. 24, 2025. 2. 5.> 1. 「은행법」에 의해 인가를 받아 설립된 은행(다만, 「은행법」제58조에 의해 인가를 받은 외국금융회사의 국내지점은 제외한다) <개정 2013. 12. 3.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				2. 「한국산업은행법」에 의한 한국산업은행, 「중소기업은행법」에 의한 중소기업은행, 「농업협동조합법」에 의한 농협은행, 「수산업협동조합법」에 의한 수협은행 <개정 2013. 12. 3., 2025. 2. 5.> 3. 「자본시장과 금융투자업에 관한 법률」에 의한 투자매매업자·투자중개업자(다만, 「자본시장과 금융투자업에 관한 법률」 제12조에 의해 인가를 받은 외국 투자매매업자·투자중개업자의 지점 등은 제외한다) 4. 「자본시장과 금융투자업에 관한 법률」에 의한 증권금융회사 및 한국예탁결제원 5. 「자본시장과 금융투자업에 관한 법률」에 의한 거래소 <개정 2013. 12. 3.> 6. 「여신전문금융업법」에 의한 신용카드업자(다만, 법인신용카드 회원에 한하여 신용카드업을 영위하는 자는 제외한다) 6의2. 「여신전문금융업법」에 의한 시설대여업자, 할부금융업자, 신기술사업금융업자(시행령 제11조의4제1항에 해당하는 회사에 한정한다) <신설 2025. 2. 5.> 7. 「보험업법」에 의한 보험요율산출기관 8. 「상호저축은행법」에 의한 상호저축은행중앙회 및 자체 전산시스템을 구축하여 운영 하는 상호저축은행 <개정 2025. 2. 5.> 9. 「신용협동조합법」에 의한 신용협동조합중앙회 10. 「보험업법」에 의한 보험회사 11. 「전자금융거래법」에 의한 전자금융업자(연간 전자금융거래 총액이 2조원 이상인 회사에 한정한다) <신설 2025. 2. 5.>
FISM-232	8.1 업무 지속성 확보방안	재해복구 목표시간 내 재해복구 가능 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운영) ⑨ 제8항 각 호의 금융회사는 업무별로 업무지속성 확보의 중요도를 분석하여 핵심업무를 선정하여야 하며, 업무별 복구목표시간을 정하여야 한다. 이 경우 핵심업무의 복구목표 시간은 3시간 이내로 하되, 「보험업법」에 의한 보험회사의 핵심업무의 경우에는 24시간 이내로 한다. <신설 2015. 6. 24.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)	
FISM-233	8.1 업무 지속성 확보방안	매년 1회 이상 재해복구센터로 재해복구전환훈련 실시 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ⑩ 제8항의 규정에 따른 재해복구센터를 운영하는 금융회사는 매년 1회 이상 재해복구센터로 실제 전환하는 재해복구전환훈련을 실시하여야 한다. <종전의 제9항에서 이동 2015. 6. 24.> <개정 2013. 12. 3.>	
FISM-238	8.3 위기대응 행동매뉴얼 수립	위기대응 행동매뉴얼 또는 비상대책 수립 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ④ 「국가위기관리기본지침」에 따라 금융위원회가 지정한 금융회사는 금융위원회의 「금융전산분야위기대응실무매뉴얼」에 따라 위기대응행동매뉴얼(이하 "행동매뉴얼"이라 한다)을 수립·준수하고 이를 금융위원회에 알려야 한다. <개정 2013. 12. 3., 2016. 10. 5.> ⑤ 금융위원회가 별도로 지정하지 아니한 금융회사 또는 전자금융업자는 자연 재해, 인적 재해, 기술적 재해, 전자적 침해 등으로 인한 전산시스템의 마비 방지와 신속한 복구를 위한 비상대책을 수립·운용하여야 한다. <개정 2013. 12. 3., 2016. 10. 5., 2025. 2. 5.>	
FISM-240	8.3 위기대응 행동매뉴얼 수립	위기대응 행동매뉴얼 또는 비상대책에 업무지속성 확보대책의 반영 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운용) ⑥ 제4항에 따른 행동매뉴얼 또는 제5항에 따른 비상대책에는 제1항의 규정에 따른 업무지속성 확보대책이 반영되어야 한다.	
FISM-241	11.2 침해사고 대응	연 1회 해킹, 디도스공격 등 침해사고 대응 및 복구훈련 실시와 침해사고대응기관에 제출 여부	5	○ (전자금융감독규정) 제37조의6(침해사고대응기관 지정 및 업무범위 등) ⑤ 금융회사 및 전자금융업자는 침해사고에 대한 대응능력 확보를 위하여 연 1회 이상 침해사고 대응 및 복구훈련 계획을 수립·시행하여야 하며 그 계획 및 결과를 침해사고대응기관의 장에게 제출하여야 한다. 다만 다음 각 호의 어느 하나에 해당하는 금융회사는 그러하지 아니한다. 1. 법 제2조제3호가목의 금융회사 중 신용협동조합 2. 법 제2조제3호다목·라목의 금융회사 3. 시행령 제2조제4호부터 제6호까지의 조합 4. 시행령 제5조제2항의 요건을 충족한 금융회사	

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-242	8.3 위기대응 행동매뉴얼 수립	금융위원회 주관 금융분야 합동비상대응훈련 실시 여부	5	○ (전자금융감독규정) 제24조(비상대응훈련 실시) ① 금융회사 또는 전자금융업자는 제23조제4항에 따른 행동매뉴얼 또는 같은 조 제5항에 따른 비상대책에 따라 연 1회의 비상대응훈련을 실시하고 그 결과를 금융위원회에 보고하여야 한다. 이때, 제23조제10항에 따른 재해복구전환훈련을 포함하여 실시할 수 있다. <개정 2013. 12. 3., 2016. 6. 30.> ② 금융위원회는 금융분야의 비상대응능력을 강화하기 위하여 금융회사 또는 전자금융업자를 선별하여 금융분야 합동비상대응훈련을 실시할 수 있다. <개정 2013. 12. 3.> ③ 금융위원회는 제2항의 규정에 따른 합동비상대응훈련을 실시할 때, 다음 각 호의 기관에게 지원을 요청할 수 있다. 1. 「정부조직법」 제17조에 따른 "국가정보원(국가사이버안전센터)" <개정 2025. 2. 5.> 2. 「국가경찰과 자치경찰의 조직 및 운영에 관한 법률」 제12조에 따른 "경찰청(사이버 수사국)" <개정 2025. 2. 5.> 3. 침해사고대응기관 <개정 2013. 12. 3.> 4. 그밖에 비상대응훈련의 실효성 확보를 위하여 금융위원회가 필요하다고 인정하는 기관 ④ 금융회사 또는 전자금융업자는 제1항 및 제2항에 따른 의무의 이행을 위하여 전자 금융보조업자에게 협조를 요청할 수 있다. <신설 2018. 12. 21.> ○ (전자금융감독규정) 제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다. 1. 전화 등 거래수단 성격상 암호화가 불가능한 경우를 제외한 전자금융거래는 암호화 통신을 할 것(다만, 전송선을 사용하는 경우로서 제36조의 규정에 따라 자체 보안성임을 실시한 경우에는 그러하지 아니하다)
FISM-243	9.1 전자금융거래 시 준수사항	전자금융거래 시 암호화 통신 여부	5	○ (전자금융감독규정) 제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다. 1. 전화 등 거래수단 성격상 암호화가 불가능한 경우를 제외한 전자금융거래는 암호화 통신을 할 것(다만, 전송선을 사용하는 경우로서 제36조의 규정에 따라 자체 보안성임을 실시한 경우에는 그러하지 아니하다)
FISM-244	9.1 전자금융거래 시 준수사항	전자금융거래 시 비대면 전자금융거래를 허용하지 않는 계좌개설 서비스를 제공할 수 있도록 시스템 구축 여부	5	○ (전자금융감독규정) 제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다. 2. 전자금융사고를 예방하기 위하여 비대면 전자금융거래를 허용하지 않는 계좌 개설, 중요거래정보에 대한 문자메시지 및 이메일(e-mail) 통지 등의 서비스를 이용자가 요청하는 경우, 동 서비스를 제공할 수 있도록 시스템을 갖출 것

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-245	9.1 전자금융거래 시 준수사항	전자금융거래 시 중요거래정보에 대한 문자메시지 및 이메일서비스를 제공할 수 있도록 시스템 구축 여부	5	○ (전자금융감독규정) 제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다. 2. 전자금융사고를 예방하기 위하여 비대면 전자금융거래를 허용하지 않는 계좌 개설, 중요거래정보에 대한 문자메시지 및 이메일(e-mail) 통지 등의 서비스를 이용자가 요청하는 경우, 등 서비스를 제공할 수 있도록 시스템을 갖출 것
FISM-246	9.1 전자금융거래 시 준수사항	전자금융거래 시 전자금융거래에 사용되는 접근매체의 본인 실명증표 확인 후 교부 여부	5	○ (전자금융감독규정) 제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다. 3. 전자금융거래에 사용되는 접근매체를 발급받기 위해서는 반드시 실명확인 후 교부할 것
FISM-247	9.1 전자금융거래 시 준수사항	전자금융거래에 관한 거래인증수단 채택시 안전성, 보안성, 이용편의성 등을 충분히 고려 여부	5	○ (전자금융감독규정) 제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다. 4. 금융회사 또는 전자금융업자는 전자금융거래에서 이용자에게 제공하거나 거래를 처리하기 위한 전자금융거래프로그램(거래전문포함)의 위·변조 여부 등 무결성을 검증할 수 있는 방법을 제공할 것<종전의 제5호에서 이동, 2025. 2. 5>
FISM-249	9.1 전자금융거래 시 준수사항	전자금융거래의 종류·성격·위험수준 등을 고려한 인증방법 사용 여부	5	○ (전자금융감독규정) 제34조의2(인증방법 사용기준) 금융회사 또는 전자금융업자는 전자금융거래의 종류·성격·위험수준 등을 고려하여 안전한 인증방법을 사용하여야 한다. [본조 신설 2025. 2. 5.]
FISM-251	9.4 이용자 정보보호	이용자 비밀번호 유출위험 및 관리에 관한 사항 공지 여부	5	○ (전자금융감독규정) 제35조(이용자 유의사항 공지) 금융회사 또는 전자금융업자는 전자금융거래의 안전한 수행을 위하여 이용자에게 필요한 사항을 공지하여야 한다.<개정 2013. 12. 3., 2025. 2. 5>
FISM-256	10.1 외부주문 계약 준수사항	IT외부주문 업무에 대한 업무정성성 검토 여부	5	○ (전자금융감독규정) 제8조(인력, 조직 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3> 2. 외부주문등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-257	10.1 외부주문 계약 준수사항	IT 외부주문 계약 체결시 계약내용의 적정성 검토 여부	5	○ (전자금융감독규정) 제8조(인력, 조직 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 2. 외부주문등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것
FISM-258	10.1 외부주문 계약 준수사항	외부주문 등의 입찰·계약·수행·완료 등 각 단계별로 금융감독원장이 정하는 보안관리방안 준수 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 7. 외부주문등의 입찰·계약·수행·완료 등 각 단계별로 금융감독원장이 정하는 보안관리 방안을 따를 것 <개정 2015. 2. 3.> ○ (전자금융감독규정시행세칙) 제9조의2(외부주문등에 대한 기준) ① 규정 제60조제1항제7호에 따라 감독원장이 정하는 보안관리방안은 별표 5-2와 같다.
FISM-259	10.1 외부주문 계약 준수사항	외부주문 시 내부통제방안 수립 및 운용 여부	5	○ (전자금융감독규정) 제8조(인력, 조직 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 2. 외부주문등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것 - 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 9. 정보관리의 취약점을 최소화하고 보안유지를 위한 내부통제방안을 수립·운용하고, 통제는 제8조제1항제2호의 조직에서 수행 <개정 2015. 2. 3.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-260	10.2 외부주문 시 보호대책	외부주문 시 정보처리시스템 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치·운영 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 1. 외부주문등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치·운영 <개정 2015. 2. 3.>
FISM-261	10.2 외부주문 시 보호대책	외부주문 시 금융기관과 이용자간 암호화정보 해독 및 원장 등 중요 데이터 변경 금지 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 2. 금융회사와 이용자 간 암호화정보 해독 및 원장 등 중요 데이터 변경 금지 <개정 2013. 12. 3.>
FISM-262	10.2 외부주문 시 보호대책	외부주문 시 계좌번호, 비밀번호 등 이용자 금융정보 보관 및 유출 금지 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 3. 계좌번호, 비밀번호 등 이용자 금융정보 무단보관 및 유출 금지
FISM-263	10.2 외부주문 시 보호대책	외부주문 시 접근매체 위/변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 4. 접근매체 위·변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립
FISM-264	10.2 외부주문 시 보호대책	외부주문 시 금융기관과 전자금융보조업자간의 접속은 전용회선 사용 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 5. 금융회사와 전자금융보조업자 간의 접속은 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다)을 사용 <개정 2013. 12. 3., 2016. 10. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-265	10.2 외부주문 시 보호대책	외부주문 시 정보처리시스템 장애 등 서비스 중단에 대비한 비상대책 수립 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 6. 정보처리시스템 장애 등 서비스 중단에 대비한 비상대책 수립
FISM-266	10.2 외부주문 시 보호대책	외부주문 시 중요전산자료의 백업자료 보존 및 백업설비 확보 등 백업대책 수립 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 8. 업무지속성을 위한 중요 전산자료의 백업(backup)자료 보존 및 백업설비 확보 등 백업대책 수립
FISM-267	10.3 외부주문 등에 대한 기준	외부주문 사항에 대해 연1회 이상 재무건전성 평가 및 주요 경영활동 상시모니터링 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 10. 전자금융보조업자에 대한 재무건전성을 연1회 이상 평가하여 재무상태 악화에 따른 도산에 대비하고 전자금융보조업자의 주요 경영활동에 대해 상시 모니터링을 실시
FISM-268	10.3 외부주문 등에 대한 기준	외부주문 사항에 대해 연1회 이상 서비스 품질수준 평가 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 11. 전자금융보조업자가 제공하는 서비스의 품질수준을 연1회 이상 평가할 것
FISM-269	10.3 외부주문 등에 대한 기준	외부주문 사항에 대해 사전 동의 없는 재위탁, 계약업체 변경 금지(사전 동의시 계약서 계약서 기재사항 포함) 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 12. 전자금융보조업자가 사전 동의 없이 다시 외부주문등 계약을 체결하거나 계약업체를 변경하지 못하도록 하고, 사전 동의시 해당 계약서에 제7호의 사항을 기재하도록 통제 <개정 2016. 6. 30.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-270	10.3 외부주문 등에 대한 기준	외부주문 사항에 대해 위탁회사가 전자금융거래정보 보호와 관련된 전산장비·소프트웨어 개발, 운영, 유지관리 업무 재위탁 시, 금융거래 정보 변경사항에 대해 위탁회사 또는 원수탁업자가 이를 관리, 통제할 수 있는 절차 마련 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ④ 법 제40조제6항 단서에서 "금융위원회가 인정하는 경우"란 전자금융거래정보의 보호와 관련된 전산장비·소프트웨어에 대한 개발·운영 및 유지관리 업무를 재위탁하는 경우로서 다음 각 호의 사항을 준수하는 경우를 말한다. 1. 재수탁업자가 재위탁된 업무를 처리함에 있어 금융거래 정보의 변경이 필요한 경우에는 위탁회사 또는 원수탁업자의 개별적 지시에 따라야 하며, 위탁회사 또는 원수탁업자는 변경된 정보가 지시 내용에 부합하는지 여부를 확인하여야 함
FISM-271	10.3 외부주문 등에 대한 기준	외부주문 사항에 대해 위탁된 금융거래정보가 위탁회사의 전산실 내 관리 및 보관 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ④ 법 제40조제6항 단서에서 "금융위원회가 인정하는 경우"란 전자금융거래정보의 보호와 관련된 전산장비·소프트웨어에 대한 개발·운영 및 유지관리 업무를 재위탁하는 경우로서 다음 각 호의 사항을 준수하는 경우를 말한다. 2. 위탁업무와 관련된 이용자의 금융거래정보는 위탁회사의 전산실 내에 두어야 함. 다만, 재수탁업자가 이용자의 이용자 정보를 어떠한 경우에도 알지 못하도록 위탁회사 또는 원수탁업자가 금융거래정보를 처리하여 제공한 경우에는 위탁회사의 관리·통제 하에 재수탁회사 등 제3의 장소로 이전 가능함
FISM-272	10.3 외부주문 등에 대한 기준	외부주문 시 업무 수행인력에 대한 사전 신원조회 실시, 대표자 신원보증서 징구, 인력변경시 인수인계에 관한사항 등 업무수행인력에 관한 관리방안 수립 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 13. 업무수행인력에 대하여 사전 신원조회 실시(이 경우 신원보증보험 증권 징구로 갈음할 수 있다) 또는 대표자의 신원보증서 징구, 인력변경시 인수인계에 관한 사항 등을 포함한 업무수행인력 관리방안 수립 <개정 2018. 12. 21.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-273	10.3 외부주문 등에 대한 기준	외부주문 시 자체 보안성 검토 및 정기 보안점검 실시 여부	5	○ (전자금융감독규정) 제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다. <개정 2013. 12. 3.> 14. 외부주문등은 자체 보안성검토 및 정기(금융감독원장이 정하는 중요 점검사항에 대해서는 매일) 보안점검 실시 <개정 2015. 2. 3.> ○ (전자금융감독규정시행세칙) 제9조의2(외부주문등에 대한 기준) ② 규정 제60조제1항제14호에 따라 감독원장이 정하는 중요 점검사항은 별표 5-3과 같다. <신설 2015. 4. 8.>
FISM-274	11.1 정보기술부문 및 전자금융 사고보고	전자금융 사고 관련 사고의 유형 분류, 영향도 등이 포함된 절차를 마련, 운영 여부	5	○ (전자금융감독규정) 제37조의5(정보기술부문 및 전자금융 사고보고) ① 금융회사 및 전자금융업자는 정보기술부문 및 전자금융과 관련된 사고에 관하여 다음 각 호를 준수하여야 한다. 1. 사고의 유형 분류, 처리단계, 조치방법, 영향도 및 심각도 평가 방법 등이 포함된 절차를 마련·운영. ○ (전자금융감독규정시행세칙) 제7조의4(정보기술부문 사고보고) ① 규정 제37조의5제4항에 따라 감독원장이 정하는 사고보고 대상은 다음 각 호와 같다. <신설 2025. 2. 3.> 1. 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음 각 목 중 하나에 해당하는 사고가 발생한 경우 가. 전자금융업무 지연·중단 시간이 30분 이상인 경우 나. 전자금융업무 지연·중단 시간이 10분 이상이고 해당 전자금융서비스 가입자가 1만명 이상인 경우 2. 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우 3. 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융회사 또는 전자금융업자에게 통지한 경우 4. 법 제9조제1항의 규정에서 정하는 사고가 발생한 경우

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				② 제1항에도 불구하고 다음 각 호에 해당하는 경우는 사고보고 대상에서 제외한다. 〈신설 2025. 2. 3.〉 1. 제1항제1호에 해당하는 사고 중 영업점 내 장애의 경우 1개 영업점에 국한된 전자금융 업무 중단·지연 2. 제1항제1호에 해당하는 사고 중 이용자에게 단순 정보 제공을 위한 공개용 웹사이트 등의 장애 또는 금융상품 및 서비스와 무관한 장애 3. 법 제9조제1항제1호 또는 제3호의 사고가 발생하였으나 사고금액이 100만원 미만인 경우 ③ 금융회사 및 전자금융업자는 제1항의 사고가 발생한 경우 별지 제2호서식 별첨1에 따라 지체 없이 보고하여야 하며, 정당한 사유없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다. 다만, 법 제9조제1항제1호의 사고 중 사고금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 별지 제2호서식 별첨2에 따라 일괄 보고할 수 있다. 〈개정 2014. 3. 31., 2017. 9. 5., 2025. 2. 3.〉 〈제1항에서 이동 2025. 2. 3.〉 ④ 제3항에 따른 사고보고는 최초보고, 중간보고 및 종결보고로 구분한다. 〈제2항에서 이동 2025. 2. 3.〉 1. 최초보고 : 사고를 인지 또는 발견한 때로부터 24시간 이내에 전자금융사고대응시스템(Electronic Financial Accident Response System : EFARS)으로 보고한다. 단, 전산장애, 금융정보교환망 미연결 등 부득이한 경우에는 서면, 팩시밀리 또는 유선으로 보고할 수 있으며, 이 경우에 전자금융사고대응시스템(EFARS)으로 보고가능한 즉시 전자금융사고대응시스템(EFARS)으로 보고한다.〈개정 2015. 4. 8., 2025. 2. 3.〉 2. 중간보고 : 제1호의 최초보고 후 사고내용을 보완할 필요가 있는 경우에는 즉시 중간보고를 하여야 하며, 제3호의 조치완료 시까지 2월 이상 소요될 경우에는 인지·발견일로부터 2월 이내 및 종결 시까지 매 6월마다 제1호의 방법에 따라 보고한다. 다만, 최초보고 후 조치완료 시까지 2월 미만이 소요될 경우에는 중간보고를 생략할 수 있다.〈개정 2017. 9. 5.〉 3. 종결보고 : 사고발생 원인 파악 및 조치, 재발방지 대책 마련 등이 완료(사고금액에 대한 배상책임이 있는 경우에는 배상조치까지 포함)되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고 시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다. 〈개정 2017. 9. 5., 2025. 2. 3.〉

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				⑤ 감독원장은 금융회사 및 전자금융업자 정보기술부문 사고보고 등을 전담할 비상연락 담당자를 회사별로 지정할 수 있다. <개정 2014. 3. 31., 2015. 4. 8.> <제3항에서 이동 2025. 2. 3.> ⑥ 금융회사 및 전자금융업자는 비상연락 담당자가 제5항에 따라 지정되거나 변경된 경우에는 제4항제1호에서 정한 보고방법에 따라 감독원장에게 즉시 보고하여야 한다. <개정 2014. 3. 31., 2015. 4. 8.> <제4항에서 이동 2025. 2. 3.> ⑦ 감독원장은 제4항에 따라 보고 받은 내용이 제1항제3호의 사고 발생인 경우에는 규정 제37조의6제1항 각 호에 따른 침해사고대응기관에도 알려야 한다. <신설 2025. 2. 3.> [중전의 제12조에서 이동]
				○ (전자금융감독규정) 제37조의5(정보기술부문 및 전자금융 사고보고) ① 금융회사 및 전자금융업자는 정보기술부문 및 전자금융과 관련된 사고에 관하여 다음 각 호를 준수하여야 한다. 2. 금융감독원장이 정하는 사고가 발생한 경우에는 지체없이 금융감독원장에게 보고 ② 금융회사 및 전자금융업자는 제1항제2호에 따른 사고보고를 고의로 지연하거나 숨긴 자에 대하여 소정절차에 따라 징계 등 필요한 조치를 취하여야 한다.
FISM-275	11.1 정보기술부문 및 전자금융 사고보고	전자금융 사고 발생 시 지체없이 금융감독원장 보고 여부	5	○ (전자금융감독규정시행세칙) 제7조의4(정보기술부문 사고보고) ① 규정 제37조의5제4항에 따라 감독원장이 정하는 사고보고 대상은 다음 각 호와 같다. <신설 2025. 2. 3.> 1. 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음 각 목 중 하나에 해당하는 사고가 발생한 경우 가. 전자금융업무 지연·중단 시간이 30분 이상인 경우 나. 전자금융업무 지연·중단 시간이 10분 이상이고 해당 전자금융서비스 가입자가 1만명 이상인 경우 2. 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우 3. 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융회사 또는 전자금융업자에게 통지한 경우 4. 법 제9조제1항의 규정에서 정하는 사고가 발생한 경우

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				② 제1항에도 불구하고 다음 각 호에 해당하는 경우는 사고보고 대상에서 제외한다. 〈신설 2025. 2. 3.〉 1. 제1항제1호에 해당하는 사고 중 영업점 내 장애의 경우 1개 영업점에 국한된 전자금융 업무 중단·지연 2. 제1항제1호에 해당하는 사고 중 이용자에게 단순 정보 제공을 위한 공개용 웹사이트 등의 장애 또는 금융상품 및 서비스와 무관한 장애 3. 법 제9조제1항제1호 또는 제3호의 사고가 발생하였으나 사고금액이 100만원 미만인 경우 ③ 금융회사 및 전자금융업자는 제1항의 사고가 발생한 경우 별지 제2호서식 별첨1에 따라 지체 없이 보고하여야 하며, 정당한 사유없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다. 다만, 법 제9조제1항제1호의 사고 중 사고금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 별지 제2호서식 별첨2에 따라 일괄 보고할 수 있다. 〈개정 2014. 3. 31., 2017. 9. 5., 2025. 2. 3.〉 〈제1항에서 이동 2025. 2. 3.〉 ④ 제3항에 따른 사고보고는 최초보고, 중간보고 및 종결보고로 구분한다. 〈제2항에서 이동 2025. 2. 3.〉 1. 최초보고 : 사고를 인지 또는 발견한 때로부터 24시간 이내에 전자금융사고대응시스템(Electronic Financial Accident Response System : EFARS)으로 보고한다. 단, 전산장애, 금융정보교환망 미연결 등 부득이한 경우에는 서면, 팩시밀리 또는 유선으로 보고할 수 있으며, 이 경우에 전자금융사고대응시스템(EFARS)으로 보고가능한 즉시 전자금융사고대응시스템(EFARS)으로 보고한다.〈개정 2015. 4. 8., 2025. 2. 3.〉 2. 중간보고 : 제1호의 최초보고 후 사고내용을 보완할 필요가 있는 경우에는 즉시 중간보고를 하여야 하며, 제3호의 조치완료 시까지 2월 이상 소요될 경우에는 인지·발견일로부터 2월 이내 및 종결 시까지 매 6월마다 제1호의 방법에 따라 보고한다. 다만, 최초보고 후 조치완료 시까지 2월 미만이 소요될 경우에는 중간보고를 생략할 수 있다.〈개정 2017. 9. 5.〉 3. 종결보고 : 사고발생 원인 파악 및 조치, 재발방지 대책 마련 등이 완료(사고금액에 대한 배상책임이 있는 경우에는 배상조치까지 포함)되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고 시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다. 〈개정 2017. 9. 5., 2025. 2. 3.〉

평가항목ID	통제구분	평가항목	위험도	
				[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.) ⑤ 감독원장은 금융회사 및 전자금융업자 정보기술부문의 사고보고 등을 전달할 비상연락 담당자를 회사별로 지정할 수 있다.〈개정 2014. 3. 31., 2015. 4. 8.〉〈제3항에서 이동 2025. 2. 3.〉 ⑥ 금융회사 및 전자금융업자는 비상연락 담당자가 제5항에 따라 지정되거나 변경된 경우에는 제4항제1호에서 정한 보고방법에 따라 감독원장에게 즉시 보고하여야 한다.〈개정 2014. 3. 31., 2015. 4. 8.〉〈제4항에서 이동 2025. 2. 3.〉 ⑦ 감독원장은 제4항에 따라 보고 받은 내용이 제1항제3호의 사고 발생인 경우에는 규정 제37조의6제1항 각 호에 따른 침해사고대응기관에도 알려야 한다.〈신설 2025. 2. 3.〉 [종전의 제12조에서 이동] ○ (전자금융감독규정) 제15조(해킹 등 방지대책) ④ 금융회사 또는 전자금융업자는 해킹 등 전자적 침해의 예방, 피해 최소화 및 신속한 복구를 위한 대책을 수립·운용하여야 한다.〈개정 2013. 12. 3., 2025. 2. 5.〉 ○ (전자금융감독규정) 제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준) ① 금융회사 또는 전자금융업자가 법 제9조제4항에 따라 전자금융사고 책임이행을 위한 보험 또는 공제에 가입하는 경우 보상한도는 전자금융거래 규모, 전자금융사고 발생 건수 등을 고려하여 다음 각 호에서 정하는 금액 이상으로 설정해야 한다.〈개정 2025. 2. 5.〉 1. 「금융위원회의 설치 등에 관한 법률」 제38조제1호(다만, 「은행법」에 의한 지방금융회사 및 같은 법 제58조에 의해 인가를 받은 외국금융회사의 국내지점은 제외한다) 및 제7호의 회사, 「전자금융거래법 시행령」 제2조제2호의 회사 : 20억원 〈개정 2013. 12. 3.〉 2. 「금융위원회의 설치 등에 관한 법률」 제38조제2호의 회사(명의개서대행회사는 제외한다. 이하 이 조에서 같다) 중 자산이 2조원 이상인 회사, 같은 법 제38조제8호의 회사, 「전자금융거래법」제2조제3호나목(신용카드업자에 한한다) 및 다목적 회사, 「전자금융거래법 시행령」 제2조제1호의 회사, 「은행법」에 따른 지방금융회사 및 같은 법 제58조에 의해 인가를 받은 외국금융회사의 국내지점 : 10억원 〈개정 2025. 2. 5.〉
FISM-281	11.2 침해사고 대응	해킹 등 전자적 침해행위로 인한 피해 발생시 즉시 대처할 수 있도록 적절한 대책 수립 및 운용 여부	5	
FISM-282	11.3 손해배상	전자금융사고 시 책임이행을 위한 보험 등 가입 여부	5	

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				3. 「금융위원회의 설치 등에 관한 법률」 제38조제2호의 회사 중 자산이 2조원 미만인 회사 : 5억원 <개정 2025. 2. 5.> 4. 제1호 부터 제3호 이외의 금융회사 : 2억원. 다만, 제1호 부터 제3호 이외의 금융회사 등이 관련 법령에 의해 당해 금융회사를 구성원으로 하는 금융회사를 통해 전자금융거래 관련 정보기술부문의 주요부분을 공동으로 이용하는 경우, 정보기술부문의 주요부분을 제공하는 금융회사가 공동 이용 금융회사 전체의 사고를 보장하는 내용으로 제2호의 금액 (시행령 제2조제5호의 금융회사는 제1호의 금액) 이상의 보험 또는 공제에 가입하면 공동 이용 금융회사는 본호의 보험 또는 공제에 가입한 것으로 본다. <개정 2025. 2. 5.> 5. 법 제28조제2항제1호의 전자금융업자 : 2억원 <개정 2025. 2. 5.> 6. 법 제28조제2항제2호의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 7. 법 제28조제2항제3호의 전자금융업자 : 2억원 <개정 2025. 2. 5.> 8. 법 제28조제2항제4호의 전자금융업자 중 제1호 또는 제2호에 속하는 금융회사가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자금융업자 : 10억원<종전의 제6호에서 이동, 2025. 2. 5.> 9. 법 제28조제2항제4호의 전자금융업자 : 2억원(제1호 또는 제2호에 속하는 금융회사가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자금융업자는 제외한다) <신설 2025. 2. 5.> 10. 시행령 제15조제3항제1호의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 11. 시행령 제15조제3항제2호의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 12. 법 제28조제1항의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 13. 제1호부터 제12호에 2개 이상 해당하는 회사는 각 호의 금액의 합계액으로 한다. 다만 제5호부터 제12호의 합계액이 15억원을 초과하는 경우에는 제5호부터 제12호의 합계액을 15억원으로 한다. <신설 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-283	11.3 손해배상	전자금융사고시 보상한도설정의 적정성 여부	5	○ (전자금융감독규정) 제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준) ① 금융회사 또는 전자금융업자가 법 제9조제4항에 따라 전자금융사고 책임이행을 위한 보험 또는 공제에 가입하는 경우 보장한도는 전자금융거래 규모, 전자금융사고 발생 건수 등을 고려하여 다음 각 호에서 정하는 금액 이상으로 설정해야 한다. <개정 2025. 2. 5.> 1. 「금융위원회의 설치 등에 관한 법률」 제38조제1호(다만, 「은행법」에 의한 지방금융회사 및 같은 법 제58조에 의해 인가를 받은 외국금융회사의 국내지점은 제외한다) 및 제7호의 회사, 「전자금융거래법 시행령」 제2조제2호의 회사 : 20억원 <개정 2013. 12. 3.> 2. 「금융위원회의 설치 등에 관한 법률」 제38조제2호의 회사(명의개사대행회사는 제외한다. 이하 이 조에서 같다) 중 자산이 2조원 이상인 회사, 같은 법 제38조제8호의 회사, 「전자금융거래법」 제2조제3호나목(신용카드업자에 한한다) 및 다목적 회사, 「전자금융거래법 시행령」 제2조제1호의 회사, 「은행법」에 따른 지방금융회사 및 같은 법 제58조에 의해 인가를 받은 외국금융회사의 국내지점 : 10억원 <개정 2025. 2. 5.> 3. 「금융위원회의 설치 등에 관한 법률」 제38조제2호의 회사 중 자산이 2조원 미만인 회사 : 5억원 <개정 2025. 2. 5.> 4. 제1호 부터 제3호 이외의 금융회사 : 2억원. 다만, 제1호 부터 제3호 이외의 금융회사들이 관련 법령에 의해 당해 금융회사를 구성원으로 하는 금융회사를 통해 전자금융거래 관련 정보기술부문의 주요부분을 공동으로 이용하는 경우, 정보기술부문의 주요부분을 제공하는 금융회사가 공동 이용 금융회사 전체의 사고를 보장하는 내용으로 제2호의 금액(시행령 제2조제5호의 금융회사는 제1호의 금액) 이상의 보험 또는 공제에 가입하면 공동 이용 금융회사는 본회의 보험 또는 공제에 가입한 것으로 본다. <개정 2025. 2. 5.> 5. 법 제28조제2항제1호의 전자금융업자 : 2억원 <개정 2025. 2. 5.> 6. 법 제28조제2항제2호의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 7. 법 제28조제2항제3호의 전자금융업자 : 2억원 <개정 2025. 2. 5.> 8. 법 제28조제2항제4호의 전자금융업자 중 제1호 또는 제2호에 속하는 금융회사가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자금융업자 : 10억원<중전의 제6호에서 이동, 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				9. 법 제28조제2항제4호의 전자금융업자 : 2억원(제1호 또는 제2호에 속하는 금융회사 가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자금융업자는 제외한다) <신설 2025. 2. 5.> 10. 시행령 제15조제3항제1호의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 11. 시행령 제15조제3항제2호의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 12. 법 제28조제1항의 전자금융업자 : 2억원 <신설 2025. 2. 5.> 13. 제1호부터 제12호에 2개 이상 해당하는 회사는 각 호의 금액의 합계액으로 한다. 다만 제5호부터 제12호의 합계액이 15억원을 초과하는 경우에는 제5호부터 제12호의 합계액을 15억원으로 한다. <신설 2025. 2. 5.>
FISM-284	11.3 손해배상	전자금융사고 시 책임이행을 위한 준비금 관리 및 지급에 관한 내부절차 수립 및 운영 여부	5	○ (전자금융감독규정) 제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준) ② 금융회사 또는 전자금융업자가 전자금융사고 책임이행을 위한 준비금을 적립하는 경우에는 전자금융거래 규모, 전자금융사고 발생 건수 등을 고려하여 제1항 각 호에서 정한 금액 이상의 금액을 보유하고 책임이행이 신속히 이루어질 수 있도록 준비금 관리 및 지급에 관한 내부 절차를 수립하여 운영하여야 한다. <개정 2013. 12. 3., 2016. 10. 5., 2025. 2. 5.>
FISM-285	8.3 위기대응 행동매뉴얼 수립	위기대응 행동매뉴얼 또는 비상대책에 따라 연 1회의 비상대응훈련을 실시하고 그 결과를 금융위원회에 보고하는지 여부 확인	5	○ (전자금융감독규정) 제24조(비상대응훈련 실시) ① 금융회사 또는 전자금융업자는 제23조제4항에 따른 행동매뉴얼 또는 같은 조 제5항에 따른 비상대책에 따라 연 1회의 비상대응훈련을 실시하고 그 결과를 금융위원회에 보고하여야 한다. 이때, 제23조제10항에 따른 재해복구전환훈련을 포함하여 실시할 수 있다. <개정 2013. 12. 3., 2016. 6. 30.>
FISM-286	11.1 정보기술부문 및 전자금융 사고보고	침해사고 인지 시 24시간 이내 금융위원회 보고 여부	5	○ (전자금융감독규정) 제37조의4(침해사고 통지의 방법) 금융회사 및 전자금융업자는 법 제21조의5에 따른 침해사고가 발생한 사실을 안 때에는 지체 없이 사고 내용, 사고에 따른 영향 등을 <별지 7호 서식>에 기재하여 금융위원회에 보고하여야 하며, 정당한 사유 없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다. [본조신설 2025. 2. 5.]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				○ (전자금융감독규정시행세칙) 제12조(정보기술부문 사고보고) ① 금융회사 및 전자금융업자는 규정 제73조에 따른 정보기술부문 및 전자금융 사고가 발생한 경우 별지 제2호서식 별첨1에 따라 즉시 보고하여야 한다. 다만, 규정 제73조제1항제4호의 사고 중 사고금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 별지 제2호서식 별첨2에 따라 일괄 보고할 수 있다. <개정 2014. 3. 31., 2017. 9. 5.> ② 제1항에 따른 사고보고는 최초보고, 중간보고 및 종결보고로 구분한다. 1. 최초보고 : 사고를 인지 또는 발견한 즉시 감독원의 전자금융사고 대응시스템 (Electronic Financial Accident Response System : EFARS), 서면, 팩시밀리 또는 전화로 보고하되, 전화로 보고한 경우에는 즉시 전자금융사고 대응시스템, 서면 또는 팩시밀리로 보고한다. <개정 2015. 4. 8.> 2. 중간보고 : 제1호의 즉시보고 후 사고내용 보완할 필요가 있는 경우에는 즉시 중간 보고를 하여야 하며, 제3호의 조치완료 시까지 2월 이상 소요될 경우에는 인지·발견일로 부터 2월 이내 및 종결 시까지 매 6월마다 제1호의 방법에 따라 보고한다. 다만, 즉시보고 후 조치완료 시까지 2월 미만이 소요될 경우에는 중간보고를 생략할 수 있다. <개정 2017. 9. 5.> 3. 종결보고 : 사고금액에 대한 배상조치가 완료되거나 사고조치 등이 완료되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고 시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다. <개정 2017. 9. 5.> ③ 감독원장은 금융회사 및 전자금융업자 정보기술부문의 사고보고 등을 전담할 비상연락 담당자를 회사별로 지정할 수 있다. <개정 2014. 3. 31., 2015. 4. 8.> ④ 금융회사 및 전자금융업자는 비상연락 담당자가 제3항에 따라 지정되거나 변경된 경우에는 제2항제1호에서 정한 보고방법에 따라 감독원장에게 즉시 보고하여야 한다. <개정 2014. 3. 31., 2015. 4. 8.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-287	5.4 취약점 분석·평가	오픈뱅킹 운영기관에서 정한 기준에 따라 오픈뱅킹 서비스 보안 점검 실시 및 이행점검 실시 여부	5	○ (전자금융감독규정) 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) ① 전자금융기반시설의 취약점 분석·평가는 총자산이 2조원 이상이고, 상시 종업원 수(「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 기준으로 한다. 이하 같다) 300명 이상인 금융회사 또는 전자금융업자이거나 「수산업협동조합법」, 「산림조합법」, 「신용협동조합법」, 「상호저축은행법」 및 「새마을금고법」에 따른 중앙회의 경우 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시하여야 한다. ⑤ 금융회사 또는 전자금융업자는 취약점 분석·평가에 따라 이행계획을 수립·시행하여야 하며 다음 각 호의 사항을 준수하여야 한다.
FISM-288	5.2 전산자료 보호대책	전자금융거래기록 생성 및 보존·파기 관리 여부	5	○ (전자금융거래법 시행령) 제12조(전자금융거래기록의 보존기간·보존방법 및 파기 절차·방법 등) ① 법 제22조제1항 및 제3항에 따른 전자금융거래기록의 종류별 보존기간은 다음 각 호와 같다.〈개정 2008. 2. 29., 2015. 4. 14.〉 1. 다음 각 목의 전자금융거래기록은 5년간 보존하여야 한다. 가. 제7조제4항제1호 내지 제5호에 관한 사항 나. 해당 전자금융거래와 관련한 전자적 장치의 접속기록 다. 전자금융거래의 신청 및 조건의 변경에 관한 사항 라. 건당 거래금액이 1만원을 초과하는 전자금융거래에 관한 기록 2. 다음 각 목의 전자금융거래기록은 1년간 보존하여야 한다. 가. 건당 거래금액이 1만원 이하인 전자금융거래에 관한 기록 나. 전자금융수단의 이용과 관련된 거래승인에 관한 기록 다. 그 밖에 금융위원회가 정하여 고시하는 전자금융거래기록 ② 금융회사 또는 전자금융업자와 동일한 전자금융거래기록을 생성·보존하는 전자금융 보조업자가 제1항제1호 각 목의 전자금융거래기록을 보존하여야 하는 기간은 같은 호에도 불구하고 3년으로 한다.〈개정 2013. 11. 22., 2015. 4. 14.〉 ③ 금융회사등은 제1항 및 제2항의 전자금융거래기록을 서면, 마이크로필름, 디스크 또는 자기테이프, 그 밖의 전산정보처리조직을 이용한 방법으로 보존하여야 한다.〈개정 2013. 11. 22., 2015. 4. 14., 2020. 11. 17.〉

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				④ 금융회사들은 제3항에 따라 전자금융거래기록을 디스크, 자기테이프, 그 밖의 전산정보처리조직을 이용하여 보존하는 경우에는 「전자문서 및 전자거래 기본법」 제5조제1항 각 호의 요건을 모두 갖추어야 한다.〈개정 2012. 8. 31., 2013. 11. 22., 2015. 4. 14.〉 ⑤ 금융회사들이 법 제22조제2항에 따라 전자금융거래기록을 파기할 때 그 절차와 방법에 관하여는 「개인정보 보호법 시행령」 제16조를 준용한다.〈신설 2015. 4. 14.〉 ⑥ 법 제22조제3항에 따른 상거래관계가 종료된 날의 기준은 금융회사등과 거래상대방 간의 상거래관계가 관계 법령, 약관 또는 합의 등에 따라 계약기간의 만료, 해지권·해제권·취소권의 행사, 소멸시효의 완성, 변제 등으로 인한 채권의 소멸, 그 밖의 사유로 종료된 날을 그 기준으로 한다.〈신설 2015. 4. 14.〉 [제목개정 2015. 4. 14.]
FISM-289	9.1 전자금융거래 시 준수사항	클라우드컴퓨팅서비스 이용계약 신규 체결 시 금융감독원 보고 여부	5	○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ④ 금융회사 또는 전자금융업자는 다음 각 호의 어느 하나에 해당하는 사유가 발생한 날로부터 3개월 이내에 금융감독원장에게 보고하여야 하고, 관련 서류를 최신상태로 유지하여야 한다.〈신설 2018. 12. 21., 개정 2022. 11. 23., 2025. 2. 5.〉 1. 클라우드컴퓨팅서비스 이용계약을 신규로 체결하거나, 기존 클라우드컴퓨팅서비스 이용계약을 통해 신규 업무를 처리하는 경우〈신설 2022. 11. 23., 개정 2025. 2. 5.〉 ○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다.〈개정 2022. 12. 29., 2025. 2. 3.〉 ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용약관서 [종전의 제2조의3에서 이동]
				○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ④ 금융회사 또는 전자금융업자는 다음 각 호의 어느 하나에 해당하는 사유가 발생한 날로부터 3개월 이내에 금융감독원장에게 보고하여야 하고, 관련 서류를 최신상태로 유지하여야 한다.〈신설 2018. 12. 21., 개정 2022. 11. 23., 2025. 2. 5.〉 2. 클라우드컴퓨팅서비스 제공자의 합병, 분할, 계약상 지위의 양도, 재위탁 등 중대한 변경사항이 발생한 경우 〈개정 2022. 11. 23.〉
FISM-290	10.1 외부주문 계약 준수사항	클라우드컴퓨팅서비스 제공자 변경(합병, 재위탁 등) 시 금융감독원 보고 여부	5	○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다.〈개정 2022. 12. 29., 2025. 2. 3.〉 ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과 4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용약관서 [종전의 제2조의3에서 이동]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-291	8.3 위기대응 행동매뉴얼 수립	클라우드컴퓨팅서비스 제공자의 서비스 품질 미이행 시 대응 계획 보고 여부	5	○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ④ 금융회사 또는 전자금융업자는 다음 각 호의 어느 하나에 해당하는 사유가 발생한 날로부터 3개월 이내에 금융감독원장에게 보고하여야 하고, 관련 서류를 최신상태로 유지하여야 한다.〈신설 2018. 12. 21., 개정 2022. 11. 23., 2025. 2. 5.〉 3. 클라우드컴퓨팅서비스 제공자가 서비스품질의 유지, 안전성 확보 등과 관련한 중요 계약사항을 이행하지 아니한 경우 〈개정 2022. 11. 23.〉 ○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다.〈개정 2022. 12. 29., 2025. 2. 3.〉 ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 안전성 및 안전성 등에 대한 평가 결과 4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용계약서 [중전의 제2조의3에서 이동]
FISM-292	1.1 정보보호 계획	클라우드컴퓨팅서비스 이용 업무의 중요도 평가 기준 수립 및 시행 여부	5	○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ① 금융회사 또는 전자금융업자는 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제2조제3호에 따른 클라우드컴퓨팅서비스를 이용하고자 하는 경우 다음 각 호의 절차를 수행하여야 한다. 〈개정 2018. 12. 21.〉

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
				1. 다음 각 목의 기준에 따른 이용업무의 중요도 평가 <개정 2022. 11. 23.> 가. 규모, 복잡성 등 클라우드컴퓨팅서비스를 통해 처리되는 업무의 특성 <신설 2022. 11. 23.> 나. 클라우드컴퓨팅서비스 제공자로부터 제공받는 서비스가 중단될 경우 미치는 영향 <신설 2022. 11. 23.> 다. 전자적 침해행위 발생 시 고객에게 미치는 영향 <신설 2022. 11. 23.> 라. 여러 업무를 같은 클라우드컴퓨팅서비스 제공자에게 위탁하는 경우 해당 클라우드컴퓨팅서비스 제공자에 대한 종속 위험 <신설 2022. 11. 23.> 마. 클라우드컴퓨팅서비스 이용에 대한 금융회사 또는 전자금융업자의 내부통제 및 범주 준수 역량 <신설 2022. 11. 23.> 바. 그 밖에 금융감독원장이 정하여 고시하는 사항 <신설 2022. 11. 23.> ○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다.<개정 2022. 12. 29., 2025. 2. 3.> ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과 4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용약관서 [종전의 제2조의3에서 이동]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-293	7.6 자체 보안성심의	클라우드컴퓨팅서비스 제공자의 건전성 및 안전성에 대한 평가 실시 여부	5	○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ① 금융회사 또는 전자금융업자는 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제2조제3호에 따른 클라우드컴퓨팅서비스를 이용하고자 하는 경우 다음 각 호의 절차를 수행하여야 한다. <개정 2018. 12. 21.> 2. 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가(단, 제1호의 평가를 통해 비중요업무로 분류된 업무에 대해서는 <별표 2의2>의 평가항목 중 필수항목만 평가할 수 있다.) <개정 2022. 11. 23.> ○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다.<개정 2022. 12. 29., 2025. 2. 3.> ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과 4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용약관서 [총전의 제2조의3에서 이동]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-294	8.3 위기대응 행동매뉴얼 수립	클라우드컴퓨팅서비스 업무 연속성 계획 수립 및 안전성 확보 조치 수립 여부	5	○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ① 금융회사 또는 전자금융업자는 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제2조제3호에 따른 클라우드컴퓨팅서비스를 이용하고자 하는 경우 다음 각 호의 절차를 수행하여야 한다. <개정 2018. 12. 21.> 3. 클라우드컴퓨팅서비스 이용과 관련한 업무 연속성 계획 및 안전성 확보조치의 수립·시행(단, 제1호의 평가를 통해 비중요업무로 분류된 업무에 대해서는 <별표 2의3> 및 <별표 2의4>의 필수 사항만 수립·시행할 수 있다.) <개정 2022. 11. 23.> ○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다.<개정 2022. 12. 29., 2025. 2. 3.> ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과 4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용계약서 [총전의 제2조의3에서 이동]

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-295	2.3 정보보호최고 책임자 지정 및 업무	클라우드컴퓨팅서비스 정보보호위원회 심의 및 의결을 통해 평가 결과 승인 여부	5	○ (전자금융감독규정) 제14조의2(클라우드컴퓨팅서비스 이용절차 등) ② 금융회사 또는 전자금융업자는 제1항 각 호에 따른 평가결과, 업무연속성 계획 및 안전성 확보조치에 대하여 제8조의2에 따른 정보보호위원회의 심의·의결을 거쳐야 한다. <개정 2018. 12. 21., 2022. 11. 23.> ○ (전자금융감독규정시행세칙) 제2조의4(클라우드컴퓨팅서비스의 보고) ①규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호서식에 따른다. <개정 2022. 12. 29., 2025. 2. 3.> ②규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다. 1. 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 각 호에 관한 서류 2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과 3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과 4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항 5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과 6. 규정 별표 2의5의 계약서 주요 기제사항을 포함한 클라우드컴퓨팅서비스 이용약관서 [중전의 제2조의3에서 이동]
	8.1 업무 지속성 확보방안	업무지속성 확보방안에 비상지원인력의 확보 및 운영 포함 여부	5	○ (전자금융감독규정) 제23조(비상대책 등의 수립·운영) ① 금융회사 또는 전자금융업자는 장애·재해·파업·테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립·준수하여야 한다. <개정 2013. 12. 3., 2016. 10. 5.> 8. 비상지원인력의 확보 및 운영 <신설 2025. 2. 5.>

평가항목ID	통제구분	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
FISM-298	6.4 이용자 비밀번호 관리	이용자 비밀번호 변경 시 본인확인 절차 수행 여부	5	○ (전자금융감독규정) 제34조의3(이용자 비밀번호 관리) ② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다. 4. 이용자 비밀번호 변경 시 본인확인 절차를 수행할 것 [본조 신설 2025. 2. .5.]
FISM-299	1.1 정보보호 계획	정보기술 및 정보보호 분야별 전문 인력과 충분한 예산 확보 여부	5	○ (전자금융감독규정) 제8조(인력, 조직, 교육 및 예산) ② 금융회사 또는 전자금융업자는 정보기술 및 정보보호 분야별 전문성을 갖춘 인력과 충분한 예산을 확보해야 한다. <개정 2013. 12. 3., 2025. 2. 5.>

가상화 시스템 관리체계

❖ 평가기준

평가항목ID	통제구분	평가항목	위험도	상세설명
PRCI-001	5.3 정보처리시스템 보호대책	정기적인 가상화 인스턴스(가상머신, 컨테이너) 식별 여부	5	가상화 인스턴스(가상머신, 컨테이너)가 식별이 되지 않을 경우, 시스템 침입, 데이터 유출 등을 목적으로 생성한 불필요 인스턴스가 존재할 수 있으므로, 정기적인 가상화 인스턴스(가상머신, 컨테이너) 식별 여부를 점검 * 클라우드는 중앙집중화 되며, 스케일 업/아웃이 빈번하게 발생될 수 있으므로 자동화 방식으로 식별하는 것을 권고
PRCI-002	5.3 정보처리시스템 보호대책	가상화 인스턴스(가상머신, 컨테이너)의 생성, 변경, 회수 등에 관한 승인절차 수립 및 이행	3	인가되지 않은 가상화 인스턴스(가상머신, 컨테이너) 생성, 변경, 회수 등을 방지하기 위한, 승인 절차 수립 및 이행 여부를 점검
PRCI-003	5.3 정보처리시스템 보호대책	가상화 인스턴스(가상머신, 컨테이너) 변경에 대한 기록 관리	3	가상화 인스턴스(가상머신, 컨테이너)를 통해 발생될 수 있는 침해사고에 대한 사후 추적성 확보를 위해 가상 인스턴스의 변경(생성, 이동, 삭제, 복사 등)에 관한 기록 관리 여부를 점검
PRCI-004	5.3 정보처리시스템 보호대책	가상화 인스턴스(가상머신, 컨테이너)의 보안 등급에 따른 책임자 지정	5	가상화 인스턴스(가상머신, 컨테이너)의 용도, 취급 정보, 법적 요구사항 등을 고려한 보안 등급(중요도)을 측정하고, 그에 따른 책임자 지정 여부를 점검
PRCI-005	5.3 정보처리시스템 보호대책	가상머신 구축시 표준 이미지 사용	3	개별 가상머신에 대한 보안수준을 일정하게 적용하기 위하여, 사전에 보안 취약점을 제거한 표준 이미지(Golden Image)*를 생성, 배포 여부를 점검 * 표준 이미지(Golden Image) : 클라우드 운영자가 정의한 보안성이 적용된 상태의 이미지
PRCI-006	5.4 취약점 분석·평가	주기적인 표준 이미지 보안 검증 수행	3	주기적으로 표준 이미지에 대한 보안성 점검을 수행하지 않을 경우 신규 취약점에 의해 표준 이미지의 보안성이 약화될 수 있으므로, 표준 이미지에 대한 주기적인 보안 점검 수행 여부

평가항목ID	통제구분	평가항목	위험도	상세설명
PRCI-007	5.4 취약점 분석·평가	컨테이너 구성 파일에 대한 사전 보안 검증 수행	3	○ 컨테이너 생성을 위해 사용되는 컨테이너 구성 파일(쿠버네티스 매니페스트 파일, 도커파일 등)의 보안 수준 향상을 위한, 사전 보안점검 수행 여부를 점검
PRCI-008	5.3 정보처리시스템 보호대책	시스템 가동기록 보관	5	○ 클라우드 시스템에 대한 가동기록* 보관(1년이상) 여부를 점검 * 클라우드 시스템에 접속한 일시, 접속자 및 접근을 확인할 수 있는 접근 기록 (시스템 로그, 콘솔로그 등)
PRCI-009	5.3 정보처리시스템 보호대책	시스템에 대한 성능 및 용량 모니터링	5	○ 가상 시스템, 가상자원에 대한 성능 및 용량을 자동화된 방식으로 모니터링하고, 주기적으로 시스템 사용 현황 및 추이 분석 등 수행 여부를 점검
PRCI-010	5.3 정보처리시스템 보호대책	시스템 운영 매뉴얼 작성	5	○ 클라우드 시스템에 대한 구동, 조작방법, 명령어 사용법, 운용순서, 장애조치 및 연락처 등 시스템 운영매뉴얼 작성(및 주기적 갱신) 여부를 점검
PRCI-011	5.3 정보처리시스템 보호대책	장애 발생시 장애상황기록부 작성	5	○ 클라우드 시스템에 대한 장애 발생시 장애상황기록부에 장애일시, 장애내용, 조치 사항 등을 작성 및 보관 여부를 점검
PRCI-012	5.3 정보처리시스템 보호대책	시스템 정기 백업 및 보관 여부	5	○ 가상화 인스턴스(가상머신, 컨테이너), 가상 네트워크 접근통제 정책을 정기 백업하고, 안전지역 소산 및 백업자료 1년 이상 기록/관리 여부를 점검
PRCI-013	8.1 업무지속성 확보 방안	재해 또는 장애발생 시 복구 위한 별도 구간 확보	5	○ 재해, 장애 등의 비상시를 대비해 재해 복구 센터 또는 백업센터 등의 별도 네트워크 구간 마련 여부
PRCI-014	5.1 단말기 보호대책	시스템 접근 시 강화된 보호대책이 적용된 단말기를 통한 접속	5	○ 클라우드 시스템에 접근 시, 비인가자에 의한 시스템 무단 접근을 방지하기 위해 강화된 보호대책*이 적용된 단말기를 통한 접근 여부 점검 * 외부 반출, 인터넷 접속, 그룹웨어 접속의 금지 등

평가항목ID	통제구분	평가항목	위험도	상세설명
PRCI-015	5.3 정보처리시스템 보호대책	가상네트워크 접근통제 정책에 대한 변경통제 절차 수립	5	가상네트워크의 접근통제 정책 승인 및 적용 시, 정책 등록, 변경, 삭제 내용에 대한 보관 여부
PRCI-016	5.3 정보처리시스템 보호대책	소프트웨어 및 하드웨어 지원 서비스가 종료(EoS)된 노후장비 교체	5	벤더의 소프트웨어 및 하드웨어의 지원이 종료된 경우 장비의 성능저하 및 장애, 신규 취약점 패치 등이 원활하지 않을 수 있으므로 지원이 종료(End of Service)된 노후장비 존재 여부를 점검
PRCI-017	5.3 정보처리시스템 보호대책	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	최신 보안패치 및 벤더 권고사항을 적용하지 않은 경우, 알려진 취약점에 노출될 수 있는 위험이 존재하므로 최신 보안 패치 및 권고사항 이행 여부를 점검
PRCI-018	8.1 업무지속성 확보 방안	시스템의 이중화 구성 여부	5	클라우드 관리 플랫폼, 하이퍼바이저 등 클라우드 시스템의 이중화(클러스터 구성) 구성 여부를 점검
PRCI-019	5.9 IP주소 관리	업무 특성별 가상 네트워크 구간 분리 구성	5	업무 특성별로 가상 네트워크 구간이 분리되지 않을 경우 침해사고 발생 시, 인접한 네트워크를 경유한 정보 유출 등의 보안 위험이 발생될 수 있으므로 가상 네트워크 구간을 업무 특성별로 적절하게 분리하고 있는지 점검
PRCI-020	5.9 IP주소 관리	클라우드 시스템과 가상자산 간 IP 분리 구성	5	클라우드 시스템과 가상화 인스턴스(가상머신, 컨테이너)가 동일 네트워크 구간에 존재할 경우, 가상자산을 경유한 클라우드 시스템에 침입할 수 있는 위험이 있으므로, 시스템과 가상화 인스턴스 간 IP 분리 구성 여부를 점검

클라우드 관리체계

❖ 평가대상

A	B
AWS	Azure

❖ 평가기준

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-001	○	○	5.3 정보처리시스템 보호대책	통신구간 암호화 적용 여부	5	○ HTTP 요청을 허용할 경우 중요정보가 평문으로 노출될 위험이 존재하므로, HTTP 요청 거부 설정을 활성화하여 통신구간 암호화 적용 여부를 점검
PISM-002		○	5.3 정보처리시스템 보호대책	취약한 HTTPS 프로토콜 허용	3	○ 취약한 버전의 암호 프로토콜 사용 시 MITM 등의 공격에 의해 암호화된 통신 내용이 유출될 수 있어 취약한 버전의 암호 프로토콜(TLS 1.2 미만) 허용 여부를 점검
PISM-003		○	7.5 프로그램 통제절차 수립	앱 배포 시 취약한 프로토콜 허용	5	○ 앱 배포 시 FTP 기반 배포를 허용할 경우 소스코드 등 중요 정보가 평문으로 노출될 위험이 존재하므로 앱 배포 시 FTP 기반 배포 허용 여부를 점검
PISM-004		○	5.9 IP주소 관리	소스코드 저장소 접근 시 안전한 네트워크 경로 사용	5	○ 애플리케이션 소스코드 저장소 접근 시 암호화되지 않은 공용 경로 대신 사설 네트워크 경로를 사용하고 있는지 여부를 점검
PISM-005	○	○	5.3 정보처리시스템 보호대책	가상자원에 대한 퍼블릭 액세스 허용	5	○ 가상자원에 대한 퍼블릭 액세스를 차단하지 않을 경우 중요정보 노출 등의 위험이 존재하므로 가상자원의 퍼블릭 액세스 차단 설정 활성화 여부를 점검
PISM-006	○	○	5.9 IP주소 관리	업무 목적 기반 네트워크 분리 및 접근 통제	5	○ 업무 목적에 따라 네트워크가 분리되지 않은 경우, 불필요한 접근으로 인해 내부 정보가 유출되거나 서비스가 간섭받을 수 있는 위험이 존재하므로, 개발·운영 등 목적에 맞는 네트워크 분리 구성 및 접근통제 설정 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-007	○	○	5.9 IP주소 관리	네트워크 접근 제어 설정의 최소 권한 적용	5	○ 기본 네트워크 보안 설정(방화벽, 보안그룹 등)이 최소 권한 원칙을 준수하도록 구성되어 있는지, 과도한 접근 권한이 허용되지 않도록 점검 ○ VPC, NAT 등 네트워크 설정 변경 이력이 남지 않을 경우, 침해 시टना 설정 오류로 인한 사고 발생 시 원인 분석이 불가능한 위험이 존재하므로, 네트워크 구성요소의 생성, 변경, 삭제 등의 이력이 감사 로그로 기록되고 있는지 여부를 점검
PISM-008	○	○	5.9 IP주소 관리	네트워크 설정 변경 이력 추적	4	
PISM-009	○	○	5.3 정보처리시스템 보호대책	확장 가능한 데이터 수명주기 관리 정의	3	○ 데이터 수명주기 정책을 정의하고 있으며, 수집 시점부터 삭제 시점까지의 절차(암호화, 저장소 이동, 파기 등)가 자동화되고, 정책 위반 여부를 점검할 수 있는 체계가 마련되어 있는지 여부를 점검
PISM-010	○	○	5.3 정보처리시스템 보호대책	데이터 민감도에 따른 보호 조치	3	○ 민감도 수준에 따라 데이터의 저장 위치, 접근 권한, 암호화 방식 등 보호 조치를 차등 적용하고 있으며, 설정이 잘못되었을 경우 이를 탐지하는 모니터링 체계가 운영되고 있는지 여부를 점검
PISM-011	○	○	5.3 정보처리시스템 보호대책	데이터 분류 체계 수립	3	○ 처리 중인 데이터의 종류, 민감도, 저장 위치, 보존 주기 등을 기준으로 분류체계를 정의하고 있으며, 각 분류 수준에 맞는 보호 조치 및 접근 정책이 수립되어 있는지 여부를 점검
PISM-012	○	○	5.3 정보처리시스템 보호대책	보안 로그의 안전한 저장 및 장기 보존 설정	5	○ 감사 및 보안 로그가 장기 보존이 가능한 안전한 저장소에 저장되도록 설정되어 있으며, 무결성과 접근 통제가 적용되고 있는지 여부를 점검
PISM-013	○	○	5.3 정보처리시스템 보호대책	접근 로그 수집 기능 활성화 여부	5	○ 시스템 또는 네트워크 경계에서 수집되는 접근 로그 기능이 활성화되어 있으며, 사용자 요청 이력 및 행동 추적이 가능한지 여부를 점검
PISM-014	○	○	5.3 정보처리시스템 보호대책	보안 로그 및 이벤트 상관 관계 분석	3	○ 다양한 로그 및 이벤트를 수집한 후 자동화된 방식으로 상관 관계 분석을 수행하여 위협 이벤트의 전후 관계를 파악하고, 적절한 대응 체계가 구축되어 있는지 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-015	○	○	5.3 정보처리시스템 보호대책	가상자원 생성·변경·삭제 행위 추적	5	○ 가상자원에 대한 생성, 변경, 삭제 등의 행위가 로그로 남지 않을 경우, 비정상 행위나 설정 변경에 대한 원인 분석이 불가능한 위험이 존재하므로, 가상자원 관련 행위 추적 로그가 수집되고 있는지 여부를 점검
PISM-016		○	5.3 정보처리시스템 보호대책	저장소 임의 삭제 방지 대책 적용 여부	4	○ 중요 정보가 저장된 저장소가 의도치 않게 삭제되는 상황을 방지하기 위하여 저장소 삭제 방지 대책 적용 여부를 점검
PISM-017	○	○	5.3 정보처리시스템 보호대책	삭제된 저장소 내 데이터 복원 기능 활성화 여부	5	○ 중요 정보가 저장된 저장소가 의도치 않게 삭제된 경우 데이터를 복원할 수 있도록 복원 기능의 활성화 여부를 점검
PISM-018	○	○	5.3 정보처리시스템 보호대책	API 호출 이력 행위 추적	5	○ API 호출 이력이 기록되지 않을 경우, 외부 또는 내부에서 수행된 비정상적인 호출 행위에 대한 원인 분석이 어려운 위험이 존재하므로, 호출자·시점·대상 등의 API 사용 이력이 추적 가능하도록 기록되고 있는지 여부를 점검
PISM-019	○	○	5.3 정보처리시스템 보호대책	가상자원 상태 및 장애 모니터링 기능 적용	5	○ 가상자원의 상태 및 장애 상황을 모니터링하지 않을 경우, 장애 발생 시 대응 지연이나 서비스 중단 등의 위험이 존재하므로, 자원의 상태·트래픽·장애 상황 등을 실시간으로 모니터링할 수 있는 기능이 확보되어 있는지 여부를 점검
PISM-020	○	○	5.3 정보처리시스템 보호대책	강화된 이미지 기반 컴퓨팅 리소스 제공	5	○ 신뢰할 수 있는 저장소에서 가져온 강화된 이미지로만 컴퓨팅 자원을 구성하고, 이미지 및 종속성의 무결성을 검증하며 주기적으로 업데이트되고 있는지 여부를 점검
PISM-021	○	○	5.3 정보처리시스템 보호대책	소프트웨어 및 이미지 무결성 확인 체계 구축	5	○ 사용하는 모든 소프트웨어 및 이미지가 검증된 출처에서 제공되며, 공급자 서명 또는 자체 서명 방식으로 무결성 검증이 수행되고 있는지 여부를 점검
PISM-022	○	○	5.3 정보처리시스템 보호대책	가상 머신 이미지 또는 템플릿이 외부에 노출되지 않도록 설정	5	○ 가상 머신 이미지 또는 템플릿이 외부에 노출되는지 확인하여 이미지 노출 위험을 방지하고 있는지 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-023	○	○	5.3 정보처리시스템 보호대책	업무상 불필요한 가상자원 존재	3	○ 업무상 불필요하거나 장기간 사용되지 않은 가상자원이 남아있을 경우, 이를 통해 비인가자가 의도되지 않은 행위를 수행할 위험이 존재하므로 업무상 불필요한 가상자원이 존재하는지 여부를 점검
PISM-024	○	○	5.3 정보처리시스템 보호대책	운영체제 및 플랫폼 구성요소에 대한 보안 업데이트 정책 설정	4	○ 클라우드 플랫폼에서 사용하는 운영체제 및 소프트웨어 구성요소 보안 업데이트를 위한 정책 설정 여부를 점검
PISM-025	○	○	5.3 정보처리시스템 보호대책	서비스 지원이 종료된(EoS) 런타임 교체 여부	5	○ 서비스 지원이 종료된(EoS) 버전을 사용하는 경우, 알려진 취약점 또는 신규로 발견되는 취약점으로 부터 발생하는 보안위협에 대처할 수 없는 위험이 존재하므로 서비스 지원이 종료된(EoS) 버전의 런타임 사용 여부를 점검 ※ 런타임 교체 계획을 수립하고 보고를 마친 경우 취약으로 반영하고, 위험수용으로 관리
PISM-026	○	○	5.3 정보처리시스템 보호대책	암호화 키 생성·보관·교체·폐기 관리 정책 수립	5	○ 암호화 키가 생성, 저장, 변경, 폐기 등의 과정에서 안전하게 관리되지 않을 경우, 키 탈취 또는 오남용을 통해 암호화된 데이터가 유출될 수 있는 위험이 존재하므로, 암호키에 대한 안전한 관리 방안이 수립되어 있는지 여부를 점검
PISM-027	○	○	5.3 정보처리시스템 보호대책	안전한 암호화 알고리즘 적용	5	○ 약하거나 검증되지 않은 암호화 알고리즘이 사용될 경우, 암호화된 정보가 복호화되어 민감 정보가 유출될 수 있는 위험이 존재하므로, 적용된 암호화 알고리즘이 안전한 표준에 부합하는지 여부를 점검
PISM-028	○	○	5.3 정보처리시스템 보호대책	자격증명 주기적인 갱신	5	○ 자격증명(API 키, 비밀번호, 토큰 등)이 저장 위치와 무관하게 암호화·최소 권한으로 관리되고, 가능 시 자동 로테이션(미지원 시 문서화된 수동 회전 + 보완통제)이 적용되며, 코드, 이미지, 리포지토리에 포함되지 않도록 자동 검출 체계 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-029	○	○	5.3 정보처리시스템 보호대책	암호화 대상 자원 식별 및 암호화 적용	5	○ 관련 법령에 따라 암호화가 필요한 데이터가 저장된 가상자원에 암호화 기능이 적용되지 않은 경우, 민감 정보가 외부로 유출될 수 있는 위험이 존재하므로, 암호화 적용이 가능한 자원에 대해 적절히 암호화가 수행되고 있는지 여부를 점검
PISM-030	○		5.3 정보처리시스템 보호대책	디스크 볼륨 생성 시 암호화 설정 여부	3	○ 디스크 볼륨 암호화 설정이 비활성화되어 있는 경우 새로 생성되는 볼륨이 암호화 미적용 상태로 생성되어 중요 정보가 유출될 위험이 존재하므로, 디스크 볼륨 생성 시 암호화 적용 설정의 활성화 여부를 점검
PISM-031	○		5.3 정보처리시스템 보호대책	디스크 볼륨 암호화 적용 여부	5	○ 디스크 볼륨이 암호화되지 않은 경우 비인가자에 의해 복원되어 중요 정보가 유출될 수 있는 위험이 존재하므로, 디스크 볼륨의 암호화 적용 여부를 점검
PISM-032	○		5.3 정보처리시스템 보호대책	스냅샷 암호화 적용 여부	5	○ 스냅샷이 암호화되지 않은 경우 타 계정 또는 비인가자에 의해 복원되어 저장된 데이터가 유출될 수 있는 위험이 존재하므로, 스냅샷의 암호화 적용 여부를 점검
PISM-033	○		5.3 정보처리시스템 보호대책	이미지 암호화 적용 여부	5	○ 이미지가 암호화되지 않은 경우 해당 이미지를 기반으로 생성되는 인스턴스 또는 디스크에 포함된 데이터가 비인가자에게 노출될 수 있는 위험이 존재하므로, 이미지의 암호화 적용 여부를 점검
PISM-034	○		5.3 정보처리시스템 보호대책	DB 인스턴스 암호화 적용 여부	5	○ DB 인스턴스에 대한 암호화를 적용하지 않을 경우 스토리지에 직접 접근을 통한 데이터 유출 등의 위험이 있으므로, DB 인스턴스에 대한 암호화 적용 여부를 점검
PISM-035	○	○	5.3 정보처리시스템 보호대책	초기화 스크립트 내 인증정보 또는 비밀값 미포함 여부	5	○ 컴퓨팅 인스턴스 초기화 시 입력되는 사용자 데이터 또는 초기화 스크립트에 인증정보나 비밀값이 포함되지 않도록 설정되어 있는지 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-036	○	○	5.3 정보처리시스템 보호대책	환경변수 내 중요정보 암호화 적용 여부	5	○ 가상자산의 환경변수 내에 비밀번호, API Key 등 중요정보가 암호화되지 않은 평문 형태로 저장되어 있는 경우, 중요정보가 외부로 유출될 수 있는 위험이 존재하므로 중요정보를 암호화하여 저장하고 있는지 점검 * 환경변수 내 암호화 기능이 지원되지 않을 경우 자격 증명 관리 도구(AWS Secrets Manager, Azure Key Vault 등)를 활용 ○ 계정의 비밀번호가 취약하게 설정되어 있거나 복잡도 정책이 미흡한 경우, 비인가자가 비밀번호를 유추하거나 무작위 대입 공격을 통해 계정을 탈취하여 가상자산 또는 관리 시스템에 접근할 수 있는 위험이 존재하므로 비밀번호 설정 상태 및 복잡도 정책이 적절하게 적용되어 있는지 여부를 점검 ○ 가상자산 접속 시 인증 절차가 안전하게 구성되어 있지 않은 경우, 비인가자가 SSH 또는 콘솔을 통해 시스템에 무단 접근할 수 있는 위험이 존재하므로, 인증서 기반 접속 또는 권한 검증 방식 등 안전한 인증 방안이 적용되어 있는지 여부를 점검
PISM-037	○	○	5.3 정보처리시스템 보호대책	비밀번호 정책 수립 및 로그인 제한 설정	5	○ 계정의 비밀번호가 취약하게 설정되어 있거나 복잡도 정책이 미흡한 경우, 비인가자가 비밀번호를 유추하거나 무작위 대입 공격을 통해 계정을 탈취하여 가상자산 또는 관리 시스템에 접근할 수 있는 위험이 존재하므로 비밀번호 설정 상태 및 복잡도 정책이 적절하게 적용되어 있는지 여부를 점검 ○ 가상자산 접속 시 인증 절차가 안전하게 구성되어 있지 않은 경우, 비인가자가 SSH 또는 콘솔을 통해 시스템에 무단 접근할 수 있는 위험이 존재하므로, 인증서 기반 접속 또는 권한 검증 방식 등 안전한 인증 방안이 적용되어 있는지 여부를 점검
PISM-038	○	○	5.3 정보처리시스템 보호대책	가상자산 접속 보안 인증 절차 적용	5	○ 가상자산 접속 시 인증 절차가 안전하게 구성되어 있지 않은 경우, 비인가자가 SSH 또는 콘솔을 통해 시스템에 무단 접근할 수 있는 위험이 존재하므로, 인증서 기반 접속 또는 권한 검증 방식 등 안전한 인증 방안이 적용되어 있는지 여부를 점검
PISM-039	○	○	6.1 계정 및 권한 관리	클라우드 자원에 접근 가능한 계정에 추가인증수단 적용 여부	5	○ 클라우드 자원에 접근 가능한 계정(관리자 계정 포함)에 대한 추가 인증 수단이 적용되지 않으면 계정이 탈취될 경우 공격자가 클라우드 자원에 접근할 수 있는 위험이 존재하므로, OTP, 이메일, 바이오 인증 등의 이중 인증이 설정되어 있는지 여부를 점검
PISM-040	○	○	5.3 정보처리시스템 보호대책	최고 권한 계정(root 등) 보호 및 사용 제한	5	○ 루트 계정은 가장 높은 권한을 가지므로 루트 계정의 접근을 제한하고, 비상 접근용으로만 사용되도록 설정되어 있으며, 루트 계정 사용에 대한 모니터링과 통제가 이루어지고 있는지 여부를 점검
PISM-041	○	○	6.1 계정 및 권한 관리	관리자 계정의 액세스 키 삭제 여부	5	○ 관리자 계정(root)의 액세스 키가 유출될 경우 프로그래밍 방식으로 접근하여 제약 없이 가상자산에 대한 제어가 가능해지는 위험이 존재하므로 관리자 계정의 액세스 키 삭제 여부를 점검
PISM-042	○	○	6.1 계정 및 권한 관리	API 자격 증명 다중 발급 방지 여부	3	○ API 자격 증명(AWS Access Key, Azure 인증서 및 Client Secret 등)을 안전하게 관리하기 위해 API 자격 증명을 다중 보유한 식별자(계정, 애플리케이션 등) 존재 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-043	○	○	6.1 계정 및 권한 관리	API 자격 증명의 정기적 갱신 이행 여부	3	○ API 자격 증명(AWS Access Key, Azure 인증서 및 Client Secret 등)이 유출된 경우 악용될 위험을 줄이기 위해 API 자격 증명의 정기적 갱신 정책을 수립하고 이행 여부를 점검
PISM-044	○	○	5.3 정보처리시스템 보호대책	조직 내부 자원 안전 공유	2	○ 내부 여러 부서 또는 계정 간의 리소스 공유 시 보안 정책을 준수한 방식으로 자원이 공유되며, 중복 구성 없이 통합적이고 일관된 방식으로 리소스를 활용할 수 있도록 구성되어 있는지 여부를 점검
PISM-045	○	○	5.3 정보처리시스템 보호대책	그룹 및 속성 기반 권한 부여 및 최소 권한 정책 적용	3	○ 사용자 그룹과 속성을 기반으로 접근 권한을 설정하여 개별 사용자 정책이 아닌 일괄적인 권한 관리가 이루어지며, 그룹 및 속성 기반 정책이 최소 권한 원칙을 효과적으로 구현하도록 설정되어 있는지 점검
PISM-046	○	○	6.1 계정 및 권한 관리	웹 기반 셸 환경 권한 통제 여부	4	○ 클라우드에서 제공되는 웹 기반 셸 환경은 인터넷 접근, 인스턴스에 파일 업로드 및 다운로드 등이 가능하여 사용자 정보가 유출되거나 다른 공격에 활용될 수 있으므로, 웹 기반 셸 환경에 대한 권한 통제 여부를 점검
PISM-047	○	○	5.3 정보처리시스템 보호대책	사용 권한 정기 검토 및 불필요 권한 제거 여부	3	○ 권한 정책을 주기적으로 검토하여 불필요한 권한은 제거하고, 사용되지 않는 계정 및 권한을 제거하는 등의 지속적인 최소 권한 유지 방안이 마련되어 있는지 여부를 점검
PISM-048	○	○	5.3 정보처리시스템 보호대책	외부/계정 간 리소스 공유 및 접근 권한	4	○ 외부 또는 타 계정에 공유된 리소스를 주기적으로 분석하고 있으며, 불필요한 공개 또는 교차 계정 접근이 설정되어 있지 않은지 점검하여 최소한의 접근만 허용하고 있는지 여부를 점검
PISM-049	○	○	5.3 정보처리시스템 보호대책	테넌트 간 개체 복제 허용 방지	3	○ 타 테넌트에서 접근하여 중요 정보가 노출될 위험이 존재하므로 테넌트 간 복제 허용 설정 활성화 여부를 점검
PISM-050	○	○	5.3 정보처리시스템 보호대책	컨테이너 작업에서 호스트 네트워킹 사용 시 권한 상승 제한 여부	5	○ 컨테이너 작업에서 호스트 네트워킹 모드를 사용하는 경우, 권한 상승을 제한하여 호스트 리소스에 대한 무단 접근이 차단되도록 설정되어 있는지 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-051	○	○	5.3 정보처리시스템 보호대책	제3자 접근 시 임시 권한 부여 및 최소 권한 적용	5	○ 외부 제3자와의 리스스 공유 시 일회성, 단기성 접근 권한을 기반으로 하며, IAM 역할과 외부 ID 식별자를 통해 최소 권한 접근을 적용하고 있는지 여부를 점검 ○ 보안 책임이 전담 조직에만 집중되어 있을 경우, 개발 과정에서 보안이 고려되지 않아 취약한 시스템이 운영될 수 있는 위험이 존재하므로 각 워크로드 팀이 보안 책임을 갖고 자율적으로 보안 결정을 내릴 수 있도록 관련 프로그램을 운영하고 있는지 여부를 점검
PISM-052	○	○	5.3 정보처리시스템 보호대책	워크로드 팀의 보안 책임 부여 및 자율적 보안 수행 체계	1	○ 조직의 위험 모델 및 컴플라이언스 요구사항에 따라 보안 통제 목표를 정의하고, 통제 적용 효과에 대해 지속적으로 평가하며 자동화된 정책을 기반으로 검증을 수행하고 있는지 여부를 점검
PISM-053	○	○	5.3 정보처리시스템 보호대책	보안 통제 목표 식별 및 검증	3	○ 위험 모델링을 수행하여 워크로드별 위험을 식별하고, 식별된 위험에 대해 예방·탐지·대응 통제를 수립하며, 보안 환경 변화에 따라 지속적으로 이를 갱신하고 있는지 점검
PISM-054	○	○	5.3 정보처리시스템 보호대책	위험 모델링을 통한 보안 위험 식별 및 대응	3	○ 최신 보안 위험 인텔리전스를 지속적으로 수집하고, 이를 기반으로 자동화된 탐지 및 대응 체계를 적용하여 새로운 위험에 대한 방어 조치가 반영되고 있는지 여부를 점검
PISM-055	○	○	5.3 정보처리시스템 보호대책	최신 보안 위험 및 권고사항 반영	5	○ 클라우드 제공 관리 도구 또는 에이전트를 활용하여 컴퓨팅 인스턴스가 일관되고 중앙에서 관리되고 있는지 여부를 점검
PISM-056	○	○	5.3 정보처리시스템 보호대책	중앙 관리 도구 또는 에이전트를 활용한 인스턴스 관리	3	○ 관리형 서비스 및 자동화 기능을 활용하여 보안 관리 범위를 축소하고, 인프라 구성, 패치, 백업 등 반복적인 작업의 보안 부담을 줄이는 구조가 설계되어 있는지 여부를 점검
PISM-057	○	○	5.3 정보처리시스템 보호대책	보안 관리 범위 최소화	1	○ 보안 정책 및 통제를 코드화하여 버전 관리 시스템에 저장하고, CI/CD 파이프라인을 통해 자동 테스트 및 배포가 이루어지며, 승인된 표준 환경에 배포되도록 구성되어 있는지 여부를 점검
PISM-058	○	○	5.3 정보처리시스템 보호대책	표준 보안 통제 자동화 적용	2	

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-059	○	○	5.4 취약점 분석·평가	개발 및 배포 전 과정에서 보안 테스트 자동화	3	○ 보안 테스트가 수동으로만 수행되거나 누락될 경우, 개발 주기 중 보안 취약점이 탐지되지 않아 운영환경에 노출될 수 있는 위험이 존재하므로 보안 테스트 자동화 도구를 통해 개발 및 배포 전 과정에서 보안 검증이 이루어지고 있는지 여부를 점검
PISM-060	○		7.5 프로그램 통제절차 수립	실행 코드 무결성 검증 절차 운용 여부	5	○ 인가되지 않은 실행 코드가 포함되지 않도록, 서명 기능을 활용한 가상자원 실행 코드의 무결성 검증 절차를 구축하여 운용하고 있는지 점검
PISM-061	○	○	5.3 정보처리시스템 보호대책	컴퓨팅 자원 보호 작업(스캔, 패치, 대응)의 자동화	3	○ 컴퓨팅 자원에 대한 패치, 취약점 스캔, 비정상 상태 탐지 등을 자동화하여 인적 오류를 최소화하고, 비정상 상황 시 자동 조치를 수행하는 구조로 구성되어 있는지 여부를 점검
PISM-062	○	○	5.3 정보처리시스템 보호대책	취약점 관리 수행	5	○ 소스코드, 종속성, 인프라 구성에 대해 정기적이고 자동화된 취약점 스캔 및 패치 관리 체계를 운영하고 있으며, 위험도 기반으로 우선순위를 설정하여 조치하고 있는지 여부를 점검
PISM-063	○	○	5.4 취약점 분석·평가	정기적인 침투 테스트 수행	5	○ 자동화된 검증만으로는 발견되지 않는 실질적인 보안 취약점이 존재할 수 있으며, 이를 악의적인 공격자가 악용할 수 있는 위험이 존재하므로 정기적인 침투 테스트를 수행하고 결과에 따라 취약점을 개선하고 있는지 여부를 점검
PISM-064	○		5.3 정보처리시스템 보호대책	컴퓨팅 인스턴스에서 IMDSv1 비활성화 여부	5	○ IMDSv1는 별도의 인증을 요구하지 않아 SSRF(Server-Side Request Forgery)를 통해 자격증명 탈취 위험 등이 존재하므로 IMDSv2 활성화 여부를 점검
PISM-065	○	○	5.3 정보처리시스템 보호대책	보안 사고 대응을 위한 체계 구축	2	○ 보안 사고 발생 시 대응을 담당할 내부 인력 및 외부 협력사의 역할과 연락 체계를 사전에 정의하고 정기적으로 업데이트하며, 각 주체가 책임을 수행할 수 있는 체계를 갖추고 있는지 여부를 점검
PISM-066	○	○	8.1 업무 지속성 확보방안	보안 사고 대응 계획 문서화 및 정기 점검	2	○ 보안 사고 발생 시 신속하게 대응할 수 있도록 사고 대응 프로세스를 문서화 하고, 대응 단계별 역할과 책임을 명확히 하며, 이를 주기적으로 점검 및 개선하고 있는지 여부를 점검

평가항목ID	A	B	통제구분	평가항목	위험도	상세설명
PISM-067	○	○	8.1 업무 지속성 확보방안	사고 대응 시나리오 개발 및 테스트	2	○ 사고 유형별 대응 시나리오(플레이북)를 수립하고, 이를 기반으로 정기적인 모의훈련 및 대응 테스트를 실시하여 실제 사고 발생 시 신속한 대응이 가능한지 여부를 점검
PISM-068	○	○	8.1 업무 지속성 확보방안	사고 발생 시 재발 방지 체계 구축	2	○ 보안 사고 발생 시 원인 분석 및 재발 방지 대책을 체계적으로 문서화하여 조직 내 공유하고, 이를 반영해 보안 정책과 운영 절차를 개선하는 피드백 체계를 마련하고 있는지 여부를 점검
PISM-069	○	○	5.3 정보처리시스템 보호대책	사전 접근 권한 부여	2	○ 사고 대응 인력에게는 사고 시점에 빠르게 시스템에 접근할 수 있도록 미리 권한을 부여하거나, 필요 시 즉시 부여할 수 있는 프로세스가 마련되어 있는지 여부를 점검
PISM-070	○	○	8.1 업무 지속성 확보방안	침해사고 조사 분석 역량 체계 구축	2	○ 보안 사고 발생 시 원인 파악 및 침해 범위를 확인할 수 있도록 로그 수집·보관, 증적 분석 도구 및 절차를 사전에 준비하여 침해사고 조사 역량을 갖추고 있는지 여부를 점검
PISM-071	○	○	5.3 정보처리시스템 보호대책	비상 접근 절차 수립	2	○ 평상시에는 중앙 인증 시스템을 통해 접근하되, 인증 시스템 장애 등 비상 상황 발생 시 클라우드 자원에 접근할 수 있도록 별도의 절차를 마련하고 있으며, 이를 문서화하고 테스트하고 있는지 여부를 점검
PISM-072	○	○	8.1 업무지속성 확보방안	중요 데이터 백업 및 복구 정책 적용 여부	5	○ 중요 전산자료 및 로그를 정기적으로 백업하고 있으며, 백업 파일의 무결성을 검증하고 있는지 여부를 점검
PISM-073	○	○	5.1 단말기 보호대책	관리용 단말기 보호대책 적용 여부	5	○ 클라우드 환경 관리용 단말기가 악성코드 감염이나 비인가 접근의 경로가 되는 위험이 존재하므로, 해당 단말을 종요단말기로 지정하고 인터넷 접속, 매체 제어, 무단조작 방지 등 강화된 보호대책을 적용하고 있는지 여부를 점검

서버, 웹서버-WAS

❖ 평가분야 ID

SRV		WST
서버 평가항목 ID		웹서버-WAS 평가항목 ID

❖ 평가대상

A	B	C	D	E	F	G	H	I	J
AIX 계열	HP-UX 계열	LINUX 계열	Solaris 계열	Windows 계열	Apache	WebtoB	IIS	Tomcat	JEUS

❖ 평가기준

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 001	WST 001	o	o	o	o	o						5.3.1 보안 관리	안전한 네트워크 모니터링 서비스 사용	3	네트워크 모니터링 서비스 사용 시 보안 설정이 미비할 경우 데이터 변조, 도청 및 중간자 공격으로 시스템 정보 및 상태정보가 유출될 가능성이 존재하므로 프로토콜에 따라 알맞은 버전 및 안전한 보안 설정을 적용하여 사용하고 있는지 여부를 점검
SRV 003	WST 002	o	o	o	o	o						5.3.1 보안 관리	네트워크 모니터링 서비스 접근통제 설정 적절성	3	네트워크 모니터링 서비스는 네트워크 관리 및 네트워크 장치의 동작을 감시/통제하는 서비스로, 네트워크 모니터링 서비스를 사용하는 경우 해당 서비스를 사용할 수 있는 호스트를 특정하여 접근통제를 수행하고 있는지 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 004	WST 003	o	o	o	o	o						5.3.1 보안 관리	불필요한 SMTP 서비스 비활성화	3	SMTP 서비스는 인터넷에서 메일을 전송하는 SMTP 프로토콜을 기반으로 하는 서비스로, 악의적인 공격자가 SMTP 서비스를 실행 중인 서버의 정보를 획득하는 등 다양한 공격이 가능하므로 불필요한 SMTP 서비스 자동 여부를 점검
SRV 005	WST 004	o	o	o	o	o						5.3.1 보안 관리	SMTP 서비스의 expn/vrfy 명령어 실행 제한 여부	3	SMTP 서비스에서 제공하는 expn/vrfy 명령어는 시스템 계명명 수집 가능성이 존재하므로, 해당 명령의 허용 여부를 점검
SRV 006	WST 005	o	o	o	o	o						5.3.1 보안 관리	SMTP 서비스 로그 수준 설정 적절성	2	SMTP 서비스는 일반적으로 로그 설정을 할 때, 중요한 이벤트만 기록하는 수준부터 발생한 모든 이벤트를 기록하는 수준까지 로그의 기록 정도를 설정할 수 있다. 로그 수준이 너무 낮게 설정되었을 경우, 오류 또는 침해 행위로 인한 서비스 장애의 원인을 추적하지 못할 위험이 있기 때문에 로그 수준 설정의 적절성을 점검
SRV 007	WST 006	o	o	o	o	o						5.3.1 보안 관리	SMTP 서비스 보안 패치 적용 여부	5	특정 SMTP 서비스 버전에서 공개된 취약점이 존재할 경우, 악의적인 사용자가 이를 활용한 공격을 수행할 위험이 있으므로 취약한 SMTP 서비스 버전의 사용 여부 점검
SRV 008	WST 007	o	o	o	o	o						5.3.1 보안 관리	SMTP 서비스의 DoS 방지 기능 설정 여부	1	네트워크 화선 용량 및 서버 처리 용량 초과로 인한 메일 서비스 거부 및 시스템 다운을 방지하기 위한 보안설정의 적정성을 점검
SRV 009	WST 008	o	o	o	o	o						5.3.1 보안 관리	SMTP 서비스 스팸 메일 릴레이 제한 설정 여부	4	SMTP 서비스는 인터넷에서 메일을 전송하는 프로토콜로, 다른 메일 서버가 보낸 메일을 다시 발송하는 relay 기능을 제공하는데 해당 기능은 공격자가 정당한 인증 과정 없이 다량의 메일(스팸 메일 등) 발송을 할 위험이 존재하므로 이에 대한 설정을 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 010	WST 009	o	o	o	o							5.3.1 보안 관리	SMTP 서비스의 메일 queue 처리 관한 설정 적절성	4	- SMTP 서비스 운영 시 메일 queue 처리 기능이 임의의 사용자에게 허용되어 있을 경우, 비인가자가 악의적으로 queue의 데이터를 삭제하는 등의 공격 발생 위험이 존재하므로 적절한 보안 설정이 되어있는지 점검 - FTP 서비스는 단독으로 사용 시 네트워크에서 계정과 패스워드가 암호화되지 않으므로, 중요한 시스템 관리자 계정들을 보호하기 위해 해당 계정의 FTP 접속을 ftpusers 파일을 활용하여 제한하고 있는지 점검 .netrc 파일은 ftp 나 rexec 사용 시 자동 로그인을 위한 계정과 패스워드를 저장할 수 있는 파일로 계정 정보를 평문으로 저장하는 취약한 설정이므로, 해당 설정 파일이 존재하는지 점검 - FTP 서비스는 파일을 전송하기 위한 프로토콜을 기반으로 하는 서비스로, 임의의 사용자가 FTP 서비스를 이용할 수 있는 익명(Anonymous) FTP 기능이 활성화된 경우 악의적인 사용자도 손쉽게 접근이 가능하므로 해당 기능의 허용 여부를 점검 - NFS 서비스는 원격지의 시스템에 위치한 파일을 공유할 수 있는 서비스로 잘못된 설정에 의해 원치 않는 파일 또는 디렉터리 등이 외부에 노출되고 있는지 여부를 점검 - NFS 서비스는 원격지의 시스템에 위치한 파일을 공유할 수 있는 서비스로 해당 서비스가 업무와 관계없이 불필요하게 실행되고 있는지 여부를 점검 - RPC(Remote Procedure Call) 서비스는 순수한 분산 처리 환경을 제공하지만, 오래된 버전의 특정 서비스들은 알려진 취약점이 존재하거나 잠재적인 취약점 발견 가능성이 있으므로 해당 서비스가 업무와 관계없이 불필요하게 활성화 되어 있는지 점검
SRV 011	WST 010	o	o	o	o							5.3.1 보안 관리	시스템 관리자 계정의 FTP 사용 제한 여부	3	
SRV 012	WST 011	o	o	o	o							5.3.1 보안 관리	.netrc 파일 내 중요 정보 미포함 여부	4	
SRV 013	WST 012	o	o	o	o	o						5.3.1 보안 관리	Anonymous 계정의 FTP 서비스 접속 제한 여부	5	
SRV 014	WST 013	o	o	o	o							5.3.1 보안 관리	NFS 접근통제 설정 적절성	5	
SRV 015	WST 014	o	o	o	o							5.3.1 보안 관리	불필요한 NFS 서비스 비활성화	4	
SRV 016	WST 015	o	o	o	o							5.3.1 보안 관리	불필요한 RPC 서비스 비활성화	4	

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 018	WST 016					o						5.3.1 보안 관리	불필요한 하드디스크 기본 공유 비활성화	4	Windows는 프로그램 및 서비스를 네트워크나 컴퓨터 환경에서 관리하기 위해 시스템 기본 공유 항목을 자동으로 생성하며, 이러한 공유 기능을 이용하여 비인가자가 불법적으로 모든 시스템 자원에 접근할 수 있는 위험이 있으므로 해당 서비스가 업무에 관계없이 활성화되어 있는지 점검
SRV 020	WST 017					o						5.3.1 보안 관리	공유 기능에 대한 접근통제 설정 적절성	5	Windows의 공유 기능은 폴더, 디스크 드라이브, 프린터 등을 공유하여 다른 사용자들과 함께 사용 가능하며 접근통제가 미흡한 공유는 비인가 접근 위험이 존재하므로, 사용자 권한 및 사용자 그룹 설정 등 보안 설정의 적절성을 점검
SRV 021	WST 018					o	o	o	o			5.3.1 보안 관리	FTP 서비스 접근통제 설정 적절성	5	FTP에 대한 적절한 접근통제 정책 미적용 시 비인가자에게 시스템 파일이 노출될 수 있으므로 FTP 접근 제어 설정의 적절성 여부를 점검
SRV 022	WST 019					o	o	o	o			5.3.1 보안 관리	계정의 비밀번호 미설정, 빈 암호 사용 관리 여부	3	시스템 접속 계정에 대한 비밀번호가 설정되어 있지 않은 경우 비인가자가 계정을 도용하여 인가되지 않은 파일 및 서비스에 접근할 수 있는 위험이 존재하므로, 계정에 비밀번호가 설정되어 있지 않거나 빈 비밀번호를 설정하였는지를 점검
SRV 023	WST 020					o						5.3.1 보안 관리	원격 터미널 서비스의 암호화 설정 적절성	3	원격 터미널 서비스는 원격지에 있는 서버를 관리하기 위한 유용한 도구이지만 원격 터미널 서비스의 암호화 수준이 낮을 경우, 계정 탈취 위험이 증가하므로 해당 설정의 적절성을 점검
SRV 024	WST 021					o						5.3.1 보안 관리	취약한 Telnet 인증 방식 사용 제한 여부	3	Telnet 서비스는 평문으로 데이터를 송수신하므로 패스워드 방식으로 인증을 수행할 경우 계정 및 패스워드가 노출될 위험성이 존재함. 네트워크상으로 패스워드를 전송하지 않는 NTLM 인증 설정을 적용하고 있는지 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 025	WST 022	o	o	o	o							5.3.1 보안 관리	hosts.equiv 또는 .hosts 설정 제한 여부	5	- hosts.equiv, .rhosts 파일 내에 등록된 시스템이나 사용자는 시스템 접근 시 인증 절차 없이 r 계열 명령어(rexec, rlogin 등)를 사용이 가능함. 특히 hosts.equiv, .rhosts 파일 내에 '+' 구분 존재 시 시스템 root를 제외한 모든 사용자가 인증절차 없이 r 계열 명령어를 실행할 수 있는 등 보안 수준이 낮으므로 이러한 설정이 존재하는지 점검 - 시스템 관리를 위한 root 계정의 원격 접속 허용은 악의적인 사용자가 무작위 대입 공격을 통해 시스템의 관리자 권한을 획득할 수 있는 위험을 증가시키므로, root 계정의 직접적인 원격 접속을 차단하고 있는지 여부를 점검
SRV 026	WST 023	o	o	o	o							5.3.1 보안 관리	root 계정 원격 접속 제한 여부	5	서비스로의 접근이 통제되지 않을 경우 악의적인 사용자의 공격 목표가 될 수 있기 때문에 보안상 접근통제가 필요함. 방화벽, 3rd-party 제품 또는 tcpwrapper를 활용하여 서비스에 대한 IP 및 포트 접근제어를 수행하고 있는지 점검 ※ 예외 사항: 네트워킹에 연결되지 않은 오프라인 서버(rootCA 등)
SRV 027	WST 024	o	o	o	o	o						5.3.1 보안 관리	서비스 접근 IP 및 포트 제한 여부	4	사용자 부재시, 비인가자에 의한 시스템 무단 사용을 방지하기 위해 일정시간 사용하지 않는 세션에 대한 자동 종료시간 설정 여부를 점검하고, 세션 종료시간이 설정되어 있을 경우 과도하게 설정 되어 있는지 점검
SRV 028	WST 025	o	o	o	o	o						5.3.1 보안 관리	원격 터미널 접속 타임아웃 설정 여부	2	SMB 세션은 서버 리소스를 소모하므로 세션 수가 많으면 서버 속도가 느려지거나 성능저하가 발생할 수 있음. 공격자가 악의적으로 SMB 세션을 반복 설정하는 등의 방법을 활용하여 SMB 서비스에 대한 서비스 거부 공격을 감행할 수 있으므로 유효한 로그인 시간이 초과된 세션이 자동으로 종료되도록 설정되었는지 점검
SRV 029	WST 026					o						5.3.1 보안 관리	SMB 세션 중단 관리 설정 여부	3	

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 031	WST 027					o						5.3.1 보안 관리	계정 목록 및 네트워크 공유 이름 노출 방지 여부	5	- o SAM(보안계정관리자) 계정과 공유의 익명 열거가 허용된 경우, 악의적인 사용자가 계정 이름 목록을 확인하고 사회공학 공격 및 기타 공격에 활용할 수 있으므로, 계정과 공유의 익명 열거를 방지하고 있는지 점검 - o 시스템 운영 중 불필요한 서비스들이 설치되어 실행되고 있는 경우, 시스템의 성능 저하를 야기하거나 잠재적인 보안 취약점이 발생할 수 있으므로 업무와 관계 없이 활성화되어 있는 서비스를 점검 (취약한 버전의 automountd, NetBIOS, DMI, WebDAV, RDS 등 일반적으로 불필요한 서비스 점검)
SRV 034	WST 028											5.3.1 보안 관리	불필요한 서비스 비활성화	3	o 알려진 취약점이 존재하는 서비스를 실행할 경우, 공격자의 침입 경로로 활용될 수 있기 때문에 취약한 서비스나 취약한 버전의 서비스가 실행되고 있는지 점검(tftp, talk, finger, r 계열 서비스, echo, discard, daytime, chargen, NIS, NIS+ 서비스 등) ※ 단, OS 백업 솔루션에서 tftp를 반드시 사용해야 하는 경우 등 업무와 연관 업무 및 추가 보호대책 적용 확인 후 예외 처리
SRV 035	WST 029											5.3.1 보안 관리	취약한 서비스 비활성화	5	o 알려진 취약점이 존재하는 서비스를 실행할 경우, 공격자의 침입 경로로 활용될 수 있기 때문에 취약한 서비스나 취약한 버전의 서비스가 실행되고 있는지 점검(tftp, talk, finger, r 계열 서비스, echo, discard, daytime, chargen, NIS, NIS+ 서비스 등) ※ 단, OS 백업 솔루션에서 tftp를 반드시 사용해야 하는 경우 등 업무와 연관 업무 및 추가 보호대책 적용 확인 후 예외 처리
SRV 037	WST 030											5.3.1 보안 관리	취약한 FTP 서비스 비활성화	3	o FTP는 파일을 전송하기 위한 프로토콜로 계정과 패스워드를 암호화하지 않고 평문 전송을 하여 네트워크 스니핑의 위험이 존재하므로, 해당 서비스가 업무와 관계없이 불필요하게 실행되고 있는지 점검 ※ 단, 업무상 필요하여 FTPS를 활용하는 등 통신 암호화를 위한 별도의 보안수단이 적용되는지 확인 후 예외 처리
	WST 031											5.3.1 보안 관리	웹 서비스 디렉터리 리스팅 방지 설정 여부	5	o 디렉터리 리스팅은 디렉터리에 대한 요청 시 그 디렉터리에 기본 문서가 존재하지 않을 경우 디렉터리 내에 존재하는 모든 파일들의 목록을 출력함. 해당 기능이 활성화되어 있는 경우 백업 파일이나 소스 파일 등 중요 파일이 외부에 노출될 수 있으므로 해당 기능의 활성화 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
	WST 032					○						5.3.1 보안 관리	웹 서비스의 CGI 스크립트 관리 여부	5	○ CGI(Common Gateway Interface)는 동적 콘텐츠를 생성하기 위해 호출하는 처리 프로그램과 통신하기 위해 정의된 인터페이스 명세이다. CGI 도입 초기에 취약점이 있는 스크립트들이 존재하였으므로 취약 스크립트가 있는지 확인하고, 악성 CGI 스크립트의 비인가 생성을 방지하기 위해 CGI 디렉터리의 권한이 적절하게 설정되어 있는지 여부를 점검 ○ 상위 디렉터리로 이동이 가능하면 하위경로에 접속한 후 상위로 이동하여 중요 파일들에 대한 접근이 가능한 위험이 존재하므로 “.”와 같은 상위 경로를 사용하지 못하도록 적절하게 설정하였는지 점검 ○ 웹 서비스 설치 시 기본으로 생성되는 설명 파일 또는 테스트 페이지로 인한 불필요한 정보 노출이 발생할 수 있으므로, 불필요한 파일의 존재 여부를 점검 ○ 웹 서버에 불필요한 대량의 파일 업로드, 다운로드로 인한 서비스 거부 공격 위험이 존재하므로, 서버에 영향을 줄 정도의 대량의 업로드와 다운로드에 대한 통제 여부를 점검 ○ 웹 서버에 대한 요청을 처리하는 프로세스의 권한을 제한하지 않을 경우, 취약점 존재 시 공격자가 해당 서버의 높은 권한을 획득 가능한 위험이 존재함. 웹 서버 요청을 처리하는 프로세스 권한이 적절하게 설정되어 있는지 여부를 점검 ○ 웹 서비스 경로를 기타 업무와 영역이 분리되지 않은 경로로 설정하거나, 불필요한 경로가 존재할 경우 외부에서 시스템의 중요 파일이나 기능에 비인가 접근이 발생할 위험이 존재하므로 웹 서비스 경로 설정의 적절성을 점검
	WST 033	○	○	○	○	○						5.3.1 보안 관리	웹 서비스 상위 디렉터리 접근 제한 설정 여부	5	
	WST 034	○	○	○	○	○	○	○	○		○	5.3.1 보안 관리	웹 서비스 경로 내 불필요한 파일 관리 여부	4	
	WST 035	○	○	○	○	○	○	○	○		○	5.3.1 보안 관리	웹 서비스 파일 업로드 및 다운로드 용량 제한 설정 여부	4	
	WST 036	○	○	○	○	○	○	○	○			5.3.1 보안 관리	웹 서비스 프로세스 권한 제한 여부	5	
	WST 037	○	○	○	○	○	○	○	○		○	5.3.1 보안 관리	웹 서비스 경로 설정 적절성	4	

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
	WST 038	○	○	○	○	○	○					5.3.1 보안 관리	웹 서비스 경로 내 불필요한 링크 파일 관리 여부	4	○ 웹 서버에 설정된 웹 서비스 루트 경로를 벗어나는 외부 링크 파일이 있다면, 공격자에 의한 비인가 접근 가능성이 존재하므로 불필요한 링크 파일 존재 여부를 점검
	WST 039	○	○	○	○	○	○	○	○	○	○	5.3.1 보안 관리	불필요한 웹 서비스 비활성화	3	○ 웹 서비스는 구동 중일 경우 잠재적인 보안 취약점이 발생할 수 있고 흔히 공격의 목표가 되는 서비스이므로, 업무와 관계 없이 불필요하게 활성화되어 있는지 여부를 점검
	WST 040					○		○				5.3.1 보안 관리	웹 서비스 설정 파일 노출 방지 여부	5	○ Global.asa 파일에는 데이터베이스 관련 정보(IP주소, DB명, 패스워드), 내부 IP주소, 웹 애플리케이션 환경설정 정보 및 기타 정보 등 중요 정보가 포함될 수 있으므로 해당 파일에 대한 접근통제의 적절성 여부 등을 점검 * .asa 파일을 매핑하여 Global.asa 파일이 요청되었을 때 웹 서버가 평문으로 응답하지 않도록 조치 필요
	WST 041					○		○				5.3.1 보안 관리	웹 서비스 경로 내 파일의 접근통제 설정 적절성	5	○ 웹 서비스 경로 내 파일의 접근 권한을 확인하여 비인가자에 의한 웹 서비스 파일의 실행 및 읽기 방지가 이루어지고 있는지 점검
	WST 042					○		○				5.3.1 보안 관리	웹 서비스의 불필요한 스크립트 매핑 제거	4	○ 웹 서비스에서 사용하지 않는 스크립트 매핑은 잠재적 보안 위험이 될 수 있으므로, 업무와 관계없는 불필요한 스크립트가 매핑되어 있는지 여부를 점검
	WST 043					○			○			5.3.1 보안 관리	웹 서비스 서버 명령 실행 기능 제한 설정 적절성	5	○ 웹 서버에서 임의의 명령을 실행할 수 있도록 설정되어 있는 경우, 비인가자에 의한 임의 파일 수정 및 시스템 관리자 권한 획득이 가능한 위험이 있어 이에 대한 보안설정 적절성 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
	WST 044	○	○	○	○	○					○	5.3.1 보안 관리	웹 서비스 기본 계정(아이디 또는 비밀번호) 변경 여부	5	○ Tomcat은 Apache 웹 서버에 JSP와 자바 서버릿을 실행시킬 수 있는 기능을 제공하는 자바 애플리케이션 서버로 Tomcat이 설치 될 때 기본으로 설정되는 계정을 변경하지 않을 경우 비인가자에 의한 시스템 접근이 발생할 수 있으므로 기본 계정에 대한 보안 설정의 적절성 여부를 점검
SRV 062	WST 045	○	○	○	○							5.3.1 보안 관리	DNS 서비스 정보 노출 방지 여부	1	○ DNS 서버 종류 및 버전 등의 정보가 노출될 경우 공격자가 기타 공격에 활용할 가능성이 있으므로, 적절한 보안 설정이 되었는지 점검
SRV 063	WST 046	○	○	○	○	○						5.3.1 보안 관리	DNS Recursive Query 제한 설정 여부	3	○ 공격자가 스푸핑 IP 주소(IP Spoofing)로 다량의 DNS 응답을 보내는 공격(DNS Cache Poisoning-DNS 캐시에 거짓정보가 들어 가게 하는 공격) 등의 DNS 공격 위험이 존재하므로 DNS 서버가 불필요하게 Recursive Query를 지원하고 있는지 점검
SRV 064	WST 047	○	○	○	○							5.3.1 보안 관리	DNS 서비스 보안 패치 적용 여부	5	○ DNS 서비스 운영 시 낮은 버전을 사용하고 있을 경우 Cache Poisoning (CVE-2008-1447) 공격, 서비스 거부 공격, 버퍼 오버플로우(Buffer Overflow), DNS 원격 침입 등의 알려진 취약점이 존재하므로 주기적인 DNS 보안 패치를 통해 안전한 서비스를 운영하고 있는지에 대한 점검
SRV 066	WST 048	○	○	○	○	○						5.3.1 보안 관리	DNS Zone Transfer 제한 설정 적절성	4	○ DNS 서버에 저장되어 있는 도메인 정보의 사본을 전송하는 DNS Zone Transfer 기능이 내부 DNS 서버만 접근할 수 있도록 통제되어 있지 않다면, 임의의 공격자가 도메인 내 호스트 목록 정보를 획득하여 공격에 활용할 수 있기 때문에 해당 기능의 설정 적절성을 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 069	WST 049	○	○	○	○	○						5.3.2 사용자 인증	비밀번호 관리정책 설정 적절성	5	○ 사용자 비밀번호에 대한 관리정책 설정이 미흡할 경우 유추하기 쉬운 비밀번호 설정, 주기적인 비밀번호 미변경 등 비인가자에 의한 계정 탈취 가능성이 높아지는 위험이 존재하므로 적절한 비밀번호 관리정책이 설정되어 있는지 여부를 점검
SRV 070	WST 050	○	○	○	○	○						5.3.1 보안 관리	취약한 패스워드 저장 방식 사용 제한 여부	5	○ 취약한 패스워드 저장 방식을 사용할 경우, 공격자에게 계정의 로그인 정보가 탈취되어 악용될 위험이 존재하므로 관련 설정의 적절성 여부를 점검
SRV 072	WST 051					○						5.3.2 사용자 인증	기본 관리자 계정명(Administrator) 변경 여부	4	○ Windows는 널리 알려진 관리자 계정(Administrator)명이 디폴트로 생성되어, 공격자가 쉽게 계정명을 유추하고 탈취 시도를 할 수 있으므로 Administrator 계정의 계정명 변경 유무를 점검
SRV 073	WST 052	○	○	○	○	○						5.3.1 보안 관리	관리자 그룹에 불필요한 사용자 제거	4	○ 시스템에 다수의 관리자 계정이 존재할 경우, 공격자가 탈취를 시도할 수 있는 관리자 계정이 많아지므로 관리자 그룹에 업무상 필요한 최소한의 사용자만 등록하여 사용하고 있는지 여부를 점검
SRV 074	WST 053	○	○	○	○	○						5.3.2 사용자 인증	불필요하거나 관리되지 않는 계정 제거	4	○ 시스템 설치 시 기본으로 생성되는 계정, 업무상 더 이상 사용되지 않는 계정 등 불필요한 계정이나 장기간 비밀번호가 변경되지 않은 계정이 존재할 경우 비인가자의 계정 탈취 위험이 증가하므로 불필요한 계정 삭제 및 내부 정책에 따른 주기적인 비밀번호 변경을 실시하고 있는지 여부를 점검
SRV 075	WST 054	○	○	○	○	○						5.3.2 사용자 인증	비밀번호 복잡도 설정	5	○ 패스워드 설정 시 문자/숫자/특수문자를 모두 포함하여 강력한 패스워드가 설정될 수 있도록 암호 복잡성을 설정하여야 하며 영/숫자만으로 이루어진 암호는 현재 공개된 패스워드 크랙 유틸리티 및 무작위 공격에 의해 쉽게 유추할 수 있으므로 회사에서 정한 비밀번호 관리정책 준수 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 078	WST 055					o						5.3.2 사용자 인증	불필요한 Guest 계정 비활성화	4	Guest 계정이 활성화 되어있을 경우 시스템에 대한 접근 권한을 보유하고 있지 않은 사용자가 Guest 계정 권한으로 접근할 위험이 존재하므로, Guest 계정을 비활성화하여 접근 권한이 없는 사용자의 접근을 제한하고 있는지를 점검
SRV 079	WST 056					o						5.3.1 보안 관리	익명 사용자에게 부적절한 권한(Everyone) 제거	5	익명 사용자가 Everyone 그룹에게 접근 권한이 부여된 모든 리소스에 접근 가능한지를 결정하는 설정으로 “사용”으로 설정할 경우, 공격자가 익명의 비인가 접근으로 정보를 획득할 위험이 존재하므로 해당 정책 설정의 적절성을 점검
SRV 080	WST 057					o						5.3.1 보안 관리	일반 사용자의 프린터 드라이버 설치 제한 여부	3	프린터 드라이버 설치 권한이 부여된 경우 악의적인 사용자가 고의적으로 잘못된 프린터 드라이버를 설치하여 서버를 손상시킬 수도 있고, 프린터 드라이버로 위장한 악성코드를 설치할 가능성도 존재하므로 일반 사용자의 프린터 드라이버 설치를 제한하고 있는지 점검
SRV 081	WST 058					o						5.3.1 보안 관리	Crontab 설정파일 권한 설정 적절성	4	cron은 특정 시간에 특정 작업을 수행할 수 있는 데몬으로 공격에 악용되거나 정보가 노출될 위험이 존재함. 이에 따라 cron 서비스를 보호하기 위해 서비스의 설정 파일들에 부여된 권한의 적절성을 점검
SRV 082	WST 059					o						5.3.1 보안 관리	시스템 주요 디렉터리 권한 설정 적절성	4	시스템 주요 디렉터리에 대한 권한 설정 미흡으로 인하여 중요 파일에 대한 접근 및 변조가 발생할 위험이 존재하므로, 시스템 주요 디렉터리에 부여된 권한의 적절성을 점검
SRV 083	WST 060					o						5.3.1 보안 관리	시스템 스타트업 스크립트 권한 설정 적절성	3	시스템 스타트업 스크립트의 소유권 및 권한 설정이 미흡할 경우, 임의의 공격자가 스크립트의 내용 변경 등을 통해 시스템 침입에 악용할 위험이 존재하므로, 해당 파일에 대한 권한 설정의 적절성을 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 084	WST 061	o	o	o	o	o						5.3.1 보안 관리	시스템 주요 파일 권한 설정 적절성	5	○ 시스템 중요 파일에 대한 권한 설정이 미흡할 경우, 중요 정보가 유출, 다른 공격에 활용, 또는 파일 자체가 변조될 위험이 존재하므로 주요 중요 파일의 권한이 일반적으로 권장되는 권한 수준으로 부여되었는지 점검 ○ 공격자가 시스템에 침입 후 공격 코드가 작성된 소스 파일을 컴파일하여 시스템 공격(관리자 권한 획득, 서비스 거부 유발 등)에 악용 가능하므로, 시스템에 C 컴파일러 존재 여부 및 권한 부여의 적절성을 점검 ○ 원격 레지스트리 서비스는 권한 있는 사용자가 원격으로 접근하여 레지스트리 값을 변경할 수 있는 서비스로, 악의적인 사용자가 권한을 탈취한 경우 레지스트리 값 변경을 통한 침해 행위가 발생할 수 있으므로 불필요한 경우 서비스를 비활성화하고 있는지 점검 ○ SUID(Set User-ID)와 SGID(Set Group-ID)가 설정된 파일은 취약점이 존재할 경우, 권한 상승 공격에 활용될 수 있으므로 불필요한 SUID, SGID가 설정된 파일이 존재하는지 점검 ○ 사용자 계정별 홈 디렉터리 경로 및 권한이 올바르게 설정되지 않을 경우, 비인가 접근이 발생할 가능성이 존재하므로 사용자별 홈 디렉터리 경로 및 접근 권한의 적절성을 점검 ○ World Writable 파일 또는 디렉터리가 존재할 경우 이를 임의의 사용자가 변경하여 추가적인 공격에 활용할 위험이 존재하므로, 모든 사용자가 변경할 수 있는 불필요한 World Writable 파일 및 디렉터리 권한이 존재하는지 점검 ○ Crontab에 정의된 작업에서 실행 또는 참조하는 파일에 others 쓰기 권한이 있는 경우, 파일 내용을 수정하여 악의적인 작업의 수행이 가능하므로 해당 파일 권한의 적절성을 점검
SRV 087	WST 062	o	o	o	o							5.3.1 보안 관리	설치된 C 컴파일러 권한 설정 적절성	3	
SRV 090	WST 063					o						5.3.1 보안 관리	불필요한 원격 레지스트리 서비스 비활성화	5	
SRV 091	WST 064	o	o	o	o							5.3.1 보안 관리	불필요하게 SUID, SGID bit가 설정된 파일 제거	4	
SRV 092	WST 065	o	o	o	o	o						5.3.1 보안 관리	사용자 홈 디렉터리 경로 및 권한 설정 적절성	4	
SRV 093	WST 066	o	o	o	o							5.3.1 보안 관리	불필요한 world writable 파일 제거	4	
SRV 094	WST 067	o	o	o	o							5.3.1 보안 관리	Crontab 참조파일 권한 설정 적절성	4	

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 095	WST 068	o	o	o	o							5.3.1 보안 관리	존재하지 않는 소유자 및 그룹 권한을 가진 파일 또는 디렉터리 제거	4	o 사용하지 않는 디렉터리나 파일의 존재는 시스템 자원의 낭비 및 관리의 부재가 발생할 수 있으므로, 불필요한 계정이 삭제된 이후 해당 계정이 생성한 디렉터리 및 파일 등이 서버에 불필요하게 남아 있는지 점검
SRV 096	WST 069	o	o	o	o							5.3.1 보안 관리	사용자 환경파일의 소유자 또는 권한 설정 적절성	4	o 사용자 shell 환경 파일에 others 권한이 부여되어 있으면 사용자 정보가 유출되거나 다른 공격에 활용될 수 있으므로, 관련 파일에 대한 권한 설정의 적절성을 점검
SRV 097	WST 070				o							5.3.1 보안 관리	FTP 서비스 디렉터리 접근권한 설정 적절성	4	o FTP 홈 디렉터리에 Everyone 그룹 접근 허용과 같이 불필요한 권한이 부여되어있는 경우 비인가 접근 위험이 존재하기 때문에, FTP 홈 디렉터리의 접근 권한 설정 적절성을 점검
SRV 101	WST 071				o							5.3.1 보안 관리	불필요한 예약된 작업 제거	3	o 미리 설정해둔 프로그램을 실행할 수 있는 예약 작업은 시작프로그램과 더불어 공격자가 악성코드 설치 등에 자주 활용하는 경로이므로 예약 작업 목록에 의심스러운 작업이 존재하는지 점검
SRV 103	WST 072				o							5.3.1 보안 관리	LAN Manager 인증 수준 적절성	3	o Lan Manager 인증 수준 설정을 통해 네트워크 로그온에 사용할 Challenge/Response 인증 프로토콜의 보안 강도를 설정할 수 있음. 이 설정은 클라이언트가 사용하는 인증 프로토콜 수준, 협상된 세션 보안 수준, 서버가 사용하는 인증 수준에 영향을 주기 때문에 네트워크 로그온을 사용하는 경우 보다 안전한 인증을 위한 NTLMv2 사용 설정 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 104	WST 073					o						5.3.1 보안 관리	보안 채널 데이터 디지털 암호화 또는 서버 기능 설정 적절성	3	- o 보안 채널 데이터 디지털 암호화 또는, 서버 설정을 통해 도메인 구성원이 시작한 모든 보안 채널 트래픽의 서명과 암호화 여부를 설정함. 인증 트래픽 끼어들기 공격, 재전송 공격 및 기타 유형의 네트워크 공격으로부터 보호하기 위해 Windows는 NetLogon 보안 통신 채널을 만들어 컴퓨터 및 사용자 계정 인증을 함. 이 정책을 활성화하면 모든 보안 채널의 서명 또는, 암호화가 협상되지 않는 한 보안 채널이 생성되지 않으며, 비활성화할 경우 모든 보안 채널 트래픽의 암호화 및 서버가 가능할 경우에만 수행하기 때문에 도메인에 가입된 서버에 적절한 보안 설정이 되어 있는지 점검 - o 시작프로그램 목록에 공격자가 악의적으로 설치한 악성 프로그램이나 공격 도구 등이 포함되어 시스템에 피해를 줄 수 있으므로, 시작 프로그램 목록을 수시로 검사하여 불필요하거나 의심스러운 프로그램이 존재하는지 점검
SRV 105	WST 074					o						5.3.1 보안 관리	불필요한 시작프로그램 제거	3	o 로그에 대한 접근통제가 미흡할 경우, 비인가자가 로그에서 정보를 획득하거나 로그 자체를 변조할 수 있는 위험이 존재하므로, 로그에 대한 접근 권한의 적절성을 점검
SRV 108	WST 075	o	o	o	o	o						5.3.1 보안 관리	로그에 대한 접근통제 및 관리 적절성	3	o 시스템 문제 발생 시 원활한 원인 파악/문제 해결 등을 위해서 각종 보안 로그가 저장 및 관리되어야 하며, 특히 인증 관련이나 중요 이벤트 로그가 남도록 설정되었는지 점검
SRV 109	WST 076	o	o	o	o	o						5.3.1 보안 관리	시스템 주요 이벤트 로그 설정 적절성	3	o Cron 서비스 실행에 대한 로깅 미설정 시 비인가자에 의한 시스템 행위를 추적할 수 없으므로 적절한 로깅 설정이 되어있는지 점검
SRV 112	WST 077	o	o	o	o	o						5.3.1 보안 관리	Cron 서비스 로깅 설정 적절성	2	o 각종 공격이나 시스템 오류에 대해 원활히 추적이 가능하려면, 로그에 대한 관리와 분석이 중요하므로 정기적으로 로그에 대한 검토 및 보고가 이루어지고 있는지 점검
SRV 115	WST 078	o	o	o	o	o						5.3.1 보안 관리	로그의 정기적 검토 및 보고 수행 여부	4	

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 116	WST 079					o						5.3.1 보안 관리	“보안 감사를 수행할 수 없는 경우, 즉시 시스템 종료” 기능 비활성화	5	보안 감사 로그 불가 시 시스템 종료가 설정되어 있으면 보안 감사 로그가 가독처거나 기타 여러 등의 이유로 로그를 기록하지 못할 경우 시스템이 재부팅되어 서비스 가용성의 문제가 발생할 수 있으므로 적절한 보안설정을 적용하여 운영하고 있는지 점검
SRV 118	WST 080	o	o	o	o	o	o	o	o	o	o	5.3.3 패치 관리	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	- 공개된 취약점에 의한 침해를 방지하고, 시스템에 대한 안전성 향상을 위해 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행 (또는 보호방안 수립) 여부를 점검 - 취약한 버전의 웹 서비스(WEB/WAS) 사용 여부 등을 점검 ※ 예외 사항: 네트워크에 연결되지 않은 오프라인 서버는 별도 내부 기준을 마련하여 관리
SRV 119	WST 081					o						5.3.3 패치 관리	백신 프로그램 업데이트 적용 여부	5	지속적으로 기존에 없던 신종 악성코드가 개발 및 배포되는 위협이 존재하므로, 악성코드 정보에 대한 주기적인 업데이트가 적절하게 이루어지고 있는지 점검 ※ 예외 사항: 네트워크에 연결되지 않은 오프라인 서버는 별도 내부 기준을 마련하여 관리
SRV 121	WST 082	o	o	o	o							5.3.1 보안 관리	root 계정의 PATH 환경변수 설정 적절성	5	- 사용자가 특정 명령어를 실행할 때 PATH에 지정된 디렉터리를 검색하여 해당 명령어를 찾기 때문에, 관리자의 PATH 환경변수에 현재 디렉터리 또는 알 수 없는 디렉터리가 포함되지 않았는지 점검 - 이 필요함. PATH에 현재 디렉터리 또는 임의의 디렉터리가 포함되어 있고 실행할 명령(예 : ls, cd 등)과 동일한 이름을 가진 악성 프로그램이 해당 디렉터리에 숨겨져 있다면 실행시키고자 했던 원래의 프로그램 대신 악성 프로그램이 실행되어 시스템이 침해 당할 수 있는 위협이 존재하므로, 시스템의 PATH 설정이 적절하지 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 122	WST 083	o	o	o	o							5.3.1 보안 관리	umask 설정 적절성	3	- o umask 값은 신규 파일이나 디렉터리 생성 시 기본으로 설정되는 권한을 결정하는 값으로, umask 설정에 따라 특정 사용자가 새로운 파일 또는 디렉터리를 생성했을 때 다른 사용자에게 의도치 않은 접근 권한이 부여될 가능성이 존재하므로 적절한 umask 값이 설정되었는지 점검 - o 최종 로그인한 사용자 계정이 로그인 창에 표시되도록 설정된 경우, 해당 계정의 계정이 존재한다는 정보가 노출될 수 있고, 이후 추가적인 계정 탈취 시도가 발생할 수 있기 때문에 해당 설정이 적절하게 설정되었는지 점검
SRV 123	WST 084				o							5.3.1 보안 관리	최종 로그인 사용자 계정 노출 방지 여부	3	o 화면 보호기 설정이 되어 있지 않으면, 관리자가 자리를 비운 사이에 임의의 사용자가 서버에 접근할 수 있는 위험이 존재하므로 적절하게 화면보호기를 설정하였는지 점검
SRV 125	WST 085				o							5.3.1 보안 관리	화면보호기 설정 적절성	4	o 화면 보호기 설정이 되어 있지 않으면, 관리자가 자리를 비운 사이에 임의의 사용자가 서버에 접근할 수 있는 위험이 존재하므로 적절하게 화면보호기를 설정하였는지 점검
SRV 126	WST 086				o							5.3.2 사용자 인증	자동 로그인 방지 설정 여부	4	o 자동 로그인 시스템 시작 시 미리 설정되어 있는 사용자로 자동으로 로그인하도록 하는 기능으로 관리자 권한으로 자동 로그인 설정이 되어있는 경우, 임의의 사용자가 관리자 권한 획득이 가능한 위험이 존재하므로 불필요한 자동 로그인 설정이 존재하는지 점검
SRV 127	WST 087	o	o	o	o	o						5.3.2 사용자 인증	로그인 실패 횟수에 따른 접속 제한 설정	4	o 계정 비밀번호에 대한 무작위 대입 공격으로 비인가자가 계정 정보를 탈취할 위험이 존재하므로 로그인 입력 횟수 제한 등의 임계값 설정 여부를 점검
SRV 128	WST 088				o							5.3.1 보안 관리	NTFS 파일 시스템 사용 여부	3	o FAT 파일 시스템은 NTFS 파일 시스템에 비하여 지원되는 보안 기능이 제한되어 접근 통제에 어려움이 존재하므로 보다 강화된 보안 기능을 지원하는 NTFS 파일시스템 사용 여부를 점검
SRV 129	WST 089				o							5.3.1 보안 관리	백신 프로그램 설치 여부	5	o 악성코드 감염 시 정보 유출/삭제 등 뿐만 아니라 악성코드 확산 등의 위험성이 있으므로, 악성코드 감염 대비 및 치료 수행을 위한 백신 프로그램의 설치 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 131	WST 090	o	o	o	o							5.3.1 보안 관리	SU 명령 사용가능 그룹 제한 설정 적절성	3	- o su(set user or superuser or switch user) 명령은 로그아웃하지 않고 다른 사용자로 전환할 수 있게 해주는 명령으로, 관리자 비밀번호를 알고 있을 때 이 명령을 통해 관리자 권한을 획득(관리자로 전환) 가능하므로 su 명령을 사용할 수 있는 그룹을 설정하여 해당 그룹에 속한 사용자에게만 명령을 허용하고 있는지 여부를 점검 - o cron은 특정 시간에 특정 작업을 수행할 수 있는 데몬으로 공격에 악용되거나 정보가 노출될 위험이 존재함. 이에 따라 cron 서비스를 이용할 수 있는 계정을 정의하는 방식 등의 접근 통제를 수행하고 있는지 점검
SRV 133	WST 091	o	o	o	o							5.3.1 보안 관리	Cron 서비스 사용 계정 제한 설정 적절성	3	o cron은 특정 시간에 특정 작업을 수행할 수 있는 데몬으로 공격에 악용되거나 정보가 노출될 위험이 존재함. 이에 따라 cron 서비스를 이용할 수 있는 계정을 정의하는 방식 등의 접근 통제를 수행하고 있는지 점검
SRV 134	WST 092				o							5.3.1 보안 관리	스택 영역 실행 방지 설정 여부	2	o 스택 영역에서의 실행이 가능한 경우, “stack smashing” 등의 버퍼 오버플로우 공격에 취약하므로, 스택 영역 실행 기능에 대한 보안설정의 적절성을 점검
SRV 135	WST 093				o	o						5.3.1 보안 관리	TCP 보안 설정 여부	2	o 하이재킹 공격이나 IP Spoofing, DoS 와 같은 네트워크 공격 위협을 감소시키기 위해, TCP 연결의 보안을 강화하는 설정이 활성화되어있는지 점검 ※ 예외 사항: 네트워크에 연결되지 않은 오프라인 서버(rootCA 등)
SRV 136	WST 094					o						5.3.1 보안 관리	로그온 단계에서 “시스템 종료” 기능 비활성화	5	o 로그온 단계에서 “시스템 종료”가 허용될 경우, 로그온을 하지 않더라도 시스템 종료가 가능하여 비인가 서버 종료 위험 등이 존재하므로 로그온 단계에서의 시스템 종료 기능 비활성화 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 137	WST 095					o						5.3.1 보안 관리	네트워크 서비스 접근 권한 적절성	3	○ 네트워크에서 이 컴퓨터 액세스 정책은 다수의 네트워크 프로토콜(SMB 기반 프로토콜, NetBIOS, CIFS(Common Internet File System) 및 COM+ 등) 접근에 필요한 정책으로 해당 설정이 미흡할 경우, 임의의 사용자 또는 그룹이 네트워크 서비스로 접근이 가능하여 시스템 침해 위험이 증가하므로 접근 권한 설정의 적절성을 점검
SRV 138	WST 096					o						5.3.1 보안 관리	백업 및 복구 권한 설정 적절성	2	○ 백업 및 복구 권한은 해당 권한을 활용하여 실제 객체에 대해 필요한 접근 권한을 우회하여 정보를 획득하거나 시스템 무결성을 침해할 위험이 존재하므로, 불필요한 사용자 및 그룹에게 부여된 권한이 존재하는지 점검
SRV 139	WST 097					o						5.3.1 보안 관리	시스템 자원 소유권 변경 권한 설정 적절성	3	○ 시스템 자원(Active Directory 개체, 프린터, 레지스트리 키, 서비스 등)은 서비스 운영에 영향을 주기 때문에 관리자 또는 관리자 그룹이 아닌, 일반 사용자가 권한을 보유하면 데이터 및 자원 보호 정책 설정 등의 인가되지 않은 변경이 발생할 위험이 존재하므로 해당 정책의 설정 적절성을 점검
SRV 140	WST 098					o						5.3.1 보안 관리	이동식 미디어 포맷 및 꺼내기 허용 정책 설정 적절성	4	○ 이동식 미디어(USB 등) 포맷 및 꺼내기 허용 권한이 불필요한 사용자에게 권한이 주어질 경우 비인가가 데이터 복사/삭제 등의 행위가 발생할 위험이 증가하므로 해당 보안 정책의 설정 적절성을 점검
SRV 142	WST 099	o	o	o	o							5.3.1 보안 관리	중복 UID가 부여된 계정 제한 여부	4	○ 시스템에 중복 UID가 존재하는 경우, 접근통제와 감사 추적의 어려움이 발생할 수 있으므로, 동일한 UID가 부여된 계정의 존재 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 144	WST 100	○	○	○	○							5.3.1 보안 관리	/dev 경로에 불필요한 파일 제거	4	○ 디바이스가 존재하지 않거나 이름이 잘못 입력된 경우 시스템은 /dev 디렉터리에 계속해서 파일이 생성되거나, 에러가 발생할 가능성이 존재함. 또한 /dev 디렉터리는 악의적인 공격자가 rootkit을 숨기는 경로로 사용되는 경우도 있음. 따라서 파일 시스템 손상 및 장애 등의 문제를 방지하기 위해 실제 존재하지 않는 디바이스 파일이 해당 경로에 있는지 점검
SRV 147	WST 101	○	○	○	○	○						5.3.1 보안 관리	불필요한 네트워크 모니터링 서비스 비활성화	3	○ 네트워크 모니터링 서비스는 시스템을 모니터링 하기 위한 서비스로서 불필요하게 운영할 경우 정보노출 위험이 존재하므로 불필요한 네트워크 모니터링 서비스가 구동 중인지에 대한 점검
	WST 102	○	○	○	○	○	○	○	○	○		5.3.1 보안 관리	웹 서비스 정보 노출 방지 여부	3	○ 웹 서버 종류 및 버전 등에 대한 정보가 노출될 경우 공격자가 기타 공격에 활용할 가능성이 있으므로 적절한 보안 설정이 되었는지 점검
SRV 149	WST 103				○							5.3.1 보안 관리	디스크 볼륨 암호화 적용 여부	4	○ 디스크 볼륨이 암호화 되어 있지 않는 경우, 비인가자가 데이터에 물리적으로 직접 접근하여 데이터를 획득할 위험이 존재하므로 암호화 여부를 점검
SRV 150	WST 104				○							5.3.2 사용자 인증	로컬 로그인 허용 계정 제한 여부	3	○ 로컬 로그인이 불필요한 계정의 로컬 로그인이 허용된 경우 해당 계정이 탈취되었을 때 추가적인 침해 행위를 수행하는 등 피해가 커질 가능성이 존재하기 때문에, 불필요하게 로컬 로그인이 허용된 계정이 존재하는지 점검
SRV 151	WST 105				○							5.3.1 보안 관리	익명 SID/이름 변환 설정 제한 여부	3	○ 익명 SID/이름 변환 허용 정책 설정 시 잘 알려진 Administrator SID를 요청하여 해당 계정의 실제 이름을 알아낼 수 있으며 암호 추측 공격을 통해 계정 권한을 획득할 위험이 존재하므로 해당 정책의 활성화 여부를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 152	WST 106					o						5.3.1 보안 관리	원격터미널 접속 가능한 사용자 그룹 제한 여부	3	- 원격 서비스는 서버 관리를 위한 서비스로 접근 가능한 그룹이나 계정을 제한하지 않을 경우 임의의 사용자가 서버에 접근하여 정보 변경, 유출 등이 발생할 위험이 있으므로 해당 설정을 점검 - Telnet 서비스는 Password 인증 방식 사용 시 데이터를 평문으로 송수신하기 때문에 인증 시 아이디/패스워드가 노출될 수 있는 위험이 존재하므로 가급적 사용하지 않는 것이 바람직하여, 업무와 관계없이 불필요하게 활성화되어 있는지 점검
SRV 158	WST 107	o	o	o	o	o						5.3.1 보안 관리	불필요한 Telnet 서비스 비활성화	3	
SRV 161	WST 108	o	o	o	o	o						5.3.1 보안 관리	ftputers 파일의 소유자 및 권한 설정 적절성	3	ftputers 파일에서 FTP 서비스에 접근 가능한 사용자 계정을 관리 할 수 있으므로, 해당 파일에 대한 권한 설정의 적절성을 점검
SRV 163	WST 109	o	o	o	o	o						5.3.1 보안 관리	시스템 사용 주의사항 출력	1	비인가자의 부적절한 로그인 권한 획득을 사전에 방지하기 위하여 로그인 시 경고 및 시스템 사용 주의사항 등의 문구를 표시하고 있는지 점검
SRV 164	WST 110	o	o	o	o	o						5.3.1 보안 관리	구성원이 존재하지 않는 GID 제거	2	계정이 존재하지 않는 그룹 권한(GID)이 존재할 경우, 해당 그룹이 소유한 파일이 비인가자에게 노출될 위험이 존재하므로 소속된 계정이 없는 GID가 존재하는지 점검
SRV 165	WST 111	o	o	o	o	o						5.3.1 보안 관리	불필요하게 Shell이 부여된 계정 제거	1	로그인이 불필요한 계정들에 /bin/false 등을 부여하여 계정 탈취 시의 피해를 감소시키기 위한 설정을 적용하고 있는지 여부를 점검
SRV 166	WST 112	o	o	o	o	o						5.3.1 보안 관리	불필요한 숨김 파일 또는 디렉터리 제거	1	악의적인 목적으로 생성한 파일 혹은 디렉터리를 숨김파일로 저장 하는 경우가 많으므로, 숨김 파일 및 디렉터리 중 침해 행위로 인해 생성된 파일이 존재하는지 점검
SRV 170	WST 113	o	o	o	o	o						5.3.1 보안 관리	SMTP 서비스 정보 노출 방지 여부	1	SMTP 접속 시 노출되는 배너에서 공격자가 유용한 정보를 획득할 가능성이 존재하므로, 불필요하게 노출되는 정보 유무를 점검

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 171	WST 114	0	0	0	0	0						5.3.1 보안 관리	FTP 서비스 정보 노출 방지 여부	1	FTP 접속 시 노출되는 배너에서 공격자가 유용한 정보 획득할 가능성이 존재하므로, 불필요하게 노출되는 정보 존재 여부를 점검
SRV 172	WST 115					0						5.3.1 보안 관리	불필요한 시스템 자원 공유 제거	3	Windows의 공유 기능은 폴더, 디스크 드라이브, 프린터 등을 공유하여 다른 사용자와 함께 사용할 수 있는 서비스이지만, 불필요한 공유의 활성화는 여러가지 공격의 목표가 될 가능성이 존재하므로, 불필요한 공유의 존재 여부를 점검
SRV 173	WST 116	0	0	0	0	0						5.3.1 보안 관리	DNS 서비스 동적 업데이트 설정 적절성	3	DNS(Domain Name Service) 서비스의 동적 업데이트 기능이 불필요하게 활성화되어 있고 신뢰할 수 있는 출처 이외에도 업데이트가 가능한 경우, 악의적인 사용자에 의해 DNS 레코드가 변조될 위험이 존재하므로, 해당 기능의 설정 적절성을 점검
SRV 174	WST 117	0	0	0	0	0						5.3.1 보안 관리	불필요한 DNS 서비스 비활성화	3	DNS(Domain Name Service)는 도메인 이름과 IP간의 변환을 위한 서비스로, 불필요하게 운영할 경우 잠재적인 보안 취약점으로 인한 공격의 경로가 될 수 있으므로 해당 서비스가 업무와 관계없이 활성화되어 있는지 여부를 점검
SRV 175	WST 118	0	0	0	0	0						5.3.1 보안 관리	시간 동기화를 위한 NTP 설정	2	NTP는 컴퓨터 시스템 간에 시간 동기화를 위한 네트워킹 프로토콜로, 인증 무결성 및 이벤트 발생 시 정확한 로그 분석에 정확한 시간 동기화가 필요하므로 NTP 설정 여부를 점검 ※ 네트워크에 연결되지 않은 오프라인 서버는 수동 설정
SRV 177	WST 119	0	0	0	0	0						5.3.1 보안 관리	sudo 명령어 접근 권한 설정 적절성	3	sudo 명령어의 접근 권한을 느슨하게 설정할 경우 악성코드·침해 계정이 곧바로 root 권한을 획득할 수 있어 권한 상승, 사고 확산, 추적 불가, 규제 위반으로 이어질 수 있으므로 접근 권한이 적절하게 관리되고 있는지 확인

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 178	WST 120					o						5.3.2 사용자 인증	개인 키 사용 시 passphrase 설정 여부	4	SSH 키 생성 시 passphrase를 사용하지 않고 생성할 경우, 해당 키 파일 유출 시 별도의 추가 인증 없이 누구나 로그인 가능해지므로 이러한 상황을 방지하기 위해 키 파일의 passphrase 설정 여부를 확인
	WST 121	o	o	o	o	o	o	o				5.3.1 보안 관리	웹 서비스 불필요한 프로세스 설정 제한 여부	4	불필요한 Proxy 설정을 제한하지 않는 경우 공격자가 Proxy 서버를 이용하여 원래 의도되지 않은 방식으로 시스템에 접근하거나 시스템 관련 정보가 유출될 위험이 존재하므로 불필요한 Proxy 설정을 제한하는지 여부를 확인
	WST 122	o	o	o	o	o	o	o	o	o		5.3.1 보안 관리	웹 서비스 불필요한 SSI(Server Side Includes) 기능 비활성화	3	SSI의 설정 및 사용을 잘못된 경우 RCE, 파일 노출, 내부 경로/서비스 노출, 캐시 혼선 같은 보안·운영 리스크가 생기므로 기본적으로 사용하지 않도록 설정되어 있는지 확인
	WST 123	o	o	o	o	o	o	o	o	o		5.3.1 보안 관리	웹 서비스 기본 에러 페이지 노출 방지 여부	2	웹 서비스의 기본 에러 페이지를 사용할 경우 스택 트레이스, 버전 정보 등 민감 정보가 유출될 수 있으므로 별도로 에러 페이지를 설정하였는지 여부를 점검
	WST 124	o	o	o	o	o	o	o	o	o		5.3.1 보안 관리	웹 서비스 부적절한 LDAP 알고리즘 설정 제한 여부	3	LDAP/LDAPS 연동 시 취약/구식 알고리즘을 허용할 경우 인증 우회 및 중간자 공격 위험이 증가하므로 LDAP 연결 중 취약/구식 알고리즘을 이용한 설정이 존재하는지 확인
	WST 125	o	o	o	o	o	o	o	o	o		5.3.1 보안 관리	웹 서비스 독립된 업로드 경로 및 권한 설정 여부	3	업로드 파일을 웹 루트 내 공용 경로에 저장하거나 실행·읽기 권한을 과도하게 부여하면 웹shell 실행, 권한상승, 민감정보 노출 위험이 생기므로 별도의 업로드 경로 사용 및 권한 설정을 확인

SRV	WST	A	B	C	D	E	F	G	H	I	J	통제 구분	평가항목	위험도	상세설명
SRV 179	WST 126											5.3.3 패치 관리	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	4	○ 서비스 지원이 종료된(EoS) 버전을 사용하는 경우, 알려진 취약점 또는 신규로 발견되는 취약점으로 부터 발생하는 보안위협에 대처할 수 없는 위험이 존재하므로 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검 ※ 장비 교체 계획을 수립하고 보고를 마친 경우 취약으로 반영하고, 위험 수용으로 관리 ※ 예외 사항: 네트워크에 연결되지 않은 오프라인 서버는 별도 내부 기준을 마련하여 관리

❖ 평가대상

A	B	C	D	E	F
ORACLE	MSSQL	MYSQL	PostgreSQL	MariaDB	Tibero

❖ 평가기준

평가항목 ID	클라 우드	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
DBM-001	○	○	○	○	○	○	○	5.3.2 사용자 인증	취약하게 설정된 비밀번호 제거	4	- 계정의 비밀번호가 취약하게 설정된 경우, 비인가자가 비밀번호를 유추하거나 무작위 대입 공격을 통해 계정을 탈취하여 데이터베이스에 접근할 수 있는 위험이 존재하므로 취약하게 설정된 비밀번호가 있는지 여부를 점검 ※ 클라우드 기반 MSSQL, PostgreSQL은 제외
DBM-003	○	○	○	○	○	○	○	5.3.2 사용자 인증	불필요하거나 관리되지 않는 계정 제거	4	업무상 사용되지 않는 계정 등 불필요한 계정이 존재할 경우, 비인가자가 해당 계정 탈취를 통해 데이터베이스에 접근할 수 있는 위험이 존재하므로 불필요한 계정이 존재하는지 여부를 점검
DBM-004	○	○	○	○	○	○	○	5.3.1 보안 관리	불필요한 관리자 계정 제거	5	관리자 권한이 업무상 불필요하게 부여된 계정이 존재할 경우, 해당 계정을 통해 비인가자가 관리자 권한을 도용할 수 있는 위험이 존재하므로 업무상 불필요하게 관리자 권한이 부여된 계정이 존재하는지 여부를 점검
DBM-005	○	○	○	○	○	○	○	5.3.1 보안 관리	데이터베이스 내 중요정보 안전한 암호화 적용 여부	5	데이터베이스 내에 주민등록번호, 비밀번호 등 중요 정보가 암호화되지 않은 평문 형태 또는 안전하지 않은 암호화가 적용된 암호문으로 저장되어 있는 경우, 중요 정보가 외부로 유출될 수 있는 위험이 존재하므로 중요 정보를 안전한 암호화 알고리즘을 사용하여 보관하고 있는지 점검

평가항목 ID	클라우드	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
DBM-006	○	○	○	○	○	○	○	5.3.2 사용자 인증	로그인 실패 횟수에 따른 접속 제한 설정	3	- 계정의 로그인 시도에 대한 제한이 없는 경우, 비인가자가 비밀번호의 무작위 대입 공격을 통해 계정을 탈취하여 데이터베이스에 접근할 수 있는 위험이 존재하므로 계정의 로그인 실패 횟수에 따라 일시 또는 영구적으로 접속을 제한하고 있는지 여부를 점검 - 비밀번호의 복잡도 설정이 미흡한 경우, 비인가자가 비밀번호를 유추하거나 무작위 대입 공격을 통해 계정을 탈취하여 데이터베이스에 접근할 수 있는 위험이 존재하므로 비밀번호 설정 시 복잡도 정책이 적절하게 설정되어 있는지 여부를 점검
DBM-007	○	○	○	○	○	○	○	5.3.2 사용자 인증	비밀번호 복잡도 설정	5	장기간 비밀번호가 변경되지 않은 계정이 존재할 경우, 비인가자에 의해 계정의 비밀번호가 탈취될 수 있는 위험이 증가하므로 회사 내부 정책에 따라 주기적으로 비밀번호 변경을 실시하고 있는지 여부를 점검
DBM-008	○	○	○	○	○	○	○	5.3.2 사용자 인증	비밀번호 변경 주기 충족 여부	4	사용되지 않는 불필요한 세션이 관리되지 않을 경우, 세션 도용을 통한 비인가 접근, 다수의 세션 생성을 통한 서비스 장애 등의 위험이 존재함에 따라, 자동 세션종료 설정을 통해 사용되지 않는 세션 종료 여부를 점검
DBM-009	○	○	○	○	○	○	○	5.3.1 보안 관리	사용되지 않는 세션 종료 여부	3	데이터베이스에서 수행한 주요 행위를 기록 및 백업하지 않는 경우, 장애 및 침해사고 발생 시 이를 효과적으로 대처할 수 없으므로 로그 수집 및 백업이 적절하게 이루어지고 있는지 점검
DBM-011	○	○	○	○	○	○	○	5.3.1 보안 관리	감사 로그 수집 및 백업 여부	5	Listener Control Utility(Isnrnct) 보안 설정이 미흡한 경우, 비인가자가 TNS(Transparent Network Substrate) Listener 에 접근하여 서비스를 중지하는 등의 위험이 존재하므로 Listener Control Utility(Isnrnct)의 보안 설정 여부를 점검
DBM-012	○	○	○	○	○	○	○	5.3.1 보안 관리	Listener Control Utility(Isnrnct) 보안 설정 여부	5	업무상 불필요한 원격 접속을 허용하는 경우, 이를 통해 비인가자가 원격으로 데이터베이스에 접근할 수 있는 위험이 존재하므로 원격 접속에 대한 통제 여부를 점검
DBM-013	○	○	○	○	○	○	○	5.3.1 보안 관리	원격 접속에 대한 접근 제어 여부	5	* 클라우드에서 DB 인스턴스 사용 시 퍼블릭 액세스 옵션 비활성화 여부 점검

평가항목 ID	클라 우드	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
DBM-014	○	○						5.3.1 보안 관리	취약한 운영체제 역할 인증 기능(OS_ROLES, REMOTE_OS_ROLES) 비활성화	4	○ 운영체제 역할 인증 기능(OS_ROLES, REMOTE_OS_ROLES)을 사용하는 경우, 비인가된 OS 사용자 및 그룹이 데이터베이스에 접근하여 데이터베이스 역할(Role)을 제어할 수 있으므로 해당 기능이 사용중으로 설정되어 있는지 점검 ○ Public Role에 응용프로그램 관리 권한, DBA 권한 등이 존재할 경우, 해당 업무와 직접적인 연관이 없는 사용자에게 동일한 권한이 부여될 수 있는 위험이 존재하므로 불필요한 권한이 Public Role에 부여되어 있는지 점검 ○ 공개된 취약점에 의한 침해를 방지하고, 시스템에 대한 안전성 향상을 위해 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행(또는 보호방안 수립) 여부를 점검 ※ 예외 사항: 네트워크에 연결되지 않은 오프라인 서버는 별도 내부 기준을 마련하여 관리 ○ 시스템 테이블에 접근할 수 있는 권한이 업무상 불필요하게 부여된 경우, 비인가자가 이를 통하여 시스템의 주요 정보를 획득하거나 주요 데이터베이스 설정 변경할 수 있는 위험이 존재하므로 인가되지 않은 사용자에게 시스템 테이블 접근 권한이 부여되어 있는지 점검
DBM-015	○	○	○	○	○		○	5.3.1 보안 관리	Public Role에 불필요한 권한 제거	4	
DBM-016	○	○	○	○	○	○	○	5.3.3 패치 관리	최신 보안패치와 벤더 권고사항 적용 여부	4	
DBM-017	○	○	○	○	○	○	○	5.3.1 보안 관리	업무상 불필요한 시스템 테이블 접근 권한 제거	5	
DBM-019	○	○	○	○	○	○	○	5.3.2 사용자 인증	이전 비밀번호 재사용 요구사항 충족 여부	3	
DBM-020	○	○	○	○	○	○	○	5.3.2 사용자 인증	사용자별 계정 분리	3	
DBM-021		○						5.3.1 보안 관리	업무상 불필요한 ODBC/OLE-DB 데이터 소스 및 드라이버 제거	3	○ 업무상 불필요한 ODBC, OLE-DB 데이터 소스 및 드라이버가 존재하는 경우, 이를 통해 비인가자가 데이터베이스에 접근할 가능성이 존재하므로 해당 ODBC, OLE-DB 데이터 소스 및 드라이버를 제거하였는지 여부를 점검

평가항목 ID	클라 우드	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
DBM-022		○	○	○	○	○	○	5.3.1 보안 관리	설정 파일 및 중요정보가 포함된 파일의 접근 권한 설정 적절성	3	○ 데이터베이스 주요 설정 파일 및 중요정보(데이터베이스 비밀번호, 로그 등)가 포함된 파일의 접근 권한이 적절하지 않은 경우, 비인가자가 이를 수정/삭제 할 수 있는 위험이 있으므로 해당 파일들의 접근권한이 적절한지 여부를 점검 ○ 운영상 불필요하게 WITH GRANT OPTION 이 설정된 권한이 있는 경우, 해당 권한을 가진 사용자가 다른 사용자에게 동일한 권한을 부여할 수 있으므로 불필요하게 WITH GRANT OPTION 옵션이 설정되어 있는 권한이 있는지 점검
DBM-024	○	○	○	○	○	○	○	5.3.1 보안 관리	불필요하게 WITH GRANT OPTION 옵션이 설정된 권한 제거	3	○ 서비스 지원이 종료된(EoS) 버전을 사용하는 경우, 알려진 취약점 또는 신규로 발견되는 취약점으로 부터 발생하는 보안위협에 대처할 수 없는 위험이 존재하므로 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검 ※ 장비 교체 계획을 수립하고 보고를 마친 경우 취약으로 반영하고, 위험수용으로 관리 ※ 예외 사항: 네트워크에 연결되지 않은 오프라인 서버는 별도 내부 기준을 마련하여 관리
DBM-025	○	○	○	○	○	○	○	5.3.3 패치 관리	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	4	
DBM-026		○	○	○	○	○	○	5.3.1 보안 관리	데이터베이스 구동 계정의 umask 설정 미흡	2	○ 데이터베이스 구동 계정이 파일(로그 등) 생성 시 기본적으로 적용되는 권한이 적절하지 않은 경우, 비인가자가 데이터베이스의 주요 파일들에 접근 및 수정 가능한 위험이 존재하므로 해당 파일들이 적절한 권한을 가지고 생성하도록 설정하였는지 여부를 점검
DBM-028	○	○	○	○	○	○	○	5.3.1 보안 관리	업무상 불필요한 데이터베이스 Object 제거	1	○ 업무상 불필요한 데이터베이스 Object가 존재하는 경우, 비인가자가 이를 이용하여 데이터베이스에 접근할 수 있는 위험이 있으므로 업무상 불필요한 데이터베이스 Object가 존재하는지 점검
DBM-029	○	○						5.3.1 보안 관리	데이터베이스의 자원 사용 제한 설정 미흡	1	○ Oracle 프로파일 옵션 중 자원 사용 제한 설정(RESOURCE_LIMIT)이 활성화 되어있지 않은 경우, 비밀번호 관련 제한 설정을 제외한 프로파일 제한 옵션 값들이 동작하지 않으므로 이를 점검

평가항목 ID	클라 우드	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
DBM-030	○	○					○	5.3.1 보안 관리	Audit Table에 대한 접근 제어 미흡	1	○ 감사 로그가 저장되는 Audit Table에 대하여 일반 사용자의 수정/삭제 권한이 존재할 경우, 해당 계정을 이용해 비인가자가 감사 로그를 수정/삭제할 수 있는 위험이 존재하므로 Audit Table의 수정/삭제 권한을 관리자 계정으로 제한하는지 여부를 점검
DBM-031			○					5.3.1 보안 관리	SA 계정에 대한 보안설정 미흡	3	○ SA계정은 MS-SQL(SQL SERVER)에서 기본적으로 제공하는 관리자 계정으로서 비인가자에게 탈취당할 경우, 데이터베이스의 모든 권한을 탈취 당할 위험이 있으므로 해당 계정이 활성화 되어있는 경우 적절한 보안 정책이 적용되고 있는지 여부를 점검
DBM-032	○			○				5.3.1 보안 관리	데이터베이스 접속 시 통신구간에 비밀번호 평문 노출	3	○ 데이터베이스 접속시 통신구간에서 계정의 비밀번호가 평문으로 노출되는 경우, 네트워크 스니핑을 통해 비인가자가 계정 정보를 탈취할 수 있는 위험이 존재하므로 데이터베이스 접속시 비밀번호가 평문으로 노출되는지 여부 점검
DBM-033				○				5.3.1 보안 관리	DB 이중화 구성 시 비밀번호 평문 노출	4	○ 데이터베이스 이중화 구성 시, 안전하지 않은 방식으로 연결할 경우 비밀번호가 평문으로 노출*되는 위험이 존재함에 따라 데이터베이스의 이중화 설정의 적정성을 점검 * 파일 또는 테이블에 Master 데이터베이스 접속 비밀번호 평문 저장
DBM-034		○		○	○	○	○	5.3.1 보안 관리	DBMS 서비스 구동 권한 적절성	3	○ DBMS가 root 계정 또는 root 권한으로 구동될 경우, DB 취약점·오류가 곧바로 전체 OS 권한 탈취로 이어져 피해 범위가 확장될 수 있으므로 서비스 구동 권한이 적절하게 설정되어 있는지 점검
DBM-035	○		○					5.3.1 보안 관리	xp_cmdshell 사용 비활성화	5	○ xp_cmdshell은 MS-SQL에서 제공하는 확장 프로시저로, SQL 쿼리를 통해 윈도우 운영체제의 명령어를 실행할 수 있는 기능이 있어 해킹 등에서 악용될 수 있기에 사용이 제한되어 있는지 확인
DBM-036	○		○					5.3.1 보안 관리	Registry Procedure 접근 권한 설정 적절성	5	○ 레지스트리 확장 프로시저의 임의 접근을 허가할 경우, 악의적인 사용자가 Windows 레지스트리에 액세스할 수 있어 서버 및 데이터베이스 손상 및 비인가된 접근을 할 위험이 존재하므로 권한 제한 여부를 확인

네트워크 인프라

❖ 평가기준

평가항목 ID	통제 구분	평가항목	위험도	상세설명
INF-001	5.5.1 보안 관리	네트워크 화선(ISP) 이중화 구성	3	○ 네트워크(ISP) 화선이 단일화 구성되어 있어 화선 장애시 서비스 장애가 발생할 우려가 있으므로 네트워크 화선(ISP)을 이중화하여 구성하고 있는지 점검
INF-002	5.5.1 보안 관리	네트워크 장비 이중화 구성	3	○ 네트워크 장비가 단일장비 구성으로 운영 중 장비 장애시 서비스 장애가 발생할 우려가 있으므로 네트워크 장비를 이중화 구성하고 있는지 점검
INF-003	5.5.1 보안 관리	정보보호시스템 이중화 구성	3	○ 정보보호시스템이 단일장비 구성으로 운영 중 장비 장애시 서비스 장애가 발생할 우려가 있으므로 정보보호시스템을 이중화 구성하고 있는지 점검
INF-004	5.5.1 보안 관리	중요 서버 이중화 구성	3	○ 서버의 단일장비 구성으로 운영 중 장비 장애시 서비스 장애가 발생할 우려가 있으므로 중요서버를 이중화 구성하고 있는지 점검
INF-006	5.5.1 보안 관리	재해 또는 장애발생 시 복구를 위한 별도 구간 확보 여부	3	○ 재해, 장애 등의 비상시를 대비해 재해복구센터 또는 백업센터 등의 네트워크 구간 마련 여부
INF-007	5.5.1 보안 관리	업무 특성별 네트워크 망분리 구성	5	○ 업무 특성별로 네트워크 구간이 분리되지 않을 경우 침해사고 발생 시, 전체 네트워크가 위험에 노출될 가능성이 있으므로 네트워크 구간을 업무 특성별로 적절하게 분리하고 있는지 점검
INF-008	5.5.1 보안 관리	개발/테스트와 운영 네트워크 망분리 구성	5	○ 개발 및 테스트(검증계) 서버의 경우 보안설정의 강도가 운영서버에 비해 낮게 설정될 소지가 있고, 정보보호시스템의 보호범위에서도 벗어나 있는 경우가 있으므로 등 구간을 별도로 분리하여 운영하고 있는지 점검
INF-009	5.5.1 보안 관리	사용자들의 주요 서버구간의로의 접근통제	4	○ 사용자 단말에서 주요서버구간으로 접근통제가 실시되지 않을 경우 허용되지 않은 접근 및 악성코드 등에 노출될 위험이 존재하므로 사용자 단말에서 주요 서버 접근 시 해당 사용자의 권한에 맞는 접속만 허용되도록 통제를 수행하고 있는지 점검
INF-010	5.5.1 보안 관리	분리된 각 네트워크 구간 사이에 접근통제	4	○ 업무 특성에 맞게 분리한 네트워크 구간 사이에 비인가 접근이 발생하지 않도록 최소한의 허용정책을 통해 적절한 접근통제를 수행하고 있는지 점검

평가항목 ID	통제 구분	평가항목	위험도	상세설명
INF-011	5.5.1 보안 관리	보안 정책 미적용 우회 경로 유무 여부	4	○ 분리된 네트워크 구간내 접근통제를 거치지 않는 네트워크 점점의 우회경로가 있는지 점검
INF-012	5.5.1 보안 관리	외부통신망에서 접근이 필요한 구간에 불필요한 접근에 대한 접근통제 여부	5	○ 외부통신망에서 접근이 허용된 DMZ구간 이외에 접근통제가 적절히 수행되지 않아 외부로부터 직접 접근이 가능한 구간 또는 시스템이 있는지 점검
INF-013	5.5.1 보안 관리	내부통신망 공인IP 사용 통제	3	○ 공인IP는 외부에서 직접 접속이 가능하여 부적절한 접근을 허용할 위험이 있으므로 내부통신망에 불필요하게 공인IP가 할당되어 있는지 점검
INF-015	5.5.1 보안 관리	내부구간에 위치한 정보시스템(서버,DB)에 대한 외부통신망 차단 여부	5	○ 내부서버에서 외부통신망에 접속이 가능한 경우 정보유출 또는 바이러스 감염 등에 대한 위험이 존재하므로 내부구간 정보시스템에서 외부로의 허용 여부 점검
INF-016	5.5.1 보안 관리	중요 단말기에서 외부통신망 및 내부통신망(그룹웨어 등)에 대한 접근통제의 적절성	5	○ 중요단말기에서 외부통신망 접속으로 인한 악성코드 감염의 위험이 있으며, 중요정보 유출 또는 파괴의 가능성이 있음
INF-017	5.5.1 보안 관리	장애 인지 및 대응 방안 수립 여부	1	○ 장애 발생시 담당자가 인지하지 못하는 경우 즉각적인 상황파악 및 대처가 어려우므로 모니터링 시스템을 통해 장애 발생에 대한 즉각적인 인지 및 대응 방안이 마련되어 있는지 점검
INF-018	5.5.1 보안 관리	네트워크 구간별 침입탐지시스템 구성의 적절성	4	○ 네트워크 구간별 침입탐지시스템이 없거나 부적절한 위치에 설치되어 있을 경우 침입 시도 및 비정상 트래픽 탐지가 불가능하므로 탐지여외 구간이 있는지 점검
INF-019	5.5.1 보안 관리	외부통신망과 통신을 하는 서버(웹 서버 등)의 DMZ 구성의 적절성	3	○ DMZ구간에 위치해야할 공개용 서버가 내부구간에 위치할 경우 해당 구간 및 전체 구간에 대한 침해가 발생할 수 있으므로 공개용 서버 내부구간 존재여부 점검
INF-020	5.5.1 보안 관리	네트워크 관리시스템의 작업내역, 로그관리 및 사용자권한 설정에 대한 보안설정의 적절성	3	○ 네트워크 관리시스템의 권한 설정이 제대로 되어 있지 않아 중요정보가 비인가자에게 노출될 위험이 있으며, 작업이력 및 로그관리가 제대로 이루어지지 않아 장애발생시 원인 파악이 어려울 수 있음

네트워크 장비

❖ 평가대상

A	B	C	D
CISCO 계열	A10 계열	BROCADE, ALTEON, NOTEL, BIGIP, CITRIX, PIOLINK 계열	3COM, JUNIPER 계열

❖ 평가기준

평가항목 ID	스위치	라우터	A	B	C	D	통제 구분	평가항목	위험도	상세설명
NET-001	○	○	○	○	○	○	5.5.1 보안 관리	네트워크 장비 설정 백업 여부	4	○ 네트워크 장비의 장애, 가동중지 등 비상상황 발생 시 신속하게 시스템의 정상복구가 가능하도록 하기 위함
NET-003	○	○	○	○	○	○	5.5.1 보안 관리	안전한 네트워크 모니터링 서비스 사용 여부	4	○ 네트워크 모니터링 서비스의 보안 설정이 미비할 경우 데이터 변조, 도청 및 중간자 공격으로 시스템 정보 및 상태정보가 유출될 가능성이 존재하므로 프로토콜에 따라 알맞은 보안설정 및 안전한 버전을 적용하여 사용하고 있는지 점검
NET-004	○	○	○	○	○	○	5.5.1 보안 관리	SNMP 커뮤니티 권한 설정 적정성	4	○ SNMP Community String 권한을 RO(Read Only)로 설정하여 비인가자가 Community String을 탈취하여도 네트워크 설정 정보를 변경할 수 없도록 하기 위함
NET-005	○	○	○	○	○	○	5.5.1 보안 관리	SNMP 접근통제(ACL) 설정 여부	5	○ SNMP ACL(Access list)을 설정하여 비인가자의 SNMP 접근을 차단하는 등 네트워크 정보 노출을 제한하기 위함

평가항목 ID	스위치	라우터	A	B	C	D	통제 구분	평가항목	위험도	상세설명
NET-006		○	○		○		5.5.1 보안 관리	외부인터페이스 SNMP 접근 차단 여부	1	○ 네트워크 장비 외부인터페이스에 SNMP 서비스 포트에 대한 ACL(Access list) 차단 설정을 적용하여 비인가자의 접근을 제한하기 위함
NET-007	○	○	○	○	○	○	5.5.2 사용자 인증	Local 사용자 생성 및 권한관리 여부	3	○ 장비 접속 시 Local 사용자를 생성하여 비인가자의 접근을 차단하기 위함
NET-008	○	○	○	○	○	○	5.5.2 사용자 인증	강화된 인증기능(AAA) 사용 여부	3	○ 장비 접속 시 AAA(Authentication Authorization Accounting) 인증 기능을 활성화하여 비인가자의 접근을 차단하기 위함
NET-009	○	○	○	○	○	○	5.5.2 사용자 인증	중복 비밀번호 및 비밀번호 미설정 금지 여부	5	○ 사용자, 관리자 등이 사용하는 비밀번호를 중복으로 사용할 경우 비인가자에 의해 계정정보 유출이 가능함에 따라 비밀번호 호 중복 사용 여부를 점검
NET-010	○	○	○	○	○	○	5.5.2 사용자 인증	enable secret 설정 여부	5	○ 네트워크 장비 설정(Configuration)이 노출될 경우 평문으로 노출되었던 Enable 비밀번호를 암호화 적용하여 비인가자가 쉽게 식별할 수 없도록 하기 위함
NET-011	○	○	○	○	○	○	5.5.2 사용자 인증	안전한 암호화 알고리즘 설정 여부	5	○ 사용자 및 관리자의 비밀번호를 암호화하여 네트워크 장비 설정(Configuration) 파일이 외부로 노출될 경우 비인가자의 장비 내 비밀번호 식별을 어렵게 하기 위함
NET-012	○	○	○	○	○	○	5.5.2 사용자 인증	비밀번호 복잡도 정책 준수 여부	5	○ 비밀번호 복잡도 정책을 준수하여 공격자가 네트워크 장비에 접속 시도 시 접근이 용이하지 않게 하기 위함
NET-013	○	○	○	○	○	○	5.5.1 보안 관리	원격 관리 접근 통제 여부	5	○ 원격에서 네트워크 장비 접근 시 접근이 허가된 사용자 외에 비인가자의 접근을 차단하기 위함

평가항목 ID	스위치	라우터	A	B	C	D	통제 구분	평가항목	위험도	상세설명
NET-014	○	○	○	○	○	○	5.5.1 보안 관리	세션 타임아웃 설정 여부	4	○ 사용자 부재 시, 비인가자에 의한 시스템 무단 사용을 방지하기 위해 일정시간 사용하지 않는 세션에 대한 자동 종료시간 설정 여부를 점검하고, 세션 종료시간이 설정되어 있을 경우 과도하게 설정 되어 있는지를 점검
NET-015	○	○	○	○	○	○	5.5.1 보안 관리	VTY 접속 시 안전하지 않은 프로토콜(TELNET 등) 사용 제한 여부	4	○ 원격 터미널(vty)을 통해 네트워크 장비 접근 시 암호화프로토콜을 사용하여, 네트워크 스니핑 공격에 의해 평문데이터가 공격자에게 노출되지 않게 하기 위험
NET-016	○	○	○				5.5.1 보안 관리	불필요한 보조 입출력 포트(AUX) 차단 여부	2	○ 사용하지 않는 입출력 포트 사용을 중지하여 비인가자의 접근을 차단하기 위험
NET-022		○	○	○			5.5.1 보안 관리	불필요한 Source 라우팅 차단 설정 여부	2	○ Source 라우팅은 라우팅 경로를 통하지 않고 패킷 발송자가 원하는 경로로 패킷을 보낼 수 있는 기능으로 비인가자에 의해 공격에 악용되는 것을 차단하기 위험
NET-026		○	○	○		○	5.5.1 보안 관리	Proxy ARP 차단 설정 여부	3	○ 비인가자가 패킷 주소를 위조하여 Proxy ARP를 요청할 수 있으며 이에 응답하는 것을 이용하여 라우터와 네트워크 관련 정보를 획득할 수 있으므로 이를 차단하기 위험
NET-027	○	○	○	○			5.5.1 보안 관리	IP Directed Broadcast 차단 설정 여부	3	○ IP Directed Broadcast를 비활성화 하여 DoS 공격(Smurf 공격 등)을 차단하기 위험
NET-030	○	○	○	○	○	○	5.5.1 보안 관리	불필요한 서비스 비활성화 여부	2	○ 운영에 필요하지 않는 서비스가 불필요하게 설정되어 있을 경우 의도치 않는 공격의 대상이 될 수 있으므로 잠재적인 위험을 제거하기 위험
NET-031	○	○	○	○	○	○	5.5.1 보안 관리	NTP 설정 및 시각 동기화 여부	3	○ 시스템 시간 정확성 및 이벤트 발생 시 정확한 로그 분석을 하기 위험

평가항목 ID	스위치	라우터	A	B	C	D	통제 구분	평가항목	위험도	상세설명
NET-033	○	○	○	○	○	○	5.5.1 보안 관리	로그 활성화 설정 여부	3	○ 네트워크 장비 운영 및 보안을 위한 모니터링이 가능하도록 하기 위함
NET-034	○	○	○	○	○	○	5.5.1 보안 관리	로그 메시지 시간 설정 여부	1	○ 로그 메시지에 정확한 시간을 포함시켜 공격에 대한 분석이 가능하도록 하기 위함
NET-035	○	○	○	○	○	○	5.5.1 보안 관리	로그 버퍼 사이즈 설정 여부	2	○ Log 메시지를 메모리 버퍼에 저장하는데 버퍼의 용량을 일정 수준 이상으로 설정하여 디버깅이나 모니터링 시에 활용하기 위함
NET-036	○	○	○	○	○	○	5.5.1 보안 관리	원격 로그서버 연동 설정 여부	3	○ 네트워크 장비에 로그를 저장하는 데 한계가 있어, 로그가 삭제 될 수 있으므로 원격에 로그서버를 설치하여 별도의 로그파일 을 관리하기 위함
NET-037	○	○	○	○	○	○	5.5.1 보안 관리	콘솔 로깅 레벨 설정 적정성	1	○ 로그 메시지가 콘솔 메시지에 출력되는 경우 콘솔에만 출력될 뿐 운영상 불필요한 경우가 있으므로 불필요한 로그 메시지 출력을 방지하기 위함
NET-038		○	○				5.5.1 보안 관리	외부 인터페이스에 ingress 필터 설정 여부	5	○ 외부 인터페이스에 ingress 필터를 설정하여 내부 네트워크로 유입되는 패킷을 필터링하기 위함
NET-039		○	○				5.5.1 보안 관리	외부 인터페이스에 egress 필터 설정 여부	3	○ 외부 인터페이스에 egress 필터를 설정하여 내부에서 외부로 전송되는 패킷을 필터링하기 위함
NET-040		○	○				5.5.1 보안 관리	스푸핑방지 필터 설정 여부	4	○ 내부 네트워크 IP 대역을 스스 IP로 사용하여 들어오는 패킷을 외부 인터페이스에서 필터하여 스푸핑 공격을 차단하기 위함
NET-041		○	○				5.5.1 보안 관리	IP 멀티캐스트 차단 설정 여부	1	○ IP 멀티캐스트를 사용하지 않는 경우 멀티캐스트 패킷을 필터 하여 공격에 악용되는 것을 차단하기 위함

평가항목 ID	스위치	라우터	A	B	C	D	통제 구분	평가항목	위험도	상세설명
NET-042		○	○				5.5.1 보안 관리	ICMP 차단 설정 여부	2	○ 외부에서 내부로 유입되는 ICMP 패킷을 차단하여 내부의 정보가 유출되지 않도록 하고 서비스 거부공격 등을 차단하기 위함
NET-043		○	○				5.5.1 보안 관리	ICMP redirect 차단 설정 여부	2	○ 외부 인터페이스에 ICMP redirect 패킷을 차단하여 라우팅 테이블이 변경되는 것을 방지하기 위함
NET-044		○	○				5.5.1 보안 관리	ICMP unreachable 차단 설정 여부	2	○ ICMP unreachable 메시지를 이용하여 스캐닝 시 네트워크 장비의 특정 포트 활성화 여부 노출 및 DoS 공격에 악용되는 것을 차단하기 위함
NET-045		○	○				5.5.1 보안 관리	ICMP mask-reply 차단 설정 여부	2	○ ICMP mask-reply 서비스를 차단하여 비인가자에게 네트워크 구성정보가 노출되는 것을 차단하기 위함
NET-046		○	○				5.5.1 보안 관리	ICMP Timestamp, Information Requests 차단 설정 여부	1	○ ICMP Timestamp, Information Requests를 차단하여 비인가자에게 네트워크 정보가 노출되지 않게 하기 위함
NET-047		○	○				5.5.1 보안 관리	서비스 거부(DDoS) 공격 차단 필터링 설정 여부	4	○ 서비스 거부 공격을 발생할 수 있는 포트를 차단하기 위함
NET-048	○	○	○	○	○	○	5.5.3 패치 관리	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	○ 공개된 취약점에 의한 침해를 방지하고, 시스템에 대한 안전성 향상을 위해 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행(또는 보호방안 수립) 여부를 점검
NET-049	○	○	○	○			5.5.1 보안 관리	명령어 실행 권한 제한 여부	3	○ 사용자에게 명령어별 권한 수준을 Level 15로 설정하여 비인가자의 접근을 차단하기 위함
NET-050	○	○	○	○	○	○	5.5.1 보안 관리	로그온 시 경고메시지 설정 여부	3	○ 라우터에 접근하는 사용자에게 배너를 통하여 적절한 경고 메시지를 보여주기 위함

평가항목 ID	스위치	라우터	A	B	C	D	통제 구분	평가항목	위험도	상세설명
NET-051		○	○				5.5.1 보안 관리	tcp keepalives 사용 설정 여부	3	○ 원격 사용자가 종료되었을 때 tcp keepalives를 사용하여 세션을 차단함으로써 하이재킹을 통한 공격 차단 및 세션의 정상적인 종료를 위함
NET-052	○	○	○	○	○	○	5.5.1 보안 관리	미사용 인터페이스 비활성화 설정 여부	4	○ 비인가자에 의해 사용하지 않는 인터페이스를 통해 통신 장비와 연결된 네트워크 정보 파악 및 장애 유발을 차단하기 위함
NET-054	○		○	○	○	○	5.5.1 보안 관리	스위치 허브 보안 설정 여부	1	○ 보안설정을 통해 네트워크 트래픽이 비인가자에게 노출 또는 변조되는 것을 차단하기 위함
NET-056	○	○	○	○	○	○	5.5.1 보안 관리	비밀번호의 주기적인 변경관리 여부	3	○ 네트워크 장비 접근자의 비밀번호를 장기간 변경하지 않을 경우 비밀번호 대입공격으로 인한 비밀번호 탈취 위험이 존재하므로 보안장비의 비밀번호를 주기적으로 변경/관리하는지 여부를 점검
NET-057	○	○	○				5.5.1 보안 관리	취약한 서비스 비활성화 여부	2	○ 취약한 서비스*가 구동 될 경우 장비정보 노출, 전송 정보 노출 등의 위험이 존재함에 따라 취약한 서비스 구동 여부를 점검 * CDP, LLDP, TFTP, Finger, identd, Smart Install 등
NET-058	○	○	○	○	○	○	5.5.2 사용자 인증	계정 잠금 임계값 설정 여부 및 적정성	4	○ 계정 비밀번호에 대한 무작위 대입 공격으로 비인가자가 장비에 대한 계정 정보를 탈취할 위험이 존재하므로 로그인 입력 횟수 제한 등의 임계값 설정 여부를 점검
NET-059	○	○	○	○	○	○	5.5.3 패치 관리	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	5	○ 서비스 지원이 종료된(EoS) 버전을 사용하는 경우, 알려진 취약점 또는 신규로 발견되는 취약점으로 부터 발생하는 보안위협에 대처할 수 없는 위험이 존재하므로 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검 ※ 장비 교체 계획을 수립하고 보고를 마친 경우 취약으로 반영하고, 위험수용으로 관리

정보보호시스템 장비

❖ 평가대상

A	B	C	D	E	F
침입차단시스템 (FW)	가상사설망 (VPN)	침입탐지시스템 (IDS)	침입방지시스템 (IPS)	DDoS대응장비 (DDoS)	웹방화벽 (WAF)

❖ 평가기준

평가항목 ID	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
ISS-001	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 정책 및 로그 백업 설정 여부	4	○ 보안장비 장애, 가동중지 등 비상상황 발생 시 신속하게 시스템의 정상복구가 가능하도록 하기 위함
ISS-002	○	○	○	○	○	○	5.5.1 보안 관리	원격 로그 서버 사용 여부	3	○ 정보보호시스템에 로그를 저장하는데 한계가 있어, 로그가 삭제될 수 있으므로 원격에 로그서버를 설치하여 별도의 로그파일을 관리하기 위함
ISS-003	○	○					5.5.1 보안 관리	DMZ 구간 설정 여부	4	○ 외부에 연결될 필요가 없는 시스템에 대해 NAT(Network Address Translation) 설정이 되어 불필요한 네트워크 연결 경로가 구성되어 있지 확인하기 위함
ISS-004	○	○					5.5.1 보안 관리	NAT 정책 설정 적정성	4	○ 외부에 연결될 필요가 없는 시스템에 대해 NAT(Network Address Translation) 설정을 하여 비인가자가 내부 네트워크에 접근하는 것을 차단하기 위함

평가항목 ID	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
ISS-005	○	○	○	○	○	○	5.5.3 패치 관리	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	○ 공개된 취약점에 의한 침해를 방지하고, 시스템에 대한 안전성 향상을 위해 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행(또는 보호방안 수립) 여부를 점검
ISS-006	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 사용량의 주기적인 점검 및 보고 여부	4	○ 보안장비에 사용량을 검토하여 CPU, 메모리 등 장비 가용성을 확보하기 위함
ISS-007	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 장애/보안이벤트 모니터링 실시 여부	4	○ 장애 및 보안 이벤트에 대한 모니터링을 설정하여 해킹 등 공격 징후 또는 시스템 운영상 장애 발생에 대해 실시간 대응을 하기 위함
ISS-008			○	○	○	○	5.5.1 보안 관리	탐지된 이벤트 및 로그에 대한 정기적 분석 및 보고 여부	3	○ 탐지된 이벤트 및 로그에 대한 분석을 실시하여 침해사고 발생을 점검하기 위함
ISS-009			○	○	○	○	5.5.1 보안 관리	위험도가 높은 이벤트 및 로그에 대한 RAW 패킷 저장 여부	2	○ 침해사고 발생 시 RAW 패킷이 저장되지 않는 경우 정확한 분석에 어려움이 있으므로, 정확한 분석을 위해 탐지된 패킷에 대한 RAW 데이터 저장 여부를 확인하기 위함
ISS-010			○	○	○		5.5.1 보안 관리	TCP/UDP/ICMP 탐지/차단 패턴 적용 여부	2	○ TCP/UDP/ICMP Flooding 공격에 대한 탐지 및 차단 패턴을 적용하여 외부 인터넷망을 통한 공격 시 내부 서버 및 단말기 등을 보호하기 위함
ISS-011			○	○	○		5.5.1 보안 관리	Port Scan 탐지/차단 패턴 적용 여부	2	○ 외부 인터넷 망을 통해 내부 시스템에 대한 접근 정보 획득을 차단하기 위함
ISS-012			○	○		○	5.5.1 보안 관리	해킹 툴 탐지/차단 패턴 적용 여부	2	○ 악성코드에 대한 탐지 및 차단패턴을 적용하여 첨부파일 등을 통한 악성 코드 감염을 차단하기 위함

평가항목 ID	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
ISS-013	○	○					5.5.1 보안 관리	불필요한 Source Routing 차단 설정 여부	2	○ 정해진 경로가 아닌 특정 경로를 통한 공격을 차단하기 위험
ISS-014	○	○	○	○	○	○	5.5.1 보안 관리	사용하지 않는 SNMP 비활성화 여부	4	○ 사용하지 않는 SNMP 서비스를 중지하여 SNMP 서비스 취약점(장비의 소프트웨어 정보 및 하드웨어 정보 제공, DoS 등 각종 공격에 노출)을 이용한 공격을 차단하기 위험
ISS-015	○	○	○	○	○	○	5.5.1 보안 관리	안전한 네트워크 모니터링 서비스 사용 여부	4	○ 네트워크 모니터링 서비스의 보안 설정이 미비할 경우 데이터 변조, 도청 및 중간자 공격으로 시스템 정보 및 상태정보가 유출될 가능성이 존재하므로 프로토콜에 따라 알맞은 보안설정 및 안전한 버전을 적용하여 사용하고 있는지 점검
ISS-016	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 접속 시 보안 접속 사용 여부	5	○ 암호화 접속을 통해 비인가자에 의한 스니핑 공격에 노출되는 것을 방지하기 위험
ISS-017	○	○	○	○	○	○	5.5.2 사용자 인증	보안장비 Default 계정 변경 여부	4	○ 외부에서 쉽게 계정정보 획득이 가능한 보안장비의 Default 계정을 이용하여 비인가자가 보안장비에 접근하는 것을 차단하기 위험
ISS-018	○	○	○	○	○	○	5.5.2 사용자 인증	보안장비 Default 비밀번호 변경 여부	4	○ 외부에서 쉽게 획득이 가능한 보안장비의 초기 Default 비밀번호를 사용하여 비인가자가 보안장비에 접근하는 것을 차단하기 위험
ISS-019	○	○	○	○	○	○	5.5.2 사용자 인증	보안장비 계정 관리 적정성	5	○ 침해사고 발생 시 계정별 권한에 대한 관리 및 감사증적 기록을 남기기 위험
ISS-020	○	○	○	○	○	○	5.5.2 사용자 인증	보안장비 계정별 권한 설정 여부	4	○ 보안장비 계정을 용도별로 권한을 부여함으로써 권한 없는 사용자의 의도하지 않은 보안정책 수정이나 설정값 변경을 방지하기 위험

평가항목 ID	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
ISS-021	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 원격 관리 접근 통제 여부	5	○ 관리용도로 허용된 IP에 대해서만 보안장비에서 허용하여 비인가자에 대한 접근을 차단하기 위함
ISS-022	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 접속성공/실패 로깅 여부	3	○ 보안장비 접근 권한에 대해 계정의 로그인 성공/실패 로그를 저장하여 비인가자의 접근을 확인하기 위함
ISS-023	○	○	○	○	○	○	5.5.1 보안 관리	로그인 실패횟수 제한 설정 여부	3	○ 비인가자가 자동화된 방법을 통해 사용자 계정에 반복적인 대입을 시도 하여 계정 및 비밀번호를 탈취하여 접근하는 것을 방지하기 위함
ISS-024	○	○	○	○	○	○	5.5.1 보안 관리	세션 타임아웃 설정 여부	4	○ 사용자 부재 시, 비인가자에 의한 시스템 무단 사용을 방지하기 위해 일정시간 사용하지 않는 세션에 대한 자동 종료시간 설정 여부를 점검하고, 세션 종료시간이 설정되어 있을 경우 과도하게 설정 되어 있는지를 점검
ISS-025	○	○	○	○	○	○	5.5.1 보안 관리	시간 동기화를 위한 NTP 설정	2	○ 시스템 시각 정확성 및 이벤트 발생 시 정확한 로그 분석을 하기 위함
ISS-026	○	○	○	○	○	○	5.5.1 보안 관리	주요 파일에 대한 주기적인 무결성 검사 여부	2	○ 주요 파일(설정, 로그 등)이 불법 변조되어 있는 것을 확인하기 위함
ISS-027	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 기능외 서비스 제한 여부	2	○ 정보보호시스템 장비 기능 외 다른 서비스가 시스템에서 실행되는 경우 비인가자에 의해 공격에 활용될 수 있으므로 이를 차단하기 위함
ISS-028	○	○					5.5.1 보안 관리	보안장비 정책 변경통제 절차 수립 여부	4	○ 보안장비 관리자가 사용자 편의 등을 위해 정책을 임의적으로 생성, 변경, 삭제하는 것을 차단하기 위함

평가항목 ID	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
ISS-029	○	○					5.5.1 보안 관리	보안장비 변경요청 정책의 기술적 검토 여부	4	○ 보안장비 정책을 생성, 변경, 삭제 시 네트워크 및 시스템 운영에 영향을 미칠 수 있으므로, 보안정책 신청에 대해 관리자가 적정성 여부 등을 검토 후 적용하고 있는지 확인하기 위한
ISS-030	○	○					5.5.1 보안 관리	모든 목적지 및 서비스로의 허용 정책 금지 여부	5	○ 신뢰할 수 있는 내부 시스템인 경우에도, 모든 목적지의 모든 서비스로의 허용정책은 비인가자에 의한 불필요한 접근을 허용하여 잠재적인 위험에 노출될 수 있으므로 이를 차단하기 위한
ISS-031	○	○					5.5.1 보안 관리	취약한 서비스의 네트워크 대역 단위 허용 금지 여부	5	○ 관리용도 또는 취약한 서비스 포트로 출발지나 목적지 IP를 광범위 하게 허용할 경우 비인가자에 의한 불필요한 접근을 허용하여 잠재적인 위험에 노출될 수 있으므로 이를 방지하기 위한
ISS-032	○	○					5.5.1 보안 관리	서비스 포트 허용 정책 적정성	5	○ 신뢰할 수 있는 내부 시스템인 경우에도, 과도한 서비스로의 허용 정책은 비인가자에 의한 불필요한 접근을 허용하여 잠재적인 위험에 노출될 수 있으므로 이를 차단하기 위한
ISS-033	○	○					5.5.1 보안 관리	불필요한 양방향 정책 금지 여부	4	○ 불필요하게 양방향으로 설정된 정책은 비인가자에 의한 불필요한 접근을 허용하여 잠재적인 위험에 노출될 수 있으므로 이를 방지하기 위한
ISS-034	○	○					5.5.1 보안 관리	정책 적용 순서의 적절성	4	○ 잘못된 정책 적용으로 인해 비인가자에 의한 불필요한 접근을 허용할 수 있으므로 이를 차단하기 위한
ISS-035	○	○					5.5.1 보안 관리	출발지 포트 기반의 정책 금지 여부	5	○ 공격자로 하여금 출발지 포트를 속여 목적지 서버의 임의의 서비스 포트에 접속하는 것을 차단하기 위한
ISS-036	○	○					5.5.1 보안 관리	취약한 원격 서비스 금지 여부	5	○ 비밀번호 없이 서버에 접근이 가능하거나 보안 취약점에 노출된 원격 서비스를 허용하고 있는지 점검하기 위한

평가항목 ID	A	B	C	D	E	F	통제 구분	평가항목	위험도	상세설명
ISS-037	○	○					5.5.1 보안 관리	불필요한 정책 제거 여부	4	○ 테스트용도 혹은 현재 사용하지 않은 서비스에 대한 허용정책 등 불필요한 포트 및 사용하지 않는 정책을 점검하기 위함
ISS-038	○	○					5.5.1 보안 관리	서버간 관리포트 허용 금지 여부	5	○ 서버간 관리포트 허용 등 취약한 정책 존재여부를 점검하기 위함
ISS-039	○	○					5.5.1 보안 관리	단말과 서버간 접근통제를 우회한 접속 금지 여부	5	○ 사용자 단말과 서버간에 비인가 접속용 관리포트 허용정책 등 취약한 정책이 존재하는지 점검하기 위함
ISS-040	○	○	○	○	○	○	5.5.1 보안 관리	보안장비 비밀번호의 주기적인 변경 여부	3	○ 보안장비 접근자의 비밀번호를 장기간 변경하지 않을 경우 비밀번호 대입공격으로 인한 비밀번호 탈취 위험이 존재함으로 보안장비의 비밀번호를 주기적으로 변경/관리하는지 여부를 점검
ISS-041	○	○					5.5.1 보안 관리	불필요한 네트워크 대역 단위 설정 금지 여부	4	○ 출발지나 목적지 IP를 불필요하게 네트워크 대역 단위로 허용할 경우 비인가자에 의한 접근을 허용하여 잠재적인 위험에 노출될 수 있으므로 이를 방지하기 위함
ISS-042					○		5.5.1 보안 관리	차단 기능 활성화 여부	5	○ 서비스 장애 여부 등과 관련없이 불필요하게 보안장비의 차단 기능을 비활성화하여 운영할 경우, 악의적인 공격에 노출될 위험이 존재하므로, 차단 기능에 대한 비활성화 여부를 점검
ISS-043	○	○	○	○	○	○	5.5.3 패치 관리	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	5	○ 서비스 지원이 종료된(EoS) 버전을 사용하는 경우, 알려진 취약점 또는 신규로 발견되는 취약점으로 부터 발생하는 보안위협에 대처할 수 없는 위험이 존재하므로 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검 ※ 장비 교체 계획을 수립하고 보고를 마친 경우 취약으로 반영하고, 위험수용으로 관리

OS 가상화 시스템

❖ 평가대상

A	B	C
vCenter	ESXi	XenServer

❖ 평가기준

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-001	○	○	○	5.5.2 사용자 인증	사용자별 계정 분리	3	○ 사용자별 계정을 분리하지 않고 사용하는 경우(공용계정을 사용하는 경우) 사용자 행위 등의 감사추적에 어려움이 존재함에 따라 사용자 행위 등의 감사추적을 위한 공용계정 사용 여부를 점검
PRCV-002	○	○	○	5.5.1 보안 관리	관리자 그룹 내 불필요한 계정 제거	5	○ 다수의 관리자 계정이 존재할 경우 공격자가 탈취를 시도할 수 있는 관리자 계정이 많아지므로 업무상 필요한 최소한의 사용자만 관리자 그룹에 등록하여 사용하고 있는지 여부를 점검
PRCV-003	○	○	○	5.5.2 사용자 인증	불필요하거나 관리되지 않는 계정 제거	4	○ 시스템 설치 시 기본으로 생성되는 계정, 업무상 사용되지 않는 계정 등 불필요한 계정이나 장기간 비밀번호가 변경되지 않은 계정이 존재할 경우 비인가자의 계정 탈취 위험이 증가하므로 불필요하거나 관리되지 않는 계정 존재 여부를 점검
PRCV-004	○	○	○	5.5.2 사용자 인증	비밀번호 복잡도 설정	5	○ 계정 비밀번호에 대한 복잡도가 적절하게 설정되어 있지 않을 경우 유추하기 쉬운 비밀번호 설정이 가능함에 따라, 적절한 비밀번호 관리정책이 설정되어 있는지 여부를 점검
PRCV-005	○	○	○	5.5.1 보안 관리	비밀번호 변경 주기 충족 여부	4	○ 장기간 변경되지 않은 비밀번호 사용을 허가할 경우, 이전 획득한 비밀번호의 재사용, 무작위 대입을 통한 비밀번호 추측 등의 위험이 발생될 수 있으므로, 적절한 비밀번호 변경 주기 설정 여부를 점검

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-006	○	○	○	5.5.2 사용자 인증	이전 비밀번호 재사용 요구사항 충족 여부	3	○ 비밀번호 변경 시 이전 비밀번호 사용을 허가 할 경우, 비밀번호 추측, 이전 획득한 비밀번호 재사용 등의 위험이 발생 될 수 있으므로 이전 비밀번호 재사용을 제한하는 설정 존재 여부를 점검
PRCV-007	○	○	○	5.5.1 보안 관리	로그인 실패 횟수에 따른 접속 제한 설정	3	○ 일정 횟수 이상의 잘못된 비밀번호 입력을 허용할 경우 무작위 대입 공격과 같은 위험이 발생될 수 있으므로 비밀번호 오류에 따른 접속 제한(계정 잠금, 차단 등) 설정 여부를 점검
PRCV-008		○		5.5.1 보안 관리	예외 사용자 목록 내 불필요한 사용자 제거	4	○ 예외 사용자 목록 내 불필요한 사용자가 존재할 경우 비인가자에 의해 시스템 무단 침입을 할 수 있으므로, 예외 사용자 목록 내 불필요한 사용자 존재 여부를 점검
PRCV-009	○	○	○	5.5.1 보안 관리	관리 용도 외 IP 접근 제한	4	○ 관리 목적 이외의 IP에 대한 시스템 접근을 허용하고 있을 경우, 비인가자의 접근으로 인한 침해 위험이 발생 될 수 있으므로 관리 목적의 IP에 대해서만 시스템을 접근할 수 있도록 제한하고 있는지를 점검
PRCV-010		○	○	5.5.1 보안 관리	하이퍼바이저 잠금 모드(Lockdown mode) 설정	4	○ 하이퍼바이저에 대한 잠금 모드*가 설정되어 있지 않을 경우 비인가자의 접속으로 인해 하이퍼바이저 및 가상머신 설정 변경, 수정·삭제 등의 침해 위험이 발생 될 수 있으므로, 잠금 모드 설정 여부를 점검 * 잠금모드(LockDown mode) : 클라우드 관리 플랫폼을 통해 하이퍼바이저에 접근 하도록 제한하는 기능
PRCV-011	○	○	○	5.5.1 보안 관리	시스템 사용 주의사항 출력	1	○ 원격 로그인 시 시스템 사용 주의사항을 안내하지 않을 경우 사용자가 시스템에 접근 시 보안 정책을 인식하지 못해 인위적인 공격 또는 데이터 유출 등의 보안 위험이 생길 수 있으므로, 원격 로그인 시 시스템 사용 주의사항 등의 경고 문구를 표시하는 설정의 존재 여부를 점검
PRCV-012	○	○	○	5.5.1 보안 관리	시간 동기화를 위한 NTP 설정	2	○ 시스템이 NTP를 통한 시간 동기화가 되지 않을 경우 침해, 장애 등의 위험 발생 시 로그 분석에 어려움이 발생될 수 있으므로 NTP 설정을 통한 시간 동기화 여부를 점검

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-013	○	○	○	5.5.1 보안 관리	안전한 네트워크 모니터링 서비스 사용	3	○ 네트워크 모니터링 서비스의 보안 설정이 미비할 경우 데이터 변조, 도청 및 중간자 공격으로 시스템 정보 및 상태정보가 유출될 가능성이 존재하므로 프로토콜에 따라 알맞은 보안설정 및 안전한 버전을 적용하여 사용하고 있는지 여부를 점검
PRCV-014	○	○		5.5.1 보안 관리	불필요한 시스템 관리 인터페이스 비활성화 여부	3	○ MOB(Managed Object Browser) 서비스가 활성화되어 있을 경우, 해당 인터페이스를 통해 시스템 정보 수집, 가상 머신 제어, 시스템 설정 변경 등의 위험이 발생될 수 있으므로, MOB 서비스 비활성화 여부를 점검
PRCV-015		○		5.5.1 보안 관리	실행할 수 없는 소프트웨어 패키지 설치 제한 여부	3	○ 실행할 수 없는 VIB(Vsphere Install Bundle) 설치를 허용할 경우 악의적인 기능을 수행하는 소프트웨어가 설치될 수 있으므로, 해당 벤더사 또는 신뢰할 수 있는 파트너 테스트를 거친 VIB만 설치하였는지 점검 ※ VIB(Vsphere Install Bundle) : ESXi에 설치 가능한 소프트웨어 패키지
PRCV-016	○	○		5.5.1 보안 관리	CEIP 기능 제한 여부	2	○ CEIP(Customer Experience Improvement Program) 기능이 활성화 되어 있을 경우 불필요한 정보 유출 등이 발생될 수 있으므로 CEIP 기능 비활성화 여부를 점검 * CEIP(Customer Experience Improvement Program) : 고객 경험 개선 프로그램은 제품 및 서비스 품질, 안정성 및 기능 개선을 위해 사용 패턴, 이벤트 데이터 등을 수집하여 수집 서버로 전송
PRCV-017	○	○		5.5.1 보안 관리	관리 홈페이지 세션 타임아웃 설정	3	○ 비인가자에 의한 무단 사용을 방지하기 위해, 관리 홈페이지(웹 기반 관리 인터페이스)의 세션 타임아웃(로그인 후 일정시간 사용하지 않을 경우 세션 종료) 설정 적정성을 점검

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-018		○		5.5.1 보안 관리	불필요한 하이퍼바이저 관리도구 비활성화 여부	5	○ ESXi Shell(TSM, TSM-SSH)에서 이루어지는 행위는 관리 플랫폼 (vCenter)과 동기화 되지 않을 수 있으며, 감사기록 관리에 대한 관리가 어려울 수 있으므로 ESXi Shell(TSM, TSM-SSH) 비활성화 여부를 점검 * 참고사항 1. TSM(Tech Support Mode) : 문제 해결 및 진단을 위해 ESXi 호스트에 물리적으로 접근하여 사용할 수 있는 텍스트 기반 명령 인터페이스 2. TSM-SSH(Tech Support Mode via SSH) : SSH 프로토콜을 통해 원격에서 TSM의 기능을 사용할 수 있게 하는 서비스
PRCV-019		○		5.5.1 보안 관리	하이퍼바이저 관리도구 서비스 타임아웃 설정	4	○ 비인가자에 의한 시스템 무단 사용을 방지하기 위해, ESXi Shell(TSM, TSM-SSH)의 서비스 타임아웃(일정시간 서비스를 사용하지 않을 경우 서비스 종료) 설정의 적정성을 점검 * 참고사항 1. TSM(Tech Support Mode) : 문제 해결 및 진단을 위해 ESXi 호스트에 물리적으로 접근하여 사용할 수 있는 텍스트 기반 명령 인터페이스 2. TSM-SSH(Tech Support Mode via SSH) : SSH 프로토콜을 통해 원격에서 TSM의 기능을 사용할 수 있게 하는 서비스
PRCV-020		○		5.5.1 보안 관리	하이퍼바이저 관리도구 세션 타임아웃 설정	4	○ 비인가자에 의한 시스템 무단 사용을 방지하기 위해, ESXi Shell(TSM, TSM-SSH)의 세션 타임아웃(로그인 후 일정시간 사용하지 않을 경우 세션 종료) 설정의 적정성을 점검 * 참고사항 1. TSM(Tech Support Mode) : 문제 해결 및 진단을 위해 ESXi 호스트에 물리적으로 접근하여 사용할 수 있는 텍스트 기반 명령 인터페이스 2. TSM-SSH(Tech Support Mode via SSH) : SSH 프로토콜을 통해 원격에서 TSM의 기능을 사용할 수 있게 하는 서비스

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-021		○	○	5.5.1 보안 관리	콘솔 세션 타임아웃 설정	4	○ 사용자 부재시, 비인가자에 의한 시스템 무단 사용을 방지하기 위해, 일정시간 사용하지 않는 콘솔에 대한 세션 타임아웃(로그인 후 일정시간 사용하지 않을 경우 세션 종료) 설정의 적정성을 점검 * DCUI(Direct Console User Interface) : ESXi 호스트에 물리적으로 접근하여 사용할 수 있는 GUI 기반 관리 인터페이스
PRCV-022	○	○	○	5.5.1 보안 관리	원격 로그 서버 이용	3	○ 원격 로그 서버를 이용하여 로그 관리를 하지 않을 경우, 시스템 가용성 저하, 침해에 따른 로그 유실 등의 위험이 발생될 수 있으므로 원격 로그 서버를 이용한 로그 저장 여부를 점검
PRCV-023	○	○	○	5.5.1 보안 관리	시스템 주요 이벤트 로그 설정	3	○ 시스템 주요 이벤트 로그가 설정되어 있지 않을 경우 시스템 문제 발생 시 보안, 성능 등의 이슈를 파악하기 어려우므로 시스템, 가상머신, 보안 등의 로그가 저장되도록 설정되어 있는지를 점검
PRCV-024		○	○	5.5.1 보안 관리	비휘발성 경로 내 로그 파일 저장	3	○ 휘발성 경로에 로그 파일이 저장될 경우, 일정시간이 지나거나 시스템 재시작 시 저장된 로그를 상실할 수 있으므로 비휘발성 경로에 로그파일 저장 여부를 점검 ※ (참고) ESXi의 경우 기본적으로 /scratch 경로에 로그가 저장되며, 해당 로그는 시스템 재시작 시 또는 하루가 지나면 삭제
PRCV-025	○	○	○	5.5.1 보안 관리	API 통신에 대한 보안 프로토콜 사용	3	○ API 통신 구간의 암호화가 적용되지 않을 경우, API 요청 내용이 위변조될 수 있으므로, API 통신에 대한 보안 프로토콜(TLS) 적용 여부를 점검
PRCV-026		○	○	5.5.1 보안 관리	코어덱프 수집 기능 활성화 여부	3	○ 코어 덤프 기능이 활성화 되어 있지 않을 경우, 시스템 장애 발생에 대한 원인을 파악하기 어려우므로, 코어덱프 수집 기능 활성화 여부를 점검 * 코어 덤프 기능(Vmware vSphere Network Dump Collector 서비스) : 시스템에서 심각한 오류 발생 시 VMKernel 메모리 상태를 서버로 전송

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-027		○	○	5.5.1 보안 관리	가상머신의 장치 변경 제한 설정	3	○ 가상머신(게스트 OS)에서 관리자 권한이 없는 사용자(또는 프로세스)에 의한 장치(네트워크 어댑터, CD-ROM 등) 연결을 끊거나, 설정 변경을 방지하기 위한 설정 적용 여부를 점검
PRCV-028		○		5.5.1 보안 관리	가상머신의 장치 연결 제한 설정	3	○ 가상머신(게스트 OS)에서 관리자 권한이 없는 사용자(또는 프로세스)에 의한 장치(네트워크 어댑터, CD-ROM 등) 임의 연결을 방지하기 위한 설정 적용 여부를 점검
PRCV-029		○	○	5.5.1 보안 관리	가상머신의 불필요한 장치 제거	3	○ 불필요하게 연결된 외부 장치는 잠재적인 공격 루트로 활용될 수 있으므로, 불필요한 장치(USB, CD/DVD, 플로피 디스크, 병렬 포트, 직렬 포트)를 제거하지 않고 사용하는지를 점검
PRCV-030		○		5.5.1 보안 관리	가상 디스크 축소 및 삭제 기능 제한	3	○ 가상머신(게스트 OS)에서 관리자 권한이 없는 사용자(또는 프로세스)가 가상 디스크 축소 및 삭제 기능을 반복적으로 사용할 경우, 해당 기간 가상디스크를 사용할 수 없어 서비스 거부가 발생될 수 있으므로 가상 디스크 축소 및 삭제 기능 제한 설정 여부를 점검
PRCV-031		○		5.5.1 보안 관리	가상머신 콘솔 클립보드 복사&붙여넣기 기능 비활성화 여부	3	○ 가상 머신에 클립보드를 활용한 복사/붙여넣기 작업이 허용되어 있을 경우 파일 송·수신 기록이 로그에 저장되지 않으므로 클립보드를 활용한 가상머신 콘솔 복사 기능 비활성화 여부를 점검
PRCV-033		○		5.5.1 보안 관리	가상머신 콘솔 드래그 앤 드롭 기능 비활성화 여부	3	○ 가상 머신에 대한 드래그 앤 드롭 기능이 허용되어 있을 경우 파일 송·수신 기록이 로그에 저장되지 않으므로 가상머신 드래그 앤 드롭 기능 비활성화 여부를 점검
PRCV-034		○		5.5.1 보안 관리	가상스위치 MAC 주소 변경 정책 비활성화 여부	3	○ 가상스위치에 MAC 주소 변경 정책이 설정되어 있을 경우, 악의적인 사용자(또는 악성코드)가 장치 내의 MAC 주소를 변경하여 스누핑 등의 공격을 수행할 수 있으므로, MAC 주소 변경 정책 비활성화(false)를 점검

* 맥주소 변경 정책 : 가상머신 내부에서 MAC 주소를 변경하는 것을 허용하는 정책

평가항목 ID	A	B	C	통제 구분	평가항목	위험도	상세설명
PRCV-035		○	○	5.5.1 보안 관리	가상스위치 트래픽 복제 및 무차별 수신 방지	3	○ 가상스위치에서 트래픽 복제(Mirror/SPAN) 또는 무차별 수신 (Promiscuous/Trunk 등) 설정이 활성화된 경우 특정 포트 또는 VM이 자신에게 전달되지 않은 트래픽까지 수신하거나 외부로 유출 되어 스니핑, 세션 하이재킹 등 보안 위협이 되므로, 트래픽 복제 및 무차별 수신 관련 설정이 존재하지 않는지 점검 * Promiscuous 모드 : 자신에게 직접 전달되지 않은 모든 네트워크 트래픽 패킷을 수신하는 기능 ○ 가상스위치에 위조 MAC 송신을 허용하는 설정이 활성화되어 있을 경우 MAC 스푸핑, 세션 하이재킹 등 보안 위협이 발생될 수 있으므로 해당 기능을 차단하고 있는지 점검 * Forged Transmits(위조전송) 모드 : 가상 스위치가 수신하는 모든 트래픽을 연결 된 모든 가상 NIC에게 전송하는 기능
PRCV-036		○	○	5.5.1 보안 관리	가상스위치 위조 MAC 송신 차단 정책 설정	3	

컨테이너 가상화 시스템

❖ 평가대상

A	B	C	D	E	F	G	H	I
k8s master	k8s worker	eks master	eks worker	aks master	aks worker	ocp master	ocp worker	docker

❖ 평가기준

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-001	○	○	○	○	○	○	○	○	○	5.5.1 보안 관리	불필요한 클러스터 관리자 역할 제거 여부	5	클러스터 관리자(cluster-admin) 역할이 부여되어 있을 경우, 리소스 조작, 민감정보 조작 등 모든 리소스 조작에 대한 권한이 부여됨에 따라, 사용자, 그룹, 서비스 계정(service account)에 불필요한 클러스터 관리자(cluster-admin) 역할 부여 여부를 점검
PRCC-002	○	○	○	○	○	○	○	○	○	5.5.1 보안 관리	Role(ClusterRole)의 과도한 권한 부여 제거 여부	4	Role 또는 ClusterRole에 와일드카드(*)가 부여되어 있을 경우, 모든 리소스에 대한 모든 권한이 부여되므로 와일드 카드 부여 여부를 점검
PRCC-003	○	○	○	○	○	○	○	○	○	5.5.1 보안 관리	기본 서비스 계정(default) 사용 제거 여부	4	기본 서비스 계정은 네임스페이스 내의 모든 리소스에 대한 접근 권한을 가질 수 있으므로, 불필요한 기본 서비스 계정 사용 유무를 점검
PRCC-004	○	○	○	○	○	○	○	○	○	5.5.1 보안 관리	안전한 인증 방식 사용	5	취약한 인증방식(토큰 인증파일)을 사용할 경우, 인증정보 유출, 재사용 등의 보안 위험이 발생될 수 있으므로, 취약한 인증 방식 사용 여부를 점검

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-005	○					○				5.5.1 보안 관리	컨트롤러 별 서비스 계정 자격 증명 사용	3	○ 컨트롤러 매니저의 모든 컨트롤러가 동일한 서비스 계정을 사용할 경우, 단일 컨트롤러의 위험이 다른 컨트롤러에도 영향을 미칠 수 있으므로 각 컨트롤러가 별도의 서비스 계정을 사용하도록 설정되어 있는지를 점검
PRCC-006	○		○	○	○					5.5.1 보안 관리	서비스 계정 토큰 자동 마운트 제한 설정 여부	3	○ 서비스 계정 토큰이 모든 Pod에 기본적으로 마운트될 경우, 불필요한 권한 노출 및 토큰 유출에 따른 보안 위험이 발생할 수 있으므로 서비스 아카운트 토큰 자동 마운트 제한 설정 여부를 점검
PRCC-007	○	○	○	○		○	○	○	○	5.5.1 보안 관리	시스템 주요 설정파일(디렉터리)의 권한 설정	3	○ 시스템 주요 설정파일(디렉터리)에 대한 권한 설정이 미흡할 경우, 설정 정보 위·변조, 정보 노출 등의 위험이 발생될 수 있으므로, 주요 설정파일(디렉터리)의 권한 설정의 적절성을 점검
PRCC-008	○					○				5.5.1 보안 관리	서비스 바인딩 주소 제한 여부	4	○ Controller Manager, Scheduler에 무단 접근 가능할 경우, 클러스터의 동작을 수정 또는 변경하거나, 클러스터의 정보 유출, 리소스 임의 활용 등 악성행위가 수행 가능함에 따라, 사전 정의된 주소에서만 접근 가능하도록 제한하는지를 점검
PRCC-009	○	○	○	○	○	○	○	○	○	5.5.1 보안 관리	시스템 주요 이벤트 로그 설정	3	○ 시스템 주요 이벤트 로그가 설정되어 있지 않을 경우 시스템 문제 발생 시 보안, 성능 등의 이슈를 파악하기 어려움으로 시스템, 가상머신, 보안 등의 로그가 저장되도록 설정되어 있는지를 점검
PRCC-010	○	○				○	○			5.5.1 보안 관리	비휘발성 경로 내 로그 파일 저장	3	○ 휘발성 경로에 로그 파일이 저장될 경우, 시스템 재시작 시 로그가 삭제될 수 있으므로, 로그파일 위치를 휘발성 위치가 아닌 곳으로 변경 해서 저장하는지 점검
PRCC-011									○	5.5.1 보안 관리	원격 로그 서버 이용	3	○ 원격 로그 서버를 이용하여 로그 관리를 하지 않을 경우, 시스템 가용성 저하, 침해에 따른 로그 유실 등의 위험이 발생될 수 있으므로 원격 로그 서버를 이용한 로그 저장 여부를 점검

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-012	○	○	○	○			○			5.5.1 보안 관리	API 통신에 대한 보안 프로토콜 사용	3	○ API 통신 구간의 암호화가 적용되지 않을 경우, API 요청 내용이 위변조 될 수 있으므로, API 통신에 대한 보안 프로토콜(TLS) 적용 여부를 점검
PRCC-013	○	○	○	○						5.5.1 보안 관리	Anonymous 계정의 API 접속 제한 여부	3	○ API 서버에 대한 Anonymous 계정 허용 등 부적절한 인증 설정이 되어 있을 경우, 비인가자에 의한 API사용, 인증정보 탈취 등의 위험이 발생될 수 있으므로, API 서버 인증 구성의 적절성을 점검
PRCC-014	○									5.5.1 보안 관리	API 요청 타임아웃 설정	3	○ API 서버 요청에 대한 제한시간이 과도하게 크게 설정될 경우, API 서버 리소스가 소진되어 서비스 부하가 발생 될 수 있으므로 API 요청 타임아웃 설정 여부를 점검
PRCC-015	○	○	○	○			○	○		5.5.1 보안 관리	API 사용에 대한 안전한 인증 모드 적용	3	○ 클라우드 시스템에서 제공하는 API에 대한 인증이 적용되지 않을 경우 비인가자에 의해 API가 무단 사용됨으로써 시스템 설정 변경, 가상 머신 제어 등의 보안 위험이 발생 될 수 있으므로, API 사용에 대한 인증 모드의 적절성을 점검
PRCC-016	○						○			5.5.1 보안 관리	API 사용시 서비스 계정 토큰 검증 여부	3	○ 인증 토큰 검증 시, 서비스 계정에 존재하는지를 검증하지 않을 경우, 서비스 계정 삭제 후에도 인증토큰을 사용할 수 있으므로 서비스 계정 토큰 검증 여부를 점검
PRCC-017	○	○	○	○				○		5.5.1 보안 관리	kubelet 읽기 전용 포트 비활성화 여부	4	○ Kubelet의 읽기 전용 포트가 활성화되어 있을 경우, 인증되지 않은 접근이 가능하게 되어 정보 유출 위험이 있으므로, kubelet 읽기 전용 포트 비활성화 여부를 점검
PRCC-018	○	○	○	○				○		5.5.1 보안 관리	kubelet의 iptables 동기화 설정	4	○ Kubelet의 iptables 동기화 설정이 적절히 이루어지지 않은 경우, 네트워크 트래픽이 예상치 못한 방식으로 라우팅될 수 있으므로, iptables 동기화 설정 여부를 점검

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-019										5.5.1 보안 관리	컨테이너 런타임 데몬의 관리자 권한 실행 제한 여부	4	○ Docker 데몬이 루트로 실행되면, 데몬과 관련된 프로세스가 호스트 시스템에서 높은 권한을 가지게되어, 컨테이너가 데몬을 통해 호스트 시스템을 조작하거나, 데몬 취약점을 이용하여 호스트 시스템에 영향을 미칠 가능성이 있으므로 컨테이너 런타임 데몬의 Non-root 사용자 실행(rootless mode) 여부를 확인
PRCC-020										5.5.1 보안 관리	실험적 기능 비활성화 여부	3	○ 실험적 기능 설정이 적용되어 있을 경우 안정적이지 않은 기능이 활성화되어 시스템 안정성에 영향일 끼칠 수 있으므로, 실험적 기능 비활성화 여부를 점검
PRCC-021										5.5.1 보안 관리	데몬의 사용자 영역(userland) 프록시 사용 제한 여부	3	○ 사용자 영역(userland) 프록시는 컨테이너와 호스트 또는 다른 컨테이너 사이의 네트워크 통신을 가능하게 하는데 사용되나, 사용자 영역 프록시를 사용할 경우 시스템 부하 등의 보안 위험이 발생될 수 있으므로 사용자 영역(userland) 프록시 사용 여부를 점검 ※ userland-proxy : 호스트와 컨테이너 간의 포트 포워딩을 담당하는 컴포넌트
PRCC-022	○	○	○	○			○	○	○	5.5.1 보안 관리	레지스트리 연결 구간에 대한 보안 프로토콜 사용	2	○ 레지스트리 연결 시, 통신구간 암호화가 적용되지 않을 경우 중간자 공격 등에 의한 리소스 위변조 등이 발생될 수 있으므로 레지스트리 연결 구간에 암호화 통신 여부를 점검
PRCC-023										5.5.1 보안 관리	사용자 정의 네트워크 사용 여부	3	○ 기본 네트워크 인터페이스를 사용할 경우 컨테이너들은 동일한 네트워크 대역을 공유하게되며 ARP Spoofing 및 MAC Flooding 등의 공격에 취약할 수 있으므로 기본 네트워크 인터페이스가 아닌 사용자 정의 네트워크 사용 여부를 점검

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-024	○		○	○	○	○	○			5.5.1 보안 관리	컨테이너간 불필요한 통신 제한 설정	3	○ 컨테이너간 불필요한 통신이 가능할 경우 취약한 컨테이너를 통해 침투한 공격자가 다른 컨테이너를 공격할 가능성이 있으므로 컨테이너간 불필요한 통신을 제한하기 위한 설정 활성화 여부를 점검
PRCC-025	○									5.5.1 보안 관리	불필요한 프로파일링 기능 비활성화 여부	2	○ 프로파일링 기능이 활성화 되어 있을 경우, 프로파일링 기능을 통해 시스템 정보 유출이 될 수 있으므로, 업무상 불필요할 경우 프로파일링 기능 활성화 여부를 점검 ※ 프로파일링 기능을 통해 서버의 성능 문제를 진단할 수 있으나, 성능 데이터 수집 등을 위해 추가적인 데이터를 수집함에 따라 업무상 불필요할 경우 프로파일링 기능 비활성화 필요
PRCC-026	○		○	○	○	○	○	○		5.5.1 보안 관리	컨테이너의 privileged 플래그 제거	5	○ privileged 플래그를 사용하여 컨테이너를 실행하는 경우, cgroup 컨트롤러 등에 의해 시행되는 모든 제한 사항이 제거되어, 컨테이너에서 호스트 시스템에 접근할 수 있는 보안 위험이 발생될 수 있으므로, privileged 플래그 제거 여부를 점검 ※ privileged 플래그가 설정되어 있을 경우 컨테이너에서 호스트 시스템의 디바이스에 대한 접근(Access) 권한을 부여
PRCC-027	○		○	○	○	○	○			5.5.1 보안 관리	과도한 커널 접근 권한 제거	4	○ 업무상 불필요하게 과도한 커널 접근 권한(capabilities)이 부여 될 경우 컨테이너는 커널에 높은 접근 권한을 가질 수 있으므로, 업무상 불필요하게 capabilities를 부여(add)하였는지를 점검 ※ SYS_ADMIN, NET_ADMIN, SYS_PTRACE, SYS_CHROOT, SYS_MODULE, DAC_OVERRIDE, SETUID, SETGID

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-028	○		○	○	○					5.5.1 보안 관리	불필요한 커널 접근 권한 제거	4	○ 높은 수준의 커널 접근 권한(capabilities)을 제거 하지 않을 경우, 컨테이너는 호스트 시스템의 커널에 높은 접근 권한을 가질 수 있으므로, 업무상 필요하지 않은 capabilities를 제거(drop)하였는지를 점검 ※ SYS_ADMIN, NET_ADMIN, SYS_PTRACE, SYS_CHROOT, SYS_MODULE, DAC_OVERRIDE, SETUID, SETGID
PRCC-029	○		○	○	○					5.5.1 보안 관리	컨테이너의 권한 통제 설정	4	○ 컨테이너는 suid, sgid 등을 통한 권한 상승을 시도를 사전에 방지하기 위해, 컨테이너의 권한 통제 설정 여부를 점검 ※ 'allowPrivilegeEscalation', 'no-new-privileges' 설정이 비활성화 될 경우 컨테이너 내부의 프로세스는 suid나 sgid 실행 파일과 같은 메커니즘을 통해 권한을 상승 가능
PRCC-030	○									5.5.1 보안 관리	컨테이너 및 POD에 seccomp 활성화 및 적용	5	○ seccomp(Secure Computing Mode)을 사용할 경우, 컨테이너 내의 프로세스가 사용할 수 있는 악의적인 시스템 호출을 제한할 수 있으므로 seccomp 활성화 및 적용 여부를 점검 * 기본 seccomp 프로파일은 컨테이너 격리 경계를 우회하고 노드 또는 다른 컨테이너에 대한 액세스 권한을 허용하는 데 사용할 수 있는 syscall(reboot, kexec_load, open_by_handle_at 등)을 차단
PRCC-031	○		○	○	○					5.5.1 보안 관리	컨테이너의 관리자 권한 실행 제한	4	○ 컨테이너가 관리자(root)로 실행될 경우, 컨테이너 내부에서의 공격이 호스트 시스템에 영향을 미칠 수 있으므로 일반 사용자 계정으로 컨테이너 실행 여부를 점검

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-032										5.5.1 ○ 보안 관리	컨테이너의 상태 보존 설정	2	○ 컨테이너 런타임 데몬이 장애 또는 업데이트로 인한 재시작 발생으로 인한 컨테이너의 가용성 확보를 위해, 컨테이너의 상태를 보존하기 위한 옵션 설정 여부를 점검 ※ LiveRestoreEnabled 옵션이 활성화 되어 있을 경우 Docker daemon을 재시작하더라도 실행 중인 컨테이너들은 중지되지 않아 서비스 가용성 확보 가능
PRCC-033	○		○	○	○	○				5.5.1 ○ 보안 관리	컨테이너 재시작 정책 설정	2	○ 컨테이너의 재시작 정책이 설정되지 않을 경우, 장애 발생 시 시스템이 복구되지 않아 서비스 가용성에 영향을 끼칠 수 있으므로 재시작 정책 설정 여부를 점검
PRCC-034										5.5.1 ○ 보안 관리	컨테이너 HEALTHCHECK	2	○ 서비스 가용성 확보를 위해 이미지 내 또는 컨테이너 실행 시 HEALTHCHECK 명령 포함여부를 확인 ※ HEALTHCHECK는 컨테이너 내의 애플리케이션의 상태를 주기적으로 검사하는데 사용되는 명령어나 구성으로, 이를 통해 컨테이너의 정상 동작 상태 여부를 판별 가능
PRCC-035	○		○	○	○	○	○	○		5.5.1 ○ 보안 관리	컨테이너 내 시스템 디렉터리 마운트 제거	4	○ 호스트 시스템 디렉터리가 읽기, 쓰기 모드로 컨테이너 볼륨으로 마운트 될 경우, 컨테이너에서 호스트 시스템으로의 침해가 발생될 수 있으므로, 시스템 디렉터리에 읽기, 쓰기 모드로 마운트 여부를 점검 * /boot, /dev, /etc, /lib, /proc, /sys, /usr

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-036	○						○			5.5.1 보안 관리	컨테이너 내 CRI socket 볼륨 마운트 제거	4	○ CRI(Container Runtime Interface) socket* 볼륨이 마운트된 컨테이너는 컨테이너 내부에서 호스트 시스템의 API에 직접 액세스 가능함에 따라, 호스트 시스템 조작, 시스템 리소스 접근, 컨테이너 간 침입 등의 보안 위험이 발생될 수 있으므로, 컨테이너 내 CRI Socket 볼륨 마운트 여부를 확인 * Docker Socket : /var/run/docker.sock * containerd Socket : /run/containerd/containerd.sock
PRCC-037	○						○			5.5.1 보안 관리	읽기 전용 모드로 컨테이너 루트 파일 시스템 마운트 여부	3	○ 기본적으로 컨테이너의 루트 파일 시스템은 읽기/쓰기 모드로 마운트되나, 읽기 전용 모드로 설정할 경우 컨테이너 내에서 파일이나 디렉토리가 무단으로 수정되는 것을 방지하여 컨테이너의 무결성을 유지할 수 있으므로 읽기 전용 모드로 컨테이너 루트 파일 시스템 마운트 여부를 점검
PRCC-038	○						○			5.5.1 보안 관리	마운트 전파 모드(Mount Propagation Mode) 공유 설정 제한 여부	3	○ 마운트 전파(Mount Propagation) 모드가 공유로 설정될 경우, 컨테이너 내부에서 마운트 또는 언마운트 작업이 호스트에 전파되고, 호스트에서의 변경 사항이 다른 컨테이너에 전파될 수 있으므로 마운트 전파 모드의 공유 설정 여부를 확인
PRCC-039	○						○			5.5.1 보안 관리	컨테이너의 불필요한 외부 장치 제거	3	○ 컨테이너에 호스트 장치가 연결되어 있을 경우, 컨테이너는 호스트의 장치 제거 등의 행위를 통해 예측하지 못한 위험을 발생시킬 수 있으므로 불필요한 장치 연결 비활성화 여부를 점검
PRCC-040	○							○		5.5.1 보안 관리	불필요한 AUFS 스토리지 드라이버 제거	3	○ AUFS 스토리지 드라이버를 사용할 경우, 유지보수 문제, 안정성 문제 등을 일으킬 수 있으므로, AUFS 스토리지를 불필요하게 사용하는지를 점검

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-041										5.5.1 보안 관리	호스트의 사용자 네임스페이스 공유 제한 설정	3	컨테이너 내부에서 root 권한을 가진 프로세스가 호스트 시스템에서도 root 권한을 갖지 않도록 하는 등 컨테이너 내부에서 실행되는 프로세스가 호스트 시스템에 불필요한 권한을 갖지 않게 하기 위해, 호스트의 사용자 네임스페이스(User namespaces)를 공유하지 않도록 설정되어 있는지를 점검 * User namespace : 컨테이너 내부와 외부에서 사용자 ID와 그룹 ID를 분리하여, 컨테이너 내에서 root 권한을 가진 프로세스가 호스트 시스템에서도 root 권한을 갖지 않도록 하는 Linux 커널의 기능으로, 비활성화(disabled) 되어 있을 경우, 컨테이너 내의 'root' 사용자가 호스트 시스템의 'root' 사용자와 직접 매핑
PRCC-042										5.5.1 보안 관리	컨테이너의 호스트 PID 네임스페이스 공유 제한 설정	3	PID 네임스페이스는 호스트와 컨테이너 간에 프로세스를 분리하는 역할을 수행하나, PID 네임스페이스를 공유할 경우 컨테이너 내 프로세스가 호스트 시스템의 모든 프로세스에 접근 및 조작할 수 있으므로, PID 네임스페이스 공유 여부를 점검
PRCC-043										5.5.1 보안 관리	컨테이너의 호스트 IPC 네임스페이스 공유 제한 설정	3	IPC 네임스페이스는 호스트와 컨테이너 간에 IPC를 분리하는 역할을 수행하나, IPC 네임스페이스를 공유할 경우 컨테이너 내 프로세스가 호스트 시스템의 모든 IPC에 접근 및 조작할 수 있으므로, IPC 네임스페이스 공유 여부를 점검 * IPC(Inter Process Communication) : 프로세스 간 통신을 가능하게 하는 기술

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-044	○		○	○	○	○	○			5.5.1 보안 관리	컨테이너의 호스트 네트워크 네임스페이스 공유 제한 설정	3	○ 컨테이너에 네트워크 네임스페이스 공유 옵션이 설정되어 있을 경우, 컨테이너 내 프로세스가 호스트 시스템의 네트워크 인터페이스에 접근 및 조작 권한을 얻게 됨에 따라 네트워크 스니핑, 불필요한 서비스 구동 등의 보안 위험이 발생 될 수 있으므로, 네트워크 네임스페이스 공유 옵션 설정 여부를 점검 ※ (참고) 네트워크 네임스페이스는 각 컨테이너에 독립적인 네트워크 스택, IP 주소, 라우트 테이블 및 포트를 제공하여 다른 컨테이너나 호스트로부터의 네트워크를 격리 ○ 컨테이너에 UTS 네임스페이스 공유 옵션이 설정되어 있을 경우, 컨테이너가 호스트의 hostname을 변경하여 서비스 중 단, 네트워크 통신 오류 등의 발생시킬 수 있으므로 UTS 네임스페이스 공유 옵션 설정 여부를 점검 ○ HostPort를 사용하는 컨테이너는 컨테이너의 포트가 노드의 네트워크 공간에 그대로 노출되어 외부로부터 직접 접근이 가능해지며, 포트 충돌로 인해 다른 Pod의 배포를 방해하거나, 방화벽 및 네트워크 정책을 우회할 수 있으므로, 불필요한 HostPort 사용 여부를 점검 ※ 인터넷 또는 내부 네트워크를 통해 직접적인 접속이 불필요한 서비스 (WAS, DB)의 경우 hostport 노출 최소화 필요 ○ 컨테이너에 메모리 사용제한이 설정되지 않을 경우, 특정 컨테이너의 메모리 과다 사용으로 인해 호스트 서버의 리소스가 고갈될 수 있으므로 컨테이너에 대한 메모리 사용제한 설정 여부를 점검
PRCC-045	○					○	○			5.5.1 보안 관리	컨테이너의 호스트 UTS 네임스페이스 공유 제한 설정	3	
PRCC-046	○			○	○	○	○			5.5.1 보안 관리	불필요한 HostPort 제거	4	
PRCC-047	○		○	○	○	○	○	○		5.5.1 보안 관리	컨테이너의 메모리 사용 제한 설정	2	

평가항목 ID	A	B	C	D	E	F	G	H	I	통제 구분	평가항목	위험도	상세설명
PRCC-048		o								5.5.1 보안 관리	cgroup 사용 설정	2	컨테이너가 리소스를 과도하게 사용하는 것을 방지하기 위해, CPU, 메모리, I/O 제한 설정이 적용된 명확하게 관리되고 있는 cgroup (control groups) 사용 여부를 점검
PRCC-049										5.5.1 보안 관리	PID 제한 설정	2	PID cgroup을 제한하지 않을 경우, 포크 폭탄(Fork Bomb)에 의한 시스템 장애가 발생할 수 있으므로 PID cgroup을 통한 최대 프로세스 개수 제한 여부를 점검
PRCC-050										5.5.1 보안 관리	Ulimit 구성의 적절성	2	컨테이너는 호스트 시스템의 리소스를 공유하기 때문에, 하나의 컨테이너가 너무 많은 자원을 소비하는 경우 호스트 시스템 가용성에 문제가 발생할 수 있으므로, ulimit 설정을 통해 컨테이너의 자원 제한 여부를 점검 * ulimit(user limit) : 사용자가 생성할 수 있는 프로세스 수, 열 수 있는 파일의 수, 사용할 수 있는 메모리 양 등을 제한하기 위한 명령

웹·모바일·HTS 애플리케이션

❖ 평가기준

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-FIN	MOB-FIN	HTS-FIN	001	5.8.2 (전자금융) 거래정보 검증	[전자금융] 거래 인증수단 검증	5	○ 전자금융거래에 적용된 거래 인증수단 검증의 적절성 여부를 점검 * (평가 예시) - 잘못된 인증정보(비밀번호, OTP, 보안카드 번호 등) 입력 후 정상 거래 가능 여부 점검 - 폐기된 인증수단(인증서, 보안카드, OTP 등)을 통해 인증 시도 후 정상 거래 가능 여부 점검 - SMS, ARS, 계좌 등의 인증수단 이용 시, 인증 유효시간 제한 여부 점검 - 인증 매체를 통해 전달받은 인증정보를 금융회사에서 정한 시간 이후에 인증 요청 시 정상 처리 가능 여부를 점검 ○ 전자금융거래 시 이용되는 거래정보의 무결성 검증 여부를 점검 * (평가 예시) - 예비거래에 이용된 거래정보와 본거래에서 이용된 거래정보의 일치 여부 점검 - 본 거래정보와 최종 승인된 거래정보의 일치 여부 점검 - 전자서명기술 이용 시 타인인증서로 서명 후 거래 가능 여부 점검 - 전자서명기술 이용 시 전자서명 검증결과 오류 여부 점검 - 전자서명기술 이용 시 전자서명 무결성 검증 오류 여부 점검 - 전자서명기술 이용 시 매번 동일한 전자서명값 이용 여부 점검 등
WEB-FIN	MOB-FIN	HTS-FIN	004	5.8.2 (전자금융) 거래정보 검증	[전자금융] 거래정보 무결성 검증	5	

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
							- 계좌 인증 수행 시 이체 금액을 변조하여 전송 가능 여부를 점검 - 유로 인증수단(범용 인증서) 발급 시, 발급 비용 변조 가능 여부를 점검 등 * 거래정보의 무결성 : 이용자가 단말기(PC/모바일 등)를 통해 입력한 거래정보가 금융회사 시스템으로 안전하게 전송됨을 의미
WEB-FIN-	MOB-FIN-	HTS-FIN-	005	5.8.2 (전자금융) 거래정보 검증	[전자금융] 거래정보 재사용 방지	5	○ 전자금융거래 시 이용되는 거래정보의 재사용 가능 여부를 점검 * (평가 예시) - 기 사용된 거래정보(이체 전문, 결제 전문 등)를 재전송하여 정상 거래 가능 여부를 점검 등
WEB-FIN-	MOB-FIN-	HTS-FIN-	006	5.8.2 (전자금융) 거래정보 검증	[전자금융] 거래시 소유주 검증	5	○ 전자금융거래 시 이용자의 이용 권한 검증 여부를 점검 * (평가 예시) - 계좌(카드,계약)정보 조회 시 타 이용자의 계좌(카드,계약)번호 입력 후 타 이용자 계좌 조회 가능 여부 점검 - 거래 요청 시 계좌 번호를 현재 로그인 중인 이용자가 아닌 다른 이용자의 계좌번호로 변조하여 거래 시도 등
WEB-FIN-	MOB-FIN-	HTS-FIN-	009	5.8.1 (전자금융) 거래 인증	[전자금융] 비밀번호 변경 시 본인확인 절차 수행	5	○ 전자금융거래 시 사용되는 비밀번호 변경 시 본인확인 절차의 존재 여부를 점검 * (평가 예시) - 비밀번호 변경 시 본인확인 절차 존재 여부 점검 등
WEB-FIN-	MOB-FIN-	HTS-FIN-	010	5.8.1 (전자금융) 거래 인증	[전자금융] 비밀번호 변경 시 이전 비밀번호 재사용 방지	5	○ 전자금융거래 시 사용되는 비밀번호 변경 시 동일 비밀번호 재사용 가능 여부를 점검 * (평가 예시) - 비밀번호 변경 시 과거에 이용했던 비밀번호의 재사용 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
	MOB- FIN-		011	5.8.3 (전자금융) 단말 보안	[전자금융] OS 버전 탐지 기능 적용	5	○ OS가 변조(루팅, 탈옥)된 단말 이용 시 보안 위험이 증대됨에 따라, OS변조 시 전자금융 서비스 이용 가능 여부를 점검 * (평가 예시) - 권한이 상승된 OS변조 단말에서 서비스 이용 가능 여부 점검 등 ○ 악성코드에 대한 대응이 필요함에 따라, 전자금융서비스 이용 시 악성코드 차단 및 탐지 프로세스 동작 여부를 점검 * (평가 예시) - 애플리케이션 이용 시 악성코드 방지 프로세스 동작 여부 점검 - 악성코드 방지 프로세스 강제 종료 후 재구동 여부 점검 등 ○ 보안 프로그램이 동작하지 않을 경우 이용자의 입력값 및 중요 정보와 파일이 유출 될 수 있는 위험을 점검 * (평가 예시) - 최초 설치 시 보안프로그램 동작 여부 점검 등 ○ 보안 프로그램이 임의해제되는 경우 이용자의 입력값 및 중요 정보와 파일이 유출 될 수 있는 위험을 점검
	MOB- FIN-		012	5.8.3 (전자금융) 단말 보안	[전자금융] 악성코드 방지	5	* (평가 예시) - 애플리케이션 이용 시 악성코드 방지 프로세스 동작 여부 점검 - 악성코드 방지 프로세스 강제 종료 후 재구동 여부 점검 등 ○ 보안 프로그램이 동작하지 않을 경우 이용자의 입력값 및 중요 정보와 파일이 유출 될 수 있는 위험을 점검 * (평가 예시) - 최초 설치 시 보안프로그램 동작 여부 점검 등 ○ 보안 프로그램이 임의해제되는 경우 이용자의 입력값 및 중요 정보와 파일이 유출 될 수 있는 위험을 점검
		HTS- FIN-	013	5.8.3 (전자금융) 단말 보안	[전자금융] 보안프로그램 동작 여부	5	* (평가 예시) - 최초 설치 시 보안프로그램 동작 여부 점검 등 ○ 보안 프로그램이 임의해제되는 경우 이용자의 입력값 및 중요 정보와 파일이 유출 될 수 있는 위험을 점검
		HTS- FIN-	014	5.8.3 (전자금융) 단말 보안	[전자금융] 보안프로그램 임의해제 방지	5	* (평가 예시) - 보안 프로그램 강제종료, 레지스트리 변조, 환경 파일 변조 등의 방법 또는 이용자가 임의로 해제 기능 여부 점검 - 이용자가 직접 해제를 요청하는 경우 위험에 대한 주의사항 등의 내용을 이용자 고지 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
		HTS-FIN-	015	5.8.3 (전자금융) 단말 보안	[전자금융] 프로그램 실행 명령줄(Command Line) 내 중요정보 평문 노출 방지	5	○ 프로그램 실행을 위해 전달되는 명령줄(Command Line) 내 사용자 중요정보 노출 여부를 점검 * (평가 예시) - 실행 명령줄 내 중요정보 평문 여부를 확인 ○ 노출된 실행 파라미터 정보를 이용하여 인증절차 없이 타인의 HTS계정으로 로그인 할 수 있는 위험을 점검 * (평가 예시) - 실행 파라미터를 재사용하여, 별도의 인증절차없이 로그인 가능 여부를 확인 ○ 사용자 거래입력 수단(手段)을 보호하기 위한 금융회사 대응 수단 및 적용범위 등을 점검 * (평가 예시) - 사용자 거래정보 입력보호 범위가 금융회사가 정한 범위와 달리 적용되어 있거나 또는 일관성 확인 - 사용자 거래정보 입력보호에 대응하기 위한 절차 또는 방법 존재 여부 점검 등 ○ 변조된 프로그램이 정상실행 될 경우 악성코드가 포함되어 재배포 되는 등의 보안 위험이 존재함에 따라, 변조 프로그램 이용 시 정상 실행 가능 여부를 점검 * (평가 예시) - 설치파일(APK, IPA) 변조 후 재 설치 시, 정상 실행 가능 여부 점검 - 애플리케이션 설치 후 실행파일 및 관련 라이브러리 변조를 통해 정상 실행 가능 여부 점검 등
		HTS-FIN-	016	5.8.3 (전자금융) 단말 보안	[전자금융] HTS 구동시 실행 파라미터 재사용 방지	5	
		HTS-FIN-	017	5.8.3 (전자금융) 단말 보안	[전자금융] 사용자 입력정보 보호	4	
WEB-FIN-	MOB-FIN-	HTS-FIN-	018	5.8.3 (전자금융) 단말 보안	[전자금융] 프로그램 무결성 검증	5	

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
	MOB-FIN-	HTS-FIN-	020	5.8.3 (전자금융) 단말 보안	[전자금융] 소스코드 난독화 적용	4	○ 디컴파일(DeCompile) 기술을 이용하여 복구된 소스코드의 분석(프로그램 흐름 파악, 중요정보 획득 등)을 어렵게 하기 위해, 소스코드(또는 실행파일) 난독화 여부를 점검 * (평가 예시) - 실행 프로그램 또는 소스코드 난독화 미적용으로 인한 중요 로직의 해독 가능 여부를 점검 ○ 디버깅을 통한 코드 흐름, 메모리 상태 분석 등 프로그램 역분석을 어렵게 하기 위해, 안티디버깅 기능 적용 여부를 점검 * (평가 예시) - 동적 디버깅 프로그램(gdb, lldb, windbg 등)을 통해 디버깅 시 정상 실행 가능 여부 점검 등 ○ 보안 프로그램이 최신 버전으로 업데이트되지 않은 경우 새로운 보안 취약점을 통해 이용자의 입력값 및 중요정보와 파일이 유출 될 수 있는 위험을 점검 * (평가 예시) - 보안프로그램 최신 버전 업데이트 여부 점검 등 ○ 비인가자에 의한 접근매체 무단 발급에 대응하기 위해 접근매체 발급 시 실명확인 수행 여부를 점검 * (평가 예시) - 접근매체 발급 시 실명확인 수행 여부를 점검 ※ 실명확인 수행 방법 - (필수) ① 신분증 사본 제출, ② 영상통화, ③ 접근매체 전달시 확인, ④ 기존계좌 활용, ⑤ 기타 이에 준하는 새로운 방식(생체 인증 등) 중 2가지 이상 의무 적용
	MOB-FIN-	HTS-FIN-	021	5.8.3 (전자금융) 단말 보안	[전자금융] 디버깅 탐지기능 적용	4	
		HTS-FIN-	022	5.8.3 (전자금융) 단말 보안	[전자금융] 보안프로그램 구동시 최신 업데이트 수행	4	
WEB-FIN-	MOB-FIN-	HTS-FIN-	027	5.8.1 (전자금융) 거래 인증	[전자금융] 접근매체 발급 시 실명확인 수행	5	

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
							- (권고) ⑥ 타 기관 신원확인 결과 활용(휴대폰 본인확인 등), ⑦ 다수의 개인정보 검증 ※ 접근매체 : 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 수단 또는 정보
							○ 사용자가 간접 가능한 매개변수(URL 파라미터, XML 등)에 의해 SQL 질의문이 완성되는 점을 이용하여, 해당 매개변수 변수를 통해 비정상 질의 가능 여부를 점검
WEB-SER	MOB-SER	HTS-SER	001	5.8.4 (일반공통) 서비스 보호	SQL Injection	5	* (평가 예시) - URL 파라미터 또는 XML 등 입력하는 부분에 SQL 구문 입력 후 서버에서 응답한 값에 대한 위험성 점검 - SQL문으로 해석될 수 있는 값(글번호, 검색 내용 등)을 입력하여 데이터베이스내에 저장된 정보 열람 및 시스템 명령 실행가능 여부 점검 - 조작된 XPath 쿼리를 보내어 비정상적인 질의 가능 여부 점검 등
							○ 웹쉘 등과 같은 악성파일이 업로드 될 경우 시스템 명령어 실행 및 인접 서버에 대한 침입 가능성이 존재함에 따라, 악성파일 업로드 및 실행 가능 여부를 점검
WEB-SER	MOB-SER	HTS-SER	002	5.8.4 (일반공통) 서비스 보호	악성파일 업로드	5	* (평가 예시) - 이미지, 한글(hwp) 등의 파일을 업로드 할 수 있는 부분에 JSP, ASP 등의 스크립트 파일 업로드 기능 여부 점검 - 업로드 된 파일의 위치 및 실행 가능 여부 점검 등 * 웹쉘(web shell) : 업로드 취약점을 통하여 해커가 원격에서 웹서버를 조종할 수 있도록 작성한 웹 스크립트(단체표준 TTA:KO-12.0002/R3 정보 보호 기술 용어)

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-	HTS-SER-	003	5.8.4 (일반공통) 서비스 보호	부적절한 이용자 인가	5	○ 접근 권한에 대한 검증 과정이 구현되지 않아 다른 이용자의 민감한 정보나 권한이 노출 될 수 있으므로 이에 대한 검증절차 존재 여부를 점검 * (평가 예시) - 현재 로그인 중인 이용자가 중요 정보가 포함된 페이지에 대해 접근권한 확인 여부 점검 - 중요 정보 페이지에서 이용자 파라미터 변경으로 타인의 정보를 열람, 수정이 가능 여부 점검 - 통상 파라미터 변조에 따른 비정상적인 권한상승/조화/변경 가능 여부 등을 점검 ○ 중간자 공격 등에 의해 탈취된 인증정보가 재사용되는 것을 방지 하기 위해 이미 사용된 인증정보(전자서명값 등)에 대해 재사용 가능 여부를 점검
WEB-SER-	MOB-SER-	HTS-SER-	004	5.8.5 (일반공통) 이용자 인증	이용자 인증정보 재사용 방지	5	* (평가 예시) - 이용자 인증 수행을 위해 생성된 전자서명 값의 재사용 가능 여부를 점검 - OTP/SMS/계좌 인증에 사용되는 일회성 값의 재사용 가능 여부를 점검 - 비대면 실명인증(신분증 사본 제출) 수행 시, 서버에 전송되는 신분증 사진 및 신분증 정보(주민등록번호, 이름, 발급일자 등)에 대해 재사용 가능 여부를 점검 등 ○ SMS 등 이용자 인증을 위해 생성되는 값에 대해 인증정보 탈취 방지를 위해 가변적인 데이터 사용 여부를 점검 * (평가 예시) - SMS, ARS 등 이용자 인증 시 매번 동일한 인증코드 생성 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	005	5.8.5 (일반공통) 이용자 인증	고정된 인증정보 이용 방지	5	* (평가 예시) - SMS, ARS 등 이용자 인증 시 매번 동일한 인증코드 생성 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-	HTS-SER-	006	5.8.5 (일반공통) 이용자 인증	유추 가능한 인증정보 이용 방지	5	○ 비인가자에 의한 인증정보 유추에 대응하기 위해, 인증정보 (로그인 비밀번호, 계좌원장 비밀번호, PIN번호 등)의 등록 또는 변경 시 해당 값의 적절성 및 복잡성을 점검 * (평가 예시) - 이용자의 주민등록번호, 전화번호 등과 같이 쉽게 유추 가능한 개인 신상정보를 이용한 인증정보 사용 가능 여부를 점검 - 연속숫자, 연속문자, 동일숫자, 이를 등과 같이 제 3자가 비밀 번호를 쉽게 유추할 수 있는 인증정보 사용 가능 여부를 점검 - 로그인 및 ARS 등에 사용되는 인증정보가 계좌 원장 비밀번호와 동일하게 사용 가능여지를 점검 - 복잡도를 준수하지 않는 비밀번호를 등록 및 변경 가능 여부를 점검 등 ※ 비밀번호 복잡도 : 영문 대문자, 영문 소문자, 숫자, 특수문자 2개 조합시 10자리 이상, 3개 조합시 8자리 이상
WEB-SER-	MOB-SER-	HTS-SER-	007	5.8.5 (일반공통) 이용자 인증	유추 가능한 초기화 비밀번호 이용 방지	5	○ 비밀번호 복구 매커니즘(비밀번호 찾기 등) 이용 시 복구된 비밀번호의 고정성 및 규칙성을 통해 타 이용자의 비밀번호 획득, 변경, 복구 등에 대한 가능 여부를 점검 * (평가 예시) - 비밀번호 찾기 또는 복구 메뉴에서 신규 비밀번호 생성 시 패스워드 생성 규칙 점검 - 타인의 비밀번호 초기화 가능 여부 점검 - 앞서 발견한 비밀번호 생성 규칙을 통해 타인의 계정으로 접속 가능 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS	008	5.8.6 (일반공통) 단말 보안	단말기 내 중요정보 저장 방지	5	○ 애플리케이션 사용 폴더 및 외부 저장소에 존재하는 파일 내 중요정보 저장 여부를 점검 * (평가 예시) - 애플리케이션 사용 폴더 및 외부 저장소에 존재하는 파일에 중요 정보 저장 여부 점검 등 * 중요정보 : 개인정보(주민등록번호), 금융정보(비밀번호, 카드번호, OTP, 보안카드 번호 등), 기타 중요정보라 판단되는 정보 * 중요정보 주요 검색영역 : 해당 애플리케이션 동작과 연관된 파일/폴더 등
	MOB-SER-	HTS-SER-					
			009	5.8.6 (일반공통) 단말 보안	메모리 내 중요정보 노출 방지	5	○ 이용자 단말기 메모리 영역에서 이용자 중요정보의 평문노출 여부를 점검 * (평가 예시) - GDB 등 메모리 덤프를 이용하여 이용자 입력 정보(중요정보)의 평문노출 여부 점검 등 - UI 에서 노출되지 않은 계좌번호, 비밀번호 등의 정보가 메모리에서 노출되는지 점검 등 * 중요정보 : 개인정보(주민등록번호), 금융정보(비밀번호, 카드번호, OTP, 보안카드 번호 등), 기타 중요정보라 판단되는 정보 * 중요정보 주요 검색영역 : 해당 애플리케이션 동작과 관련된 메모리 영역 등
	MOB-SER-	HTS-SER-					
							※ 관계 법령 등에 중요정보 노출(일회성 노출)이 반드시 필요한 서비스의 경우, 본인확인 후 서비스를 운영할 경우 예외 처리

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-	HTS-SER-	010	5.8.4 (일반공통) 서비스 보호	파일 다운로드	5	○ 파일 다운로드 인터페이스를 이용하여 서버의 주요파일 다운로드 가능 여부 점검 * (평가 예시) - 파일 다운로드 시 파일이 저장된 디렉터리 이외에 경로에 접근하여 주요파일의 다운로드 가능 여부 점검 등 * 주요파일 : 소스코드, 서버설정파일 등 ○ 검색엔진 또는 외부 사이트에 분석 대상과 연관된 중요정보 노출 여부를 점검 * (평가 예시) - 검색 엔진 및 외부 사이트에서 제공하는 분석 도구를 이용하여 분석 대상과 연관된 중요정보의 노출 여부 점검 등 ○ 세션ID에 대한 무차별 대입공격에 대응하기 위해, 세션ID에 대한 복잡성을 점검 * (평가 예시) - 세션 ID가 무차별 대입 공격에 용이한 약한 강도 설정 여부 점검 - 세션 ID가 단순히 숫자가 증가하는 등의 규칙성 존재 여부 점검 등 ○ 쿠키 정보를 통해 이용자 검증 또는 데이터 입력에 사용되는 점을 악용하여, 쿠키 정보 조작을 통해 타이머 권한 획득 또는 기타 중요정보 유출 가능 여부를 점검 * (평가 예시) - 쿠키에 계정, 권한 구분자, 인증ID 등 이용자의 권한을 식별할 수 있는 내용에 대한 조작을 통해 타 이용자의 권한으로 정상 이용 가능 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	011	5.8.4 (일반공통) 서비스 보호	외부사이트에 의한 시스템 운영정보 노출 여부	5	
WEB-SER-	MOB-SER-		012	5.8.5 (일반공통) 이용자 인증	유추 가능한 세션ID	5	
WEB-SER-	MOB-SER-		013	5.8.5 (일반공통) 이용자 인증	쿠키변조	5	

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-	HTS-SER-	014	5.8.4 (일반공통) 서비스 보호	운영체제 명령실행	5	○ 운영체제 내 임의 명령어 실행이 가능한 인터페이스의 존재 여부를 점검 * (평가 예시) - 내부 서버에 명령어를 내릴 수 있는 인터페이스가 존재할 경우, 지정된 명령어 이외의 임의 명령 실행 기능 여부 점검 등 ○ XML 구문 분석기의 입력값 검증 누락으로 인해 시스템의 자원에 접근 가능한 취약점으로, XML 구문에 대한 검증 여부를 점검 * (평가 예시) - XML 에 정의 되지 않은 구문을 삽입하여 서버로 전송 후 해당 내용이 실행 가능 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	015	5.8.4 (일반공통) 서비스 보호	XML 외부객체 공격 (XXE)	5	○ 리다이렉트 기능이 존재 시 URL 인자값에 대한 검증 누락으로 인해 임의페이지로 이동 가능성이 존재 하여 해당 기능 및 인자 값 검증 여부를 점검 * (평가 예시) - 리다이렉트 기능이 존재할 경우 URL 인자값을 임의의 페이지로 지정하여 이동 가능 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	016	5.8.4 (일반공통) 서비스 보호	리다이렉트 기능을 이용한 피싱 공격	4	○ 이용자 입력을 기반으로 LDAP(Lightweight Directory Access Protocol) 구문을 구축하여 웹 기반 응용 프로그램 악용 여부를 점검 * (평가 예시) - LDAP 명령어가 실행되는지 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	017	5.8.4 (일반공통) 서비스 보호	LDAP Injection	5	* (평가 예시) - 쿼리를 주입함으로써 개인정보 등의 내용이 유출 가능 여부 점검 - 입력 값에 대해 특수문자(=, +, <, >, #, ;, / 등)를 입력하여 LDAP 명령어가 실행되는지 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-			018	5.8.4 (일반공통) 서비스 보호	SSl Injection	5	○ CGI 또는 서버사이드 스크립트를 통해 만들어진 웹사이트에서 입력값에 부적절한 명령문을 삽입하여 실행 가능 여부를 점검 * (평가 예시) - 변수 값에 부적절한 명령문을 삽입하여 실행 가능 여부 점검 - <code><!--#echo var="DOCUMENT_NAME"--></code>, <code><!--#exec cmd="ls" --></code>, <code><!--#exec cmd="dir"--></code> 과 같은 명령어 삽입 시 실행 가능 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	019	5.8.4 (일반공통) 서비스 보호	불충분한 이용자 인증	4	○ 민감한 데이터 또는 이용자 인증이 필요한 경로에 임의의 이용자가 접근할 수 있으므로 이에 대한 인증절차가 존재 또는 우회가능한지 여부를 점검 * (평가 예시) - 개인정보 및 비밀번호 수정 기능 페이지 접근 전에 본인인증에 대한 재인증 여부 확인 - 인증 절차 후 접근이 가능한 페이지의 URL을 수집하여 인증 절차 없이 접근 시도, 클라이언트 스크립트를 통한 접근 제어 시 해당 스크립트를 삭제하여 인증 없이 해당 페이지에 접근 가능 여부 점검 - 플로우 통제 우회 가능 여부 점검 등 * 플로우 통제 : 이용자 인증 시 단계별 인증을 통해 하는 경우 전 단계의 요건을 갖춰야 다음 단계로 진입하도록 된 구조 - ex) step 1. 연락처 작성 > step 2. 주소 작성 > step 3. 개인정보 작성 > step 4. 완료

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
	MOB-SER-	HTS-SER-	020	5.8.6 (일반공통) 단말 보안	화면 내 중요정보 평문노출 방지	5	○ 이용자 단말기에서 화면 내에 이용자 중요정보의 평문 노출 여부를 점검 * (평가 예시) - 화면 내 중요정보 평문 노출 여부 점검 등(화면캡처 등) - 이체 내역에 송금인의 계좌번호가 노출되는지 점검 등 * 중요정보 : 개인정보(주민등록번호), 금융정보(비밀번호, 카드번호, OTP, 보안카드 번호 등), 기타 중요정보라 판단되는 정보 등 ※ 관계법령 등에 의해 중요정보 노출(일회성 노출)이 반드시 필요한 서비스의 경우, 본인확인 및 화면캡처 방지 적용 시 예외 처리
WEB-SER-	MOB-SER-	HTS-SER-	021	5.8.4 (일반공통) 서비스 보호	무제한 요청 차단	5	○ 시스템 자원 고갈, 비용 발생 등 서비스 운영상 영향을 미칠 수 있는 기능(SMS, 이메일 발송, 계좌인증 호출, 글쓰기, 파일 업로드 등)에 대해 반복된 호출 가능 여부를 점검 * (평가 예시) - SMS 발송, 계좌인증(1원이체) 호출, 글쓰기 등의 반복된 작업 수행 가능 여부 점검 등
WEB-SER-		HTS-SER-	022	5.8.4 (일반공통) 서비스 보호	버퍼오버플로우 (Buffer Overflow Attack)	5	○ C언어의 strcpy, gets 등과 같이 버퍼의 경계 검사를 하지 않는 취약한 함수를 사용함으로써 발생하는 취약점으로, 해당 취약점을 통해 시스템 권한 획득, 프로그램 흐름 변경 등의 악의적인 행위 가능 여부를 점검 * (평가 예시) - 파라미터 입력 값에 허용 이상의 데이터 삽입 시 결함 발생 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-		HTS-SER-	023	5.8.4 (일반공통) 서비스 보호	포맷스트링 (Format String Attack)	5	○ C언어의 printf와 같은 함수에서 검증되지 않은 입력값을 사용함으로써 발생하는 취약점으로, 해당 취약점을 통해 다른 메모리 공간에 대한 접근 가능 여부를 점검 * (평가 예시) - printf 와 같은 취약한 함수 사용 시 별도의 문자열 검증 수행 여부 점검 등 ○ 단말기 브라우저 영역 내에서의 중요정보 평문 노출 유무 여부를 점검 * (평가 예시) - 개발자 도구 등을 통해 이용자 구간 내 중요정보 평문 노출 유무 점검 등 - 이체 내역에 송금인의 계좌번호 노출 여부 점검 등 * 웹 영역 : 웹을 구성하는 HTML, Javascript, DOM 등 웹을 표현하기 위한 영역 * 중요정보 : 고유식별정보(주민등록번호), 비밀번호(로그인 비밀번호, 계좌 비밀번호, 공인인증서 비밀번호 등), 신용정보(보안카드번호, OTP번호, 카드번호 등) 등 ※ 관계 법령 등에 중요정보 노출(일회성 노출)이 반드시 필요한 서비스의 경우, 본인확인 후 서비스를 운영할 경우 예외 처리
WEB-SER-			024	5.8.7 (일반공통) 데이터 보호	단말기 브라우저 영역 내에서의 중요정보 노출 방지	5	○ 앱 소스코드 내 운영정보 노출 여부를 점검 * (평가 예시) - 애플리케이션을 디컴파일 및 역분석하여 코드상에 운영정보의 노출 여부 점검 등 * 운영정보 : 서버정보(ID/PW), 고정된 암호키 등
	MOB-SER-		025	5.8.6 (일반공통) 단말 보안	앱 소스코드 내 운영정보 노출 방지	5	○ 앱 소스코드 내 운영정보 노출 여부를 점검 * (평가 예시) - 애플리케이션을 디컴파일 및 역분석하여 코드상에 운영정보의 노출 여부 점검 등 * 운영정보 : 서버정보(ID/PW), 고정된 암호키 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
	MOB-SER-		026	5.8.6 (일반공통) 단말 보안	화면 강제실행에 의한 인증단계 우회 방지	5	○ 화면강제 실행, 인증관련 파일 조작 등을 통해 인증단계 우회 가능 여부를 점검 * (평가 예시) - 인텐트(Intent), Cypcript 등 화면 강제 실행이 가능한 기능 및 도구를 이용하여 화면강제 실행 시 서비스 정상 사용가능 여부 점검 - 인증 관련 파일 존재 시 해당파일 조작을 통해 인증단계 우회 가능 여부 점검 등 ○ 공격자가 업로드 한 악의적 행위 구문으로 인해 타 이용자의 권한 도용이 가능한지에 대한 점검
WEB-SER-	MOB-SER-		028	5.8.4 (일반공통) 서비스 보호	크로스사이트 요청변조 (CSRF)	4	* (평가 예시) - 타 이용자의 권한으로 실행하고자 하는 구문*을 업로드 후 해당 이용자 권한으로 구문이 실행되는지 가능 여부 점검 등 ※ 일반적으로는 스크립트 구문이 많이 사용되나, 다른 방식 사용 가능 ○ 인텍스 파일로 지정한 파일이 존재하지 않거나, 디렉토리 리스팅을 허락하도록 설정했을 경우 디렉토리 리스팅이 출력됨에 따라 하위 파일 및 디렉토리 목록의 출력 여부를 점검 * (평가 예시) - URL에 디렉터리 명을 입력 했을 경우 하위 파일 및 디렉터리의 목록의 출력 여부 점검 등
WEB-SER-	MOB-SER-		029	5.8.4 (일반공통) 서비스 보호	디렉토리 목록 노출 방지	4	* (평가 예시) - URL에 디렉터리 명을 입력 했을 경우 하위 파일 및 디렉터리의 목록의 출력 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-		030	5.8.4 (일반공통) 서비스 보호	서버 인증서 무결성 검증	3	○ 서버 인증서의 무결성 조건이 위배될 경우, 웹브라우저에서 안전하지 않은 웹사이트로 경고하여 이용자의 신뢰를 떨어뜨릴 수 있으므로 서버 인증서 무결성 점검 * (평가 예시) - 이용자PC 브라우저에서 서버 인증서 유효기간이 만료되어 안전하지 않은 웹사이트로 경고 여부 점검 - CN값과 서비스URL이 일치하지 않아 안전하지 않은 웹사이트로 경고 여부 점검 - 서버 인증서 발급기관(CA)이 신뢰할 수 없는 기관이거나, 자체 서명(Self-signed)된 인증서를 사용 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	031	5.8.4 (일반공통) 서비스 보호	시스템 운영정보 노출 방지	4	○ 웹 서버의 소스 코드 및 오류 메시지를 통한 정보 노출 가능성이 존재하며, 시스템 운영정보 노출 여부를 점검 * (평가 예시) - 개발자 도구 및 웹 프록시 도구를 이용하여 서버로 부터 중요 정보의 전달 여부 점검 - 에러 발생 시 절대 경로 주소나 웹서버 버전 정보 등이 발생 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	032	5.8.5 (일반공통) 이용자 인증	인증 오류 횟수 제한기능 제공	3	○ 무작위 대입 공격에 의한 인증 우회, 인증정보 유출 등의 위협에 대응하기 위해, 이용자가 입력하는 인증 요청에 대한 오류 횟수 제한 여부를 점검 * (평가 예시) - 금융회사가 정한 오류횟수 이상으로 오인증 후 해당 계정의 상태(서비스 이용 제한, 인증수단 폐기, 다른 인증방법으로 전환 등)를 확인 - 전자금융거래에 사용되는 비밀번호의 경우 5회 이내의 범위에서 미리 정한 횟수 이상의 비밀번호 입력 오류가 발생할 경우 즉시 사용 금지 필요(전자금융감독규정 제33조 이용자 비밀번호 관리)

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-	HTS-SER-	033	5.8.5 (일반공통) 이용자 인증	세션종료 설정	4	○ 세션종료 시간 미설정 또는 과도한 세션 종료 설정 여부를 점검 * (평가 예시) - 이용자 로그인 후 일정시간 이후 동일 세션으로 접속 가능 여부 점검 등 (참고) 주요 통신기반시설 가이드에는 세션 종료 시간을 10분 설정할 것을 권고
WEB-SER-	MOB-SER-		034	5.8.7 (일반공통) 데이터 보호	취약한 HTTPS 프로토콜 이용 제한	3	○ SSL/TLS가 활성화되어야 하고, 취약한 버전의 암호 프로토콜 사용 시 MITM 등의 공격에 의해 암호화된 통신 내용이 유출될 수 있어 취약한 버전의 암호 프로토콜(SSL 3.0 이하, TLS 1.2 미만) 사용 여부를 점검 * (평가 예시) - 취약한 버전(SSL 3.0 이하, TLS 1.2 미만)의 암호 프로토콜 사용 가능 여부 점검 등
WEB-SER-	MOB-SER-		035	5.8.7 (일반공통) 데이터 보호	취약한 HTTPS 암호 알고리즘 이용	3	○ 보안강도가 낮은 암호 알고리즘을 사용할 경우, 중간자 공격 등에 의해 암호화된 통신 내용이 유출 될 수 있는 위험이 발생될 수 있으므로, 암호 알고리즘의 보안 강도의 적절성 여부를 점검 * (평가 예시) A. 짧은 키길이(112비트 미만)를 사용하는 블록 암호 알고리즘 B. 스트림 암호(RC2, RC4) 사용 C. 암호 알고리즘 미사용(NULL) D. 취약한 암호 알고리즘(DES, 3DES) ※ (참고) 해당 내용에 세부 사항은, “금융부문 암호기술 활용 가이드”를 참고 (https://www.fsec.or.kr/bbs/detail?bbsNo=6158&menuNo=222)

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER	MOB-SER		036	5.8.7 (일반공통) 데이터 보호	취약한 HTTPS 컴포넌트 제거	3	○ 취약한 HTTPS 확장 모듈 사용 시 암호화된 정보 노출 등의 위험이 존재함에 따라 이에 대한 취약점 존재 유무 점검 * (평가 예시) A. Heartbleed (CVE-2014-0160) : TLS 'heartbeat' 확장에서 발견된 취약점으로, 'heartbeat' 메시지를 악용하여 서버의 메모리에 접근 가능 (OpenSSL 1.0.1 - 1.0.1f) B. OpenSSL CCS Injection Vulnerability(CVE-2014-0224) : SSL/TLS 핸드셰이크 프로세스에서 ChangeCipherSpec(CCS) 메시지를 악용하여 발생하는 취약점으로, 취약한 핸드셰이크 방식을 악용하여 통신 내용에 대해 위변조 가능 (OpenSSL 1.0.1~1.0.1h, 1.0.0~1.0.0m, 0.9.8~0.9.8za) C. FREAK(Factoring RSA Export Keys) (CVE-2015-0204) : SSL서버가 수출용 RSA를 허용하도록 다운그레이드시킨 후, Brute-force 복호화 공격을 통하여 RSA키를 얻어 MITM 공격을 수행 (OpenSSL ~1.0.1~1.0.1f, 1.0.2) D. Ticketbleed (CVE-2016-9244) : F5 Networks BIG-IP SSL 가속기의 TLS(ticket-based) 세션 재사용 구현에서 발견되는 취약점으로, 해당 취약점을 악용하여 서버의 일부 메모리 접근 가능 (F5 BIG-IP 11.6.0~13.0.0) E. Padding Oracle Attack (CVE-2016-2107) : OpenSSL의 AES-CBC 암호화에서 패딩 값 변경을 통해 발생하는 취약점으로, MITM공격을 수행(OpenSSL ~1.0.1h, 1.0.2)

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-		037	5.8.7 (일반공통) 데이터 보호	취약한 HTTPS 재협상 차단	2	○ TLS 1.0 이하 버전에서 HTTPS 재협상(Renegotiation) 설정이 허용되어 있을 경우, MITM(Man-In-The-Middle) 공격을 통해 암호화된 통신 내용이 노출될 위험이 있으므로, 취약한 방식의 HTTPS 재협상을 허용하는지 여부를 점검 * (평가 예시) - insecure client-initiated renegotiation 값(No - 재협상 미허용, supported - 재협상 허용) 점검 등 (TLS 1.1이후 버전에서는 양호) ○ 서비스 운영상 불필요한 웹 메서드(PUT, DELETE, TRACE) 허용 여부를 점검 * (평가 예시) - 메서드를 변경하여 실제 요청 시 정상 기능 작동 여부 점검 - 최상위 경로 외에 하위 경로에서도 동일하게 테스트 수행 (설정 환경이 다른 경우가 존재) 등 ○ 일반 이용자에 의한 관리자 페이지 접근 가능 여부를 점검 * (평가 예시) - 알려진 관리자 페이지 및 유추 가능한 페이지 경로에 대해 접근 가능 여부 점검 등 ○ 서비스 운영상 불필요한 기능(테스트 파일, 샘플 파일, 테스트 목적의 기능 등)의 존재 여부를 점검 * (평가 예시) - 개발/테스트 목적으로 사용된 코드(암호화, 테스트 시스템 접속 등)가 실 운영환경에서 정상 동작 가능 여부를 확인 - 무작위 대입 또는 잘 알려진 경로 대입 등을 통해 불필요한 파일 (샘플 파일, 테스트 파일, 백업 파일 등)의 존재 여부 점검 등
WEB-SER-	MOB-SER-		038	5.8.4 (일반공통) 서비스 보호	불필요한 웹 메서드 차단	1	* (평가 예시) - 메서드를 변경하여 실제 요청 시 정상 기능 작동 여부 점검 - 최상위 경로 외에 하위 경로에서도 동일하게 테스트 수행 (설정 환경이 다른 경우가 존재) 등
WEB-SER-	MOB-SER-	HTS-SER-	039	5.8.4 (일반공통) 서비스 보호	관리자 페이지 접근 통제 여부	4	* (평가 예시) - 알려진 관리자 페이지 및 유추 가능한 페이지 경로에 대해 접근 가능 여부 점검 등
WEB-SER-	MOB-SER-	HTS-SER-	040	5.8.4 (일반공통) 서비스 보호	불필요한 파일 노출 여부	4	* (평가 예시) - 개발/테스트 목적으로 사용된 코드(암호화, 테스트 시스템 접속 등)가 실 운영환경에서 정상 동작 가능 여부를 확인 - 무작위 대입 또는 잘 알려진 경로 대입 등을 통해 불필요한 파일 (샘플 파일, 테스트 파일, 백업 파일 등)의 존재 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER	MOB-SER		041	5.8.4 (일반공통) 서비스 보호	크로스 사이트 스크립팅 (XSS)	4	○ 공격자가 업로드한 스크립트가 타 이용자의 사용환경(브라우저, 웹브라우저 등)에서의 실행 가능 여부를 점검 * (평가 예시) - 크로스사이트 스크립팅 문자열을 데이터베이스에 저장된 값을 확인할 수 있는 페이지에 업로드 시, 해당 스크립트의 실행 여부 점검 등
	MOB-SER		042	5.8.6 (일반공통) 단말 보안	디버그 로그 내 중요정보 노출 방지	5	○ 디버그 로그 내 중요정보 노출 여부를 점검 * (평가 예시) - DDMS 등 디버그 로그를 확인 할 수 있는 도구를 이용하여 디버그 로그 내 중요정보 노출 여부 점검 등 * 중요정보 : 개인정보(주민등록번호), 금융정보(비밀번호, 카드번호, OTP, 보안카드 번호 등), 기타 중요정보라 판단되는 정보
	MOB-SER		043	5.8.6 (일반공통) 단말 보안	백그라운드 화면 보호	3	○ 실행중이던 애플리케이션이 백그라운드 상태로 진입할 때 저장되는 스냅샷 파일 내 중요정보 노출 여부를 점검 * (평가 예시) - 별도의 화면 또는 부속성 변경없이 백그라운드 상태 진입 이전 화면이 스냅샷이 파일 내 중요정보 존재 여부 점검 등
WEB-SER	MOB-SER		046	5.8.4 (일반공통) 서비스 보호	서버 사이드 요청 위조 (SSRF)	4	○ 외부에서 접근 가능한 서버에서 전송하는 요청 메시지 파라미터 (IP, URL 등)값을 변조하여, 공격자가 직접 접근할 수 없는 네트워크 대역(내부망 등)에 위치한 서버에서 변조된 요청 메시지에 대해 응답값이 반환되는지 여부를 점검

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
WEB-SER-	MOB-SER-	HTS-SER-	048	5.8.4 (일반공통) 서비스 보호	세션정보 재사용 제한 여부	3	○ 세션ID, 토큰 등을 절취 후 타 이용자의 이용 환경에서 해당 값을 이용하여 권한이 필요한 페이지에 정상 접근 및 권한 우회 가능 여부를 점검 * (평가 예시) - 로그인 수행 후 해당 세션ID를 획득 후, 별도의 IP 주소를 사용하는 단말에서 사용 시 해당 이용자의 권한으로 서비스 이용 가능 여부를 점검 등 - OAuth, SSO 등에서 사용하는 토큰 정보를 획득 후, 별도의 IP 주소를 사용하는 단말에서 사용 시 해당 이용자의 권한으로 서비스 이용 가능 여부를 점검 등 ※ IP 주소 기반의 세션정보 검증이 어려운 경우 단말기 정보 기반의 검증 여부 확인
WEB-SER-	MOB-SER-	HTS-SER-	049	5.8.4 (일반공통) 서비스 보호	인증수단 소유자 검증	5	○ 타 이용자 소유의 인증수단을 이용한 인증 수행 가능 여부를 점검 * (평가 예시) - 인증서 사전 등록(등록·변경) 시, 타 이용자 명의의 인증서 등록 후 인증 우회 가능 여부 점검 - 타 이용자 명의의 전화번호 이용 또는 사전 등록하여 인증(SMS, ARS 등) 수행 가능 여부 점검 - 타 이용자 명의의 계좌 번호를 입력하여 계좌 인증 수행 가능 여부 점검 - 타 이용자 명의의 OTP 등록 가능 여부 점검 - 타 이용자의 인증서를 이용한 전자서명 기능 여부 점검 등

평가항목ID			Sub NUM	통제구분	평가항목	위험도	상세설명
WEB	Mobile	HTS					
	MOB-SER-		050	5.8.6 (일반공통) 단말 보안	모바일 DeepLink 도용 제한 여부	5	○ 공격자에 의해 조작된 URI를 이용자의 사용환경(웹뷰, 애플리케이션 등에서 접속할때 개발자가 의도하지 않은 기능 동작 여부를 점검 * (평가 예시) - 앱에 등록된 Custom scheme을 조작하여, URI 접속을 통해 특정 activity 호출을 통한 인증우회, 임의페이지 리다이렉션, Javascript Code 실행이 가능 여부를 점검 - 인텐트 스키마를 도용하여, 내부 파일에 접근, webview 조작 등 임의 기능을 실행 할 수 있는지를 점검 ○ 이용자 개인정보, 거래, 인증정보 등 송수신 구간의 정보를 보호 하기 위해 안전한 통신 프로토콜 이용 여부를 점검 * (평가 예시) - 이용자 개인정보, 신용정보, 인증정보를 취급하는 서비스에 통신 구간 암호화 프로토콜 적용 여부를 점검 ○ 서버 사이트 템플릿 인젝션(SSTI)는 웹 서버의 템플릿 엔진이 입력값을 적절하게 처리하지 않아 공격자가 서버 측의 템플릿을 조작할 수 있는 공격 기법으로, 템플릿 엔진에 임의 코드 주입을 통한 원격 코드 실행 등의 위협이 발생될 수 있으므로, 사용자 입력값이 서버측 템플릿 코드에 의해 실행 가능 여부 점검 * (평가 예시) - <code>https://{target}/url?payload=fs\${34*95}ec</code> - <code>https://{target}/url?payload={class.getResource("../..../..../index.htm").getContent()}</code> - <code>https://{target}/url?payload={T(java.lang.Runtime).getRuntime().exec('cat etc/passwd')}</code>
	MOB-SER-	HTS-SER-	051	5.8.4 (일반공통) 서비스 보호	통신구간 암호화 적용	5	
	WEB-SER-						
	MOB-SER-	HTS-SER-	052	5.8.4 (일반공통) 서비스 보호	서버 사이트 템플릿 인젝션(SSTI)	5	
	WEB-SER-						

MEMO

MEMO

2026년 전자금융기반시설 보안 취약점 평가기준 안내서 (제2026-1호)

발 행 : 2025년 12월

발행인 : 박 상 원

발행처 : 금융보안원, 보안평가부 (보안평가기술팀)

주 소 : 경기도 용인시 수지구 대지로 132

〈비 매 품〉

본 안내서 내용의 무단전재를 금하며, 가공 인용할 때에는 반드시 금융보안원
「전자금융기반시설 보안 취약점 평가기준 안내서」라고 밝혀 주시기 바랍니다.

- 상기 내용과 관련하여 궁금한 사항은 이메일(fsat@fsec.or.kr) 또는 전화(02-3495-9595)로 문의하시기 바랍니다.

2026년
전자금융기반시설 보안 취약점
평가기준 안내서